République du Cameroun

Chaire UNESCO d'Afrique Centrale Accès TIC

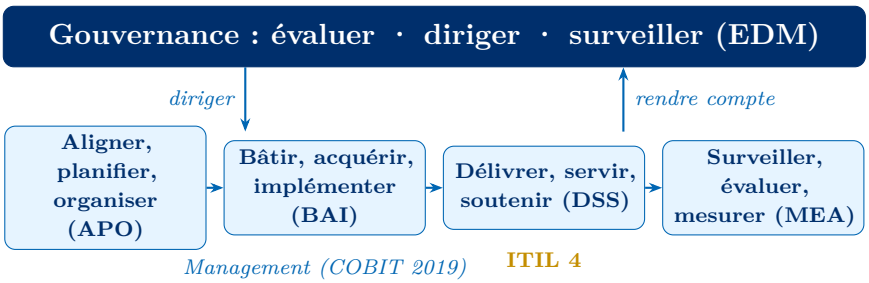
Sous la tutelle académique de l'École Nationale Supérieure Polytechnique de l'Université de Yaoundé I

Master Professionnel en Management des Systèmes d'Information

IT Governance
COBIT et ITIL

Gouverner, piloter et servir :
la gouvernance des systèmes d'information en contexte africain

GCI - UE MSN-2S3-MSI03



MINKA MI NGUIDJOÏ Thierry Emmanuel

Enseignant Chercheur | LIMSI | ENSPY

Chaire UNESCO d'Afrique Centrale Accès TIC

maletyon@proton.me

Année académique 2026–2027

Version 1.0 | Document pédagogique de l'UE MSN-2S3-MSI03

AVANT-PROPOS

> « Spécifier les droits de décision et le cadre de responsabilité qui encouragent les comportements souhaitables dans l'usage des technologies de l'information. »
>
> Peter Weill et Jeanne Ross, définition de la gouvernance des SI (2004, notre traduction)

Ce cours repose sur une double conviction. La première est que la gouvernance des systèmes d'information n'est plus une affaire de spécialistes. Au Cameroun comme dans toute l'Afrique centrale, les banques, les opérateurs, les administrations et les jeunes entreprises du numérique confient désormais leur activité à des systèmes dont la défaillance arrête tout : les paiements, les salaires, les ports, les soins. Quand un système s'arrête, la question qui suit n'est jamais seulement technique. Elle est toujours la même : *qui avait décidé, et qui devait rendre compte ?*

La seconde conviction est que cette discipline ne s'importe pas telle quelle. COBIT, ITIL et les normes ISO sont des acquis précieux, mais ils ont été pensés dans des contextes où les régulateurs, les marchés, les compétences et les contraintes budgétaires ne sont pas les nôtres. Les appliquer en Afrique suppose de les relire à la lumière du droit camerounais et communautaire (CEMAC, OHADA), des attentes de nos régulateurs et de la réalité de nos organisations.

Ce que ce cours n'est pas. Il n'est ni un résumé des publications d'ISACA ou de PeopleCert, ni une préparation à une certification. Les référentiels y sont présentés pour ce qu'ils font bien, cités avec exactitude, et discutés là où leur transposition pose problème.

Ce que ce cours est. Un traité en six parties, précédées d'un prologue, qui va du cas concret vers la théorie, de la règle vers la pratique, et du cas simple vers la recherche. La Partie I pose les fondements de la gouvernance des SI. La Partie II est consacrée à COBIT 2019, la Partie III au cadre normatif et juridique, la Partie IV à ITIL 4 et aux processus, la Partie V aux défis de l'agilité, du nuage et de l'intelligence artificielle, et la Partie VI à la recherche. Quatre organisations fictives, une banque, un opérateur portuaire, une administration et une jeune entreprise de paiement mobile, traversent le cours et servent de terrain aux exercices.

Comment utiliser ce cours. Chaque chapitre s'ouvre sur une *boîte objectifs* précisant les compétences attendues, et se ferme sur une *boîte résumé*. Les exercices sont

gradués en trois niveaux : ★☆☆ fondamental, ★★☆ intermédiaire, ★★★ expert. Chaque chapitre est accompagné d'une fiche d'auto-évaluation sur NDAP SUKULU, et dix laboratoires pratiques d'une heure complètent les 30 heures de présentiel comme travail personnel.



Yaoundé, octobre 2026

MODE D'EMPLOI DE CE COURS

Structure générale

Le cours est organisé en **6 parties précédées d'un prologue**, soit 21 chapitres numérotés de façon continue. Il accompagne une unité d'enseignement de 30 heures en présentiel, réparties en quinze séances de deux heures qui couvrent l'ensemble des parties, du prologue à la partie VI. Les ateliers de questions-réponses par chapitre et les laboratoires de NDAP SUKULU sont des travaux à faire à la maison, hors de ces 30 heures. Les parties V et VI servent en outre de point de départ aux mémoires.

Partie	Thème	Compétences visées	Niveau
0	Prologue opérationnel	Distinguer une cause technique d'une cause de gouvernance	★☆☆
I	Fondements de la gouvernance des SI	Définir, situer et justifier la gouvernance des SI	★☆☆
II	COBIT 2019	Concevoir et évaluer un système de gouvernance	★☆☆ – ★★☆
III	Cadre normatif et juridique	Identifier les obligations et auditer la conformité	★☆☆
IV	ITIL 4 et processus	Organiser et mesurer la gestion des services	★★☆ – ★★★
V	Défis avancés	Gouverner l'agilité, le nuage, les données et l'IA	★★★
VI	Recherche	Lire et produire la recherche sur la gouvernance des SI	★★★

Les environnements visuels

Définition

Définition. Introduit un terme technique avec sa définition formelle. Tous les termes définis sont indexés en fin d'ouvrage.

© *MaletYon*

✦ Objectifs du chapitre

Objectifs du chapitre. Liste les compétences mesurables attendues à l'issue du chapitre.

Scénario Opérationnel · Titre du scénario

Scénario opérationnel. Présente un cas fictif ancré dans la réalité camerounaise ou africaine, qui revient d'un chapitre à l'autre (opérations SANAGA, KRIBI, MEFOU et NOUN).

Application DSI

Application métier. Traduit le concept académique en démarche opérationnelle pour l'un des cinq métiers visés : DSI, Responsable GRC, Auditeur SI, Responsable des services IT et RSSI.

Exigence de contrôle

Exigence de contrôle. Indique ce qui doit être documenté et prouvé pour qu'une pratique soit auditable : la pièce attendue, son responsable, sa fréquence.

Fiche processus · Code et nom

Fiche processus. Présente un objectif COBIT ou une pratique ITIL sous une forme constante : finalité, pratiques, entrées et sorties, matrice RACI, indicateurs.

Jurisprudence & Droit applicable

Jurisprudence & Droit applicable. Référence les textes de loi et articles pertinents, avec accent sur le droit camerounais et africain.

★ Attention

Attention. Signale une erreur fréquente de gouvernance, de conformité ou de mise en œuvre.

★ À retenir

À retenir. Synthèse des points essentiels du chapitre.

✍ Exercice

Exercice. Travaux gradués : ★☆☆ fondamental, ★★☆ intermédiaire, ★★★ expert.

Conventions typographiques

➢ Les **termes clés** apparaissent en **gras bleu marine** et sont indexés automatiquement.

- Les ACRONYMES utilisent des petites capitales.
- Les références aux normes utilisent la commande **[ISO XXXX]**.
- Les références aux lois camerounaises utilisent **Loi AAAA/NNN**.
- Les niveaux de capacité COBIT s'écrivent *DSS02* **niv. 2**.

Matériel d'accompagnement

- **NDAP SUKULU**, code de cours MSN-2S3-MSI03 : une fiche d'auto-évaluation par chapitre et dix laboratoires pratiques de 60 minutes.
- **Dossiers de cas** : pièces des quatre organisations fictives (tableurs, extraits de tickets, contrats, procès-verbaux).
- **Modèles de documents** (Annexe C) : charte de gouvernance, matrice RACI, accord de niveau de service, grille d'évaluation de capacité.

NDAP SUKULU, LA SALLE DE CLASSE COMPAGNON



Un nom venu du pays bassa

> *Le soir tombe sur Éséka. Un enfant revient des champs avec son grand-père et lui demande pourquoi il doit marcher si loin, chaque matin, pour aller à l'école. Le vieil homme s'arrête au bord du chemin et répond, en bassa : «* Ndap sukulu*, la salle de classe, ce ne sont pas les murs. Ce sont les murs qui viennent après. La salle de classe, c'est l'endroit où quelqu'un t'attend pour t'apprendre ce qu'il sait. » L'enfant insiste : « Et qui m'attend ? » Le grand-père sourit : «* Malet yon*. Ton enseignant. »*

En bassa, la langue paternelle de l'auteur, ***ndap sukulu*** désigne la salle de classe et ***malet yon*** signifie « ton enseignant ». L'environnement compagnon de ce cours porte ce nom parce qu'il prolonge la salle de classe au-delà des heures de cours : il attend l'étudiant le soir, le week-end, à distance, avec des questions, des pièces à examiner et une correction immédiate. Il est édité par **MaletYon**, « ton enseignant », et mis à la disposition des étudiants et des praticiens qui souhaitent se perfectionner (maletyon@proton.me).

Ce que l'on y trouve

- **Une fiche d'auto-évaluation par chapitre.** Chaque fiche puise vingt questions dans une banque de quarante (QCM, vrai ou faux, textes à trous). Elle dure trente minutes ; la copie validée est verrouillée et notée aussitôt. Le seuil de réussite est de 60 %.
- **Des laboratoires pratiques.** Chaque lab place l'étudiant devant les pièces d'une affaire du fil rouge (tableurs, journaux, contrats, procès-verbaux) dans un bureau d'analyste virtuel, ouvert dans le navigateur. Il dure soixante minutes, se termine par des points de contrôle notés automatiquement et renvoie aux sections du livre qu'il mobilise.

© MaletYon

➢ **Un suivi pour l'enseignant** : rapport de classe, notes par fiche et par lab, journal d'activité.

Les fiches et les labs sont des travaux à faire hors des heures de cours. Ils ne remplacent ni le livre ni les exercices de fin de chapitre : ils en vérifient la maîtrise.

Comment y travailler

1. Se connecter au portail NDAP SUKULU avec ses identifiants et le code de cours **MSN-2S3-MSI03**.

2. Pour un lab, commencer par vérifier l'empreinte SHA-256 des pièces (`sha256sum -c MANIFESTE_SHA256.txt`), puis travailler sur la copie du dossier `travail` : les pièces originales sont en lecture seule et l'activité est journalisée, comme dans une vraie mission.

3. Lire le rappel de cours affiché par le lab et relire les sections citées avant de répondre.

Note

Si le portail n'est pas encore ouvert. En attendant le déploiement de NDAP SUKULU, les fiches de questions sont fournies au format texte dans le dossier `fiches` du cours, prêtes à être distribuées. Les corrections des fiches figurent dans le livret de correction, à la suite des corrigés des exercices de chaque chapitre.

Les laboratoires du cours

Le cours compte dix laboratoires, disponibles sous le code MSN-2S3-MSI03. Le dernier réunit les quatre organisations du fil rouge et sert de synthèse.

Lab	Sujet	Chapitre	Opération
GCI-LAB-01	Arbitrer le portefeuille de projets de l'ANPP	3	MEFOU
GCI-LAB-02	Fixer les capacités cibles de la BANQUE SANAGA	7	SANAGA
GCI-LAB-03	Dérouler la cascade des objectifs de la BANQUE SANAGA	7	SANAGA
GCI-LAB-04	Évaluer la capacité de BAI06 et de DSS02	8	SANAGA
GCI-LAB-05	Tester les contrôles généraux informatiques de l'ANPP	11	MEFOU
GCI-LAB-06	Prioriser et analyser les tickets de KRIBILOG	13	KRIBI
GCI-LAB-07	Évaluer et décider un changement de la BANQUE SANAGA	14	SANAGA
GCI-LAB-08	Disponibilité, pénalités et reprise du suivi des conteneurs	15	KRIBI
GCI-LAB-09	Construire la matrice RACI du modèle de NOUN PAY	16	NOUN
GCI-LAB-10	Synthèse des quatre cas : feuilles de route chiffrées	17	les quatre

Les laboratoires du cours dans NDAP SUKULU

TABLE DES MATIÈRES

Avant-propos iii

Mode d'emploi v

NDAP SUKULU, la salle de classe compagnon ix

Prologue Opérationnel 3

0 Prologue : Trois Jours sans Banque 3

0.1 Chronologie de la Défaillance . . . 4

0.1.1 Reconstituer avant de juger . . . 4

0.1.2 Constatation et analyse . . . 5

0.2 Cause Technique, Cause de Gouvernance . . . 6

0.2.1 Deux niveaux d'explication . . . 6

0.2.2 Remonter de l'incident à la décision . . . 6

0.3 Les Trois Questions Réflexes . . . 7

0.3.1 Décider, exécuter, rendre compte . . . 7

0.3.2 Application à la BANQUE SANAGA . . . 8

0.4 Gouvernance et Management . . . 9

0.4.1 Une distinction fondatrice . . . 9

0.5 Ceux qui Demandent des Comptes . . . 9

0.5.1 Les parties prenantes de la BANQUE SANAGA . . . 9

0.5.2 Le coût d'une décision manquée . . . 10

0.5.3 Le cadre légal camerounais . . . 10

0.6 Ce que COBIT et ITIL Auraient Changé . . . 11

0.6.1 Deux référentiels, deux niveaux . . . 11

0.6.2 Un exemple : la gestion des changements . . . 12

0.7 Retour sur la BANQUE SANAGA : ce qui Aurait Dû se Passer . . . 13

I Fondements de la Gouvernance des Systèmes d'Informati 17

1 De la Gouvernance d'Entreprise à la Gouvernance des SI 19

1.1 La Gouvernance d'Entreprise : Définition et Mécanismes . . . 20

1.1.1 Diriger et contrôler . . . 20

1.1.2 Les mécanismes de la gouvernance . . . 20

© *MaletYon*

1.2 Les Théories qui Expliquent la Gouvernance . . . 21
1.2.1 La théorie de l'agence . . . 21
1.2.2 La chaîne d'agence des systèmes d'information . . . 22
1.2.3 La théorie des parties prenantes . . . 22
1.3 Histoire : de Cadbury à la Gouvernance des SI . . . 23
1.3.1 Les scandales fondateurs . . . 23
1.3.2 Sarbanes-Oxley : l'informatique entre dans la gouvernance . . . 23
1.3.3 Les étapes de la gouvernance des SI . . . 24
1.3.4 Une voix africaine : les rapports King . . . 24
1.4 Définir la Gouvernance des SI . . . 24
1.4.1 Quatre définitions de référence . . . 24
1.4.2 Une définition de travail pour ce cours . . . 25
1.4.3 Structures, processus et mécanismes relationnels . . . 26
1.5 Gouvernance et Management des SI : Quatre Confusions . . . 26
1.6 Les Organes de la Gouvernance des SI . . . 27
1.6.1 Deux niveaux de comités . . . 27
1.6.2 La gouvernance du système de gouvernance . . . 28
1.7 Le Contexte Camerounais et Africain . . . 29
1.7.1 Des organisations, des cadres différents . . . 29
1.7.2 Quatre défis propres au contexte . . . 30

2 Grandes Défaillances et Leçons de Gouvernance 33

2.1 Une Méthode d'Analyse des Défaillances . . . 34
2.1.1 Les sources . . . 34
2.1.2 La grille d'analyse . . . 34
2.2 Knight Capital, 2012 : 45 Minutes, 460 Millions de Dollars . . . 35
2.2.1 Brief . . . 35
2.2.2 Déroulé . . . 35
2.2.3 Révélations . . . 35
2.2.4 Synthèse . . . 36
2.3 TSB, 2018 : la Migration qui a Paralysé une Banque . . . 36
2.3.1 Brief . . . 36
2.3.2 Déroulé . . . 36
2.3.3 Révélations . . . 36
2.3.4 Synthèse . . . 37
2.4 CrowdStrike, 2024 : la Mise à Jour qui a Arrêté le Monde . . . 37
2.4.1 Brief . . . 37
2.4.2 Déroulé . . . 38
2.4.3 Révélations . . . 38
2.4.4 Synthèse . . . 38
2.5 Lecture Croisée des Trois Affaires . . . 39
2.5.1 Comparaison . . . 39

2.5.2 Quatre constantes . . . 39
2.6 Une Grille d'Erreurs de Gouvernance . . . 40

3 Théories et Modèles : Alignement, Valeur et Décision 45

3.1 Le Paradoxe de la Productivité . . . 46
3.2 Le Modèle d'Alignement Stratégique . . . 46
3.2.1 Quatre domaines, deux dimensions . . . 46
3.2.2 Quatre perspectives d'alignement . . . 47
3.3 Qui Décide de Quoi : les Archétypes de Weill et Ross . . . 48
3.3.1 Cinq décisions . . . 48
3.3.2 Six archétypes . . . 48
3.3.3 La matrice des droits de décision . . . 49
3.4 Les Trois Finalités de la Gouvernance . . . 50
3.4.1 Créer de la valeur . . . 50
3.4.2 Trois objectifs de gouvernance . . . 50
3.5 Évaluer un Investissement Informatique . . . 51
3.5.1 Le coût total de possession . . . 51
3.5.2 La valeur actuelle nette . . . 52
3.5.3 Les limites de l'évaluation financière . . . 53
3.5.4 Le score multicritère . . . 53
3.6 Arbitrer un Portefeuille . . . 54
3.6.1 Projet, programme, portefeuille . . . 54
3.6.2 Équilibrer le portefeuille . . . 54
3.6.3 Le cadre de la gestion publique au Cameroun . . . 54

4 Panorama et Articulation des Référentiels 59

4.1 Trois Natures de Référentiels . . . 60
4.1.1 Cadre, norme, bonnes pratiques . . . 60
4.1.2 Certifier une organisation, certifier une personne . . . 60
4.1.3 Le cadre légal camerounais . . . 61
4.2 Les Référentiels de la Gouvernance . . . 62
4.2.1 COBIT : le cadre de gouvernance et de management . . . 62
4.2.2 ISO/IEC 38500 : les principes pour l'organe de gouvernance . . . 62
4.2.3 COSO : le contrôle interne et la gestion des risques . . . 62
4.3 Les Référentiels des Services et de la Sécurité . . . 62
4.3.1 ITIL : les bonnes pratiques de la gestion des services . . . 62
4.3.2 ISO/IEC 20000-1 : la norme du management des services . . . 63
4.3.3 ISO/IEC 27001 et 27002 : la sécurité de l'information . . . 63
4.3.4 ISO 22301 et ISO 31000 : continuité et risques . . . 63
4.4 Architecture, Projets et Maturité . . . 63
4.4.1 TOGAF : l'architecture d'entreprise . . . 64
4.4.2 PMBOK et PRINCE2 : la gestion de projet . . . 64
4.4.3 CMMI : la maturité des processus . . . 64

4.5 À Chaque Besoin son Référentiel . . . 64
4.6 La Carte d'Articulation . . . 65
4.6.1 Trois niveaux . . . 65
4.6.2 Construire la carte d'une organisation . . . 66

II COBIT 2019 : le Référentiel de la Gouvernance 71

5 COBIT 2019 : Principes et Architecture 73

5.1 Trente Ans d'Évolution . . . 74
5.1.1 Du contrôle à la gouvernance . . . 74
5.1.2 Ce que COBIT 2019 apporte . . . 74
5.1.3 Ce que COBIT n'est pas . . . 75
5.2 Les Principes de COBIT 2019 . . . 75
5.2.1 Six principes pour un système de gouvernance . . . 75
5.2.2 Trois principes pour un cadre de gouvernance . . . 76
5.3 Les Composantes du Système de Gouvernance . . . 76
5.3.1 Sept types de composantes . . . 76
5.3.2 La leçon des composantes . . . 77
5.3.3 Composantes génériques et variantes . . . 78
5.4 Objectifs et Domaines . . . 78
5.4.1 Objectifs de gouvernance et de management . . . 78
5.4.2 Cinq domaines, quarante objectifs . . . 78
5.5 Domaines d'Intérêt et Facteurs de Conception . . . 80
5.5.1 Les domaines d'intérêt . . . 80
5.5.2 Les facteurs de conception . . . 80

6 Les 40 Objectifs de Gouvernance et de Management 85

6.1 Lire un Objectif COBIT . . . 86
6.1.1 L'anatomie d'une fiche . . . 86
6.1.2 Pratiques et activités . . . 86
6.1.3 Rédiger une fiche processus . . . 87
6.2 Le Domaine de Gouvernance : EDM . . . 88
6.3 Aligner, Planifier et Organiser : APO . . . 88
6.4 Bâtir, Acquérir et Implémenter : BAI . . . 89
6.5 Délivrer, Servir, Soutenir et Surveiller : DSS et MEA . . . 90
6.6 La Cascade des Objectifs . . . 91
6.6.1 Des besoins aux objectifs COBIT . . . 91
6.6.2 Les vingt-six objectifs intermédiaires . . . 93
6.6.3 Lire la cascade dans les fiches . . . 93
6.7 Objectifs Prioritaires : une Banque, une Administration . . . 94
6.7.1 La BANQUE SANAGA . . . 94

6.7.2 L'ANPP . . . 95

7 Concevoir un Système de Gouvernance sur Mesure 99

7.1 Les Trois Effets des Facteurs de Conception . . . 100
7.2 Les Onze Facteurs de Conception . . . 100
7.2.1 Le tableau des facteurs . . . 100
7.2.2 Quatre facteurs à bien comprendre . . . 101
7.2.3 L'ancrage juridique camerounais . . . 102
7.3 La Démarche en Quatre Étapes . . . 103
7.4 Calculer un Profil d'Objectifs . . . 104
7.4.1 Une méthode pédagogique . . . 104
7.4.2 Les quatre temps du calcul . . . 104
7.4.3 Application à la BANQUE SANAGA . . . 104
7.5 Arbitrer et Justifier . . . 105
7.5.1 Résoudre les conflits . . . 105
7.5.2 Trois types de conflits fréquents . . . 106

8 Mesurer et Mettre en Œuvre : Capacité, Maturité et Feuille de Route 109

8.1 Mesurer la Performance dans COBIT . . . 110
8.1.1 Cinq principes . . . 110
8.1.2 Un modèle aligné sur CMMI . . . 110
8.2 Les Niveaux de Capacité . . . 110
8.2.1 Six niveaux . . . 110
8.2.2 Des activités rattachées à des niveaux . . . 111
8.3 Capacité et Maturité . . . 112
8.3.1 Mesurer les autres composantes . . . 112
8.4 Évaluer une Capacité . . . 112
8.4.1 L'échelle de notation . . . 112
8.4.2 La règle d'attribution du niveau . . . 113
8.4.3 Une évaluation pas à pas . . . 113
8.5 La Mise en Œuvre en Sept Phases . . . 114
8.5.1 Un programme, pas un projet . . . 114
8.5.2 Sept phases, trois anneaux . . . 115
8.5.3 Le lien avec la conception . . . 115
8.6 Construire une Feuille de Route . . . 115
8.6.1 De l'écart au plan . . . 115

III Cadre Normatif, Juridique et Déontologique 119

9 Les Normes Internationales de la Gouvernance et des Services 121

9.1 L'Architecture des Systèmes de Management . . . 122
9.1.1 Qu'est-ce qu'un système de management ? . . . 122

9.1.2 Une structure harmonisée . . . 122
9.2 ISO/IEC 38500 : la Norme de la Gouvernance . . . 123
9.2.1 Une norme pour l'organe de gouvernance . . . 123
9.2.2 Le modèle évaluer, diriger, surveiller . . . 123
9.2.3 Des principes de 2015 à ceux de 2024 . . . 123
9.3 ISO/IEC 20000-1 : le Management des Services . . . 124
9.3.1 Les exigences . . . 124
9.3.2 ITIL, COBIT et ISO/IEC 20000-1 . . . 125
9.4 ISO/IEC 27001 et 27002 : la Sécurité de l'Information . . . 125
9.4.1 Le système de management de la sécurité . . . 125
9.4.2 Deux éditions à ne pas confondre . . . 126
9.4.3 Le lien avec la gouvernance . . . 126
9.5 Le Risque : ISO 31000 et COSO . . . 127
9.5.1 ISO 31000 : des lignes directrices pour tout risque . . . 127
9.5.2 COSO : contrôle interne et risques de l'entreprise . . . 127
9.5.3 Articuler les risques . . . 128
9.6 Certification, Conformité, Alignement . . . 128
9.6.1 Trois démarches . . . 128
9.6.2 Le cycle de certification . . . 128

10 Cadre Juridique et Réglementaire Camerounais et Africain 133

10.1 Panorama des Textes . . . 134
10.2 La Loi sur la Cybersécurité . . . 134
10.2.1 L'ANTIC, régulateur de la sécurité . . . 134
10.2.2 Les obligations des exploitants de systèmes d'information . . . 135
10.2.3 Les sanctions et la responsabilité des personnes morales . . . 136
10.3 Les Régulateurs . . . 137
10.4 La Protection des Données Personnelles . . . 138
10.4.1 De la loi de 2010 à la loi de 2024 . . . 138
10.4.2 La loi n° 2024/017 . . . 138
10.4.3 Ce que la loi change pour la gouvernance des SI . . . 138
10.5 La Réglementation Bancaire de la CEMAC . . . 139
10.5.1 Le règlement COBAC R-2016/04 . . . 139
10.5.2 Ce que cela implique . . . 140
10.6 Le Droit des Sociétés OHADA . . . 140
10.6.1 La responsabilité des dirigeants . . . 140
10.6.2 Le comité d'audit et le contrôle interne . . . 141
10.7 Le Cadre Africain . . . 141
10.7.1 La Convention de Malabo . . . 141
10.7.2 Une dynamique continentale . . . 141
10.8 Les Erreurs de Qualification . . . 142

11 Audit, Contrôle et Assurance de la Gouvernance des SI 145

11.1 Le Modèle des Trois Lignes . . . 146
11.1.1 Qui fait quoi dans la maîtrise des risques . . . 146
11.1.2 Trois erreurs fréquentes . . . 146
11.2 Les Normes de l'Audit Interne . . . 147
11.2.1 Du cadre de 2017 aux Normes mondiales de 2024 . . . 147
11.3 L'Audit Public des SI : l'INTOSAI GUID 5100 . . . 148
11.3.1 Les institutions supérieures de contrôle . . . 148
11.3.2 La démarche du GUID 5100 . . . 148
11.4 Tester les Contrôles Généraux Informatiques . . . 149
11.4.1 Trois familles de contrôles . . . 149
11.4.2 L'échantillonnage . . . 150
11.5 Rédiger un Constat d'Audit . . . 151
11.5.1 Les cinq éléments . . . 151
11.5.2 Le suivi des recommandations . . . 152
11.6 La Déontologie . . . 152
11.6.1 L'auditeur . . . 152
11.6.2 Le DSI . . . 153

IV ITIL 4 et Pratique Opérationnelle 157

12 ITIL 4 : le Système de Valeur des Services 159

12.1 Trente-Cinq Ans d'ITIL . . . 160
12.2 Les Concepts Clés . . . 160
12.2.1 Service et valeur . . . 160
12.2.2 Résultats, produits et relations . . . 161
12.2.3 Utilité et garantie . . . 161
12.3 Le Système de Valeur des Services . . . 161
12.3.1 Cinq composantes . . . 161
12.3.2 ITIL et la gouvernance . . . 162
12.4 La Chaîne de Valeur des Services . . . 162
12.4.1 Six activités . . . 163
12.4.2 Des chaînes de valeur, pas un ordre fixe . . . 163
12.5 Les Quatre Dimensions . . . 164
12.6 Les Sept Principes Directeurs . . . 165
12.6.1 Les 34 pratiques . . . 165
12.7 Et ITIL Version 5 ? . . . 166

13 Centre de Services, Incidents, Problèmes et Demandes 171

13.1 Quatre Notions à ne pas Confondre . . . 172
13.2 Le Centre de Services . . . 172

13.2.1 Le point d'entrée unique . . . 172
13.2.2 Organiser le centre de services . . . 173
13.3 La Gestion des Incidents . . . 173
13.3.1 Le cycle d'un incident . . . 173
13.3.2 La matrice de priorité . . . 174
13.3.3 L'incident majeur . . . 174
13.4 La Gestion des Demandes de Service . . . 175
13.5 La Gestion des Problèmes . . . 175
13.5.1 Trois phases . . . 175
13.5.2 L'analyse de cause racine . . . 176
13.6 Mesurer la Performance . . . 177
13.6.1 Les indicateurs . . . 177
13.6.2 Un calcul pas à pas . . . 178
13.7 Le Lien avec la Gouvernance . . . 178
14 Changements, Mises en Production et Configuration 183
14.1 Les Changements et leurs Types . . . 184
14.1.1 Qu'est-ce qu'un changement ? . . . 184
14.1.2 Trois types de changements . . . 184
14.1.3 L'autorité de changement . . . 185
14.2 Évaluer et Autoriser . . . 185
14.2.1 Une grille d'évaluation du risque . . . 185
14.2.2 Le calendrier des changements . . . 186
14.3 Mises en Production et Déploiements . . . 187
14.3.1 Deux pratiques distinctes . . . 187
14.3.2 Stratégies de mise en production . . . 187
14.3.3 Le retour arrière . . . 188
14.3.4 Les pratiques de COBIT . . . 188
14.4 La Gestion de la Configuration . . . 189
14.4.1 Éléments de configuration et CMDB . . . 189
14.4.2 L'analyse d'impact . . . 189
14.4.3 L'objectif BAI10 . . . 190
14.5 Changements et Gouvernance . . . 191
15 Niveaux de Service, Disponibilité, Continuité et Fournisseurs 195
15.1 Les Engagements de Service . . . 195
15.1.1 Trois niveaux d'accord . . . 196
15.1.2 Rédiger un SLA utile . . . 197
15.2 Calculer une Disponibilité . . . 198
15.2.1 La formule . . . 198
15.2.2 Composants en série et en parallèle . . . 198
15.3 Les Pénalités . . . 199

15.3.1 Un mécanisme contractuel . . . 199
15.4 La Continuité de Service . . . 199
15.4.1 L'analyse d'impact sur l'activité . . . 199
15.4.2 Le plan et ses tests . . . 200
15.5 Piloter les Fournisseurs . . . 201
15.5.1 L'externalisation ne transfère pas la responsabilité . . . 201
15.5.2 Le cycle de la relation fournisseur . . . 202
15.5.3 Les clauses essentielles . . . 202

16 Processus : Modéliser, Responsabiliser, Mesurer 207

16.1 Processus et Pratiques . . . 208
16.2 Modéliser en BPMN . . . 208
16.2.1 Les éléments du langage . . . 208
16.2.2 Un exemple . . . 209
16.3 Responsabiliser : la Matrice RACI . . . 209
16.3.1 Quatre rôles . . . 209
16.3.2 Cinq règles . . . 210
16.4 COBIT, ITIL et ISO/IEC 20000-1 . . . 211
16.4.1 Pourquoi une correspondance . . . 211
16.4.2 Les limites d'une correspondance . . . 212
16.5 Mesurer : KPI, KGI et Tableau de Bord . . . 213
16.5.1 Deux familles d'indicateurs . . . 213
16.5.2 Un bon indicateur . . . 214
16.6 Propriétaires et Amélioration Continue . . . 214

17 Études de Cas Intégrateurs 217

17.1 La Méthode du Diagnostic Intégré . . . 218
17.1.1 Six volets . . . 218
17.1.2 Le livrable . . . 218
17.2 Cas 1 : la BANQUE SANAGA, un An Après . . . 218
17.2.1 Brief initial . . . 219
17.2.2 Investigation guidée . . . 219
17.2.3 Révélations progressives . . . 219
17.2.4 Synthèse et rapport . . . 220
17.3 Cas 2 : KRIBILOG, la Certification en Jeu . . . 221
17.3.1 Brief initial . . . 221
17.3.2 Investigation guidée . . . 221
17.3.3 Révélations progressives . . . 222
17.3.4 Synthèse et rapport . . . 222
17.4 Cas 3 : l'ANPP face à la Chambre des Comptes . . . 222
17.4.1 Brief initial . . . 223
17.4.2 Investigation guidée . . . 223

17.4.3 Révélations progressives . . . 223
17.4.4 Synthèse et rapport . . . 223
17.5 Cas 4 : NOUN PAY, Croître sans Perdre la Confiance . . . 224
17.5.1 Brief initial . . . 224
17.5.2 Investigation guidée . . . 224
17.5.3 Révélations progressives . . . 224
17.5.4 Synthèse et rapport . . . 225
17.6 Grille des Erreurs Transversales . . . 225
17.7 Simulation d'Examen . . . 226

V Défis Avancés et Émergents 229

18 Agilité, DevOps et Cloud : Gouverner à Grande Vitesse 231

18.1 L'Agilité . . . 232
18.1.1 Le manifeste et ses conséquences . . . 232
18.1.2 Ce qui change pour la gouvernance . . . 232
18.2 DevOps . . . 232
18.2.1 Rapprocher le développement et l'exploitation . . . 233
18.2.2 Mesurer la performance de la livraison . . . 233
18.2.3 Déplacer le contrôle dans la chaîne . . . 234
18.3 L'Informatique en Nuage . . . 235
18.3.1 Définitions . . . 235
18.3.2 La responsabilité partagée . . . 235
18.3.3 Gouverner le nuage . . . 236
18.4 Le Contrat de Nuage et le Droit Camerounais . . . 236
18.5 La Gouvernance Numérique en Afrique . . . 238
18.5.1 Un cadre continental . . . 238
18.5.2 Des lois nationales de protection des données . . . 238
18.5.3 Trois enseignements . . . 238

19 Gouvernance des Données et de l'Intelligence Artificielle 243

19.1 La Gouvernance des Données . . . 244
19.1.1 Les données, un actif . . . 244
19.1.2 Les rôles . . . 245
19.2 Qualité et Cycle de Vie . . . 245
19.2.1 Les dimensions de la qualité . . . 245
19.2.2 Le cycle de vie . . . 245
19.3 Gouverner l'Intelligence Artificielle . . . 246
19.3.1 Ce que l'IA change . . . 246
19.3.2 Les normes et cadres de référence . . . 247
19.4 Évaluer les Risques d'un Système d'IA . . . 247

19.4.1 Une grille en six risques . . . 248
19.4.2 Mesurer un biais . . . 248
19.5 La Notation de NOUN PAY au Regard du Droit . . . 249
19.5.1 Les questions à instruire . . . 249
19.5.2 Le dispositif de gouvernance . . . 249

VI Recherche et Contributions 253

20 Mesurer la Gouvernance des SI : État de la Recherche 255

20.1 Trois Courants de Recherche . . . 256
20.1.1 Les structures de décision . . . 256
20.1.2 Les mécanismes . . . 256
20.1.3 L'effet sur la performance . . . 256
20.2 Ce que la Recherche a Établi . . . 257
20.2.1 Des résultats convergents . . . 257
20.2.2 Ce qui reste débattu . . . 257
20.3 Le Débat sur les Modèles de Maturité . . . 258
20.3.1 Un succès considérable . . . 258
20.3.2 Quatre critiques . . . 258
20.4 Lire une Étude Empirique . . . 258
20.4.1 Une grille de lecture . . . 259
20.4.2 Le statut des sources . . . 259
20.5 Des Pistes de Recherche en Afrique Centrale . . . 260
20.5.1 Un champ peu exploré . . . 260
20.5.2 Des questions possibles . . . 260
20.5.3 Les méthodes . . . 260

21 Contributions et Pistes de Recherche 263

A Glossaire 265

B Référentiel des Outils 271

C Modèles de Documents Opérationnels 273

D Textes Législatifs et Réglementaires 277

E Bibliographie Commentée 281

F Contacts et Ressources 283

Références bibliographiques 285

TABLE DES FIGURES

© *MaletYon*

LISTE DES TABLEAUX

© *MaletYon*

Prologue Opérationnel

© *MaletYon*

0

PROLOGUE : TROIS JOURS SANS BANQUE, QUAND PERSONNE N'A DÉCIDÉ

« Une panne se répare en quelques heures.
Une décision que personne n'a prise se paie pendant des années. »

Thierry Minka, auditeur des systèmes d'information

Niveau : *Introductif* • Aucun prérequis. Ce prologue se lit avant d'ouvrir le moindre référentiel : il ne suppose aucune connaissance de COBIT ni d'ITIL.

✦ Objectifs du chapitre

- ➢ Reconstituer la chronologie d'une défaillance informatique majeure (opération SANAGA).
- ➢ Distinguer une cause technique d'une cause de gouvernance.
- ➢ Poser les trois questions réflexes : qui décide, qui exécute, qui rend compte.
- ➢ Distinguer gouvernance et management des systèmes d'information.
- ➢ Identifier les parties prenantes qui demandent des comptes (conseil d'administration, régulateur, clients).
- ➢ Situer COBIT et ITIL dans la réponse à la défaillance.

Avant de commencer : une panne qui n'était pas technique

Douala, lundi 9 mars 2026, 7 h 30. Les 38 agences de la BANQUE SANAGA[1] ouvrent leurs portes. Aucun guichet ne fonctionne. Les écrans affichent un message d'erreur du nouveau système bancaire central, mis en service pendant le week-end. Les distributeurs automatiques passent en mode dégradé, les virements et les paiements par carte sont bloqués. À Yaoundé, à Bafoussam, à Garoua, les files d'attente s'allongent devant des agences qui ne peuvent ni verser ni retirer.

La paralysie dure **trois jours**. Le service ne revient complètement que le jeudi 12 mars

[1] La BANQUE SANAGA, ses dirigeants, ses prestataires, les dates et les montants de ce cas sont fictifs. Les mécanismes de gouvernance, les référentiels et les textes cités sont exacts.

© MaletYon

au matin. Le coût, chiffré plus tard par la direction financière, atteint **1,9 milliard de francs CFA**. Le 16 mars, la Commission bancaire de l'Afrique centrale (COBAC) demande à la banque un rapport circonstancié sous trente jours.

Le conseil d'administration réunit une séance extraordinaire. Le directeur général, M. FOTSO, ouvre la séance par une phrase qui résume ce que chacun pense alors : « Le prestataire nous a livré un logiciel défaillant. » Le rapport d'enquête interne, remis trois semaines plus tard, dit tout autre chose.

★ Attention

Ce que révèle l'enquête. Le logiciel n'était pas en cause. Il avait été recetté à 63 % seulement quand la date de bascule a été maintenue. La date elle-même avait été fixée pour coïncider avec le lancement commercial d'une offre mobile, déjà annoncée à la presse. Le comité de pilotage du projet ne s'était plus réuni depuis quatre mois. Aucun comité n'avait autorisé la mise en production. Aucun retour arrière n'avait été testé, et la conversion des données de l'ancien système était irréversible. Le contrat de l'intégrateur ne prévoyait aucune pénalité. Un rapport d'audit interne avait signalé ces faiblesses cinq mois plus tôt : ses recommandations étaient restées « en cours ».

Chacune de ces défaillances est une **décision** qui n'a pas été prise, ou qui a été prise par la mauvaise personne, sans trace écrite et sans que personne en rende compte.

Ce prologue n'enseigne ni COBIT ni ITIL. Ces référentiels occupent les chapitres qui suivent. Il enseigne **le réflexe fondateur de la discipline** : devant toute défaillance d'un système d'information, chercher la décision derrière l'incident. Une panne se répare. Une organisation qui ne sait pas qui décide reproduira la même panne.

0.1 Chronologie de la Défaillance

0.1.1 Reconstituer avant de juger

La première tâche de quiconque analyse une défaillance (le DSI qui rédige le rapport au régulateur, l'auditeur mandaté par le conseil, le responsable des risques) est de **reconstituer la chronologie**. Elle fixe les faits avant toute interprétation. Elle se construit à partir de pièces : procès-verbaux, courriels, tickets, journaux d'exploitation, contrats.

■ Définition

Chronologie de défaillance (*incident timeline*) : suite datée des faits, des décisions et des absences de décision qui ont précédé, accompagné et suivi une défaillance. Chaque entrée est rattachée à une pièce justificative.

Date	Fait établi	Pièce
Juin 2025	Le conseil d'administration approuve le projet HORIZON (remplacement du système bancaire central), budget de 3,2 milliards FCFA. Intégrateur retenu : DIGICORE AFRIQUE.	Procès-verbal du conseil
Oct. 2025	L'audit interne signale l'absence de procédure de gestion des changements et de plan de continuité testé. Recommandations notées « en cours ».	Rapport d'audit n° 2025-07
Nov. 2025	Dernière réunion du comité de pilotage du projet.	Compte rendu
Janv. 2026	Le directeur général fixe la bascule au week-end du 7–8 mars, date du lancement de l'offre « SANAGA Mobile ».	Courriel du DG
20 févr. 2026	Recette à 63 % des scénarios. La DSI demande un report par note interne. Aucune réponse écrite.	Note de la DSI
7 mars, 22 h	Début de la migration.	Journal d'exploitation
8 mars, 14 h	Conversion des comptes : écarts de solde sur 11 % des comptes. Le retour à l'ancien système n'est plus possible.	Journal d'exploitation
9 mars, 7 h 30	Ouverture des agences : système indisponible.	Tickets du centre de services
12 mars, 8 h	Retour complet du service.	Journal d'exploitation
16 mars	La COBAC demande un rapport circonstancié sous 30 jours.	Lettre de la COBAC

Tableau P.1. Chronologie de l'opération SANAGA

0.1.2 Constatation et analyse

Une chronologie ne contient que des **constatations** : des faits vérifiables, rattachés à une pièce. L'interprétation vient ensuite, dans une partie distincte, et elle s'accompagne d'un niveau de confiance. Mélanger les deux est l'erreur la plus fréquente des rapports de défaillance, et la plus facile à exploiter par celui qui veut contester le rapport.

★ Attention

Violation typique. Le premier projet de rapport de la BANQUE SANAGA écrit : « Le prestataire a livré un logiciel non conforme, ce qui a provoqué la panne. » La phrase mêle un fait non établi (la non-conformité) et une causalité non démontrée. DIGICORE AFRIQUE produit aussitôt le procès-verbal de recette, qui montre que la banque a elle-même décidé de basculer avec 37 % des scénarios non testés.

Règle : écrire d'abord la constatation (« La recette couvrait 63 % des scénarios le 20 février ; la bascule a eu lieu le 7 mars »), puis l'analyse, avec son niveau de confiance (« Il est très probable que les écarts de solde proviennent de scénarios de conversion non testés »).

0.2 Cause Technique, Cause de Gouvernance

0.2.1 Deux niveaux d'explication

Toute défaillance d'un système d'information s'explique à deux niveaux. Le **niveau technique** répond à la question *comment* : quel composant a cédé, quelle donnée a été corrompue. Le **niveau de la gouvernance** répond à la question *pourquoi cela a été possible* : quelle décision, quel contrôle, quelle responsabilité a manqué.

Définition

Défaillance de gouvernance (*governance failure*) : absence, inadéquation ou contournement d'un mécanisme de décision, de contrôle ou de reddition de comptes, qui permet qu'un risque connu ou connaissable se réalise.

Cause technique (comment ?)	Cause de gouvernance (pourquoi était-ce possible ?)
Écarts de solde lors de la conversion des comptes	Bascule maintenue avec une recette incomplète, sans décision formelle d'acceptation du risque
Retour arrière impossible	Aucun plan de retour arrière exigé ni testé avant l'autorisation de mise en production
Indisponibilité prolongée	Aucun plan de continuité testé, malgré la recommandation de l'audit interne
Intervention lente de l'intégrateur	Contrat sans engagement de niveau de service ni pénalité
Communication de crise improvisée	Aucun rôle de crise défini, aucune information préalable du conseil sur le risque du projet

Tableau P.2. Les deux niveaux d'explication de l'opération SANAGA

0.2.2 Remonter de l'incident à la décision

Une méthode simple permet de passer d'un niveau à l'autre : demander « pourquoi ? » jusqu'à atteindre une décision, ou une absence de décision. Appliquée à la BANQUE SANAGA, elle donne :

1. *Pourquoi les agences étaient-elles paralysées ?* Parce que le nouveau système produisait des soldes erronés.

2. *Pourquoi les soldes étaient-ils erronés ?* Parce que des scénarios de conversion n'avaient pas été testés.

3. *Pourquoi a-t-on basculé sans les tester ?* Parce que la date était fixée par le lancement commercial.

4. *Pourquoi la date l'a-t-elle emporté sur la recette ?* Parce que personne n'avait l'autorité, ni l'obligation, d'arbitrer entre le risque technique et l'enjeu commercial.

La quatrième réponse n'est plus technique. Elle décrit une **organisation** : elle sera au cœur des Parties I et II du cours.

Note

La règle d'or : une analyse de défaillance est terminée quand elle a atteint une décision, ou une absence de décision, et qu'elle a nommé le rôle qui aurait dû la prendre. Tant qu'elle s'arrête à un composant, elle n'a expliqué que la moitié de l'incident.

0.3 Les Trois Questions Réflexes

0.3.1 Décider, exécuter, rendre compte

Devant tout projet, tout changement ou toute défaillance d'un système d'information, trois questions suffisent à révéler l'état de la gouvernance.

1. **Qui décide ?** Quelle instance ou quelle personne avait l'autorité de trancher, et l'a-t-elle fait, par écrit ?

2. **Qui exécute ?** Qui a mis en œuvre la décision, avec quels moyens, et selon quelle procédure ?

3. **Qui rend compte ?** Qui doit expliquer le résultat, à qui, et sur la base de quelles informations ?

Définition

Droits de décision (*decision rights*) : répartition formelle, entre les instances et les personnes d'une organisation, du pouvoir de décider sur une question donnée. Weill et Ross en font le cœur de la gouvernance des SI [49].

Redevabilité (*accountability*) : obligation, pour celui qui a reçu une responsabilité, d'en rendre compte à l'instance qui la lui a confiée, et d'en assumer les conséquences.

0.3.2 Application à la BANQUE SANAGA

Décision	Prise par	Aurait dû l'être par	Trace écrite
Date de bascule	Directeur général seul	Comité de pilotage, sur avis de la DSI	Courriel
Bascule avec recette incomplète	Personne (statu quo)	Comité de pilotage, avec acceptation formelle du risque	Aucune
Autorisation de mise en production	Personne	Comité des changements	Aucune
Suite des recommandations d'audit	Personne	Direction générale, suivie par le comité d'audit	« En cours »
Information du conseil sur le risque	Personne	Directeur général	Aucune

Tableau P.3. Les droits de décision dans l'opération SANAGA

Le tableau parle de lui-même. Sur cinq décisions critiques, une seule a été prise, par une personne seule, sans l'avis de ceux qui portaient le risque. Les quatre autres n'ont été prises par personne. C'est la signature d'une organisation sans gouvernance des SI : non pas des dirigeants incompétents, mais une absence de règles sur *qui décide de quoi*.

Application DSI

Protéger la décision, pas seulement le système

1. Tout désaccord sur un risque majeur (date, périmètre, recette) se formule **par écrit**, adressé à l'instance qui a le droit de décider, et non au seul supérieur hiérarchique.
2. La note expose les faits (taux de recette, scénarios non testés), le risque (ce qui peut arriver, son coût estimé) et les options (reporter, réduire le périmètre, accepter le risque).
3. Elle demande une **décision explicite** : le silence n'est pas une décision.
4. Le DSI conserve la note et la réponse, ou l'absence de réponse, dans le dossier du projet.

La note du 20 février de la DSI de la BANQUE SANAGA était juste sur le fond. Elle a échoué sur la forme : adressée au seul directeur général, elle ne demandait aucune décision et n'a jamais atteint le comité de pilotage.

0.4 Gouvernance et Management

0.4.1 Une distinction fondatrice

Les trois questions réflexes font apparaître deux familles d'activités. Les unes fixent la direction et contrôlent le résultat ; les autres réalisent. COBIT 2019 en fait une distinction structurante, chacune relevant d'activités, de structures et de finalités différentes [23].

Définition

Gouvernance des SI (*governance of enterprise I&T*) : ensemble des activités par lesquelles l'organe de gouvernance *évalue* les besoins des parties prenantes pour fixer des objectifs équilibrés, *dirige* par la priorisation et la décision, et *surveille* la performance et la conformité au regard de cette direction. Elle relève, dans la plupart des organisations, du conseil d'administration.

Management des SI (*management of enterprise I&T*) : ensemble des activités qui *planifient*, *bâtissent*, *exploitent* et *surveillent* les systèmes d'information, conformément à la direction fixée par la gouvernance. Il relève de la direction générale.

Critère	Gouvernance	Management
Question	Fait-on les bonnes choses ?	Fait-on bien les choses ?
Responsable	Conseil d'administration et ses comités	Direction générale, DSI, responsables opérationnels
Verbes (COBIT)	Évaluer, diriger, surveiller	Planifier, bâtir, exploiter, surveiller
Horizon	Stratégique, pluriannuel	Opérationnel, annuel et quotidien
Exemple SANAGA	Décider si le lancement commercial justifie le risque de bascule	Conduire la recette, préparer le retour arrière

Tableau P.4. Gouvernance et management des SI

Le DSI gouverne-t-il ?

La question revient à chaque promotion, et la réponse est nuancée. Le DSI *participe* à la gouvernance : il éclaire le conseil, propose des arbitrages, alerte sur les risques. Mais il n'en est pas l'organe. Un DSI qui décide seul de la stratégie numérique gouverne par défaut, faute d'instance compétente. Un conseil qui délègue tout au DSI renonce à sa propre responsabilité. Le Chapitre 1 reprendra cette question à partir de la théorie de l'agence.

0.5 Ceux qui Demandent des Comptes

0.5.1 Les parties prenantes de la BANQUE SANAGA

Une défaillance majeure fait apparaître, d'un coup, tous ceux à qui l'organisation doit des comptes. Chacun pose une question différente et attend une réponse documentée.

Partie prenante	Sa question	Ce qu'elle exige
Conseil d'administration	Pourquoi n'avons-nous pas été informés du risque ?	Un rapport sur les causes et la responsabilité de chacun
Actionnaires	Combien cela coûte-t-il, et cela peut-il se reproduire ?	Le chiffrage des pertes et un plan d'action
COBAC	Le contrôle interne de la banque fonctionne-t-il ?	Un rapport circonstancié sous 30 jours
Clients et commerçants	Nos opérations sont-elles justes ?	La correction des soldes et une indemnisation
Commissaire aux comptes	Les comptes de l'exercice restent-ils fiables ?	La preuve de l'exactitude des soldes convertis

Tableau P.5. Les parties prenantes et leurs exigences

0.5.2 Le coût d'une décision manquée

Le chiffrage de la direction financière donne la mesure de l'enjeu.

Poste	Montant (millions FCFA)
Commissions et frais non perçus pendant trois jours	410
Indemnisation des clients et des commerçants	380
Prestations d'urgence et heures supplémentaires	260
Retraits hors ligne au-delà du solde, non recouvrés	330
Correction des données et audit externe imposé	520
Total	**1 900**

Tableau P.6. Coût de l'opération SANAGA

Le report de la bascule de six semaines, demandé par la DSI, aurait coûté selon le même service environ 85 millions FCFA (prolongation de l'intégrateur et décalage de la campagne commerciale). Le rapport entre les deux montants, plus de vingt pour un, est l'argument que la gouvernance aurait dû voir avant la bascule, et qu'elle n'a vu qu'après.

0.5.3 Le cadre légal camerounais

La défaillance de la BANQUE SANAGA ne relève pas seulement de la réglementation bancaire. La loi camerounaise sur la cybersécurité soumet les systèmes d'information à des obligations d'audit.

⚖ Jurisprudence & Droit applicable

Loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et la cybercriminalité au Cameroun, article 32 (version anglaise officielle) :

« (1) Electronic communication networks and information systems shall be subject to a regime of compulsory and periodic auditing of their security systems by the Agency. (2) Security audit and severity scale rating shall be undertaken each year or as required by the prevailing circumstances. »

Soit, en substance : les réseaux de communications électroniques et les systèmes d'information sont soumis à un audit obligatoire et périodique de leur sécurité par l'Agence (l'ANTIC), conduit chaque année ou selon les circonstances. L'article 13 de la même loi soumet en outre les systèmes d'information des opérateurs à un audit de sécurité obligatoire, dont les modalités sont fixées par voie réglementaire.

Portée. La loi fait de l'audit des systèmes d'information une obligation, et non une bonne pratique facultative. Le Chapitre 10 précisera son champ d'application exact, ses textes d'application et son articulation avec la réglementation de la COBAC sur le contrôle interne des établissements de crédit, ainsi qu'avec le droit OHADA de la responsabilité des dirigeants.

0.6 Ce que COBIT et ITIL Auraient Changé

0.6.1 Deux référentiels, deux niveaux

Les deux référentiels au programme de ce cours répondent chacun à un niveau d'explication de la défaillance. **COBIT 2019** (Partie II) organise la gouvernance et le management de l'ensemble des systèmes d'information : qui décide, selon quels objectifs, avec quels contrôles. **ITIL 4** (Partie IV) organise la gestion des services informatiques au quotidien : comment autoriser un changement, traiter un incident, tenir un engagement de service. COBIT dit *ce qui doit être maîtrisé* ; ITIL décrit en détail *comment le faire* pour les services.

Défaillance SANAGA	Objectif COBIT 2019	Pratique ITIL 4
Aucune instance n'arbitre le risque du projet	EDM01, EDM03 (cadre de gouvernance, optimisation des risques)	·
Comité de pilotage en sommeil	BAI01, BAI11 (programmes, projets)	Gestion de projet
Mise en production non autorisée, sans retour arrière	BAI06, BAI07 (changements, acceptation et transition)	Habilitation des changements, gestion des mises en production
Contrat sans engagement de service	APO09, APO10 (accords de service, fournisseurs)	Gestion des niveaux de service, gestion des fournisseurs
Aucun plan de continuité testé	DSS04 (continuité)	Gestion de la continuité de service
Recommandations d'audit sans suite	MEA02 (système de contrôle interne)	·

Tableau P.7. Défaillances SANAGA, objectifs COBIT et pratiques ITIL (intitulés traduits par nos soins)

0.6.2 Un exemple : la gestion des changements

La mise en production du nouveau système était un **changement** au sens des deux référentiels : une modification d'un élément du système d'information susceptible d'affecter les services. COBIT en fait un objectif de management, que le cours présentera toujours sous la même forme.

Fiche processus · BAI06 · Gérer les changements informatiques

Finalité : permettre des changements rapides et fiables, en limitant le risque d'affecter la stabilité ou l'intégrité de l'environnement modifié.
Pratiques clés : évaluer, prioriser et autoriser les demandes de changement ; gérer les changements d'urgence ; suivre l'état des changements et en rendre compte ; clore et documenter les changements.
Entrées et sorties : demande de changement, évaluation d'impact et de risque, plan de retour arrière ; décision d'autorisation, calendrier des changements, rapport de clôture.
RACI (extrait) : autorisation d'un changement majeur : *A* au comité des changements, *R* au responsable du changement, *C* aux métiers concernés et au RSSI, *I* au centre de services.
Indicateurs : taux de changements en échec, nombre de changements non autorisés, part des changements majeurs dotés d'un retour arrière testé.

Exigence de contrôle

Mise en production d'un changement majeur. Pour qu'un auditeur puisse établir que le changement était maîtrisé, le dossier doit contenir :

- le procès-verbal de recette, avec le taux de couverture des scénarios et la liste des anomalies ouvertes ;
- l'évaluation du risque et la décision écrite d'acceptation des risques résiduels, signée par l'instance compétente ;
- le plan de retour arrière et la preuve qu'il a été testé ;
- le procès-verbal d'autorisation du comité des changements, daté et antérieur à la mise en production ;
- le rapport de clôture, avec les incidents survenus.

Dans l'opération SANAGA, seule la première pièce existait.

Application Auditeur SI

Les cinq pièces à demander après une défaillance majeure

1. Les procès-verbaux des instances de gouvernance (conseil, comité d'audit, comité de pilotage) sur la période du projet.
2. Le dossier du changement (voir l'exigence de contrôle ci-dessus).
3. Les contrats avec les prestataires et leurs annexes de niveau de service.
4. Le plan de continuité et les comptes rendus de ses derniers tests.
5. Le suivi des recommandations d'audit antérieures, avec leurs dates d'échéance et leurs responsables.

L'absence d'une pièce est elle-même une constatation : elle se consigne comme telle.

0.7 Retour sur la BANQUE SANAGA : ce qui Aurait Dû se Passer

Voici la même bascule, conduite cette fois par une organisation gouvernée.

Scénario Opérationnel · Opération SANAGA. La bascule gouvernée

1. **Juin 2025.** En approuvant le projet HORIZON, le conseil d'administration fixe ses règles : un comité de pilotage mensuel présidé par le directeur général adjoint, un point de risque trimestriel au comité d'audit, et l'obligation d'une décision formelle avant toute bascule.

2. **Octobre 2025.** Les recommandations de l'audit interne sur la gestion des changements et la continuité reçoivent chacune un responsable et une échéance. Le comité d'audit en suit l'avancement.
3. **20 février 2026.** La note de la DSI (recette à 63 %) est inscrite à l'ordre du jour du comité de pilotage. Le comité compare le coût d'un report (85 millions FCFA) et le risque d'une bascule prématurée.
4. **Décision.** Le comité reporte la bascule de six semaines et dissocie le lancement de « SANAGA Mobile », qui démarre sur l'ancien système. La décision est consignée au procès-verbal.
5. **Avril 2026.** Recette à 98 %, retour arrière testé à blanc, comité des changements réuni. Le contrat de DIGICORE AFRIQUE a été amendé : présence sur site pendant la bascule et pénalités de retard d'intervention.
6. **Bascule.** Un écart de solde est détecté le dimanche à 15 h. Le retour arrière est déclenché à 16 h. Les agences ouvrent le lundi sur l'ancien système. La bascule réussit deux semaines plus tard.

Résultat : le même incident technique s'est produit. Il est resté un incident d'exploitation, sans conséquence pour les clients, au lieu de devenir une crise à 1,9 milliard FCFA.

Le point essentiel est là : **la gouvernance n'empêche pas les incidents techniques**. Elle fait en sorte qu'ils soient anticipés, décidés et contenus. La suite du cours donne les outils pour construire une telle organisation.

❍

★ À retenir

Ce qu'il faut retenir de ce prologue :

- ➢ **Une défaillance a deux niveaux** : la cause technique dit comment le système a cédé, la cause de gouvernance dit pourquoi c'était possible. Une analyse qui s'arrête au composant est incomplète.
- ➢ **La chronologie d'abord** : on reconstitue les faits à partir de pièces, et on sépare toujours la constatation de l'analyse.
- ➢ **Trois questions réflexes** : qui décide, qui exécute, qui rend compte. Une décision sans trace écrite, ou prise par personne, est un signal d'alerte.
- ➢ **Gouvernance et management sont distincts** : la gouvernance évalue, dirige et surveille ; le management planifie, bâtit, exploite et surveille.
- ➢ **Les parties prenantes demandent des comptes** : conseil, actionnaires,

régulateur, clients, commissaire aux comptes. Au Cameroun, la loi n° 2010/012 fait de l'audit des systèmes d'information une obligation.

- **COBIT et ITIL se complètent** : COBIT organise ce qui doit être maîtrisé à l'échelle de l'organisation, ITIL décrit comment gérer les services au quotidien.
- **La gouvernance n'empêche pas l'incident** : elle le rend anticipé, décidé et contenu.

✍ Exercice P.1. Technique ou gouvernance ? ★☆☆

Pour chacun des constats suivants, relevés dans d'autres organisations, indiquez s'il s'agit d'une cause technique ou d'une cause de gouvernance, et justifiez en une phrase.

(a) Le disque d'un serveur de messagerie tombe en panne.

(b) Aucune sauvegarde de ce serveur n'avait été vérifiée depuis deux ans, sans que personne en soit chargé.

(c) Un administrateur applique un correctif un vendredi soir sans prévenir personne, conformément à l'usage du service.

(d) Le budget de renouvellement du matériel a été supprimé par le directeur financier sans consulter la DSI.

✍ Exercice P.2. Les droits de décision de KRIBILOG ★★☆

La société KRIBILOG SA, opérateur logistique à Kribi et à Douala, change d'infogérant en trois semaines, sur décision de son directeur des achats, pour une économie annuelle de 48 millions FCFA. Le responsable des services informatiques l'apprend par le nouveau prestataire. Deux mois plus tard, le logiciel de suivi des conteneurs connaît trois arrêts majeurs.

(a) Construisez, sur le modèle du Tableau P.3, le tableau des décisions critiques de ce changement de prestataire.

(b) Pour chaque décision, indiquez qui l'a prise, qui aurait dû la prendre, et quelle trace écrite devrait exister.

(c) Rédigez la constatation que l'auditeur SI consignerait, puis son analyse, avec un niveau de confiance.

✍ Exercice P.3. Le rapport à la COBAC ★★★

Vous êtes responsable GRC de la BANQUE SANAGA. Le directeur général vous confie la rédaction du rapport circonstancié demandé par la COBAC.

(a) Proposez le plan du rapport, en séparant la chronologie, les constatations, l'analyse des causes et le plan d'action.

(b) Le directeur général vous demande d'écrire que la panne est due au seul prestataire. Expliquez, pièces à l'appui, pourquoi cette affirmation ne résisterait pas à l'examen du régulateur.

(c) Pour chacune des six défaillances du Tableau P.7, proposez une mesure corrective, son responsable et son échéance.

(d) Quelle place donnez-vous, dans ce rapport, à la recommandation de l'audit interne d'octobre 2025 restée sans suite ? Justifiez.

Note

La suite du cours. Ce prologue a posé le réflexe fondateur : chercher la décision derrière l'incident. La Partie I donne à ce réflexe ses fondements, en commençant par la gouvernance d'entreprise et la théorie de l'agence (Chapitre 1). La Partie II construit avec COBIT 2019 le système de gouvernance qui a manqué à la BANQUE SANAGA, et la Partie IV en organise, avec ITIL 4, la pratique quotidienne.

partie I

Fondements de la Gouvernance des Systèmes d'Information

© *MaletYon*

1

DE LA GOUVERNANCE D'ENTREPRISE À LA GOUVERNANCE DES SI

> « Le gouvernement d'entreprise est le système par lequel les sociétés sont dirigées et contrôlées. »
>
> Rapport Cadbury, Royaume-Uni, 1992 (notre traduction)

Niveau : *Fondamental* • Maîtrise du Chapitre 0 (les trois questions réflexes et la distinction entre gouvernance et management).

✦ Objectifs du chapitre

- ➢ Définir la gouvernance d'entreprise et ses mécanismes (conseil, comités, contrôle).
- ➢ Expliquer la théorie de l'agence et la théorie des parties prenantes.
- ➢ Retracer l'émergence de la gouvernance des SI (rapport Cadbury, loi Sarbanes-Oxley, OHADA).
- ➢ Définir la gouvernance des SI et la distinguer du management des SI.
- ➢ Identifier les organes de gouvernance des SI (comité stratégique, comité de pilotage).

Question directrice : pourquoi le conseil ne savait-il rien ?

Le prologue s'est achevé sur une séance extraordinaire du conseil d'administration de la BANQUE SANAGA. Un administrateur y a posé la question qui ouvre ce chapitre : « Nous avons voté 3,2 milliards FCFA pour ce projet. Comment avons-nous pu ignorer, jusqu'au jour de la panne, qu'il était en danger ? »

La question n'est pas technique. Elle porte sur la relation entre ceux qui possèdent l'entreprise, ceux qui la contrôlent et ceux qui la dirigent : qui informe qui, qui surveille qui, et avec quels moyens. Cette relation est l'objet de la **gouvernance d'entreprise**, discipline bien plus ancienne que l'informatique. La gouvernance des systèmes d'information n'en est pas une invention à part : elle en est le prolongement, devenu nécessaire le jour où l'activité de l'entreprise a reposé sur ses systèmes.

© MaletYon

Ce chapitre suit ce prolongement en cinq temps : ce qu'est la gouvernance d'entreprise (section 1.1), les théories qui l'expliquent (section 1.2), son histoire et son entrée dans le champ informatique (section 1.3), la définition de la gouvernance des SI (section 1.4), et enfin ses organes (section 1.6), replacés dans le contexte camerounais (section 1.7).

1.1 La Gouvernance d'Entreprise : Définition et Mécanismes

1.1.1 Diriger et contrôler

La définition la plus citée tient en une phrase, celle de l'épigraphe : la gouvernance d'entreprise est le système par lequel les sociétés sont dirigées et contrôlées [10]. Les deux verbes comptent. Une entreprise dirigée mais non contrôlée dépend entièrement de la qualité de ses dirigeants. Une entreprise contrôlée mais mal dirigée se conforme sans avancer. La gouvernance organise l'équilibre entre les deux.

Définition

Gouvernance d'entreprise (*corporate governance*) : ensemble des relations, des règles et des mécanismes par lesquels une société est dirigée et contrôlée. Elle répartit les droits et les responsabilités entre les actionnaires, le conseil d'administration, la direction générale et les autres parties prenantes, et fixe les règles de décision et de reddition de comptes.

Les Principes de gouvernance d'entreprise du G20 et de l'OCDE, publiés pour la première fois en 1999 et révisés en dernier lieu en 2023 [33], constituent la référence internationale. Ils traitent des droits des actionnaires, de la transparence de l'information, du rôle des parties prenantes et des responsabilités du conseil d'administration.

1.1.2 Les mécanismes de la gouvernance

La gouvernance d'entreprise s'appuie sur deux familles de mécanismes. Les **mécanismes internes** sont créés par l'entreprise elle-même ; les **mécanismes externes** lui sont imposés ou s'exercent de l'extérieur.

Mécanisme	Rôle	À la BANQUE SANAGA
Mécanismes internes		
Assemblée générale	Désigne les administrateurs, approuve les comptes	Réunie une fois par an
Conseil d'administration	Fixe les orientations, contrôle la direction	A approuvé le projet HORIZON, puis n'en a plus entendu parler
Comités du conseil (audit, risques)	Préparent les décisions du conseil sur des sujets techniques	Comité d'audit sans point sur le projet
Contrôle interne et audit interne	Vérifient que les risques sont maîtrisés	Alerte d'octobre 2025 restée sans suite
Mécanismes externes		
Commissaire aux comptes	Certifie les comptes	Interroge la fiabilité des soldes convertis
Régulateur (COBAC)	Contrôle la solidité et la conformité	Demande un rapport circonstancié
Marché et clients	Sanctionnent par la réputation et le départ	Files d'attente, plaintes, presse

Tableau 1.1. Mécanismes de la gouvernance d'entreprise

Le tableau montre que la BANQUE SANAGA ne manquait d'aucun mécanisme. Ils existaient tous, mais aucun ne portait sur le système d'information. Le conseil votait le budget du projet sans en recevoir le suivi ; le comité d'audit examinait les comptes sans examiner le risque qui allait les fausser. C'est la situation typique que la gouvernance des SI vient corriger.

1.2 Les Théories qui Expliquent la Gouvernance

1.2.1 La théorie de l'agence

Pourquoi faut-il contrôler les dirigeants ? La réponse la plus influente vient de Jensen et Meckling, qui décrivent l'entreprise comme un nœud de contrats, et la relation entre actionnaires et dirigeants comme une **relation d'agence** [28].

Définition

Relation d'agence (*agency relationship*) : contrat par lequel une personne, le *principal*, engage une autre personne, l'*agent*, pour accomplir en son nom une tâche qui implique de lui déléguer un pouvoir de décision.

Coûts d'agence (*agency costs*) : somme des dépenses de surveillance engagées par le principal, des dépenses d'engagement (de « dédouanement ») engagées par l'agent pour prouver sa loyauté, et de la perte résiduelle due aux divergences d'intérêts qui subsistent malgré tout.

La théorie repose sur deux hypothèses. L'agent a ses propres intérêts, qui ne coïncident pas toujours avec ceux du principal. Et l'agent en sait plus que le principal sur ce qu'il fait : c'est l'**asymétrie d'information**. La gouvernance est alors l'ensemble des dispositifs qui réduisent cette asymétrie (rapports, audits, comités) et alignent les intérêts (rémunération, responsabilité).

1.2.2 La chaîne d'agence des systèmes d'information

L'informatique allonge la chaîne d'agence et accroît l'asymétrie d'information à chaque maillon. Le conseil délègue au directeur général, qui délègue au DSI, qui délègue à un intégrateur. À chaque niveau, l'agent comprend mieux le système que son principal.

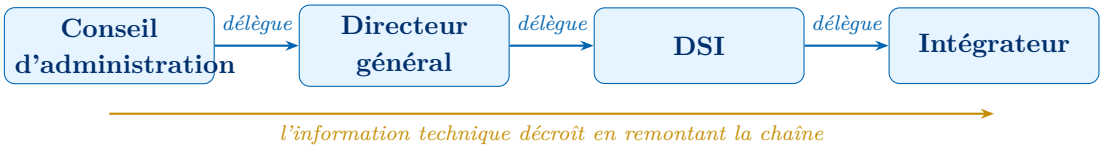


Figure 1.1. La chaîne d'agence des systèmes d'information

Scénario Opérationnel · Opération SANAGA. L'agence

Constatation. Le directeur général fixe seul la date de bascule en janvier 2026. La DSI l'alerte par une note le 20 février. Le conseil n'est informé de rien entre juin 2025 et le 9 mars 2026.

Analyse (confiance élevée). Le directeur général, agent du conseil, avait un intérêt propre au respect de la date : le lancement de l'offre mobile, déjà annoncé, était l'objectif sur lequel il serait jugé. Il disposait d'une information (la note de la DSI) que son principal n'avait pas. Le conseil n'avait mis en place aucun dispositif pour réduire cette asymétrie : ni point d'avancement obligatoire, ni accès direct du comité d'audit à la DSI. La perte résiduelle s'est élevée à 1,9 milliard FCFA.

1.2.3 La théorie des parties prenantes

La théorie de l'agence ne connaît que deux acteurs : le principal et l'agent. Freeman élargit la perspective : l'entreprise doit tenir compte de tous les groupes qui affectent ses objectifs ou sont affectés par eux [17]. Pour une banque, ce sont aussi les déposants, les salariés, le régulateur, l'État et les commerçants qui dépendent de ses paiements.

Définition

Partie prenante (*stakeholder*) : tout groupe ou individu qui peut affecter la réalisation des objectifs d'une organisation ou qui est affecté par elle.

Cette théorie a une conséquence directe pour la gouvernance des SI : la valeur d'un système d'information ne se mesure pas seulement pour l'actionnaire. La panne de la BANQUE SANAGA a touché des clients qui ne pouvaient plus payer leurs salariés, et

des commerçants dont les terminaux de paiement étaient bloqués. COBIT 2019 retient d'ailleurs, comme premier principe de tout système de gouvernance, la création de valeur pour les parties prenantes [23].

Et si les dirigeants étaient loyaux ?

La théorie de l'agence suppose un agent qui sert d'abord ses propres intérêts. La théorie de l'intendance (*stewardship theory*) part de l'hypothèse inverse : un dirigeant peut trouver sa motivation dans la réussite de l'organisation elle-même [12]. Elle plaide alors pour la confiance et la délégation plutôt que pour la surveillance. Les deux lectures ne s'excluent pas. Le directeur général de la BANQUE SANAGA était sans doute sincèrement convaincu de servir la banque en tenant sa date. Le problème n'était pas sa loyauté, mais l'absence d'un mécanisme qui confronte sa conviction aux faits techniques. Une bonne gouvernance ne présume pas la malhonnêteté : elle organise la contradiction.

1.3 Histoire : de Cadbury à la Gouvernance des SI

1.3.1 Les scandales fondateurs

La gouvernance d'entreprise s'est construite par réaction à des scandales. Au Royaume-Uni, la faillite du groupe Maxwell et celle de la banque BCCI, en 1991, conduisent à la création du comité présidé par Sir Adrian Cadbury, dont le rapport de 1992 pose les règles de séparation des pouvoirs et du rôle des comités [10]. Aux États-Unis, les faillites d'Enron (2001) et de WorldCom (2002) entraînent l'adoption de la loi Sarbanes-Oxley [40].

1.3.2 Sarbanes-Oxley : l'informatique entre dans la gouvernance

La loi Sarbanes-Oxley est le moment où l'informatique entre dans la gouvernance d'entreprise, presque sans l'avoir cherché. Sa section 404 impose à la direction des sociétés cotées aux États-Unis d'évaluer chaque année l'efficacité de son contrôle interne sur l'information financière, et à l'auditeur externe d'en attester. Or l'information financière est produite par des systèmes informatiques. Évaluer le contrôle interne, c'est donc évaluer aussi les contrôles qui garantissent la fiabilité de ces systèmes : qui peut modifier un programme, qui peut accéder aux données, comment les changements sont autorisés.

■ Définition

Contrôles généraux informatiques (*IT general controls*, ITGC) : contrôles qui s'appliquent à l'ensemble de l'environnement informatique et conditionnent la fiabilité de toutes les applications : gestion des accès, gestion des changements, exploitation, développement et acquisition des systèmes.

Le Chapitre 11 reviendra sur ces contrôles, que l'auditeur teste en priorité. Il suffit ici de noter que les défaillances de la BANQUE SANAGA en sont deux exemples directs : un changement non autorisé et des données dont l'exactitude n'était plus garantie.

1.3.3 Les étapes de la gouvernance des SI

Année	Étape
1992	Rapport Cadbury (Royaume-Uni) : séparation des pouvoirs, comités du conseil
1994	Premier rapport King (Afrique du Sud)
1996	Première édition de COBIT, alors centrée sur l'audit et le contrôle informatiques
1997	Acte uniforme OHADA relatif au droit des sociétés commerciales et du groupement d'intérêt économique
1998	Création de l'IT Governance Institute (ITGI)
2002	Loi Sarbanes-Oxley (États-Unis)
2004	Weill et Ross définissent la gouvernance des SI par les droits de décision [49]
2008	Première édition de la norme ISO/IEC 38500 sur la gouvernance des technologies de l'information
2009	Rapport King III : la gouvernance des technologies de l'information y devient un chapitre à part entière
2014	Acte uniforme OHADA révisé : comité d'audit obligatoire dans les sociétés cotées
2016	Rapport King IV : principe 12 sur la gouvernance des technologies et de l'information [20]
2018	COBIT 2019 : système de gouvernance sur mesure, facteurs de conception
2023	Révision des Principes de gouvernance d'entreprise du G20 et de l'OCDE

Tableau 1.2. Repères historiques de la gouvernance d'entreprise et de la gouvernance des SI

1.3.4 Une voix africaine : les rapports King

L'Afrique n'est pas restée en marge de ce mouvement. Les rapports King, publiés par l'Institute of Directors in Southern Africa, figurent parmi les codes de gouvernance les plus avancés au monde. Le troisième (2009) a été l'un des premiers codes nationaux à consacrer un chapitre entier à la gouvernance des technologies de l'information. Le quatrième (2016) en fait l'un de ses principes : l'organe de gouvernance doit gouverner la technologie et l'information de manière à aider l'organisation à définir et à atteindre ses objectifs stratégiques [20]. COBIT 2019 cite d'ailleurs le rapport King IV parmi ses références pour l'objectif de gouvernance EDM01 [22].

1.4 Définir la Gouvernance des SI

1.4.1 Quatre définitions de référence

Il n'existe pas une définition unique, mais quatre définitions qui se complètent. Chacune met l'accent sur un aspect différent.

Définition

COBIT 4.1 (ITGI, 2007, version française de l'AFAI) : « La gouvernance des SI est de la responsabilité des dirigeants et du conseil d'administration, et elle est constituée des structures et processus de commandement et de fonctionnement qui conduisent l'informatique de l'entreprise à soutenir les stratégies et les objectifs de l'entreprise, et à lui permettre de les élargir. » [27]

Weill et Ross (2004) : spécifier les droits de décision et le cadre de responsabilité qui encouragent les comportements souhaitables dans l'usage des technologies de l'information [49].

ISO/IEC 38500 : système par lequel l'utilisation actuelle et future de l'informatique est dirigée et contrôlée [24].

COBIT 2019 : activités par lesquelles l'organe de gouvernance évalue les besoins des parties prenantes, dirige par la priorisation et la décision, et surveille la performance et la conformité [23].

Source	Accent principal	Question qu'elle pose
COBIT 4.1	Responsabilité des dirigeants, structures et processus	Qui porte la gouvernance, et par quels dispositifs ?
Weill et Ross	Droits de décision et comportements	Qui décide de quoi, et quels comportements cela produit-il ?
ISO/IEC 38500	Direction et contrôle de l'usage de l'informatique	L'usage de l'informatique est-il dirigé et contrôlé ?
COBIT 2019	Évaluer, diriger, surveiller	Les besoins sont-ils évalués, les priorités fixées, les résultats suivis ?

Tableau 1.3. Comparaison des définitions de la gouvernance des SI

1.4.2 Une définition de travail pour ce cours

De ces quatre définitions, ce cours retient une synthèse, qui servira de référence dans tous les chapitres.

Définition

Gouvernance des SI : ensemble des responsabilités, des droits de décision et des mécanismes par lesquels l'organe de gouvernance d'une organisation s'assure que l'usage, présent et futur, de l'information et des technologies *crée de la valeur* pour les parties prenantes, *maîtrise les risques* qui en découlent et *utilise judicieusement les ressources* qui lui sont consacrées.

Les trois finalités soulignées (valeur, risque, ressources) seront développées au Chapitre 3. Elles donnent déjà un critère simple : une décision relève de la gouvernance des SI lorsqu'elle engage durablement l'une de ces trois finalités pour l'organisation entière.

1.4.3 Structures, processus et mécanismes relationnels

De Haes et Van Grembergen proposent de décrire la gouvernance des SI d'une organisation par trois familles de mécanismes [14]. La grille est utile en diagnostic : une organisation qui n'a que des structures, sans processus ni relations, a une gouvernance de façade.

Famille	Exemples	Signal d'absence
Structures	Comité stratégique des SI, comité de pilotage, rôle de DSI membre de la direction	Personne n'est désigné pour trancher
Processus	Planification stratégique des SI, gestion du portefeuille, suivi de la valeur, audit	Les décisions se prennent au cas par cas, sans calendrier ni critères
Mécanismes relationnels	Formation des administrateurs, communication entre métiers et DSI, binômes métier-informatique	Les métiers découvrent les décisions informatiques après coup

Tableau 1.4. Les trois familles de mécanismes de gouvernance des SI

1.5 Gouvernance et Management des SI : Quatre Confusions

Le prologue a posé la distinction entre gouvernance et management (section 0.4). Dans la pratique, elle est brouillée par quatre confusions fréquentes. Chacune conduit à une gouvernance qui n'en a que le nom.

1. **« La gouvernance des SI, c'est l'affaire du DSI. »** Le DSI est un acteur central du management des SI. La gouvernance, elle, relève de l'organe qui le contrôle : le conseil et ses comités. Confier la gouvernance au DSI, c'est demander à l'agent de se surveiller lui-même.
2. **« La gouvernance, c'est la conformité. »** Respecter la loi et les normes est une exigence de la gouvernance, mais ne suffit pas à la définir. Une organisation peut être conforme et investir dans des projets sans valeur.
3. **« La gouvernance, c'est la sécurité. »** La sécurité de l'information est un domaine de risque parmi d'autres. La gouvernance arbitre entre la sécurité, la valeur et le coût ; elle ne se réduit à aucun des trois.

4. **« La gouvernance, c'est de la bureaucratie. »** Une gouvernance qui multiplie les comités sans décisions alourdit l'organisation. Une bonne gouvernance est proportionnée : le Chapitre 7 montrera comment COBIT 2019 l'adapte à la taille et aux risques de chaque organisation.

★ Attention

Violation typique. Après la panne, le conseil d'administration de la BANQUE SANAGA envisage de « confier la gouvernance des SI » à un DSI adjoint nouvellement recruté, chargé de produire des rapports mensuels au directeur général.

Règle : on ne corrige pas une défaillance de gouvernance en ajoutant un acteur de management. Il faut un dispositif qui rende compte *au conseil*, et non à celui dont les décisions doivent être contrôlées.

1.6 Les Organes de la Gouvernance des SI

1.6.1 Deux niveaux de comités

L'ITGI a popularisé une distinction devenue classique entre deux comités. Le **comité stratégique des SI** (*IT strategy committee*) se situe au niveau du conseil : il l'assiste sur les orientations, la valeur et les risques du numérique. Le **comité de pilotage des SI** (*IT steering committee*) se situe au niveau de la direction générale : il priorise les projets, arbitre les ressources et suit leur exécution.

Organe	Niveau	Composition type	Décisions
Conseil d'administration	Gouvernance	Administrateurs	Approuve la stratégie numérique, l'appétence au risque, les grands investissements
Comité d'audit, comité des risques	Gouvernance	Administrateurs indépendants	Surveille le contrôle interne et les risques, dont ceux du SI
Comité stratégique des SI	Gouvernance	Administrateurs, DG, DSI, experts invités	Évalue l'alignement, la valeur et les risques du portefeuille numérique
Comité de pilotage des SI	Management	DG ou DGA, directeurs métiers, DSI	Priorise les projets, arbitre les ressources, décide des bascules
Comité des changements	Management	DSI, exploitation, sécurité, métiers	Autorise les changements majeurs (Chapitre 14)

Tableau 1.5. Les organes de la gouvernance et du management des SI

1.6.2 La gouvernance du système de gouvernance

COBIT 2019 consacre son premier objectif à la mise en place et au maintien de ce dispositif lui-même. C'est l'objectif qui manquait le plus visiblement à la BANQUE SANAGA.

Fiche processus · EDM01 · Assurer la définition et le maintien du cadre de gouvernance

Finalité : doter l'organisation d'une approche cohérente de la gouvernance de l'information et des technologies, intégrée à la gouvernance d'entreprise, avec des décisions alignées sur sa stratégie.
Pratiques : EDM01.01 *évaluer* le système de gouvernance (identifier les parties prenantes et leurs exigences) ; EDM01.02 *diriger* le système de gouvernance (définir les structures, les principes, les niveaux d'autorité et l'information nécessaire aux décisions) ; EDM01.03 *surveiller* le système de gouvernance (vérifier qu'il fonctionne et assure une supervision effective).
Sorties : principes de gouvernance, modèle de décision et niveaux d'autorité, rapports sur l'efficacité du système de gouvernance.
RACI (extrait) : *A* au conseil d'administration, *R* au directeur général et au comité stratégique des SI, *C* au DSI et à l'audit interne.
Indicateurs : part des décisions stratégiques prises par l'instance prévue ; délai de traitement des alertes remontées au conseil.

Intitulés et pratiques traduits par nos soins à partir de COBIT 2019 [22].

Exigence de contrôle

Un comité de gouvernance qui fonctionne. Pour qu'un auditeur puisse établir que le comité stratégique des SI existe autrement que sur le papier, il doit trouver :

- une charte approuvée par le conseil (mission, composition, pouvoirs, fréquence, quorum) ;
- un calendrier de réunions respecté, et des procès-verbaux datés et signés ;
- des décisions inscrites au procès-verbal, avec leur responsable et leur échéance ;
- un suivi de ces décisions d'une séance à l'autre ;
- un compte rendu régulier au conseil d'administration.

Application Responsable GRC

Rédiger la charte d'un comité stratégique des SI

1. **Mission :** assister le conseil dans l'évaluation de la stratégie numérique, de la valeur des investissements et des risques liés au SI.

2. **Composition :** au moins deux administrateurs, dont l'un préside ; le directeur général et le DSI comme membres ; l'audit interne comme invité permanent.
3. **Pouvoirs :** accès direct à la DSI et à l'audit interne ; droit de demander toute expertise externe.
4. **Fréquence :** au moins trimestrielle, et sur convocation en cas de projet majeur en difficulté.
5. **Reddition de comptes :** rapport écrit au conseil après chaque séance.

Le point décisif est le deuxième pouvoir : un comité qui ne reçoit l'information que par le directeur général reproduit l'asymétrie qu'il devait réduire.

1.7 Le Contexte Camerounais et Africain

1.7.1 Des organisations, des cadres différents

La gouvernance des SI ne s'exerce pas de la même manière dans toutes les organisations camerounaises, parce que leur gouvernance d'entreprise relève de cadres juridiques différents.

Organisation	Cadre de gouvernance	Cas du cours
Société commerciale	Acte uniforme OHADA sur les sociétés commerciales (révisé en 2014)	KRIBILOG SA, NOUN PAY
Établissement de crédit	Droit OHADA et réglementation de la COBAC	BANQUE SANAGA
Entreprise publique	Loi n° 2017/011 du 12 juillet 2017	·
Établissement public	Loi n° 2017/010 du 12 juillet 2017	ANPP (opération MEFOU)

Tableau 1.6. Cadres de gouvernance des organisations camerounaises

Les lois de 2017 sur les établissements publics et les entreprises publiques, précisées par le décret n° 2019/320 du 19 juin 2019, organisent notamment le conseil d'administration et la tutelle de l'État. Le Chapitre 10 en étudiera les dispositions.

⚖ Jurisprudence & Droit applicable

Acte uniforme OHADA relatif au droit des sociétés commerciales et du groupement d'intérêt économique, révisé le 30 janvier 2014, article 829-1 [1].

Selon la présentation de la réforme publiée par l'OHADA, l'Acte uniforme révisé rend le comité d'audit obligatoire dans les sociétés cotées. Ce comité, composé ex-

clusivement d'administrateurs non salariés et n'exerçant pas de mandat de direction générale, assure notamment le suivi de l'efficacité des systèmes de contrôle interne et de gestion des risques, et rend compte régulièrement au conseil d'administration.

Portée. Le droit OHADA institue ainsi, pour les sociétés cotées, une instance du conseil chargée de surveiller les risques. Rien ne l'oblige à examiner les risques du SI, mais rien ne l'en dispense : le système d'information porte aujourd'hui l'essentiel du contrôle interne. Pour les sociétés non cotées, comme la BANQUE SANAGA dans notre cas, la création d'un tel comité relève des statuts et de la réglementation sectorielle.

1.7.2 Quatre défis propres au contexte

1. **La concentration du pouvoir.** Dans de nombreuses organisations, le directeur général concentre la décision, et le conseil se réunit peu. La chaîne d'agence y est courte en apparence, mais l'asymétrie d'information y est forte.
2. **La tutelle.** Dans le secteur public, une partie des décisions relève du ministère de tutelle. La gouvernance des SI doit préciser ce qui se décide au conseil et ce qui remonte à la tutelle.
3. **La dépendance aux prestataires.** Les grands systèmes sont souvent conçus et maintenus par des intégrateurs étrangers. Le dernier maillon de la chaîne d'agence échappe alors au droit et au contrôle local, d'où l'importance des contrats (Chapitre 15).
4. **La compétence numérique des conseils.** Peu d'administrateurs ont une expérience des systèmes d'information. La formation des administrateurs est un mécanisme relationnel de première importance.

Scénario Opérationnel · Opération MEFOU. Une agence sans comité stratégique

L'AGENCE NATIONALE DES PAIEMENTS PUBLICS (ANPP), établissement public installé à Yaoundé, gère le paiement dématérialisé des salaires et des fournisseurs de l'État. Son schéma directeur informatique, adopté en 2023 pour 14 milliards FCFA, comprend neuf projets. Le conseil d'administration se réunit deux fois par an et consacre en moyenne vingt minutes au numérique. Aucun comité ne suit le schéma directeur. Les projets sont lancés sur décision du directeur général, M. ESSOMBA, souvent à la demande du ministère de tutelle.

Constatation. À mi-parcours, trois projets ont consommé 71 % du budget et aucun n'est achevé. Le conseil l'apprend par une question d'un administrateur représentant le ministère des Finances.

Ce cas reviendra au Chapitre 3 (arbitrage du portefeuille) et au Chapitre 11 (audit de la Chambre des comptes).

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Diriger et contrôler** : la gouvernance d'entreprise est le système par lequel les sociétés sont dirigées et contrôlées. Elle repose sur des mécanismes internes (conseil, comités, contrôle interne) et externes (commissaire aux comptes, régulateur, marché).
- **La théorie de l'agence** : le dirigeant, agent des actionnaires, en sait plus qu'eux. La gouvernance réduit cette asymétrie d'information. L'informatique allonge la chaîne d'agence et l'accroît.
- **Les parties prenantes** : la valeur d'un SI se mesure pour tous ceux qu'il affecte, et non pour le seul actionnaire.
- **L'informatique est entrée dans la gouvernance par le contrôle interne** : la loi Sarbanes-Oxley a fait des contrôles généraux informatiques une condition de la fiabilité financière.
- **La gouvernance des SI** est l'ensemble des responsabilités, des droits de décision et des mécanismes par lesquels l'organe de gouvernance s'assure que l'usage de l'information et des technologies crée de la valeur, maîtrise les risques et utilise judicieusement les ressources.
- **Deux niveaux de comités** : le comité stratégique des SI relève du conseil, le comité de pilotage relève de la direction générale. Ne pas les confondre.
- **Le contexte africain** a ses repères (rapports King, droit OHADA, lois camerounaises de 2017) et ses défis (concentration du pouvoir, tutelle, dépendance aux prestataires, compétence des conseils).

✍ Exercice 1.1. Gouvernance ou management ? ★☆☆

Classez chacune des décisions suivantes dans la gouvernance ou dans le management des SI, et indiquez l'organe qui devrait la prendre (Tableau 1.5).

(a) Fixer la part du budget de la banque consacrée au numérique pour les trois prochaines années.

(b) Choisir entre deux éditeurs pour le nouveau logiciel de gestion des crédits.

(c) Décider de reporter la bascule d'un système critique.

(d) Fixer le niveau de risque informatique que la banque accepte de supporter.

(e) Autoriser l'installation d'un correctif sur les serveurs de messagerie.

✍ Exercice 1.2. La chaîne d'agence de KRIBILOG ★★☆

La société KRIBILOG SA confie l'exploitation de son logiciel de suivi des conteneurs à l'infogérant NETPORT SERVICES. Le conseil d'administration ne reçoit aucun indicateur sur ce service ; le responsable des services informatiques, M. MBARGA, reçoit chaque mois un rapport rédigé par NETPORT SERVICES elle-même.

(a) Dessinez la chaîne d'agence de ce service, sur le modèle de la Figure 1.1.

(b) Identifiez, à chaque maillon, l'asymétrie d'information.

(c) Proposez, pour chaque maillon, un mécanisme qui la réduit, en précisant s'il s'agit d'une structure, d'un processus ou d'un mécanisme relationnel (Tableau 1.4).

✍ Exercice 1.3. Doter l'ANPP d'une gouvernance des SI ★★★

Le nouveau président du conseil d'administration de l'ANPP (opération MEFOU) vous demande une note de trois pages pour doter l'agence d'une gouvernance des SI.

(a) Rédigez la constatation de départ, à partir des faits de l'opération MEFOU, en la séparant de votre analyse.

(b) Proposez les organes à créer, leur niveau (gouvernance ou management) et leur composition, en tenant compte de la tutelle ministérielle.

(c) Rédigez les cinq articles essentiels de la charte du comité stratégique des SI.

(d) Indiquez les trois pièces qu'un auditeur demandera, dans un an, pour vérifier que ce dispositif fonctionne réellement.

● Note

Transition. Ce chapitre a défini la gouvernance des SI et ses organes à partir de la gouvernance d'entreprise. Le Chapitre 2 met ces notions à l'épreuve des faits : il analyse de grandes défaillances réelles et documentées, pour montrer qu'à chaque fois une décision de gouvernance a manqué derrière l'incident technique.

2

GRANDES DÉFAILLANCES ET LEÇONS DE GOUVERNANCE

> « Chaque grande panne informatique raconte deux histoires : celle d'un composant qui a cédé, et celle d'une décision que personne n'a prise. »
>
> Principe d'analyse des défaillances

Niveau : *Fondamental* • Maîtrise du Chapitre 1 (théorie de l'agence, gouvernance et management, organes de gouvernance).

✦ Objectifs du chapitre

- ➢ Analyser des défaillances documentées à partir de sources publiques.
- ➢ Isoler, pour chaque cas, la défaillance de gouvernance derrière l'incident technique.
- ➢ Distinguer constatation et analyse dans un rapport de défaillance.
- ➢ Construire une grille d'erreurs de gouvernance réutilisable.

Mode d'emploi du chapitre

Le prologue reposait sur un cas fictif, construit pour l'enseignement. Ce chapitre passe aux faits. Il étudie trois défaillances réelles, choisies parce qu'elles sont **documentées par des sources de première main** : la décision d'un régulateur des marchés, celle de deux régulateurs bancaires, et l'analyse de cause publiée par un éditeur de logiciels. Elles couvrent trois situations que tout DSI rencontrera : un déploiement de code, une migration de plateforme, et la mise à jour d'un logiciel fourni par un tiers.

Chaque affaire suit le même plan : le **brief** (qui, quand, quel enjeu), le **déroulé** (la chronologie), les **révélations** (ce que les enquêtes ont établi) et la **synthèse** (la cause de gouvernance). La section 2.5 croise les trois cas, et la section 2.6 en tire une grille d'erreurs que vous réutiliserez tout au long du cours.

© MaletYon

★ Attention

Règle de lecture. Les faits rapportés dans ce chapitre sont ceux qu'établissent les documents cités. Les analyses en termes de gouvernance sont les nôtres : elles sont signalées comme telles, avec leur niveau de confiance. Les organisations citées ne sont pas jugées ; leurs défaillances sont étudiées parce qu'elles ont eu le mérite d'être rendues publiques.

2.1 Une Méthode d'Analyse des Défaillances

2.1.1 Les sources

Une analyse de défaillance vaut ce que valent ses sources. Les articles de presse et les billets techniques sont utiles pour s'orienter, mais ils simplifient et se recopient. Seules les sources de première main permettent d'établir des constatations.

■ Définition

Source de première main (*primary source*) : document produit par une partie qui a eu accès direct aux faits et qui engage sa responsabilité sur leur exactitude : décision d'un régulateur ou d'un tribunal, rapport d'enquête indépendant commandé par le conseil, analyse de cause publiée par l'entreprise elle-même.

Type de source	Force	Limite
Décision d'un régulateur	Faits contradictoirement établis, sanctions motivées	Centrée sur les manquements à la réglementation
Rapport d'enquête indépendant	Examen large, accès aux pièces internes	Commandé par l'entreprise, parfois publié en partie seulement
Analyse de cause de l'éditeur	Précision technique	Rédigée par la partie en cause, prudente sur les responsabilités
Presse spécialisée	Rapidité, contexte	Chiffres approximatifs, sources secondaires

Tableau 2.1. Hiérarchie des sources d'une analyse de défaillance

2.1.2 La grille d'analyse

Pour chaque affaire, sept questions structurent l'analyse. Elles reprennent les réflexes du prologue (Chapitre 0).

1. **Quel était l'enjeu ?** Activité, taille, dépendance au système.

2. **Que s'est-il passé, et quand ?** Chronologie établie par les sources.
3. **Quelle est la cause technique ?** Le composant, le code, la donnée.
4. **Quelle décision a manqué ?** Qui décide, qui exécute, qui rend compte.
5. **Quels contrôles auraient dû jouer ?** Avant, pendant et après l'incident.
6. **Qui a demandé des comptes, et avec quelles conséquences ?** Régulateur, clients, marché, dirigeants.
7. **Quelle leçon pour une organisation camerounaise ?**

2.2 Knight Capital, 2012 : 45 Minutes, 460 Millions de Dollars

2.2.1 Brief

Knight Capital Americas était, en 2012, l'un des principaux teneurs de marché et intermédiaires sur les actions américaines. Son activité reposait entièrement sur des systèmes automatisés d'acheminement des ordres, dont le système SMARS. Les faits qui suivent sont ceux qu'établit la décision de la Securities and Exchange Commission (SEC) du 16 octobre 2013 [46].

2.2.2 Déroulé

Pour participer à un nouveau programme de la Bourse de New York, Knight déploie un nouveau code sur les huit serveurs de SMARS dans les jours qui précèdent le 1er août 2012. Ce nouveau code réutilise un indicateur qui servait autrefois à une ancienne fonction, appelée « Power Peg », abandonnée depuis des années mais jamais retirée du programme. Un technicien déploie le code sur sept serveurs seulement ; le huitième garde l'ancien code.

Le 1er août, à l'ouverture du marché, les ordres qui portent le nouvel indicateur réveillent l'ancienne fonction sur le huitième serveur. En 45 minutes, alors qu'il traitait 212 ordres de clients, SMARS envoie des millions d'ordres sur le marché. Il en résulte plus de 4 millions d'exécutions sur 154 valeurs, pour plus de 397 millions d'actions. Pour tenter de corriger, les équipes retirent le nouveau code des sept serveurs où il avait été correctement installé, ce qui étend le problème à l'ensemble des serveurs.

2.2.3 Révélations

La décision de la SEC établit notamment que :

- Knight ne disposait pas de procédures écrites de déploiement qui imposent une revue par un second technicien ;
- aucun contrôle ne vérifiait que le code était identique sur tous les serveurs ;
- avant l'ouverture du marché, le système avait émis des messages automatiques signalant une anomalie, que personne n'était chargé de traiter ;
- l'entreprise n'avait pas de procédure de réponse aux incidents adaptée à ce type de défaillance.

Knight a perdu plus de 460 millions de dollars sur les positions ainsi créées. Elle a dû lever des fonds en urgence auprès d'investisseurs, puis a été absorbée l'année suivante. La SEC lui a infligé une amende de 12 millions de dollars pour manquement à la règle sur l'accès au marché, qui impose aux intermédiaires des contrôles de gestion des risques sur leurs ordres automatisés.

2.2.4 Synthèse

Scénario Opérationnel · Knight Capital. Lecture de gouvernance

Cause technique (établie). Un code obsolète, réactivé par un indicateur réutilisé, sur un serveur où le déploiement était incomplet.

Cause de gouvernance (analyse, confiance élevée). La gestion des changements reposait sur le savoir-faire individuel, sans procédure écrite, sans double contrôle et sans vérification après déploiement. La dette technique (un code mort laissé en place) n'avait jamais été arbitrée. Et le dispositif de surveillance produisait des alertes sans qu'un rôle soit chargé de les traiter.

Les trois questions. *Qui décide* qu'un déploiement est terminé ? Personne, formellement. *Qui exécute* ? Un technicien seul. *Qui rend compte* des alertes avant l'ouverture ? Personne.

2.3 TSB, 2018 : la Migration qui a Paralysé une Banque

2.3.1 Brief

TSB Bank est une banque de détail britannique, rachetée en 2015 par le groupe espagnol Sabadell. Elle utilisait jusqu'alors la plateforme informatique de son ancien propriétaire. Le programme de migration vers une nouvelle plateforme, fournie par une filiale informatique du groupe Sabadell, devait lui donner son autonomie technique. Les faits qui suivent sont ceux qu'établissent les décisions conjointes de la Financial Conduct Authority (FCA) et de la Prudential Regulation Authority (PRA) de décembre 2022 [15].

2.3.2 Déroulé

La migration des données des clients et de l'entreprise vers la nouvelle plateforme a lieu lors d'un week-end d'avril 2018. Dès la remise en service, toutes les agences et une part importante des 5,2 millions de clients de la banque sont touchées : accès impossibles aux services en ligne et mobiles, opérations erronées, centres d'appel saturés. Le rétablissement complet du service prend plusieurs mois. Le directeur général quitte ses fonctions à l'automne 2018.

2.3.3 Révélations

Les régulateurs ont établi que TSB n'avait pas organisé ni contrôlé de manière adéquate son programme de migration, et qu'elle n'avait pas géré de manière adéquate les risques opérationnels nés de son externalisation auprès d'un fournisseur tiers critique. La banque a versé 32,7 millions de livres de réparation aux clients lésés. Les deux régulateurs lui

ont infligé une amende totale de 48,65 millions de livres (29,75 millions pour la FCA, 18,9 millions pour la PRA), après une réduction de 30 % accordée pour son règlement amiable. En 2023, la PRA a en outre sanctionné personnellement l'ancien directeur des systèmes d'information de la banque pour ne pas avoir pris de mesures raisonnables de supervision du prestataire [37].

Note

Un précédent pour tous les DSI. La sanction personnelle de l'ancien DSI de TSB montre que la redevabilité n'est pas une notion abstraite. Dans le régime britannique de responsabilité des dirigeants du secteur financier, le titulaire d'une fonction clé répond personnellement des mesures raisonnables qu'il a prises, ou omis de prendre, dans son périmètre. Externaliser une activité ne transfère pas la responsabilité de la superviser.

2.3.4 Synthèse

Scénario Opérationnel · TSB. Lecture de gouvernance

Cause technique (établie dans ses grandes lignes). Une plateforme et un fournisseur qui n'étaient pas prêts à absorber la charge et les cas réels de l'ensemble des clients au moment de la bascule.

Cause de gouvernance (analyse, confiance élevée). Le programme n'a pas été piloté avec un contrôle suffisant de son état de préparation, et la banque s'est fiée à son fournisseur, entité de son propre groupe, sans superviser elle-même les risques qu'il portait. La décision de basculer a été prise sans que l'organe de décision dispose d'une évaluation indépendante de cet état de préparation.

Les trois questions. *Qui décide* de la bascule ? La direction, sur la foi des assurances du programme. *Qui exécute* ? Un fournisseur dont la banque ne maîtrisait pas les risques. *Qui rend compte* ? La banque, son directeur général et son DSI, devant les régulateurs.

La ressemblance avec l'opération SANAGA n'est pas fortuite : le cas fictif du prologue reprend des mécanismes que les décisions des régulateurs britanniques ont rendus publics. Ils ne sont propres ni à une banque ni à un pays.

2.4 CrowdStrike, 2024 : la Mise à Jour qui a Arrêté le Monde

2.4.1 Brief

CrowdStrike est un éditeur américain de solutions de cybersécurité. Son logiciel Falcon protège les postes de travail et les serveurs de très nombreuses organisations. Pour détecter les attaques, il s'exécute au cœur du système d'exploitation Windows et reçoit plusieurs fois par jour des mises à jour de contenu, qui décrivent de nouveaux comportements malveillants. Les faits techniques qui suivent sont ceux qu'établit l'analyse de

cause publiée par l'éditeur le 6 août 2024 [11].

2.4.2 Déroulé

Le 19 juillet 2024, CrowdStrike diffuse une mise à jour de contenu pour son capteur Windows. Elle provoque l'arrêt brutal des machines qui la reçoivent, puis leur redémarrage en boucle. L'éditeur retire la mise à jour dans l'heure et demie qui suit, mais les machines déjà touchées ne peuvent plus la recevoir : il faut souvent intervenir manuellement, poste par poste. Microsoft estime à environ 8,5 millions le nombre d'appareils Windows touchés [50]. Des compagnies aériennes, des hôpitaux, des banques et des médias sont paralysés pendant plusieurs jours.

2.4.3 Révélations

L'analyse de cause établit que le capteur attendait 20 champs de données, alors que la mise à jour en fournissait 21. Ce décalage a provoqué une lecture hors des limites de la mémoire, et l'arrêt du système. Le défaut n'avait pas été détecté par les contrôles de validation du contenu. L'éditeur annonce, parmi ses mesures correctives, davantage de tests, un déploiement progressif de ces mises à jour, et la possibilité pour les clients de choisir où et quand elles s'installent.

2.4.4 Synthèse

Ce cas se lit à deux niveaux de gouvernance : celle de l'éditeur, et celle de ses clients.

Scénario Opérationnel · CrowdStrike. Lecture de gouvernance

Chez l'éditeur (analyse, confiance moyenne). Les mises à jour de contenu n'étaient pas soumises à la même rigueur de gestion des changements que les versions du logiciel, ni déployées progressivement. Un type de changement fréquent et jugé peu risqué échappait aux contrôles les plus stricts.

Chez les clients (analyse, confiance élevée). Des milliers d'organisations avaient accordé à un fournisseur unique le droit de modifier, sans délai ni contrôle de leur part, un composant qui s'exécute au cœur de tous leurs postes. Ce choix est rationnel pour la sécurité : une protection doit être à jour. Mais il crée une **dépendance critique** qui n'avait, dans la plupart des cas, jamais été évaluée ni arbitrée par les instances de gouvernance.

Application RSSI

Évaluer une dépendance critique à un fournisseur de sécurité

1. Recenser les logiciels qui disposent de droits élevés sur l'ensemble du parc et reçoivent des mises à jour automatiques.
2. Pour chacun, vérifier si l'organisation peut retarder ou échelonner les mises à jour (groupe pilote, puis déploiement général).

3. Évaluer le scénario « le fournisseur rend tout le parc inutilisable » : délai de restauration, procédure manuelle, personnel nécessaire.
4. Présenter ce risque au comité des risques, avec une recommandation : l'accepter, le réduire ou le transférer.

Ce qui compte n'est pas de supprimer la dépendance, souvent inévitable, mais qu'elle soit **connue et décidée** par l'instance compétente.

2.5 Lecture Croisée des Trois Affaires

2.5.1 Comparaison

Question	Knight Capital	TSB	CrowdStrike
Nature du changement	Déploiement de code	Migration de plateforme	Mise à jour de contenu
Durée de l'incident	45 minutes	Plusieurs mois	Plusieurs jours
Contrôle défaillant	Déploiement sans procédure ni double contrôle	Préparation de la bascule, supervision du fournisseur	Validation et déploiement progressif
Rôle d'un tiers	Aucun	Fournisseur critique du groupe	L'éditeur lui-même est le tiers des clients
Sanction	Amende de la SEC, absorption	Amendes FCA et PRA, sanction du DSI	Pertes et contentieux des clients

Tableau 2.2. Comparaison des trois affaires

2.5.2 Quatre constantes

Malgré leurs différences, les trois affaires partagent quatre traits.

1. **Un changement est à l'origine de chaque incident.** Aucune de ces pannes ne vient d'une usure ou d'une attaque. Toutes viennent d'une modification volontaire du système. La gestion des changements (Chapitre 14) est le premier contrôle de la gouvernance des SI.
2. **Le risque était connu ou connaissable.** Code mort jamais retiré, préparation insuffisante, type de mise à jour moins contrôlé : aucun de ces risques n'était imprévisible.
3. **La responsabilité était diluée.** Dans chaque cas, il est difficile de nommer la personne ou l'instance qui avait formellement décidé que le risque était acceptable.

4. **Le retour arrière était difficile ou impossible.** Knight a aggravé la situation en tentant de revenir en arrière, TSB a mis des mois à se rétablir, et les clients de CrowdStrike ont dû réparer leurs postes un par un.

Et en Afrique ?

Les trois affaires sont américaines ou européennes. Ce n'est pas que l'Afrique centrale ignore les grandes pannes : les interruptions de services bancaires, de paiement mobile ou de télécommunications y sont fréquentes et parfois longues. C'est que leurs causes sont rarement rendues publiques. Peu de régulateurs publient leurs décisions motivées, et peu d'entreprises publient leurs analyses de cause.

Cette opacité est elle-même une question de gouvernance. Une défaillance dont on ne publie pas l'analyse ne profite à personne d'autre qu'à l'organisation qui l'a subie, et souvent pas même à elle. Le Chapitre 10 examinera les obligations de déclaration des incidents prévues par le droit camerounais, et le Chapitre 20 la place de cette question dans la recherche.

2.6 Une Grille d'Erreurs de Gouvernance

Les trois affaires réelles et l'opération SANAGA permettent de construire une grille de dix erreurs. Chacune s'accompagne d'un signal d'alerte observable et de la question qu'un administrateur, un auditeur ou un DSI devrait poser. La dernière colonne renvoie à l'objectif COBIT 2019 qui traite l'erreur ; ces objectifs seront étudiés au Chapitre 6.

Erreur	Signal d'alerte	Question à poser	COBIT
1. Décision sans instance	Date ou budget fixés par une seule personne	Quelle instance a décidé, et où est le procès-verbal ?	EDM01
2. Risque non arbitré	Alerte écrite restée sans réponse	Qui a accepté ce risque, par écrit ?	EDM03
3. Changement non autorisé	Mise en production sans comité	Où est l'autorisation, datée avant la mise en production ?	BAI06
4. Pas de retour arrière	Plan de retour absent ou non testé	Quand le retour arrière a-t-il été testé, et avec quel résultat ?	BAI07
5. Recette incomplète	Bascule avec des scénarios non testés	Quel taux de couverture, et qui a accepté le reste ?	BAI07
6. Fournisseur non supervisé	Rapports de suivi rédigés par le fournisseur	Comment vérifions-nous nous-mêmes ce qu'il affirme ?	APO10
7. Contrat sans engagement	Pas de niveau de service ni de pénalité	Que se passe-t-il s'il ne tient pas ses engagements ?	APO09
8. Alertes sans propriétaire	Messages automatiques non traités	Qui est chargé de lire cette alerte, et dans quel délai ?	DSS02
9. Continuité non testée	Plan de continuité jamais exercé	Quand a eu lieu le dernier exercice, et qu'a-t-il révélé ?	DSS04
10. Audit sans suite	Recommandations « en cours » depuis des mois	Qui suit les recommandations, devant quelle instance ?	MEA02

Tableau 2.3. Grille des dix erreurs de gouvernance des SI

Exigence de contrôle

Le dossier d'analyse d'une défaillance. Pour qu'une analyse de défaillance soit opposable à la direction, au conseil ou au régulateur, elle doit contenir :

- la liste des sources utilisées, classées selon le Tableau 2.1 ;
- une chronologie où chaque entrée renvoie à une pièce ;
- des constatations séparées des analyses, chaque analyse portant un niveau de confiance (faible, moyen, élevé) ;
- la cause technique et la cause de gouvernance, distinguées ;
- pour chaque erreur de la grille relevée, la pièce qui l'établit.

Application Auditeur SI

Utiliser la grille en mission

1. Avant la mission, choisir les erreurs de la grille les plus probables au regard de l'activité (une banque qui migre : erreurs 1 à 5 ; une entreprise très externalisée : erreurs 6 et 7).
2. Pour chaque erreur retenue, préparer la question et la pièce à demander.
3. En entretien, poser la question, puis demander la pièce : une réponse orale n'est pas une preuve.
4. Consigner chaque écart sous la forme constatation, critère, cause, conséquence, recommandation (Chapitre 11).

Application Responsable des services IT

Trois contrôles à mettre en place dès demain

1. Aucun changement en production sans enregistrement préalable, et aucun changement majeur sans autorisation d'un comité.
2. Une vérification après chaque déploiement : la version installée est la même partout.
3. Un propriétaire nommé pour chaque alerte automatique, avec un délai de traitement.

Ces trois contrôles auraient, à eux seuls, très probablement évité l'affaire Knight Capital.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Les sources de première main d'abord** : décisions des régulateurs, rapports d'enquête, analyses de cause. La presse oriente, elle n'établit pas.
- **Knight Capital (2012)** : un déploiement sans procédure écrite ni double contrôle, un code mort réactivé, des alertes sans propriétaire ; 460 millions de dollars perdus en 45 minutes.
- **TSB (2018)** : une migration mal pilotée, un fournisseur critique mal supervisé ; des amendes de 48,65 millions de livres et la sanction personnelle de l'ancien DSI.
- **CrowdStrike (2024)** : une mise à jour de contenu insuffisamment validée et

déployée en une fois ; une dépendance critique que la plupart des clients n'avaient jamais arbitrée.

- **Quatre constantes** : un changement à l'origine, un risque connaissable, une responsabilité diluée, un retour arrière difficile.
- **La grille des dix erreurs** relie chaque erreur à un signal, une question et un objectif COBIT : elle servira dans tout le cours.

✍ Exercice 2.1. Constatation ou analyse ? ★☆☆

Pour chacune des phrases suivantes, indiquez s'il s'agit d'une constatation ou d'une analyse. Pour les analyses, proposez un niveau de confiance et la pièce qui permettrait de le renforcer.

(a) « Le nouveau code n'a été installé que sur sept des huit serveurs. »

(b) « Les équipes de Knight manquaient de formation. »

(c) « TSB a versé 32,7 millions de livres de réparation à ses clients. »

(d) « Le conseil de TSB aurait dû refuser la date de bascule. »

(e) « La mise à jour fournissait 21 champs au lieu des 20 attendus. »

✍ Exercice 2.2. La grille appliquée à KRIBILOG ★★☆

Chez KRIBILOG SA, le logiciel de suivi des conteneurs s'arrête trois fois en deux mois. Vous disposez des faits suivants : l'infogérant NETPORT SERVICES applique les correctifs le soir, sans prévenir ; son rapport mensuel ne mentionne aucun incident ; le contrat ne prévoit aucun délai d'intervention ; le dernier test de continuité date de 2021.

(a) Identifiez les erreurs de la grille (Tableau 2.3) présentes dans ce cas.

(b) Pour chacune, rédigez la question à poser et la pièce à demander.

(c) Classez-les par ordre de priorité, en justifiant.

✍ Exercice 2.3. Simulation d'examen ★★★

Durée conseillée : 1 heure. Choisissez une interruption de service informatique survenue en Afrique et documentée publiquement (communiqué de l'organisation, décision d'un régulateur, rapport d'enquête).

(a) Classez les sources disponibles selon le Tableau 2.1, et indiquez ce qu'elles permettent d'établir.

(b) Appliquez les sept questions de la grille d'analyse (section 2.1).

(c) Rédigez une synthèse d'une page, en séparant constatations et analyses.

(d) Si les sources ne permettent pas d'établir la cause de gouvernance, dites-le, et indiquez les pièces qu'il faudrait obtenir. Cette conclusion est une réponse valable.

Note

Transition. Les défaillances montrent ce que coûte une gouvernance absente. Le Chapitre 3 montre ce qu'une gouvernance présente doit rechercher : l'alignement du SI sur la stratégie, la création de valeur, et l'arbitrage des décisions d'investissement.

3

THÉORIES ET MODÈLES : ALIGNEMENT, VALEUR ET DÉCISION

« On voit l'ère de l'ordinateur partout, sauf dans les statistiques de productivité. »

Robert Solow, prix Nobel d'économie, 1987 (notre traduction)

Niveau : *Fondamental* • Maîtrise du Chapitre 1 (définition de travail de la gouvernance des SI et ses trois finalités).

✦ Objectifs du chapitre

- ➢ Appliquer le modèle d'alignement stratégique de Henderson et Venkatraman.
- ➢ Classer les droits de décision selon les archétypes de Weill et Ross.
- ➢ Expliquer les trois finalités : réalisation des bénéfices, optimisation des risques, optimisation des ressources.
- ➢ Évaluer un investissement informatique (coût total de possession, valeur actuelle nette, score multicritère).
- ➢ Arbitrer un portefeuille de projets.

Question directrice : 14 milliards pour quoi faire ?

À l'ANPP (opération MEFOU, Chapitre 1), le schéma directeur adopté en 2023 prévoyait neuf projets pour 14 milliards FCFA. À mi-parcours, trois projets ont consommé 71 % du budget sans être achevés. Le nouveau président du conseil d'administration pose trois questions simples : « Ces projets servaient-ils la mission de l'agence ? Qui les a choisis, et selon quels critères ? Combien rapportent-ils, ou combien de risques évitent-ils ? »

Ces trois questions sont celles de ce chapitre. La première relève de l'**alignement stratégique** (section 3.2). La deuxième relève des **droits de décision** (section 3.3). La troisième relève de la **valeur**, que le chapitre définit (section 3.4), mesure (section 3.5) et arbitre à l'échelle d'un portefeuille (section 3.6). Le laboratoire GCI-LAB-01 de NDAP SUKULU applique la démarche au portefeuille complet de l'ANPP.

3.1 Le Paradoxe de la Productivité

La phrase de Solow, en épigraphe, a ouvert un long débat. Dans les années 1980, les entreprises américaines investissent massivement dans l'informatique, sans que la productivité mesurée progresse en proportion. Les travaux ultérieurs ont largement nuancé ce constat : les gains existent, mais ils sont inégaux, différés, et dépendent moins de la technologie elle-même que de la manière dont l'organisation la met en œuvre.

Pour la gouvernance, la leçon est décisive : **la valeur n'est pas dans la technologie, elle est dans son usage**. Deux organisations qui achètent le même logiciel n'en tirent pas la même valeur. Ce qui les distingue, c'est la manière dont elles choisissent leurs projets, transforment leurs processus et suivent les bénéfices. C'est précisément le champ de la gouvernance des SI.

Note

Les quatre questions de Thorp. John Thorp a résumé la gouvernance de la valeur en quatre questions [45], reprises plus tard par le référentiel Val IT de l'ISACA : *fait-on les bonnes choses ?* (la stratégie), *les fait-on de la bonne manière ?* (l'architecture), *les mène-t-on à bien ?* (la livraison), *en tire-t-on les bénéfices ?* (la valeur). Les deux premières relèvent de la gouvernance, les deux dernières du management, sous le contrôle de la gouvernance.

3.2 Le Modèle d'Alignement Stratégique

3.2.1 Quatre domaines, deux dimensions

Le modèle d'alignement stratégique (*Strategic Alignment Model*, SAM) de Henderson et Venkatraman [18] reste le cadre de référence de l'alignement. Il distingue quatre domaines, organisés selon deux dimensions.

- La dimension de l'**ajustement stratégique** (*strategic fit*) relie le niveau externe (la stratégie : sur quel marché, avec quelles compétences distinctives, avec quelle gouvernance) et le niveau interne (l'infrastructure et les processus qui la mettent en œuvre).

- La dimension de l'**intégration fonctionnelle** (*functional integration*) relie le domaine de l'activité et le domaine des technologies de l'information.

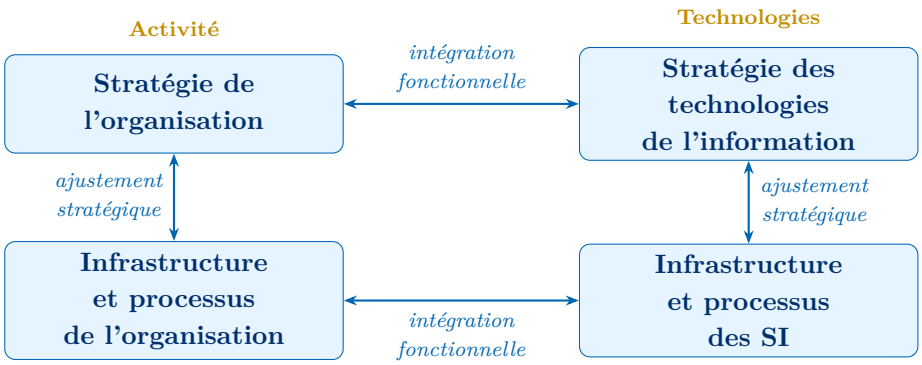


Figure 3.1. Le modèle d'alignement stratégique (d'après Henderson et Venkatraman, 1993)

Définition

Alignement stratégique (*strategic alignment*) : degré de cohérence entre la stratégie de l'organisation, la stratégie des technologies de l'information et les infrastructures et processus qui les mettent en œuvre. Pour Henderson et Venkatraman, l'alignement n'est pas un état atteint une fois pour toutes, mais un processus continu d'adaptation.

3.2.2 Quatre perspectives d'alignement

Le modèle décrit quatre manières de parcourir les domaines, selon le point de départ et le point d'arrivée. Chacune correspond à un rôle différent de la direction générale et du DSI.

Perspective	Parcours	Exemple camerounais
Exécution de la stratégie	Stratégie de l'organisation → infrastructure de l'organisation → infrastructure des SI	L'ANPP doit payer tous les fournisseurs de l'État sous 30 jours : elle réorganise ses circuits, puis outille la chaîne de paiement
Transformation technologique	Stratégie de l'organisation → stratégie des TI → infrastructure des SI	La BANQUE SANAGA veut conquérir les jeunes urbains : elle choisit une stratégie mobile, puis la plateforme qui la porte
Potentiel concurrentiel	Stratégie des TI → stratégie de l'organisation → infrastructure de l'organisation	NOUN PAY découvre que la notation par IA permet le microcrédit instantané : elle redéfinit son offre
Niveau de service	Stratégie des TI → infrastructure des SI → infrastructure de l'organisation	KRIBILOG fiabilise son suivi des conteneurs, ce qui permet aux équipes du port de réorganiser leurs rotations

Tableau 3.1. Les quatre perspectives d'alignement

★ Attention

Violation typique. Un projet est lancé parce que « la technologie existe » ou parce qu'un autre organisme l'a adoptée, sans que personne n'ait identifié l'objectif de l'organisation qu'il sert. Le projet est livré, mais aucun processus ne change, et aucun bénéfice n'est mesuré.

Règle : tout projet doit pouvoir être rattaché, par écrit, à un objectif de l'organisation et à l'une des quatre perspectives. Un projet qu'on ne peut rattacher à rien n'est pas aligné : il doit être justifié autrement, ou abandonné.

3.3 Qui Décide de Quoi : les Archétypes de Weill et Ross

3.3.1 Cinq décisions

Weill et Ross [49] identifient cinq grandes catégories de décisions relatives aux technologies de l'information. Elles sont liées : les principes encadrent les quatre autres.

1. **Les principes** : le rôle que les TI doivent jouer dans l'organisation (réduire les coûts, soutenir la croissance, transformer le métier).

2. **L'architecture** : l'organisation logique des données, des applications et de l'infrastructure, et les standards retenus.

3. **L'infrastructure** : les services techniques partagés (réseaux, centres de données, sécurité) et leur niveau.

4. **Les besoins applicatifs** : les applications à acquérir ou à développer pour les métiers.

5. **L'investissement et la priorisation** : combien investir, dans quoi, et dans quel ordre.

3.3.2 Six archétypes

Pour chaque décision, Weill et Ross se demandent *qui* détient le droit de décider, et *qui* est consulté avant. Ils distinguent six archétypes de gouvernance.

Archétype	Qui décide	Risque typique
Monarchie métier	La direction générale ou un groupe de dirigeants des métiers	Décisions déconnectées des contraintes techniques
Monarchie informatique	Les responsables informatiques	Décisions techniquement justes, mais sans adhésion des métiers
Féodalité	Chaque direction métier pour son propre périmètre	Doublons, incompatibilités, coûts non mutualisés
Fédéralisme	La direction générale et les métiers ensemble, avec ou sans l'informatique	Lenteur, compromis difficiles
Duopole	L'informatique et un groupe de métiers	Dépend de la qualité de la relation bilatérale
Anarchie	Chaque utilisateur ou petit groupe	Aucune cohérence, risques non maîtrisés

Tableau 3.2. Les six archétypes de Weill et Ross

3.3.3 La matrice des droits de décision

L'outil le plus utile est la **matrice des droits de décision** : en lignes les archétypes, en colonnes les cinq décisions, et dans chaque case qui apporte un avis (*consultation*) et qui tranche (*décision*). Elle décrit la gouvernance telle qu'elle fonctionne réellement, et non telle qu'elle est écrite.

Scénario Opérationnel · Opération MEFOU. Les droits de décision réels

L'entretien avec les responsables de l'ANPP fait apparaître la situation suivante.

Décision	Qui décide réellement	Archétype
Principes	Personne (aucun document)	Absence de décision
Architecture	Chaque prestataire, projet par projet	Anarchie
Infrastructure	Cheffe de la division informatique	Monarchie informatique
Besoins applicatifs	Chaque direction, avec son prestataire	Féodalité
Investissement	Directeur général, à la demande de la tutelle	Monarchie métier

Analyse (confiance élevée). La décision la plus lourde, l'investissement, est prise par une seule personne, sans consultation de la division informatique ni critères écrits.

Les besoins applicatifs sont définis direction par direction, ce qui explique que trois projets aient absorbé l'essentiel du budget sans cohérence d'ensemble. L'absence de principes rend tout arbitrage impossible : il n'existe aucun critère pour dire non.

Existe-t-il un bon archétype ?

Il n'existe pas d'archétype bon en soi. Weill et Ross observent que les organisations les plus performantes combinent des archétypes différents selon les décisions : par exemple une monarchie informatique pour l'architecture et l'infrastructure, où l'expertise prime, et un fédéralisme ou un duopole pour les besoins applicatifs et l'investissement, où l'adhésion des métiers est indispensable. La seule configuration à proscrire est celle qui n'a pas été choisie : la gouvernance de fait, qui s'installe faute de décision.

3.4 Les Trois Finalités de la Gouvernance

3.4.1 Créer de la valeur

COBIT 2019 définit l'objectif de la gouvernance comme la **création de valeur**, qui résulte de l'équilibre entre trois finalités [23]. La définition de travail du Chapitre 1 les reprend.

■ Définition

Réalisation des bénéfices (*benefits realization*) : créer de la valeur pour l'organisation grâce aux technologies de l'information, en entretenant et en accroissant la valeur des investissements existants, et en éliminant les initiatives et les actifs qui n'en créent pas assez.

Optimisation des risques (*risk optimization*) : traiter les risques liés à l'usage, à la propriété, à l'exploitation et à l'adoption des technologies de l'information, en les maintenant dans les limites de l'appétence au risque fixée par l'organe de gouvernance.

Optimisation des ressources (*resource optimization*) : s'assurer que les compétences et les ressources nécessaires (personnes, processus, technologies, données) sont disponibles, suffisantes et utilisées de manière efficace.

Le mot clé est **équilibre**. Maximiser les bénéfices sans se soucier des risques conduit à l'opération SANAGA. Minimiser les risques sans se soucier des bénéfices conduit à l'immobilisme. Économiser les ressources sans se soucier des deux autres conduit à des systèmes vieillissants et fragiles.

3.4.2 Trois objectifs de gouvernance

À chaque finalité correspond un objectif du domaine de gouvernance de COBIT 2019. Ils seront étudiés au Chapitre 6.

Finalité	Objectif COBIT 2019	Question au conseil
Réalisation des bénéfices	EDM02 · Assurer la réalisation des bénéfices	Les investissements produisent-ils les bénéfices annoncés ?
Optimisation des risques	EDM03 · Assurer l'optimisation des risques	Les risques sont-ils dans les limites que nous avons fixées ?
Optimisation des ressources	EDM04 · Assurer l'optimisation des ressources	Avons-nous les compétences et les moyens de notre stratégie ?

Tableau 3.3. Finalités et objectifs de gouvernance (intitulés traduits par nos soins)

Fiche processus · EDM02 · Assurer la réalisation des bénéfices

Finalité : obtenir la valeur optimale des initiatives, des services et des actifs informatiques, et une gestion des coûts efficace.
Pratiques : évaluer l'optimisation de la valeur ; diriger l'optimisation de la valeur (critères d'investissement, rôles) ; surveiller l'optimisation de la valeur (indicateurs, écarts).
Sorties : principes et critères d'investissement, retour sur le portefeuille, actions correctives.
RACI (extrait) : *A* au conseil d'administration, *R* au directeur général et au comité stratégique des SI, *C* au directeur financier et au DSI.
Indicateurs : part des investissements dont les bénéfices sont suivis après la mise en service ; écart entre bénéfices annoncés et bénéfices constatés.

3.5 Évaluer un Investissement Informatique

3.5.1 Le coût total de possession

Le prix d'achat d'un logiciel n'est qu'une partie de son coût. Le **coût total de possession** (*total cost of ownership*, TCO) additionne tous les coûts supportés sur la durée de vie de la solution : acquisition, intégration, matériel, formation, exploitation, support et sortie.

Poste (sur 5 ans)	Millions FCFA
Licences (prix affiché par l'éditeur)	300
Intégration et reprise des données	250
Matériel et hébergement	150
Formation des utilisateurs	50
Exploitation interne (90 par an)	450
Support et maintenance de l'éditeur (60 par an)	300
Coût total de possession	**1 500**

Tableau 3.4. Coût total de possession d'un logiciel de gestion des paiements (exemple)

Le coût total est cinq fois le prix affiché. C'est un ordre de grandeur fréquent, et l'une des raisons pour lesquelles les budgets des schémas directeurs dérapent : ils ont été construits sur les prix d'acquisition.

3.5.2 La valeur actuelle nette

Un franc reçu dans quatre ans vaut moins qu'un franc dépensé aujourd'hui. La **valeur actuelle nette** (VAN, *net present value*) ramène tous les flux d'un projet à leur valeur d'aujourd'hui, au moyen d'un taux d'actualisation r :

$$\mathrm{VAN} = -I_0 + \sum_{t=1}^{n} \frac{F_t}{(1+r)^t}$$

où I_0 est l'investissement initial et F_t le flux net (bénéfices moins coûts d'exploitation) de l'année t. Un projet dont la VAN est positive crée de la valeur au taux retenu.

Lorsque le flux annuel F est constant, la somme se calcule avec le facteur d'annuité :

$$\sum_{t=1}^{n} \frac{1}{(1+r)^t} = \frac{1-(1+r)^{-n}}{r}, \qquad \text{soit } 3{,}7908 \text{ pour } r = 10\ \% \text{ et } n = 5.$$

Scénario Opérationnel · Opération MEFOU. Trois projets à évaluer

L'ANPP retient un taux d'actualisation de 10 % et un horizon de cinq ans. Trois projets sont en concurrence.

Projet	I_0	F annuel	VAN
A. Paiement dématérialisé des fournisseurs	1 200	450	+506
B. Refonte du portail des ressources humaines	800	180	−118
C. Site de secours (continuité)	600	120	−145

Montants en millions FCFA.

Calcul du projet A. $450 \times 3{,}7908 = 1\,705{,}9$; $\mathrm{VAN} = 1\,705{,}9 - 1\,200 = 505{,}9$, soit environ +506 millions FCFA. Le délai de récupération est de $1\,200/450 \approx 2{,}7$ ans, et le taux de rentabilité interne, pour lequel la VAN s'annule, est d'environ 25 %.

Le cas du projet C. Le site de secours ne produit aucune recette. Son flux annuel est une *perte évitée* : l'ANPP estime à 5 % par an la probabilité d'un sinistre majeur sur son centre de données, pour une perte de 2 400 millions FCFA (pénalités de retard de paiement, reprise manuelle), soit une perte annuelle attendue de $0{,}05 \times 2\,400 = 120$ millions FCFA.

3.5.3 Les limites de l'évaluation financière

Si l'ANPP ne retenait que la VAN, elle financerait le seul projet A. Ce serait une erreur de gouvernance, pour trois raisons.

- **Les risques se chiffrent mal.** La perte attendue du projet C repose sur une probabilité très incertaine. Une variation de quelques points change le signe de la VAN.
- **Certains projets sont obligatoires.** Une obligation légale ou réglementaire ne se discute pas en VAN : elle se respecte, au moindre coût.
- **L'alignement ne se chiffre pas.** Un projet peut avoir une VAN modeste et être indispensable à la mission de l'organisation.

3.5.4 Le score multicritère

Pour dépasser ces limites, l'organe de gouvernance fixe à l'avance des critères pondérés, puis note chaque projet. Les poids traduisent ses priorités : les fixer est une décision de gouvernance, qui ne doit pas être laissée à ceux qui proposent les projets.

Critère	Poids	A	B	C
Alignement sur la mission	30 %	5	3	3
Valeur financière (VAN)	25 %	5	2	1
Réduction des risques	20 %	2	1	5
Obligation réglementaire	15 %	3	1	4
Faisabilité	10 %	4	5	3
Score pondéré		**4,00**	**2,25**	**3,05**

Tableau 3.5. Score multicritère des trois projets de l'ANPP (notes de 1 à 5)

Le calcul du projet A est le suivant : $0{,}30\times5+0{,}25\times5+0{,}20\times2+0{,}15\times3+0{,}10\times4=4{,}00$. Avec une enveloppe de 1 900 millions FCFA, l'ANPP finance A et C (1 800 millions) et écarte B. Le site de secours, rejeté par la VAN seule, est retenu au titre des risques et de l'obligation de continuité du service public.

Exigence de contrôle

Une décision d'investissement auditable. Pour qu'un auditeur, ou la Chambre des comptes, puisse établir que le portefeuille a été arbitré, le dossier doit contenir :

- les critères et leurs poids, approuvés par l'organe de gouvernance *avant* l'examen des projets ;
- pour chaque projet, un dossier d'investissement (objectif servi, coût total de

possession, bénéfices attendus et leur responsable, risques) ;

- ➢ la grille de notation, signée par ceux qui l'ont établie ;
- ➢ le procès-verbal de la décision, y compris pour les projets écartés ;
- ➢ le plan de suivi des bénéfices après la mise en service.

3.6 Arbitrer un Portefeuille

3.6.1 Projet, programme, portefeuille

Définition

Portefeuille (*portfolio*) : ensemble des projets, des programmes et des services informatiques d'une organisation, géré comme un tout pour maximiser la valeur obtenue sous contrainte de ressources et de risque. L'unité de décision de la gouvernance n'est pas le projet isolé, mais le portefeuille.

Raisonner en portefeuille change la question posée. Il ne s'agit plus de savoir si un projet est bon, mais s'il est *meilleur que les autres usages possibles des mêmes ressources*. C'est ce qui a manqué à l'ANPP : chaque projet a été approuvé seul, sans jamais être comparé aux autres.

3.6.2 Équilibrer le portefeuille

Weill et Broadbent proposent de classer les investissements informatiques selon leur finalité [48]. Un portefeuille équilibré combine les quatre catégories, dans des proportions qui reflètent la stratégie.

Catégorie	Finalité	Exemple à l'ANPP
Infrastructure	Fournir les services partagés sur lesquels tout repose	Réseau sécurisé entre l'agence et les trésoreries régionales
Transactionnel	Réduire les coûts et automatiser les opérations répétitives	Paiement dématérialisé des fournisseurs (projet A)
Informationnel	Mieux piloter, mieux contrôler	Tableau de bord des délais de paiement
Stratégique	Changer la position ou la mission de l'organisation	Paiement des usagers par téléphone mobile

Tableau 3.6. Les quatre catégories d'investissement (d'après Weill et Broadbent)

3.6.3 Le cadre de la gestion publique au Cameroun

Pour une administration ou un établissement public, l'arbitrage du portefeuille s'inscrit dans le cadre budgétaire de l'État.

Jurisprudence & Droit applicable

Loi n° 2018/012 du 11 juillet 2018 portant régime financier de l'État et des autres entités publiques, article 69.

Selon la présentation qu'en fait le ministère des Finances [31], la loi organise le budget par programmes et institue un *responsable de programme*, désigné par le ministre. Ce responsable formule le programme dans le *Projet de performance annuel* (PPA), affecte les ressources en son sein, organise le dialogue de gestion et élabore le *Rapport annuel de performance* (RAP). Il veille au respect des dispositifs de contrôle interne et de contrôle de gestion.

Portée. La gestion publique camerounaise est désormais pilotée par la performance : objectifs, indicateurs, compte rendu annuel. Un projet informatique public doit donc pouvoir être rattaché à un programme et à ses indicateurs de performance. C'est l'équivalent public de l'alignement stratégique, et un argument fort pour imposer, à l'ANPP comme ailleurs, des dossiers d'investissement et un suivi des bénéfices.

Application DSI

Présenter un portefeuille au comité stratégique

1. Une page par projet : objectif servi, perspective d'alignement, coût total de possession, VAN ou perte évitée, risques, responsable des bénéfices.
2. Une vue d'ensemble : répartition du budget entre les quatre catégories (Tableau 3.6) et comparaison avec la stratégie.
3. Le résultat de la grille multicritère, avec les poids approuvés par le comité.
4. Une recommandation explicite : financer, différer, arrêter.

Le dernier point est le plus difficile, et le plus important : proposer d'arrêter un projet en cours est souvent la meilleure décision de gouvernance qu'un DSI puisse provoquer.

Application Auditeur SI

Vérifier qu'un portefeuille est réellement arbitré

1. Demander les critères d'investissement, et vérifier leur date d'approbation au regard des dates de décision des projets.
2. Prendre un échantillon de projets approuvés *et* de projets écartés : une organisation qui n'a jamais écarté un projet n'arbitre pas.
3. Pour les projets en service, demander le suivi des bénéfices annoncés dans le dossier d'investissement.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **La valeur est dans l'usage** : le paradoxe de la productivité montre que la technologie seule ne crée pas de valeur ; la manière de la choisir et de l'exploiter, si.
- **L'alignement stratégique** relie quatre domaines (stratégie et infrastructure, de l'activité et des TI). Il se parcourt selon quatre perspectives, et c'est un processus continu.
- **Les droits de décision** portent sur cinq décisions (principes, architecture, infrastructure, besoins applicatifs, investissement) ; six archétypes décrivent qui décide. Le pire archétype est celui qu'on n'a pas choisi.
- **Trois finalités en équilibre** : réalisation des bénéfices, optimisation des risques, optimisation des ressources (EDM02, EDM03, EDM04).
- **Évaluer** : coût total de possession, VAN, délai de récupération ; mais aussi perte évitée pour les projets de risque, et score multicritère aux poids fixés par la gouvernance.
- **Arbitrer un portefeuille** : comparer les projets entre eux, équilibrer les catégories, et savoir arrêter un projet.

✍ Exercice 3.1. Calculer une VAN ★☆☆

KRIBILOG SA envisage un logiciel de planification des quais : investissement de 450 millions FCFA, gain net de 140 millions FCFA par an pendant cinq ans, taux d'actualisation de 12 %.

(a) Calculez le facteur d'annuité pour $r = 12\ \%$ et $n = 5$.

(b) Calculez la VAN du projet. Est-il créateur de valeur ?

(c) Calculez son délai de récupération simple.

✍ Exercice 3.2. La matrice de la BANQUE SANAGA ★★☆

À partir des faits du prologue (Chapitre 0), construisez la matrice des droits de décision de la BANQUE SANAGA pour le projet HORIZON.

(a) Pour chacune des cinq décisions de Weill et Ross, indiquez qui a réellement décidé et l'archétype correspondant.

(b) Proposez la matrice cible, en justifiant l'archétype retenu pour chaque décision.

(c) Rédigez la constatation et l'analyse correspondantes, avec leur niveau de confiance.

✍ Exercice 3.3. Arbitrer sous contrainte ★★★

Le comité stratégique de l'ANPP révise ses poids : l'obligation réglementaire passe à 25 % et la valeur financière à 15 %, les autres poids restant inchangés. Un quatrième projet D (tableau de bord des délais de paiement, 300 millions FCFA) obtient les notes 4, 2, 2, 5, 5.

(a) Recalculez les scores des projets A, B, C et D.

(b) Avec une enveloppe de 1 900 millions FCFA, quel portefeuille recommandez-vous ? Justifiez.

(c) Le directeur général conteste le changement des poids, qui « favorise » le projet D. Qui doit trancher, et comment l'auditeur saura-t-il que les poids n'ont pas été fixés après coup pour justifier un choix déjà fait ?

● Note

Transition. Ce chapitre a posé les modèles qui guident les décisions de gouvernance : alignement, droits de décision, valeur. Pour les mettre en œuvre, les organisations s'appuient sur des référentiels. Le Chapitre 4 dresse le panorama de ces référentiels (COBIT, ITIL, ISO, COSO, TOGAF…) et montre comment ils s'articulent.

4

PANORAMA ET ARTICULATION DES RÉFÉRENTIELS

« Un référentiel ne pense pas à votre place.
Il vous évite seulement d'oublier ce que d'autres ont appris à leurs dépens. »

Adage des praticiens de la gouvernance

Niveau : *Fondamental* • Maîtrise du Chapitre 3 (alignement, droits de décision, trois finalités de la gouvernance).

✦ Objectifs du chapitre

- ➢ Situer COBIT, ITIL, ISO/IEC 38500, ISO/IEC 20000, ISO/IEC 27001, COSO, CMMI, TOGAF et PMBOK.
- ➢ Distinguer cadre, norme certifiable et bonnes pratiques.
- ➢ Associer chaque référentiel au besoin qu'il couvre.
- ➢ Construire une carte d'articulation des référentiels pour une organisation donnée.

Question directrice : faut-il tout appliquer ?

Après la panne, le conseil d'administration de la BANQUE SANAGA reçoit en trois semaines quatre propositions de cabinets de conseil. La première propose « une mise en conformité COBIT », la deuxième « un déploiement ITIL », la troisième « une certification ISO 27001 », la quatrième « un programme de maturité CMMI ». Chacune promet de régler le problème. Le président du conseil demande à la nouvelle responsable GRC : « Faut-il tout faire ? Dans quel ordre ? Et ces référentiels se contredisent-ils ? »

Ce chapitre répond à ces questions. Il commence par distinguer les natures de référentiels (section 4.1), présente ensuite les principaux d'entre eux, regroupés par besoin (sections 4.2 à 4.4), puis montre comment les articuler en une carte cohérente (section 4.6). La réponse courte est : **non, il ne faut pas tout appliquer**, et les référentiels sérieux ne se contredisent pas : ils se répartissent le travail.

© MaletYon

4.1 Trois Natures de Référentiels

4.1.1 Cadre, norme, bonnes pratiques

Le mot « référentiel » recouvre des documents de nature très différente. Les confondre conduit à des promesses impossibles, comme celle d'une « certification COBIT » d'entreprise, qui n'existe pas.

Définition

Cadre de référence (*framework*) : ensemble structuré de principes, de concepts et d'objectifs qui organise un domaine et guide sa mise en œuvre, sans imposer d'exigences vérifiables par un tiers. Exemples : COBIT, COSO.

Norme certifiable (*certifiable standard*) : norme qui formule des *exigences* (le verbe « doit »), dont le respect peut être audité par un organisme de certification accrédité, qui délivre alors un certificat à l'organisation. Exemples : ISO/IEC 27001, ISO/IEC 20000-1, ISO 22301.

Recueil de bonnes pratiques (*body of knowledge, guidance*) : ensemble de pratiques reconnues, présentées comme des recommandations (« il convient de »), que l'organisation adapte librement. Exemples : ITIL, PMBOK, ISO/IEC 27002, ISO 31000.

4.1.2 Certifier une organisation, certifier une personne

La seconde confusion porte sur ce qui est certifié. Une organisation peut être certifiée conforme à une norme d'exigences. Une personne peut être certifiée compétente dans un référentiel. Les deux n'ont pas la même portée.

Référentiel	Certification de l'organisation	Certification des personnes (exemples)
COBIT	Non (évaluation de capacité possible)	COBIT Foundation, CGEIT, CISA (ISACA)
ITIL	Non (voir ISO/IEC 20000-1)	ITIL Foundation et niveaux supérieurs (PeopleCert)
ISO/IEC 20000-1	Oui	Auditeur ou responsable de mise en œuvre
ISO/IEC 27001	Oui	Auditeur ou responsable de mise en œuvre
ISO/IEC 38500	Non	Formations spécialisées
COSO	Non	Certificats de l'IIA et d'autres organismes
CMMI	Évaluation de niveau de maturité (pas une certification ISO)	Évaluateurs agréés
TOGAF	Non	TOGAF (The Open Group)
PMBOK	Non	PMP et autres (PMI)

Tableau 4.1. Ce qui se certifie, et pour qui

★ Attention

Violation typique. Une organisation obtient la certification ISO 27001 et en conclut que sa gouvernance des SI est « conforme ». Or le périmètre du certificat peut ne couvrir qu'un centre de données, et la norme ne traite que du management de la sécurité de l'information : elle ne dit rien de la valeur des investissements ni de la qualité des services.

Règle : lire toujours le *périmètre* d'un certificat, et ne jamais confondre la certification d'un système de management avec une gouvernance des SI d'ensemble.

4.1.3 Le cadre légal camerounais

Une certification volontaire ne remplace pas les obligations légales.

⚖ Jurisprudence & Droit applicable

Loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et la cybercriminalité au Cameroun, article 11 (version anglaise officielle) :

« The following activities may be subject to authorization: [...] the provision of security auditing, security programs editing, and other authorized security services to the public. »

Soit : la fourniture au public de services d'audit de sécurité peut être soumise à autorisation.

Portée. Au Cameroun, l'audit de sécurité des systèmes d'information n'est pas une activité libre au même titre que le conseil en organisation. Les articles 13 et 32 de

la même loi (Chapitre 0) rendent par ailleurs cet audit obligatoire pour certains systèmes. Un certificat ISO/IEC 27001, délivré par un organisme étranger, ne dispense donc pas des audits prévus par la loi : les deux démarches coexistent, et une bonne gouvernance les coordonne. Le Chapitre 10 précisera les textes d'application.

4.2 Les Référentiels de la Gouvernance

4.2.1 COBIT : le cadre de gouvernance et de management

COBIT est publié par l'ISACA, association internationale des professionnels de l'audit et de la gouvernance des SI. Né en 1996 comme un référentiel de *contrôle* à l'usage des auditeurs, il est devenu un cadre de *gouvernance et de management* de l'ensemble de l'information et des technologies de l'organisation. Sa version actuelle, COBIT 2019 [23], compte 40 objectifs répartis entre un domaine de gouvernance (EDM) et quatre domaines de management (APO, BAI, DSS, MEA). Elle fait l'objet de la Partie II.

Sa force : c'est le seul référentiel qui couvre de bout en bout le domaine, de la décision du conseil au contrôle de l'exploitation. Il sert de « référentiel parapluie » sous lequel les autres viennent se ranger. **Sa limite** : il dit *quoi* maîtriser, rarement *comment* le faire en détail.

4.2.2 ISO/IEC 38500 : les principes pour l'organe de gouvernance

La norme ISO/IEC 38500 s'adresse directement à l'organe de gouvernance (conseil d'administration, direction). Sa troisième édition date de février 2024 [26]. Courte, elle ne décrit pas de processus, mais des principes et un modèle de gouvernance fondé sur trois tâches : *évaluer*, *diriger*, *surveiller*. Elle n'est pas certifiable. Elle est étudiée au Chapitre 9.

4.2.3 COSO : le contrôle interne et la gestion des risques

Le Committee of Sponsoring Organizations of the Treadway Commission (COSO) publie deux cadres de référence. Le premier, sur le *contrôle interne* (1992, mis à jour en 2013), est la référence des auditeurs et des régulateurs financiers, notamment pour la loi Sarbanes-Oxley. Le second, sur la *gestion des risques de l'entreprise* (2004, refondu en 2017 sous le titre *Enterprise Risk Management: Integrating with Strategy and Performance*), relie le risque à la stratégie et à la performance [9]. COSO n'est pas propre à l'informatique, mais la gouvernance des SI s'y inscrit : les contrôles généraux informatiques font partie du contrôle interne.

4.3 Les Référentiels des Services et de la Sécurité

4.3.1 ITIL : les bonnes pratiques de la gestion des services

ITIL est né à la fin des années 1980 au sein de l'administration britannique, qui cherchait à rationaliser la gestion de ses services informatiques. Ses versions successives l'ont fait passer d'un catalogue de processus (version 2) à un cycle de vie des services (version 3,

2007), puis à un système de valeur des services organisé en pratiques (ITIL 4, 2019). Il est aujourd'hui la propriété de PeopleCert, qui a lancé en 2026 *ITIL version 5* [34].

Sa force : une description détaillée et éprouvée de la manière de gérer les services au quotidien (incidents, changements, niveaux de service…). **Sa limite** : il ne traite la gouvernance qu'à la marge, et ce n'est pas une norme : on ne « certifie » pas une organisation ITIL.

De ITIL 4 à ITIL version 5

ITIL version 5 a été annoncée par PeopleCert en janvier 2026, et ses modules de formation sont publiés progressivement depuis. Selon la présentation de l'éditeur, elle passe d'une approche centrée sur la gestion des services à une approche intégrée des *produits et des services numériques*, couvre leur cycle de vie de bout en bout, et se veut conçue d'emblée pour un environnement où l'intelligence artificielle est omniprésente [34]. Elle conserve les sept principes directeurs et l'essentiel des pratiques d'ITIL 4. ITIL 4 reste commercialisé et ses certifications restent reconnues pendant la transition.

Ce cours s'appuie sur **ITIL 4** dans la Partie IV : c'est la version documentée par des sources publiques, et celle que pratiquent aujourd'hui les organisations. Le Chapitre 12 situera ITIL version 5 par rapport à elle.

4.3.2 ISO/IEC 20000-1 : la norme du management des services

ISO/IEC 20000-1 formule les exigences d'un *système de management des services*. Elle est certifiable, et c'est par elle qu'une organisation peut faire reconnaître par un tiers la qualité de sa gestion des services. Ses exigences sont très proches des pratiques d'ITIL, dont elle est historiquement issue : ITIL dit *comment faire*, ISO/IEC 20000-1 dit *ce qui doit être démontré*.

4.3.3 ISO/IEC 27001 et 27002 : la sécurité de l'information

ISO/IEC 27001 formule les exigences d'un *système de management de la sécurité de l'information* (SMSI) et est certifiable. ISO/IEC 27002 détaille les mesures de sécurité qui peuvent y être mises en œuvre. Leur édition en vigueur date de 2022. Elles s'appuient sur une appréciation des risques, que précise ISO/IEC 27005. La famille ISO/IEC 27000 sera reprise au Chapitre 9.

4.3.4 ISO 22301 et ISO 31000 : continuité et risques

ISO 22301 formule les exigences d'un système de management de la continuité d'activité et est certifiable. ISO 31000 donne des lignes directrices générales sur le management du risque, applicables à tout type de risque, et n'est pas certifiable.

4.4 Architecture, Projets et Maturité

4.4.1 TOGAF : l'architecture d'entreprise

TOGAF, publié par The Open Group, est le cadre de référence le plus répandu en **architecture d'entreprise** : la description cohérente des processus métier, des données, des applications et des technologies d'une organisation, et de leur évolution. Son cœur est une méthode de développement de l'architecture (*Architecture Development Method*, ADM). TOGAF répond à la deuxième décision de Weill et Ross : l'architecture (Chapitre 3).

4.4.2 PMBOK et PRINCE2 : la gestion de projet

Le *Guide to the Project Management Body of Knowledge* (PMBOK), publié par le Project Management Institute, et la méthode PRINCE2, d'origine britannique, sont les deux grandes références de la gestion de projet. Le premier est un recueil de connaissances et de principes ; la seconde, une méthode structurée en processus et en rôles. Ils outillent l'objectif COBIT BAI11 (gérer les projets).

4.4.3 CMMI : la maturité des processus

Le CMMI (*Capability Maturity Model Integration*), né à l'université Carnegie Mellon pour évaluer les fournisseurs de logiciels du département de la Défense américain, est aujourd'hui géré par l'ISACA. Il décrit des niveaux de maturité, de 1 (processus improvisés) à 5 (processus en amélioration continue). COBIT 2019 s'en inspire directement pour son modèle de capacité des processus (Chapitre 8).

4.5 À Chaque Besoin son Référentiel

Le choix d'un référentiel ne part pas du référentiel, mais du besoin.

Besoin de l'organisation	Référentiel principal	Compléments
Organiser la gouvernance du conseil	ISO/IEC 38500, COBIT (EDM)	King IV, principes OCDE
Couvrir l'ensemble du management des SI	COBIT 2019	·
Fiabiliser le contrôle interne	COSO (contrôle interne)	COBIT (MEA02)
Gérer les risques de l'entreprise	COSO ERM, ISO 31000	COBIT (EDM03, APO12)
Gérer les services au quotidien	ITIL	ISO/IEC 20000-1
Faire reconnaître la qualité des services	ISO/IEC 20000-1	ITIL
Sécuriser l'information	ISO/IEC 27001 et 27002	COBIT (APO13, DSS05)
Assurer la continuité	ISO 22301	ITIL, COBIT (DSS04)
Cohérence des systèmes	TOGAF	COBIT (APO03)
Conduire les projets	PMBOK, PRINCE2	COBIT (BAI01, BAI11)
Améliorer la maturité des processus	CMMI	COBIT (capacité)

Tableau 4.2. Correspondance entre besoins et référentiels

Fiche processus · APO01 · Gérer le cadre de management des SI

Finalité : concevoir le système de management de l'information et des technologies de l'organisation, et en garantir la cohérence avec ses objectifs.

Pratiques (extrait) : concevoir le système de management ; communiquer les objectifs et l'orientation ; définir la structure organisationnelle ; définir et entretenir les politiques et procédures.

Sorties : politiques et procédures, définition des rôles, *choix et articulation des référentiels retenus.*

RACI (extrait) : *A* au directeur général, *R* au DSI, *C* au responsable GRC et au RSSI.

Indicateurs : part des politiques à jour et approuvées ; couverture des processus par un référentiel identifié.

Intitulé traduit par nos soins à partir de COBIT 2019 [22].

4.6 La Carte d'Articulation

4.6.1 Trois niveaux

Les référentiels s'articulent naturellement en trois niveaux. Au sommet, ceux qui s'adressent à l'organe de gouvernance. Au milieu, le cadre qui organise l'ensemble du management des SI. À la base, les référentiels spécialisés, chacun sur son domaine.

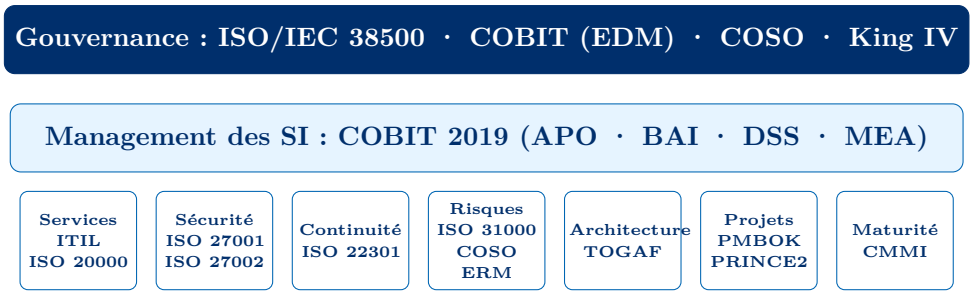


Figure 4.1. La carte d'articulation des référentiels

La règle d'articulation est simple : **COBIT fixe les objectifs, les référentiels spécialisés fournissent les pratiques**. COBIT 2019 le prévoit lui-même : pour chacun de ses objectifs, il indique les normes et référentiels qui le détaillent.

4.6.2 Construire la carte d'une organisation

Scénario Opérationnel · Opération SANAGA. La carte de la banque

La responsable GRC de la BANQUE SANAGA propose au conseil la carte suivante, à partir des défaillances du prologue et des exigences de la COBAC.

1. **Gouvernance** : principes de l'ISO/IEC 38500 dans la charte du comité stratégique des SI, objectifs EDM de COBIT.
2. **Management** : COBIT 2019 comme cadre unique, avec une évaluation de capacité sur les objectifs prioritaires (Partie II).
3. **Services** : les pratiques ITIL de gestion des changements, des mises en production et des incidents, en priorité.
4. **Continuité** : un plan conforme à ISO 22301, sans viser la certification dans un premier temps.
5. **Sécurité** : un SMSI conforme à ISO/IEC 27001, avec une certification visée à trois ans sur le périmètre des systèmes de paiement.

Ce qui est écarté, et pourquoi. Le programme CMMI proposé par un cabinet n'est pas retenu : le modèle de capacité de COBIT suffit au besoin de mesure, et la banque ne développe pas elle-même ses logiciels.

Exigence de contrôle

La carte des référentiels, pièce de gouvernance. Pour qu'un auditeur puisse établir que le choix des référentiels est maîtrisé, il doit trouver :

- un document qui liste les référentiels retenus, leur rôle et leur édition de référence ;

- la décision qui l'approuve, et sa date ;
- pour chaque norme certifiable visée, le périmètre et l'échéance ;
- la liste des référentiels écartés, avec la raison ;
- une date de revue, pour suivre les nouvelles éditions.

Application Responsable GRC

Choisir les référentiels sans les empiler

1. Partir des besoins et des obligations (lois, régulateur, clients), jamais de l'offre des cabinets.
2. Retenir un cadre unique de gouvernance et de management, puis un référentiel spécialisé par domaine.
3. Ne viser une certification que si un tiers l'exige ou si elle apporte un avantage identifié, et toujours sur un périmètre défini.
4. Suivre les éditions : une politique rédigée sur une édition périmée expose à des écarts lors de l'audit.

Les référentiels importés sont-ils adaptés à l'Afrique ?

Les référentiels internationaux ont été conçus pour des organisations dotées de moyens, de compétences et de marchés de prestataires que beaucoup d'organisations camerounaises n'ont pas. Ce n'est pas une raison de les écarter, mais d'en faire un usage *proportionné* : retenir les objectifs essentiels, viser des niveaux de capacité réalistes, et privilégier les pratiques qui traitent les risques locaux les plus probables (dépendance aux prestataires, coupures d'énergie, rareté des compétences). COBIT 2019 offre précisément cet outil d'adaptation avec ses facteurs de conception (Chapitre 7).

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Trois natures** : les cadres (COBIT, COSO) organisent, les normes certifiables (ISO/IEC 27001, 20000-1, ISO 22301) exigent, les recueils de bonnes pratiques (ITIL, PMBOK, ISO/IEC 27002) recommandent.
- **Certifier une organisation n'est pas certifier une personne** : il n'existe pas de certification COBIT ou ITIL d'une entreprise.
- **Lire le périmètre** : un certificat ne vaut que pour le périmètre qu'il désigne.

- **Trois niveaux** : gouvernance (ISO/IEC 38500, COBIT EDM, COSO), management (COBIT 2019), domaines spécialisés (ITIL, ISO 27001, ISO 22301, TOGAF, PMBOK, CMMI…).
- **COBIT fixe les objectifs, les autres fournissent les pratiques** : ils ne se contredisent pas, ils se répartissent le travail.
- **Partir du besoin** : une carte d'articulation se construit à partir des risques et des obligations, et se révise à chaque nouvelle édition.
- **La loi s'ajoute aux normes** : au Cameroun, les audits de sécurité prévus par la loi n° 2010/012 coexistent avec les certifications volontaires.

✍ Exercice 4.1. Quelle nature ? ★☆☆

Pour chacun des documents suivants, indiquez s'il s'agit d'un cadre de référence, d'une norme certifiable ou d'un recueil de bonnes pratiques, et si une organisation peut être certifiée sur sa base.

(a) ISO/IEC 27001.

(b) ITIL.

(c) COSO ERM.

(d) ISO/IEC 20000-1.

(e) ISO 31000.

(f) COBIT 2019.

✍ Exercice 4.2. Lire un certificat ★★☆

Un prestataire candidat à l'infogérance de KRIBILOG SA joint à son offre un certificat ISO/IEC 27001 dont le périmètre est : « Hébergement des serveurs du centre de données de Casablanca ». Le service proposé à KRIBILOG serait exploité depuis Douala.

(a) Que prouve ce certificat, et que ne prouve-t-il pas pour le service proposé ?

(b) Quelles pièces complémentaires M. MBARGA doit-il exiger ?

(c) Quelle clause proposez-vous d'insérer dans le contrat (Chapitre 15) ?

✍ Exercice 4.3. La carte de NOUN PAY ★★★

NOUN PAY, jeune entreprise de paiement mobile de Bafoussam, compte 45 salariés, héberge tout son SI chez un fournisseur d'informatique en nuage étranger et utilise un modèle d'intelligence artificielle pour noter les demandes de microcrédit. Ses in-

vestisseurs exigent « une gouvernance des SI au niveau des standards internationaux ».

(a) Identifiez ses besoins et ses obligations prioritaires.

(b) Construisez sa carte d'articulation sur le modèle de la Figure 4.1, en justifiant chaque référentiel retenu.

(c) Indiquez au moins deux référentiels que vous écartez, et pourquoi.

(d) Proposez un calendrier sur trois ans, compatible avec la taille de l'entreprise.

Note

Transition. La Partie I a posé les fondements de la gouvernance des SI : ses origines, ses défaillances, ses modèles et ses référentiels. La Partie II entre dans le référentiel central de ce cours. Le Chapitre 5 présente les principes et l'architecture de COBIT 2019.

partie II

COBIT 2019 : le Référentiel de la Gouvernance

© MaletYon

5

COBIT 2019 : PRINCIPES ET ARCHITECTURE

> « COBIT ne prend aucune décision à votre place. Il dit quelles décisions doivent être prises, comment, et par qui. »
>
> D'après ISACA, *COBIT 2019 Framework: Introduction and Methodology* (2018, notre traduction)

Niveau : *Fondamental* • Maîtrise du Chapitre 4 (place de COBIT parmi les référentiels) et du Chapitre 3 (trois finalités).

✦ Objectifs du chapitre

- ➢ Retracer l'évolution de COBIT, de la version 1 à COBIT 2019.
- ➢ Énoncer les six principes du système de gouvernance et les trois principes du cadre.
- ➢ Décrire les sept composantes d'un système de gouvernance.
- ➢ Présenter les cinq domaines (EDM, APO, BAI, DSS, MEA) et les domaines d'intérêt.

Positionnement : de la carte au territoire

Le Chapitre 4 a placé COBIT au centre de la carte des référentiels : il fixe les objectifs, et les autres référentiels fournissent les pratiques. La Partie II, qui s'ouvre ici, entre dans ce référentiel central. Elle suit la logique même de COBIT : comprendre son architecture (ce chapitre), connaître ses objectifs (Chapitre 6), concevoir un système de gouvernance adapté (Chapitre 7), puis le mesurer et le mettre en œuvre (Chapitre 8).

La question directrice de ce chapitre est simple : *de quoi un système de gouvernance des SI est-il fait ?* La réponse de COBIT 2019 tient en trois mots : des **principes**, des **composantes** et des **objectifs**. Le chapitre les présente dans cet ordre, après un retour sur l'histoire du référentiel.

© MaletYon

5.1 Trente Ans d'Évolution

5.1.1 Du contrôle à la gouvernance

COBIT est né en 1996 sous le nom de *Control Objectives for Information and Related Technology*. Il était alors un référentiel d'objectifs de contrôle à l'usage des auditeurs des systèmes d'information. Chaque nouvelle version a élargi son public et son champ, de l'audit vers le management, puis vers la gouvernance de l'ensemble de l'information et des technologies.

Version	Public principal	Apport
COBIT 1 (1996)	Auditeurs	Objectifs de contrôle des technologies de l'information
1998, 2000	Auditeurs, puis managers	Éditions successives : guides de management, modèles de maturité
COBIT 4.0 et 4.1 (2005, 2007)	Direction informatique, direction générale	Gouvernance des SI ; 34 processus en quatre domaines (PO, AI, DS, ME) [27]
COBIT 5 (2012)	Ensemble de l'entreprise	Gouvernance de l'entreprise numérique ; cinq principes, sept « facilitateurs », 37 processus ; intégration de Val IT et Risk IT
COBIT 2019 (2018)	Conseil, direction, auditeurs, praticiens	Système de gouvernance sur mesure ; facteurs de conception, domaines d'intérêt, 40 objectifs, mesure de la capacité alignée sur CMMI

Tableau 5.1. Évolution de COBIT

5.1.2 Ce que COBIT 2019 apporte

Par rapport à COBIT 5, dont il conserve l'essentiel, COBIT 2019 met en avant quatre améliorations [23] :

- **la flexibilité** : les facteurs de conception permettent d'adapter le système de gouvernance au contexte de l'organisation, et l'architecture ouverte permet d'ajouter des domaines d'intérêt sans toucher au modèle central ;
- **l'actualité** : le modèle se rattache plus facilement aux normes et réglementations récentes ;
- **l'application prescriptive** : une fois adapté, le modèle sert de prescription pour le système de gouvernance de l'organisation ;
- **la mesure de la performance** : les notions de capacité et de maturité sont intégrées au modèle et alignées sur CMMI.

5.1.3 Ce que COBIT n'est pas

COBIT 2019 prend soin de dissiper quatre malentendus. COBIT *n'est pas* une description complète de l'environnement informatique d'une organisation. Il *n'est pas* un cadre d'organisation des processus métier. Il *n'est pas* un référentiel technique de gestion des technologies. Surtout, il *ne prend ni ne prescrit aucune décision* : il ne dit pas quelle est la meilleure stratégie, la meilleure architecture ou le bon niveau de dépense, mais quelles décisions doivent être prises, comment, et par qui. C'est le sens de l'épigraphe.

★ Attention

Violation typique. Un cabinet promet à la BANQUE SANAGA de « mettre la banque en conformité COBIT » en six mois, avec à la clé une « certification ». La promesse repose sur deux erreurs : COBIT n'est pas une norme d'exigences, et il n'existe pas de certification COBIT d'une organisation (Chapitre 4).

Règle : on ne se « met pas en conformité » avec COBIT ; on s'en sert pour concevoir et évaluer un système de gouvernance, dont on mesure la capacité des processus (Chapitre 8).

5.2 Les Principes de COBIT 2019

COBIT 2019 repose sur deux séries de principes : six principes qui décrivent ce qu'un *système de gouvernance* doit être, et trois principes qui décrivent ce qu'un *cadre de gouvernance*, c'est-à-dire un référentiel comme COBIT lui-même, doit être [23].

5.2.1 Six principes pour un système de gouvernance

Principe	Contenu
1. Créer de la valeur pour les parties prenantes	Toute organisation a besoin d'un système de gouvernance pour satisfaire ses parties prenantes et tirer de la valeur des technologies. La valeur est un équilibre entre bénéfices, risques et ressources.
2. Approche globale	Le système de gouvernance est fait de composantes de types différents, qui fonctionnent ensemble.
3. Système dynamique	Chaque fois qu'un facteur de conception change (stratégie, technologie…), l'effet de ce changement sur le système de gouvernance doit être examiné.
4. Gouvernance distincte du management	Le système distingue clairement les activités et les structures de gouvernance de celles de management.
5. Adapté aux besoins de l'organisation	Le système est ajusté au moyen de facteurs de conception, qui servent à adapter et à prioriser ses composantes.
6. Couverture de bout en bout	Le système couvre toute l'organisation, pas seulement la fonction informatique : tout traitement de l'information et toute technologie, où qu'ils se trouvent.

Tableau 5.2. Les six principes d'un système de gouvernance (d'après COBIT 2019, notre traduction)

Scénario Opérationnel · Opération SANAGA. Les principes violés

Constatation. L'application « SANAGA Mobile » a été conçue par la direction marketing avec une agence extérieure, sans passer par la DSI. Son lancement a fixé la date de bascule du système central.

Analyse (confiance élevée). Trois principes au moins ont été méconnus. Le principe 6 : une application critique s'est développée en dehors du périmètre de la gouvernance, parce qu'elle ne relevait pas de la DSI. Le principe 4 : le directeur général a pris seul une décision de gouvernance (l'arbitrage entre enjeu commercial et risque). Le principe 3 : le changement de stratégie (le lancement mobile) n'a donné lieu à aucun réexamen du système de gouvernance du projet HORIZON.

5.2.2 Trois principes pour un cadre de gouvernance

Les trois autres principes s'appliquent au référentiel lui-même. Un cadre de gouvernance doit être **fondé sur un modèle conceptuel**, qui identifie les composantes et leurs relations, pour garantir la cohérence et permettre l'automatisation. Il doit être **ouvert et flexible**, pour accueillir de nouveaux contenus sans perdre sa cohérence. Il doit être **aligné sur les grandes normes**, référentiels et réglementations. Ces principes expliquent pourquoi COBIT renvoie, pour chaque objectif, aux normes qui le détaillent (Chapitre 4).

5.3 Les Composantes du Système de Gouvernance

5.3.1 Sept types de composantes

Pour atteindre ses objectifs, une organisation construit son système de gouvernance à partir de composantes. COBIT 5 les appelait « facilitateurs » (*enablers*) ; COBIT 2019 parle de **composantes**.

Définition

Composante (*component*) : élément qui contribue, seul et avec les autres, au bon fonctionnement du système de gouvernance de l'information et des technologies. Les composantes interagissent et forment un système global. Elles sont de sept types.

Composante	Rôle
Processus	Ensemble organisé de pratiques et d'activités qui atteint un objectif et produit des résultats.
Structures organisationnelles	Instances de décision de l'organisation (conseil, comités, fonctions).
Principes, politiques et procédures	Traduisent le comportement attendu en consignes pratiques pour le management quotidien.
Information	Toute information produite et utilisée ; COBIT s'intéresse à celle qu'exige le fonctionnement du système de gouvernance.
Culture, éthique et comportement	Facteurs souvent sous-estimés de la réussite de la gouvernance.
Personnes, aptitudes et compétences	Nécessaires aux bonnes décisions et à la bonne exécution.
Services, infrastructure et applications	Moyens techniques qui supportent le système de gouvernance lui-même.

Tableau 5.3. Les sept composantes (d'après COBIT 2019, notre traduction)

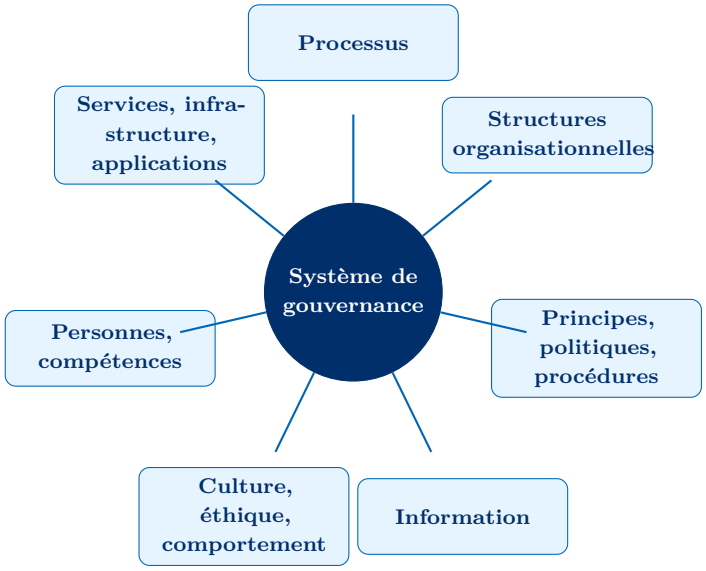


Figure 5.1. Les sept composantes du système de gouvernance

5.3.2 La leçon des composantes

La leçon principale tient au principe 2 (approche globale) : **un processus seul ne suffit jamais**. La BANQUE SANAGA avait, sur le papier, une procédure de mise en production. Il lui manquait les autres composantes : la structure (un comité des changements), l'information (un procès-verbal de recette fiable), la culture (le droit de dire non à une date) et les compétences (des testeurs formés au nouveau système).

Exigence de contrôle

Une composante qui existe vraiment. Pour chaque composante d'un objectif prioritaire, l'auditeur cherche une preuve de son existence *et* de son fonctionnement :

- *processus* : une procédure approuvée, et des enregistrements de son exécution ;
- *structure* : une charte, et des procès-verbaux ;
- *politique* : un document approuvé, daté, diffusé ;
- *information* : le document attendu, à jour et utilisé ;
- *culture* : des signaux observables (alertes remontées, décisions de report acceptées) ;
- *compétences* : des fiches de poste et un plan de formation suivi ;
- *services et applications* : l'outil qui supporte le processus, et ses journaux.

5.3.3 Composantes génériques et variantes

Les composantes décrites dans le modèle central de COBIT sont *génériques* : elles valent en principe pour toute organisation, mais doivent être adaptées avant d'être mises en œuvre. Une *variante* est une composante générique adaptée à un usage particulier : la sécurité de l'information, DevOps, une réglementation donnée.

5.4 Objectifs et Domaines

5.4.1 Objectifs de gouvernance et de management

Définition

Objectif de gouvernance ou de management (*governance or management objective*) : ce qu'il faut atteindre pour que l'information et les technologies contribuent aux objectifs de l'organisation. Chaque objectif se rapporte à un processus de même nom (ou d'un nom proche) et à un ensemble de composantes des autres types qui aident à l'atteindre.

Un objectif de gouvernance se rapporte à un processus de gouvernance, dont le conseil et la direction générale répondent. Un objectif de management se rapporte à un processus de management, qui relève de l'encadrement supérieur et intermédiaire.

5.4.2 Cinq domaines, quarante objectifs

Les 40 objectifs du modèle central sont regroupés en cinq domaines, dont les noms sont des verbes [23].

Code	Domaine	Nb	Champ
Gouvernance			
EDM	Évaluer, diriger et surveiller	5	L'organe de gouvernance évalue les options stratégiques, oriente la direction sur les options retenues et surveille la réalisation de la stratégie
Management			
APO	Aligner, planifier et organiser	14	Organisation d'ensemble, stratégie et activités de soutien
BAI	Bâtir, acquérir et implémenter	11	Définition, acquisition et mise en œuvre des solutions, et leur intégration dans les processus métier
DSS	Délivrer, servir et soutenir	6	Exploitation et soutien des services, y compris la sécurité
MEA	Surveiller, évaluer et apprécier	4	Suivi de la performance et de la conformité aux objectifs internes, au contrôle interne et aux exigences externes
Total		**40**	

Tableau 5.4. Les cinq domaines de COBIT 2019 (intitulés traduits par nos soins)

On retrouve dans ce découpage la distinction des Chapitres 0 et 1 : le domaine EDM correspond aux trois verbes de la gouvernance, et les quatre domaines de management au cycle planifier, bâtir, exploiter, surveiller. Le Chapitre 6 parcourt les 40 objectifs un par un.

Fiche processus · EDM05 · Assurer l'engagement des parties prenantes

Finalité : s'assurer que les parties prenantes sont identifiées et associées au système de gouvernance, et que la mesure et le compte rendu de la performance et de la conformité des SI leur sont transparents.
Pratiques : évaluer les exigences de compte rendu des parties prenantes ; diriger la communication et le compte rendu ; surveiller la communication.
Sorties : principes de compte rendu, plan de communication, rapports aux parties prenantes.
RACI (extrait) : *A* au conseil d'administration, *R* au directeur général, *C* au DSI et au responsable GRC.
Indicateurs : satisfaction des parties prenantes à l'égard des comptes rendus ; délai de transmission des rapports exigés par le régulateur.

Intitulé et pratiques résumés et traduits par nos soins à partir de COBIT 2019 [22].

Application Responsable GRC

Les parties prenantes de la BANQUE SANAGA, objectif EDM05

1. Dresser la liste des parties prenantes internes (conseil, comités, direction, métiers, audit interne) et externes (COBAC, commissaire aux comptes, ANTIC, clients, intégrateurs).
2. Pour chacune, noter ce qu'elle attend comme compte rendu, à quelle fréquence, et sous quelle forme.
3. Construire le calendrier des comptes rendus de l'année.
4. Faire approuver ce plan par le comité stratégique des SI.

Après la panne, c'est le rapport à la COBAC qui a révélé l'absence de ce plan : personne ne savait qui devait le rédiger, ni avec quelles données.

5.5 Domaines d'Intérêt et Facteurs de Conception

5.5.1 Les domaines d'intérêt

Définition

Domaine d'intérêt (*focus area*) : thème, domaine ou question de gouvernance traité par un ensemble d'objectifs de gouvernance et de management et de leurs composantes. Exemples donnés par COBIT 2019 : petites et moyennes entreprises, cybersécurité, transformation numérique, informatique en nuage, protection de la vie privée, DevOps.

Le nombre de domaines d'intérêt n'est pas limité : c'est ce qui rend le modèle ouvert. Un domaine d'intérêt peut combiner des composantes génériques et des variantes. Pour NOUN PAY, jeune entreprise hébergée dans le nuage, les domaines d'intérêt « petites et moyennes entreprises » et « informatique en nuage » sont naturellement pertinents.

5.5.2 Les facteurs de conception

Définition

Facteur de conception (*design factor*) : facteur susceptible d'influencer la conception du système de gouvernance d'une organisation. COBIT 2019 en retient onze : la stratégie, les objectifs de l'organisation, le profil de risque, les problèmes liés aux SI, le paysage des menaces, les exigences de conformité, le rôle des SI, le mode d'approvisionnement des SI, les méthodes de mise en œuvre, la stratégie d'adoption des technologies et la taille de l'organisation.

Les facteurs de conception sont l'outil qui rend COBIT proportionné. Une banque soumise à la COBAC et une jeune entreprise de 45 salariés n'auront ni les mêmes objectifs prioritaires, ni les mêmes niveaux de capacité cibles. Le Chapitre 7 montre

comment les appliquer, et le laboratoire GCI-LAB-02 en fait le calcul.

Un modèle conçu ailleurs, utilisable ici ?

Les facteurs de conception répondent en partie à l'objection du Chapitre 4 : les référentiels internationaux seraient taillés pour d'autres contextes. En faisant de la taille, du mode d'approvisionnement ou des exigences de conformité des paramètres explicites, COBIT 2019 permet d'intégrer les réalités camerounaises (dépendance aux intégrateurs, régulation de la COBAC et de l'ANTIC, ressources limitées) dans la conception même du système. Encore faut-il renseigner ces facteurs avec lucidité : un DSI qui se décrit comme une organisation « innovante » pour justifier un budget fausse le résultat.

Application Auditeur SI

Vérifier qu'une organisation utilise réellement COBIT

1. Demander le document qui identifie les objectifs prioritaires retenus, et la manière dont ils ont été choisis (facteurs de conception).
2. Pour deux ou trois objectifs, vérifier l'existence des sept composantes (exigence de contrôle ci-dessus).
3. Demander la dernière évaluation de capacité et ses suites.

Une organisation qui « applique COBIT » sans pouvoir produire ces trois pièces en a adopté le vocabulaire, pas la méthode.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Du contrôle à la gouvernance** : né en 1996 pour les auditeurs, COBIT est devenu avec la version 2019 un cadre de gouvernance et de management sur mesure.
- **COBIT ne décide pas** : il dit quelles décisions doivent être prises, comment et par qui. Il n'est ni une norme certifiable, ni un référentiel technique.
- **Six principes pour le système** : valeur pour les parties prenantes, approche globale, système dynamique, gouvernance distincte du management, adaptation, couverture de bout en bout.
- **Trois principes pour le cadre** : modèle conceptuel, ouverture, alignement sur les normes.
- **Sept composantes** : processus, structures, politiques, information, culture,

compétences, services et applications. Un processus seul ne suffit jamais.

- **Cinq domaines, quarante objectifs** : EDM (5) pour la gouvernance ; APO (14), BAI (11), DSS (6) et MEA (4) pour le management.
- **Domaines d'intérêt et facteurs de conception** rendent le modèle ouvert et proportionné.

✍ Exercice 5.1. Classer par domaine ★☆☆

Rattachez chacune des activités suivantes au domaine COBIT qui convient (EDM, APO, BAI, DSS, MEA), et justifiez en une phrase.

(a) Le conseil fixe le niveau de risque informatique acceptable.

(b) La DSI élabore le plan stratégique des SI à trois ans.

(c) Une équipe recette le nouveau logiciel de crédit.

(d) Le centre de services traite une panne de messagerie.

(e) L'audit interne évalue les contrôles d'accès.

(f) La direction des achats négocie le contrat d'un infogérant.

✍ Exercice 5.2. Les composantes chez KRIBILOG ★★☆

M. MBARGA, responsable des services informatiques de KRIBILOG SA, veut améliorer la gestion des incidents du logiciel de suivi des conteneurs.

(a) Pour chacune des sept composantes, décrivez ce qui devrait exister chez KRIBILOG.

(b) Pour chacune, indiquez la pièce qui prouverait son existence et son fonctionnement.

(c) Lesquelles relèvent de KRIBILOG, et lesquelles de l'infogérant NETPORT SERVICES ? Qu'en déduisez-vous pour le contrat ?

✍ Exercice 5.3. De COBIT 4.1 à COBIT 2019 à l'ANPP ★★★

Les procédures informatiques de l'ANPP (opération MEFOU) ont été rédigées en 2010 à partir de COBIT 4.1 et de ses quatre domaines (PO, AI, DS, ME).

(a) Établissez la correspondance entre les quatre domaines de COBIT 4.1 et les cinq domaines de COBIT 2019. Lequel n'a pas d'équivalent direct, et pourquoi est-ce important pour l'ANPP ?

(b) À l'aide des documents du dossier `Normes`, identifiez deux objectifs de COBIT 2019 sans équivalent clair dans COBIT 4.1, et expliquez leur intérêt pour

l'agence.

(c) Rédigez une note de deux pages au directeur général proposant une démarche de mise à jour, en appliquant les principes 3 et 5.

● Note

Transition. Ce chapitre a présenté l'architecture de COBIT 2019 : principes, composantes, domaines. Le Chapitre 6 entre dans le détail des 40 objectifs, apprend à lire leur structure et montre comment ils s'enchaînent depuis les objectifs de l'organisation par la cascade des objectifs.

6

LES 40 OBJECTIFS DE GOUVERNANCE ET DE MANAGEMENT

« Quarante objectifs ne font pas quarante chantiers.
Ils font une liste dans laquelle on choisit. »

Principe de mise en œuvre de COBIT

Niveau : *Fondamental* • Maîtrise du Chapitre 5 (principes, composantes et domaines de COBIT 2019).

✦ Objectifs du chapitre

- ➢ Parcourir les objectifs de chaque domaine et en lire la structure.
- ➢ Rédiger la fiche processus d'un objectif (finalité, pratiques, entrées et sorties, RACI, indicateurs).
- ➢ Relier objectifs d'entreprise, objectifs d'alignement et objectifs COBIT (cascade des objectifs).
- ➢ Identifier les objectifs prioritaires d'une banque et d'une administration.

Question directrice : par où commencer ?

Mme EKAMBI, directrice de l'audit interne de la BANQUE SANAGA, a remis au conseil un tableau des 40 objectifs de COBIT 2019. Devant chacun, une case « conforme » ou « non conforme ». Trente-deux cases sont rouges. Le président s'inquiète : « Faut-il lancer trente-deux chantiers ? »

La réponse est non, et ce chapitre explique pourquoi. Il apprend d'abord à **lire** un objectif (section 6.1), puis parcourt les **quarante objectifs**, domaine par domaine (sections 6.2 à 6.5). Il montre enfin comment la **cascade des objectifs** relie les besoins de l'organisation aux objectifs COBIT, et permet de choisir ceux qui comptent (sections 6.6 et 6.7).

© *MaletYon*

6.1 Lire un Objectif COBIT

6.1.1 L'anatomie d'une fiche

Le guide *COBIT 2019 Framework: Governance and Management Objectives* [22] présente chaque objectif sous une forme constante. Savoir la lire est la première compétence du praticien.

Rubrique	Contenu
En-tête	Domaine, code et intitulé de l'objectif, domaine d'intérêt (le modèle central, ou un domaine particulier)
Description et finalité	Ce que l'objectif couvre, et pourquoi il existe
Objectifs liés	Objectifs d'entreprise et objectifs d'alignement auxquels l'objectif contribue *à titre principal*, avec des exemples d'indicateurs
A. Processus	Les pratiques, leurs activités (chacune rattachée à un niveau de capacité) et des indicateurs
B. Structures organisationnelles	Une matrice RACI par pratique
C. Flux d'information	Entrées et sorties de chaque pratique, avec leur provenance et leur destination
D. Personnes et compétences	Compétences requises, avec renvoi aux référentiels de compétences
E. Politiques et procédures	Politiques pertinentes et leur contenu
F. Culture et comportement	Éléments culturels clés
G. Services et applications	Outils et services qui supportent l'objectif

Tableau 6.1. Structure d'une fiche d'objectif COBIT 2019 (d'après ISACA, notre traduction)

On retrouve dans les rubriques A à G les sept composantes du Chapitre 5. Une fiche COBIT n'est donc pas la description d'un processus : c'est la description d'un *morceau de système de gouvernance*, avec toutes ses composantes.

6.1.2 Pratiques et activités

Définition

Pratique (*governance or management practice*) : action clé qu'il faut accomplir pour atteindre un objectif. Elle porte un code (par exemple DSS02.04) et un intitulé à l'infinitif.

Activité (*activity*) : action concrète qui met en œuvre une pratique. Chaque activité est rattachée à un niveau de capacité (de 2 à 5) : c'est ce qui permet de mesurer la capacité d'un processus (Chapitre 8).

6.1.3 Rédiger une fiche processus

Le cours présente les objectifs sous une forme condensée, la *fiche processus*, qui retient l'essentiel des rubriques officielles. Voici la fiche complète d'un objectif central de l'exploitation.

Fiche processus · DSS02 · Gérer les demandes de service et les incidents

Description : répondre de manière rapide et efficace aux demandes des utilisateurs et résoudre tous les types d'incidents ; rétablir le service normal, enregistrer et satisfaire les demandes, enregistrer, analyser, diagnostiquer, faire remonter et résoudre les incidents.
Finalité : accroître la productivité et réduire les perturbations par une résolution rapide des demandes et des incidents.
Objectifs liés : EG01 (portefeuille de produits et services compétitifs), EG08 (optimisation des processus internes) ; AG05 (services conformes aux exigences des métiers).
Pratiques : DSS02.01 définir les schémas de classification des incidents et des demandes ; DSS02.02 enregistrer, classer et prioriser ; DSS02.03 vérifier, approuver et satisfaire les demandes ; DSS02.04 analyser, diagnostiquer et affecter les incidents ; DSS02.05 résoudre les incidents et rétablir le service ; DSS02.06 clore les demandes et les incidents ; DSS02.07 suivre l'état et produire des rapports.
Entrées et sorties (exemples) : entrées : accords de niveau de service (APO09), base des erreurs connues (DSS03) ; sorties : tickets classés et priorisés, rapports d'incidents, demandes de changement (vers BAI06).
RACI (extrait, adapté à la BANQUE SANAGA) : DSS02.05 : *A* au responsable de l'exploitation, *R* au centre de services et aux équipes de support, *C* aux métiers concernés, *I* au DSI pour les incidents majeurs.
Indicateurs : délai moyen de résolution, taux de résolution au premier contact, nombre d'incidents réouverts, satisfaction des utilisateurs.

Description, finalité, objectifs liés et pratiques résumés et traduits par nos soins à partir de COBIT 2019 [22].

Exigence de contrôle

Une fiche processus utilisable. Pour qu'une fiche processus serve réellement, et puisse être auditée, elle doit :

- citer l'objectif COBIT et l'édition de référence ;
- nommer le propriétaire du processus, au niveau de l'organisation (et non du référentiel) ;
- remplacer les rôles génériques de COBIT par les fonctions réelles de l'organisa-

tion dans la matrice RACI ;

- ➢ préciser pour chaque indicateur sa cible, sa source et sa fréquence ;
- ➢ être approuvée et datée, et revue au moins une fois par an.

6.2 Le Domaine de Gouvernance : EDM

Les cinq objectifs du domaine EDM relèvent de l'organe de gouvernance. Ils reprennent, objectif par objectif, la définition de travail du Chapitre 1 : un cadre de gouvernance, trois finalités et l'engagement des parties prenantes.

Code	Intitulé	Question pour le conseil
EDM01	Assurer la définition et le maintien du cadre de gouvernance	Qui décide de quoi, et le dispositif fonctionne-t-il ?
EDM02	Assurer la réalisation des bénéfices	Nos investissements produisent-ils la valeur annoncée ?
EDM03	Assurer l'optimisation des risques	Les risques liés aux SI restent-ils dans notre appétence ?
EDM04	Assurer l'optimisation des ressources	Avons-nous les compétences et les moyens de notre stratégie ?
EDM05	Assurer l'engagement des parties prenantes	Rendons-nous compte à ceux qui doivent l'être ?

Tableau 6.2. Les objectifs du domaine EDM

Les fiches EDM01, EDM02 et EDM05 ont été présentées aux Chapitres 1, 3 et 5. EDM03 a pour finalité de s'assurer que les risques d'entreprise liés aux SI ne dépassent pas l'appétence et la tolérance au risque de l'organisation ; il sera repris avec APO12.

6.3 Aligner, Planifier et Organiser : APO

Le domaine APO est le plus vaste. Il couvre l'organisation d'ensemble des SI, leur stratégie et les activités de soutien.

Code	Intitulé	Ce qu'il couvre
APO01	Gérer le cadre de management des SI	Politiques, rôles, choix des référentiels (Chapitre 4)
APO02	Gérer la stratégie	Plan stratégique des SI, feuille de route
APO03	Gérer l'architecture d'entreprise	Cohérence des processus, données, applications et technologies
APO04	Gérer l'innovation	Veille, expérimentation des technologies émergentes
APO05	Gérer le portefeuille	Arbitrage des investissements (Chapitre 3)
APO06	Gérer le budget et les coûts	Budget des SI, refacturation, suivi des coûts
APO07	Gérer les ressources humaines	Effectifs, compétences, formation, dépendance à des personnes clés
APO08	Gérer les relations	Relation entre la DSI et les métiers
APO09	Gérer les accords de service	Catalogue de services, accords de niveau de service
APO10	Gérer les fournisseurs	Sélection, contrats, supervision des prestataires
APO11	Gérer la qualité	Système de management de la qualité des SI
APO12	Gérer le risque	Identification, évaluation et traitement des risques liés aux SI
APO13	Gérer la sécurité	Système de management de la sécurité de l'information
APO14	Gérer les données	Gouvernance et qualité des données (Chapitre 19)

Tableau 6.3. Les objectifs du domaine APO (intitulés traduits par nos soins)

★ Attention

Violation typique. L'ANPP (opération MEFOU) confie l'objectif APO10 à la direction des achats, qui le réduit à la passation des marchés. Une fois le contrat signé, plus personne ne supervise les prestataires.

Règle : gérer un fournisseur ne s'arrête pas à la signature. APO10 couvre toute la relation, jusqu'à la supervision de la performance et des risques du prestataire, que l'ancien DSI de TSB a été sanctionné pour avoir négligée (Chapitre 2).

6.4 Bâtir, Acquérir et Implémenter : BAI

Le domaine BAI couvre tout ce qui fait *changer* le système d'information : projets, acquisitions, mises en production. C'est le domaine où se sont produites toutes les défaillances du Chapitre 2.

Code	Intitulé	Ce qu'il couvre
BAI01	Gérer les programmes	Pilotage des programmes et de leurs bénéfices
BAI02	Gérer la définition des exigences	Recueil et validation des besoins des métiers
BAI03	Gérer l'identification et la construction des solutions	Conception, développement, acquisition
BAI04	Gérer la disponibilité et la capacité	Dimensionnement et performance (Chapitre 15)
BAI05	Gérer le changement organisationnel	Accompagnement des utilisateurs et des métiers
BAI06	Gérer les changements informatiques	Évaluation, autorisation et suivi des changements (Chapitre 14)
BAI07	Gérer l'acceptation et la transition des changements	Recette, mise en production, retour arrière
BAI08	Gérer la connaissance	Capitalisation et partage des connaissances
BAI09	Gérer les actifs	Inventaire et cycle de vie des actifs
BAI10	Gérer la configuration	Base de configuration et ses relations
BAI11	Gérer les projets	Conduite des projets

Tableau 6.4. Les objectifs du domaine BAI (intitulés traduits par nos soins)

6.5 Délivrer, Servir, Soutenir et Surveiller : DSS et MEA

Le domaine DSS couvre l'exploitation quotidienne des services, sécurité comprise. Le domaine MEA ferme la boucle : il vérifie la performance et la conformité, et fournit l'assurance.

Code	Intitulé	Ce qu'il couvre
DSS01	Gérer l'exploitation	Exploitation courante, ordonnancement, environnement physique
DSS02	Gérer les demandes de service et les incidents	Centre de services, incidents (Chapitre 13)
DSS03	Gérer les problèmes	Causes profondes, erreurs connues
DSS04	Gérer la continuité	Plans de continuité, tests, reprise
DSS05	Gérer les services de sécurité	Protection contre les logiciels malveillants, accès, surveillance
DSS06	Gérer les contrôles des processus métier	Contrôles applicatifs intégrés aux processus
MEA01	Gérer la surveillance de la performance et de la conformité	Indicateurs, tableaux de bord
MEA02	Gérer le système de contrôle interne	Autoévaluation, suivi des déficiences
MEA03	Gérer la conformité aux exigences externes	Lois, règlements, contrats
MEA04	Gérer l'assurance	Missions d'assurance et d'audit (Chapitre 11)

Tableau 6.5. Les objectifs des domaines DSS et MEA (intitulés traduits par nos soins)

Application Responsable des services IT

Les six objectifs du quotidien

1. DSS01, DSS02 et DSS03 forment le noyau de l'exploitation : faire tourner, réparer, éviter que cela recommence.
2. BAI06 et BAI07 encadrent tout ce qui modifie la production.
3. APO09 fixe les engagements de service sur lesquels l'exploitation est jugée.

Ces six objectifs correspondent aux pratiques d'ITIL 4 étudiées dans la Partie IV : COBIT dit ce qui doit être maîtrisé, ITIL comment le faire.

6.6 La Cascade des Objectifs

6.6.1 Des besoins aux objectifs COBIT

Comment choisir, parmi les quarante objectifs, ceux qui comptent pour une organisation donnée ? COBIT 2019 propose un premier outil : la **cascade des objectifs** (*goals cascade*) [23].

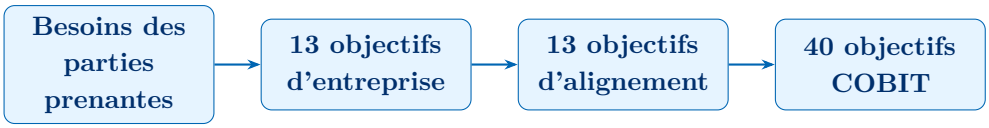


Figure 6.1. La cascade des objectifs de COBIT 2019

Définition

Objectif d'entreprise (*enterprise goal*, EG) : but de l'organisation dans son ensemble, classé selon les quatre dimensions du tableau de bord prospectif (finances, clients, processus internes, apprentissage et croissance).

Objectif d'alignement (*alignment goal*, AG) : but que l'informatique et les technologies doivent atteindre pour soutenir les objectifs d'entreprise. COBIT 5 les appelait « objectifs liés aux SI » ; le nouveau terme souligne qu'ils ne sont pas des objectifs internes de la DSI.

6.6.2 Les vingt-six objectifs intermédiaires

Code	Objectif d'entreprise	Code	Objectif d'alignement
EG01	Portefeuille de produits et services compétitifs	AG01	Conformité des SI et soutien à la conformité aux lois
EG02	Risque métier maîtrisé	AG02	Risque lié aux SI maîtrisé
EG03	Conformité aux lois et règlements	AG03	Bénéfices réalisés des investissements et services
EG04	Qualité de l'information financière	AG04	Qualité de l'information financière liée aux technologies
EG05	Culture de service orientée client	AG05	Services conformes aux exigences des métiers
EG06	Continuité et disponibilité des services métier	AG06	Agilité pour transformer les exigences en solutions
EG07	Qualité de l'information de gestion	AG07	Sécurité de l'information, des infrastructures et des applications, et vie privée
EG08	Optimisation des fonctionnalités des processus internes	AG08	Soutien aux processus métier par l'intégration des applications
EG09	Optimisation des coûts des processus	AG09	Programmes livrés dans les délais, les budgets et la qualité
EG10	Compétences, motivation et productivité du personnel	AG10	Qualité de l'information de gestion des SI
EG11	Conformité aux politiques internes	AG11	Conformité des SI aux politiques internes
EG12	Programmes de transformation numérique maîtrisés	AG12	Personnel compétent, compréhension mutuelle des technologies et des métiers
EG13	Innovation des produits et des processus	AG13	Connaissances et initiatives pour l'innovation

Tableau 6.6. Objectifs d'entreprise et objectifs d'alignement de COBIT 2019 (intitulés abrégés et traduits par nos soins)

6.6.3 Lire la cascade dans les fiches

Chaque fiche d'objectif indique les objectifs d'entreprise et d'alignement auxquels il contribue *à titre principal*. En les relevant, on peut parcourir la cascade dans les deux sens. Le relevé suivant est tiré des fiches officielles [22].

Objectif	Objectifs d'entreprise	Objectifs d'alignement
EDM03	EG02, EG06	AG02, AG07
APO12	EG02, EG06	AG02, AG07
DSS04	EG01, EG02, EG06, EG08	AG05, AG07
DSS02	EG01, EG08	AG05
BAI06, BAI07	EG01	AG06

Tableau 6.7. Liens principaux de quelques objectifs (relevés dans COBIT 2019)

Pourquoi la gestion des changements n'est-elle pas reliée au risque ?

Le Tableau 6.7 réserve une surprise. On s'attendrait à ce que BAI06 et BAI07, au cœur de toutes les défaillances du Chapitre 2, soient rattachés en priorité au risque (EG02, AG02). Or leurs liens principaux sont l'agilité (AG06) et la compétitivité de l'offre (EG01) : COBIT voit d'abord dans la gestion des changements le moyen de changer *vite et bien*.

La leçon est double. D'abord, la cascade ne relève que les liens *principaux* ; elle ne suffit pas, à elle seule, à prioriser. Ensuite, une organisation qui a connu une défaillance due à un changement doit remonter BAI06 et BAI07 par un autre chemin : le profil de risque et les problèmes liés aux SI, qui sont des facteurs de conception (Chapitre 7). C'est ce que fera la BANQUE SANAGA.

6.7 Objectifs Prioritaires : une Banque, une Administration

6.7.1 La BANQUE SANAGA

Scénario Opérationnel · Opération SANAGA. Choisir dans la liste

La responsable GRC part des objectifs d'entreprise que le conseil a déclarés prioritaires après la panne : EG06 (continuité et disponibilité), EG02 (risque métier maîtrisé) et EG03 (conformité, au regard de la COBAC).

Par la cascade. EG06 et EG02 conduisent, par les fiches officielles, à EDM03, APO12 et DSS04 (Tableau 6.7). EG03 conduit à l'objectif d'alignement AG01, et de là aux objectifs de conformité, dont MEA03.

Par l'histoire de la banque. La panne impose d'ajouter BAI06 et BAI07 (changements), APO10 (fournisseurs), MEA02 (suivi des recommandations) et EDM01 (cadre de gouvernance).

Résultat. Dix objectifs prioritaires, et non trente-deux : EDM01, EDM03, APO10, APO12, BAI06, BAI07, DSS02, DSS04, MEA02, MEA03. Les autres objectifs ne sont pas abandonnés : ils seront visés à un niveau de capacité plus modeste (Chapitre 8).

6.7.2 L'ANPP

Pour l'ANPP (opération MEFOU), le point de départ est différent. Les objectifs d'entreprise prioritaires sont EG12 (programmes de transformation numérique maîtrisés), EG09 (optimisation des coûts) et EG03 (conformité, au regard des règles de la gestion publique et de la Chambre des comptes). L'histoire de l'agence (Chapitres 1 et 3) désigne d'elle-même les objectifs de gouvernance du portefeuille (EDM02, APO05), de conduite des programmes et des projets (BAI01, BAI11) et de gestion des fournisseurs (APO10). Le choix définitif se fera avec les facteurs de conception, au Chapitre 7, puis avec les tables de correspondance complètes de COBIT 2019 dans le laboratoire GCI-LAB-03.

Application Auditeur SI

Répondre au « trente-deux cases rouges »

1. Une grille « conforme / non conforme » sur les 40 objectifs n'a pas de sens : COBIT ne fixe pas d'exigences, mais des objectifs à atteindre à un niveau de capacité choisi.
2. Demander d'abord quels objectifs ont été retenus comme prioritaires, et selon quelle démarche.
3. Évaluer ensuite la capacité des seuls objectifs prioritaires, au regard de la cible fixée.
4. Présenter au conseil l'écart entre capacité constatée et capacité cible, objectif par objectif.

Mme EKAMBI reprendra son tableau sur ces bases au Chapitre 8.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Une fiche COBIT décrit un morceau de système de gouvernance** : description, finalité, objectifs liés, puis les sept composantes (processus, RACI, flux d'information, compétences, politiques, culture, outils).
- **Pratiques et activités** : chaque activité est rattachée à un niveau de capacité, ce qui permet la mesure.
- **Quarante objectifs en cinq domaines** : EDM pour le conseil ; APO pour l'organisation et la stratégie ; BAI pour tout ce qui change ; DSS pour l'exploitation ; MEA pour la surveillance et l'assurance.
- **La cascade des objectifs** relie les besoins des parties prenantes aux 13 objectifs d'entreprise, aux 13 objectifs d'alignement, puis aux 40 objectifs COBIT.

- **La cascade ne suffit pas** : elle ne relève que les liens principaux ; l'histoire et le profil de risque de l'organisation complètent le choix.
- **Choisir, c'est retenir une dizaine d'objectifs prioritaires**, et viser pour les autres une capacité plus modeste.

✍ Exercice 6.1. Trouver l'objectif ★☆☆

Pour chacune des situations suivantes, indiquez l'objectif COBIT 2019 concerné (code et intitulé).

(a) Personne ne sait combien de licences de logiciels la banque possède.

(b) Le même incident de messagerie se reproduit chaque lundi.

(c) Le budget informatique est dépassé de 30 % sans que la direction financière en soit informée.

(d) Les recommandations de l'audit interne restent sans suite.

(e) Les métiers se plaignent de ne jamais être consultés sur les projets informatiques.

✍ Exercice 6.2. La fiche processus de DSS04 ★★☆

À l'aide du guide *COBIT 2019 Governance and Management Objectives* (dossier `Normes`), rédigez la fiche processus de l'objectif DSS04 (gérer la continuité) pour la BANQUE SANAGA, sur le modèle de la fiche DSS02 de la section 6.1.

(a) Résumez sa description et sa finalité, sans recopier le texte.

(b) Relevez ses objectifs d'entreprise et d'alignement liés.

(c) Listez ses pratiques et proposez une matrice RACI avec les fonctions réelles de la banque.

(d) Proposez trois indicateurs, avec leur cible et leur source.

✍ Exercice 6.3. Les priorités de NOUN PAY ★★★

NOUN PAY (Bafoussam) fait face à deux enjeux : l'enquête de l'autorité des données personnelles sur sa notation de crédit par IA, et sa dépendance à un fournisseur unique d'informatique en nuage.

(a) Choisissez trois objectifs d'entreprise prioritaires, et justifiez.

(b) Descendez la cascade jusqu'aux objectifs d'alignement, puis aux objectifs COBIT, en vous appuyant sur les fiches officielles.

(c) Ajoutez les objectifs que la cascade ne fait pas apparaître mais que la situation

impose, et expliquez pourquoi.

(d) Limitez votre liste finale à huit objectifs au plus, et justifiez chaque exclusion importante.

● Note

Transition. La cascade des objectifs n'est qu'un des facteurs qui orientent le choix des objectifs prioritaires. Le Chapitre 7 présente les onze facteurs de conception et la démarche complète de COBIT 2019 pour concevoir un système de gouvernance sur mesure, avec les niveaux de capacité cibles.

7

CONCEVOIR UN SYSTÈME DE GOUVERNANCE SUR MESURE

> « Il n'existe pas de formule magique. La conception finale est une décision au cas par cas. »
>
> D'après ISACA, *COBIT 2019 Framework: Introduction and Methodology* (2018, notre traduction)

Niveau : *Intermédiaire* • Maîtrise du Chapitre 6 (les 40 objectifs et la cascade des objectifs).

✦ Objectifs du chapitre

- ➢ Appliquer les onze facteurs de conception.
- ➢ Dérouler le processus de conception en quatre étapes.
- ➢ Calculer un profil d'objectifs prioritaires et en fixer les niveaux de capacité cibles.
- ➢ Justifier les arbitrages devant une direction générale.

Question directrice : dix objectifs, mais jusqu'où ?

Au Chapitre 6, la BANQUE SANAGA a retenu dix objectifs prioritaires. Le directeur général, M. FOTSO, pose aussitôt la question suivante : « Faut-il porter les dix au même niveau d'exigence ? Notre budget de mise en œuvre ne le permettra pas. » À Bafoussam, la fondatrice de NOUN PAY, Mme KAMGA, pose la question inverse : « Avec quarante-cinq salariés, avons-nous seulement besoin de COBIT ? »

Les deux questions ont la même réponse : COBIT 2019 ne s'applique pas tel quel, il se **conçoit**. Les quarante objectifs sont, dans le modèle, d'importance égale ; ce sont les caractéristiques de chaque organisation, les *facteurs de conception*, qui les hiérarchisent. Ce chapitre présente leurs effets (section 7.1), les onze facteurs (section 7.2), la démarche en quatre étapes (section 7.3), une méthode de calcul (section 7.4) et l'art de l'arbitrage (section 7.5). Les laboratoires GCI-LAB-02 et GCI-LAB-03 du NDAP SUKULU en sont l'application.

7.1 Les Trois Effets des Facteurs de Conception

Le modèle central de COBIT 2019 traite ses quarante objectifs comme intrinsèquement équivalents : il n'existe entre eux aucun ordre de priorité naturel. Les facteurs de conception rompent cette équivalence de trois manières [23].

1. **La priorité des objectifs et leur capacité cible.** Certains objectifs deviennent plus importants que d'autres, et quelques-uns peuvent même devenir négligeables. En pratique, l'importance se traduit par un *niveau de capacité cible* plus élevé. Une organisation très averse au risque, par exemple, donnera plus de poids à EDM03, APO12, APO13 et DSS05.

2. **La variation des composantes.** Certains facteurs changent l'importance d'une composante, ou en exigent une variante. Une petite organisation n'a pas besoin de toutes les structures du modèle ; une organisation très réglementée accorde plus d'importance aux procédures écrites et à la fonction conformité.

3. **Le recours à un domaine d'intérêt.** Certains facteurs (menaces, méthodes de développement, taille) appellent un contenu adapté, décrit dans un domaine d'intérêt : DevOps, petites et moyennes entreprises, cybersécurité.

Définition

Niveau de capacité cible (*target capability level*) : niveau de capacité, de 0 à 5, que l'organisation décide d'atteindre pour un processus donné. Il traduit l'importance de l'objectif pour elle. Le Chapitre 8 définit chaque niveau et la manière de mesurer la capacité constatée.

7.2 Les Onze Facteurs de Conception

7.2.1 Le tableau des facteurs

COBIT 2019 retient onze facteurs, dont les huit derniers sont parfois appelés *facteurs contextuels*. Pour chacun, il propose des valeurs types [23]. Le tableau suivant les applique à deux organisations du cours.

Facteur	Valeurs types	BANQUE SANAGA	ANPP
1. Stratégie	Croissance, innovation, maîtrise des coûts, service et stabilité	Service et stabilité (après la panne)	Service et stabilité
2. Objectifs d'entreprise	EG01 à EG13	EG06, EG02, EG03	EG12, EG09, EG03
3. Profil de risque	19 catégories de risques liés aux SI	Incidents d'exploitation, fournisseurs, non-conformité	Projets, décisions d'investissement, fournisseurs
4. Problèmes liés aux SI	20 problèmes types	Incidents majeurs, défaillance du prestataire, constats d'audit répétés	Projets en retard, doublons, dépenses hors budget
5. Paysage des menaces	Normal, élevé	Élevé (secteur bancaire)	Normal
6. Exigences de conformité	Faibles, normales, élevées	Élevées (COBAC, loi n° 2010/012)	Élevées (gestion publique)
7. Rôle des SI	Soutien, usine, redressement, stratégique	Stratégique	Usine
8. Approvisionnement	Externalisé, nuage, interne, hybride	Hybride	Externalisé
9. Méthodes de mise en œuvre	Agile, DevOps, traditionnelle, hybride	Traditionnelle	Traditionnelle
10. Adoption des technologies	Pionnier, suiveur, tardif	Suiveur	Tardif
11. Taille	Grande (plus de 250), PME (50 à 250)	Grande	Grande

Tableau 7.1. Les onze facteurs de conception appliqués à deux organisations (valeurs types d'après COBIT 2019, notre traduction)

7.2.2 Quatre facteurs à bien comprendre

Le rôle des SI. COBIT reprend une typologie classique en quatre rôles. Les SI ont un rôle de *soutien* quand ils ne sont cruciaux ni pour le fonctionnement ni pour l'innovation ; d'*usine* quand leur panne arrête immédiatement l'activité, sans qu'ils soient un moteur d'innovation ; de *redressement* quand ils sont vus comme un moteur d'innovation sans que l'activité courante en dépende encore ; *stratégiques* quand ils sont critiques à la fois pour fonctionner et pour innover. L'ANPP est une usine : une panne arrête les paiements, mais l'agence n'innove pas par le numérique. La BANQUE SANAGA est stratégique.

Les problèmes liés aux SI. Le profil de risque regarde vers l'avenir ; les problèmes regardent ce qui s'est déjà produit. COBIT en propose une liste type : frustrations entre métiers et DSI, incidents majeurs, problèmes de service des prestataires, constats d'audit répétés, dépenses informatiques cachées, projets en retard, solutions développées par les métiers sans la DSI, méconnaissance des règles de protection de la vie privée. C'est par ce facteur que la panne de la BANQUE SANAGA remonte BAI06 et BAI07 dans ses priorités (Chapitre 6).

Les exigences de conformité. Elles mesurent le poids des obligations légales, réglementaires et contractuelles. Au Cameroun, elles sont élevées pour les banques, les opérateurs de communications électroniques et, depuis 2026, pour toute organisation qui traite des données personnelles à grande échelle.

La taille. COBIT distingue les grandes organisations (plus de 250 salariés à temps plein) et les petites et moyennes (de 50 à 250). Les très petites organisations, de moins de 50 salariés, ne sont pas couvertes par le modèle.

7.2.3 L'ancrage juridique camerounais

⚖ Jurisprudence & Droit applicable

Loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et la cybercriminalité au Cameroun, article 31, alinéa 1 (version anglaise officielle) :

« Electronic communication networks and information systems content providers shall be bound to ensure the availability of material, as well as the data stored in their installations. »

Soit : les fournisseurs de contenus des réseaux de communications électroniques et des systèmes d'information sont tenus d'assurer la disponibilité des contenus et des données stockées dans leurs installations.

Loi n° 2024/017 du 23 décembre 2024 relative à la protection des données à caractère personnel. D'après les présentations publiées lors de son adoption [6], cette loi s'applique pleinement depuis le 23 juin 2026, au terme d'un délai de mise en conformité de dix-huit mois. Elle institue une Autorité de protection des données à caractère personnel et encadre strictement le transfert des données hors du territoire national.

Portée pour la conception. L'obligation de disponibilité de l'article 31, l'obligation d'audit des articles 13 et 32 (Chapitre 0) et, depuis 2026, les obligations relatives aux données personnelles justifient de classer les *exigences de conformité* en « élevées » pour la BANQUE SANAGA et pour NOUN PAY. Ce classement relève en priorité DSS04 (continuité), MEA03 (conformité aux exigences externes) et APO14 (données). Le Chapitre 10 étudiera ces textes en détail.

7.3 La Démarche en Quatre Étapes

COBIT 2019 propose une démarche de conception en quatre étapes, chacune décomposée en sous-étapes [23].

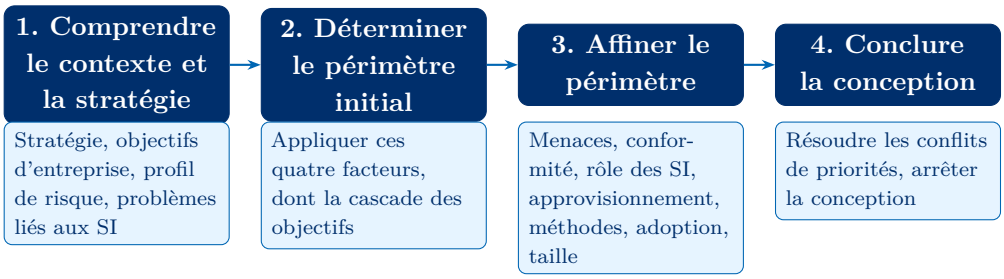


Figure 7.1. La démarche de conception de COBIT 2019 (d'après ISACA, notre traduction)

Les deux premières étapes travaillent sur les quatre premiers facteurs : la première les *comprend*, la deuxième les *applique* pour dégager un premier périmètre. La troisième étape affine ce périmètre avec les sept facteurs contextuels. La quatrième résout les contradictions et arrête la conception.

COBIT recommande de reporter toutes les indications obtenues sur un **canevas de**

conception (*design canvas*), puis de résoudre, autant que possible, les conflits qui y apparaissent. Ces conflits sont inévitables : avec onze facteurs et des correspondances génériques, certaines indications se contredisent.

7.4 Calculer un Profil d'Objectifs

7.4.1 Une méthode pédagogique

Le guide de conception de COBIT 2019 (*Design Guide*) et son outil de calcul attribuent, pour chaque facteur et chaque valeur, des coefficients d'importance à chacun des quarante objectifs. Ces tables ne sont pas reproduites ici. Ce cours utilise une **méthode pédagogique simplifiée**, qui suit la même logique : chaque facteur contribue à l'importance de chaque objectif, et l'importance se traduit en niveau de capacité cible. Le laboratoire GCI-LAB-02 applique cette méthode ; en entreprise, on utilisera l'outil officiel.

★ Attention

À ne pas confondre. Les poids, les notes et les seuils de la méthode ci-dessous sont des conventions du cours, fixées pour l'apprentissage. Ce ne sont pas les coefficients officiels du *Design Guide*. Un rapport professionnel qui les présenterait comme tels commettrait une erreur de source.

7.4.2 Les quatre temps du calcul

1. **Retenir les facteurs déterminants** et leur donner un poids (la somme des poids vaut 100 %). Le choix des poids est une décision de gouvernance.
2. **Noter, pour chaque objectif, la contribution de chaque facteur**, de 0 (aucune) à 3 (très forte), en justifiant chaque note.
3. **Calculer le score d'importance** de l'objectif :

$$S = \frac{\sum_f w_f \, n_f}{3} \times 100,$$

où w_f est le poids du facteur et n_f la note. Le score va de 0 à 100.

4. **Traduire le score en capacité cible** selon la convention du cours : 75 et plus, niveau 4 ; de 50 à 74, niveau 3 ; de 25 à 49, niveau 2 ; moins de 25, niveau 1.

7.4.3 Application à la BANQUE SANAGA

Scénario Opérationnel · Opération SANAGA. Le profil de la banque

Le comité stratégique des SI retient cinq facteurs et leurs poids : cascade des objectifs (25 %), profil de risque (25 %), problèmes liés aux SI (20 %), exigences de conformité (15 %), approvisionnement (15 %).

Objectif	Casc.	Risq.	Prob.	Conf.	Appr.	Score	Cible
DSS04	3	3	3	3	1	90,0	4
EDM03	3	3	2	3	1	83,3	4
APO12	3	3	2	2	1	78,3	4
BAI06	1	3	3	2	2	73,3	3
APO10	1	2	3	2	3	70,0	3
BAI07	1	3	3	1	2	68,3	3
MEA02	1	2	3	3	1	65,0	3
APO04	1	0	0	0	0	8,3	1

Calcul de DSS04. $0{,}25 \times 3 + 0{,}25 \times 3 + 0{,}20 \times 3 + 0{,}15 \times 3 + 0{,}15 \times 1 = 2{,}70$; $S = 2{,}70/3 \times 100 = 90{,}0$, d'où une cible de niveau 4.

Lecture. Les notes de la colonne « cascade » reprennent les liens du Tableau 6.7 : DSS04, EDM03 et APO12 sont liés à EG06 ou EG02, BAI06 et BAI07 ne le sont pas, d'où leur note de 1. Ils remontent par le risque et les problèmes. APO04 (innovation) tombe au niveau 1 : la banque n'en fait pas une priorité pendant le redressement, ce qui ne veut pas dire qu'elle renonce à innover.

Exigence de contrôle

Le dossier de conception. Pour qu'un auditeur, ou le régulateur, puisse comprendre pourquoi un objectif a reçu telle capacité cible, le dossier de conception doit contenir :

- la valeur retenue pour chacun des onze facteurs, avec sa justification ;
- les poids des facteurs et la décision qui les a approuvés ;
- les notes et les scores, avec la méthode de calcul et sa source (outil officiel ou méthode interne) ;
- le canevas de conception, avec les conflits relevés et la manière dont ils ont été résolus ;
- la liste finale des objectifs et de leurs capacités cibles, approuvée par le comité stratégique des SI.

7.5 Arbitrer et Justifier

7.5.1 Résoudre les conflits

Le calcul propose ; l'organe de gouvernance décide. La quatrième étape de la démarche consiste à confronter le résultat aux contraintes et aux intentions de l'organisation.

Scénario Opérationnel · Opération SANAGA. Le conflit sur BAI06

Le conflit. Le calcul donne une cible de niveau 3 pour BAI06. Le président du comité d'audit demande le niveau 4 : « Après ce qui s'est passé, la gestion des changements doit être exemplaire. »

Les arguments. Le niveau 4 suppose un processus piloté par des mesures quantitatives (Chapitre 8). La DSI estime qu'il faut d'abord atteindre le niveau 3, c'est-à-dire un processus défini et appliqué partout, ce qui n'est pas le cas aujourd'hui. Viser directement le niveau 4 disperserait l'effort.

La décision (procès-verbal du comité stratégique). Cible de niveau 3 à dix-huit mois, puis réexamen pour le niveau 4. En contrepartie, un indicateur trimestriel (part des changements majeurs dotés d'un retour arrière testé) est présenté au comité d'audit dès le premier trimestre.

7.5.2 Trois types de conflits fréquents

Conflit	Exemple	Piste de résolution
Contrôle contre agilité	Une jeune entreprise en DevOps soumise à des exigences de conformité élevées	Automatiser les contrôles dans la chaîne de déploiement plutôt que d'ajouter des validations manuelles
Ambition contre moyens	Dix objectifs visés au niveau 4 avec une équipe de cinq personnes	Échelonner les cibles dans le temps, concentrer l'effort sur trois objectifs
Facteurs contradictoires	Stratégie d'innovation, mais profil de risque très défavorable	Dissocier les périmètres : innover sur un périmètre isolé, stabiliser le cœur

Tableau 7.2. Conflits de conception et pistes de résolution

NOUN PAY a-t-elle besoin de COBIT ?

Avec 45 salariés, NOUN PAY se situe en dessous du seuil de 50 salariés à partir duquel COBIT 2019 considère une organisation comme une PME : les très petites organisations ne sont pas couvertes par le modèle. Faut-il pour autant renoncer ? Non, mais il faut l'utiliser comme une liste de contrôle plutôt que comme un système complet : retenir cinq ou six objectifs, viser des capacités de niveau 2 ou 3, s'appuyer sur le domaine d'intérêt consacré aux PME pour réduire les structures, et réserver l'effort aux risques qui la menacent vraiment (dépendance au fournisseur de nuage, données personnelles, notation par IA). C'est l'application directe du principe 5 : adapter le système aux besoins de l'organisation.

Application DSI

Présenter un profil de conception à la direction générale

1. Commencer par les facteurs, en langage métier : « nous sommes une banque dont les SI sont stratégiques, sous forte contrainte réglementaire, qui sort d'une panne majeure ».
2. Présenter la liste des objectifs prioritaires et leur capacité cible, sur une seule page.
3. Montrer ce qui *n'est pas* retenu, et pourquoi : c'est ce qui rend le profil crédible.
4. Chiffrer l'effort de mise en œuvre de chaque cible, et proposer un échelonnement.
5. Demander une décision formelle, et la date de réexamen.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **COBIT se conçoit, il ne s'applique pas tel quel** : les 40 objectifs sont équivalents dans le modèle, les facteurs de conception les hiérarchisent.
- **Trois effets** : priorité et capacité cible des objectifs, variation des composantes, recours à des domaines d'intérêt.
- **Onze facteurs** : stratégie, objectifs d'entreprise, profil de risque, problèmes liés aux SI, menaces, conformité, rôle des SI, approvisionnement, méthodes, adoption des technologies, taille.
- **Quatre étapes** : comprendre le contexte, déterminer le périmètre initial, l'affiner, conclure en résolvant les conflits sur un canevas de conception.
- **Le calcul propose, la gouvernance décide** : la méthode de score aide à fixer les capacités cibles, mais les arbitrages relèvent du comité stratégique et se consignent au procès-verbal.
- **Au Cameroun**, les obligations de disponibilité et d'audit de la loi n° 2010/012 et la loi n° 2024/017 sur les données personnelles placent les exigences de conformité au niveau « élevé » pour les banques et les acteurs du paiement.

Exercice 7.1. Les facteurs de KRIBILOG ★☆☆

Renseignez, pour KRIBILOG SA (opérateur logistique portuaire, 1 200 salariés, exploitation confiée à l'infogérant NETPORT SERVICES), la valeur de chacun des onze facteurs de conception, sur le modèle du Tableau 7.1. Justifiez en une phrase

les facteurs 4 (problèmes liés aux SI), 7 (rôle des SI) et 8 (approvisionnement).

✍ Exercice 7.2. Le profil de l'ANPP ★★☆

Le comité stratégique de l'ANPP retient les poids suivants : cascade (30 %), problèmes liés aux SI (30 %), exigences de conformité (20 %), approvisionnement (20 %). Les notes proposées sont : EDM02 (3, 3, 2, 1), APO05 (3, 3, 1, 1), APO10 (1, 3, 2, 3), BAI11 (2, 3, 1, 2), DSS04 (1, 1, 2, 1).

(a) Calculez le score d'importance de chaque objectif.

(b) Déduisez-en la capacité cible selon la convention du cours.

(c) Le directeur général demande que DSS04 soit porté au niveau 3. Quels arguments pourriez-vous avancer pour et contre ?

✍ Exercice 7.3. Concevoir le système de NOUN PAY ★★★

NOUN PAY développe ses applications en DevOps, héberge tout son SI chez un fournisseur de nuage étranger et doit se conformer, depuis juin 2026, à la loi n° 2024/017 sur les données personnelles.

(a) Renseignez les onze facteurs de conception, en signalant ceux pour lesquels COBIT n'est pas pleinement adapté à la taille de l'entreprise.

(b) Identifiez au moins deux conflits sur le canevas de conception et proposez leur résolution.

(c) Proposez une liste de six objectifs au plus, avec leur capacité cible et leur échéance.

(d) Rédigez la page de synthèse que Mme KAMGA présentera à ses investisseurs.

● Note

Transition. La conception a fixé des capacités cibles. Il reste à savoir ce qu'elles signifient, comment mesurer la capacité réelle d'un processus, et comment combler l'écart. C'est l'objet du Chapitre 8 : le modèle de capacité, la maturité, et la démarche de mise en œuvre en sept phases.

8

MESURER ET METTRE EN ŒUVRE : CAPACITÉ, MATURITÉ ET FEUILLE DE ROUTE

« Ce qui ne se mesure pas ne s'améliore pas.
Ce qui se mesure mal s'améliore dans la mauvaise direction. »

Adage des praticiens de la qualité

Niveau : *Intermédiaire* • Maîtrise du Chapitre 7 (facteurs de conception et niveaux de capacité cibles).

✦ Objectifs du chapitre

- ➢ Appliquer le modèle de capacité des processus (niveaux 0 à 5).
- ➢ Distinguer capacité d'un processus et maturité d'un domaine.
- ➢ Évaluer un niveau de capacité à partir de pièces justificatives.
- ➢ Dérouler le cycle de mise en œuvre en sept phases.
- ➢ Construire une feuille de route d'amélioration.

Question directrice : où en sommes-nous vraiment ?

Au Chapitre 6, Mme EKAMBI, directrice de l'audit interne de la BANQUE SANAGA, avait présenté au conseil un tableau de quarante cases « conforme / non conforme ». Au Chapitre 7, le comité stratégique a fixé, pour dix objectifs prioritaires, une capacité cible. Il reste à répondre à deux questions : *quelle est la capacité réelle de chaque processus aujourd'hui ?* et *comment combler l'écart ?*

La première question relève de la **mesure de la performance** (sections 8.1 à 8.4). La seconde relève de la **mise en œuvre** (sections 8.5 et 8.6). Le laboratoire GCI-LAB-04 de NDAP SUKULU fait évaluer la capacité de deux processus de la banque à partir d'un dossier de pièces.

© MaletYon

8.1 Mesurer la Performance dans COBIT

8.1.1 Cinq principes

COBIT 2019 désigne par *gestion de la performance* l'ensemble des méthodes qui disent dans quelle mesure le système de gouvernance et ses composantes fonctionnent, et comment les améliorer. Il fixe cinq principes à cette gestion [23] : elle doit être **simple** à comprendre et à utiliser ; **cohérente** avec le modèle conceptuel, et applicable à tous les types de composantes ; **fiable**, c'est-à-dire produire des résultats reproductibles et pertinents ; **flexible**, pour s'adapter aux priorités de chaque organisation ; et capable de soutenir **différents types d'évaluation**, de l'autoévaluation à l'audit formel.

8.1.2 Un modèle aligné sur CMMI

Le modèle de COBIT 2019 s'aligne largement sur la version 2.0 du CMMI et l'étend. Il repose sur deux notions :

- la **capacité**, qui se mesure *processus par processus* : chaque activité d'un processus est rattachée à un niveau de capacité ;
- la **maturité**, qui se mesure *domaine d'intérêt par domaine d'intérêt* : elle est atteinte quand tous les processus du domaine atteignent le niveau de capacité requis.

Et le modèle de COBIT 5 ?

COBIT 5 mesurait la capacité selon la norme ISO/IEC 15504, devenue ISO/IEC 33000, dont les niveaux ont un sens assez différent. COBIT 2019 lui substitue un modèle inspiré du CMMI. Les organisations qui veulent conserver l'approche ISO/IEC 33000 le peuvent : COBIT 2019 précise que ses pratiques tiennent lieu de « pratiques de base » et ses flux d'information de « produits de travail ». Il faut seulement ne pas mélanger les deux échelles dans un même rapport.

8.2 Les Niveaux de Capacité

8.2.1 Six niveaux

Définition

Capacité d'un processus (*process capability*) : mesure de la manière dont un processus est mis en œuvre et fonctionne. COBIT 2019 la mesure sur une échelle de 0 à 5.

Niv.	Caractère	Description
0	Absence	Aucune capacité de base ; approche incomplète ; les pratiques ne sont pas, ou pas vraiment, mises en œuvre.
1	Initial, intuitif	Le processus atteint plus ou moins sa finalité, par un ensemble incomplet d'activités, peu organisé.
2	Réalisé	Le processus atteint sa finalité par un ensemble d'activités élémentaire, mais complet.
3	Défini	Le processus atteint sa finalité de manière beaucoup plus organisée, en s'appuyant sur des ressources de l'organisation ; il est généralement bien défini.
4	Mesuré	Le processus atteint sa finalité, il est bien défini, et sa performance est mesurée de manière quantitative.
5	Optimisé	Le processus est bien défini, sa performance est mesurée pour l'améliorer, et l'amélioration continue est recherchée.

Tableau 8.1. Les niveaux de capacité des processus (d'après COBIT 2019, notre traduction)

8.2.2 Des activités rattachées à des niveaux

Le guide des objectifs rattache chaque activité à un niveau de capacité. Dans la fiche DSS02, par exemple, les activités qui consistent à enregistrer, classer et prioriser les demandes et les incidents (pratique DSS02.02) relèvent du niveau 2 ; celles qui définissent les schémas de classification et les règles d'escalade (DSS02.01) relèvent du niveau 3 ; l'analyse des tendances et son utilisation pour l'amélioration continue (DSS02.07) relèvent des niveaux 4 et 5 [22].

La progression est logique : on commence par *faire* (niveau 2), puis on *standardise* (niveau 3), puis on *mesure* (niveau 4), enfin on *améliore* en continu (niveau 5).

★ Attention

Violation typique. Une organisation se déclare « au niveau 4 » parce qu'elle produit un tableau de bord mensuel sur ses incidents. Mais les incidents ne sont pas tous enregistrés, et chaque équipe les classe à sa façon : le tableau de bord mesure un processus qui n'est ni complet (niveau 2) ni défini (niveau 3).

Règle : un niveau ne s'acquiert que si les niveaux inférieurs sont atteints. Mesurer un processus qui n'est pas défini produit des chiffres, pas une capacité.

8.3 Capacité et Maturité

Définition

Maturité (*maturity*) : mesure de performance au niveau d'un domaine d'intérêt (un ensemble d'objectifs et de leurs composantes). Un domaine d'intérêt atteint un niveau de maturité donné lorsque *tous* les processus qu'il contient atteignent ce niveau de capacité.

Niv.	Maturité	Description
0	Incomplète	Le travail n'est pas forcément accompli.
1	Initiale	Le travail est accompli, mais l'objectif du domaine n'est pas pleinement atteint.
2	Gérée	Planification et mesure de la performance existent, mais pas encore de manière standardisée.
3	Définie	Des standards communs à toute l'organisation guident le travail.
4	Quantitative	L'organisation est pilotée par les données, avec une amélioration quantitative de la performance.
5	Optimisée	L'organisation est tournée vers l'amélioration continue.

Tableau 8.2. Les niveaux de maturité des domaines d'intérêt (d'après COBIT 2019, notre traduction)

La règle d'agrégation est exigeante : la maturité d'un domaine est celle de son processus le plus faible. Une banque dont neuf processus de sécurité sont au niveau 3 et le dixième au niveau 1 a une maturité de niveau 1 dans le domaine de la sécurité. C'est voulu : une chaîne a la solidité de son maillon le plus faible.

8.3.1 Mesurer les autres composantes

COBIT 2019 reconnaît qu'il n'existe pas de méthode généralement admise pour évaluer les composantes autres que les processus, mais il propose des critères. Pour une structure organisationnelle, par exemple : elle est formellement créée ; son mandat est clair et documenté ; ses règles de fonctionnement sont écrites ; elle se réunit comme prévu ; ses procès-verbaux existent et sont utiles ; ses droits de décision sont définis et respectés ; ses procédures d'escalade sont appliquées. Ces critères rejoignent l'exigence de contrôle « un comité qui fonctionne » du Chapitre 1.

8.4 Évaluer une Capacité

8.4.1 L'échelle de notation

Un niveau de capacité peut être atteint plus ou moins complètement. COBIT 2019 propose, pour les évaluations orientées vers l'amélioration, l'échelle suivante [23].

Note	Taux de réalisation	Lecture
Complètement (*Fully*, F)	Plus de 85 %	Le niveau est acquis
Largement (*Largely*, L)	De 50 à 85 %	Acquis, avec des faiblesses
Partiellement (*Partially*, P)	De 15 à 50 %	Non acquis
Pas (*Not*, N)	Moins de 15 %	Non acquis

Tableau 8.3. L'échelle de notation des niveaux de capacité (d'après COBIT 2019)

COBIT 2019 souligne que la note reste un jugement, qui doit être étayé par l'examen des composantes : activités réalisées, pièces produites, structures en fonctionnement. Les méthodes formelles, qui débouchent sur une certification indépendante, peuvent préférer une notation binaire (atteint ou non).

8.4.2 La règle d'attribution du niveau

Le cours retient la règle usuelle des évaluations de processus, issue de la famille ISO/IEC 33000 : **un processus atteint le niveau n si ce niveau est noté au moins « largement » et si tous les niveaux inférieurs sont notés « complètement »**. Un niveau noté « largement » est donc acquis, mais il bloque l'accès au niveau suivant tant qu'il n'est pas porté à « complètement ».

8.4.3 Une évaluation pas à pas

Scénario Opérationnel · Opération SANAGA. La capacité de BAI06

L'auditrice interne, Mme EKAMBI, évalue le processus BAI06 (gérer les changements informatiques), dont la cible est le niveau 3. Elle examine, pour chaque activité, les pièces de vingt changements tirés au hasard sur six mois. *(Le nombre d'activités par niveau est simplifié pour l'exercice ; la fiche officielle BAI06 en donne la liste exacte.)*

Niveau	Activités	Réalisées	Taux	Note	Acquis ?
2	10	6	60 %	L	Oui
3	8	2	25 %	P	Non
4	4	0	0 %	N	Non

Constatation. Six activités de niveau 2 sur dix sont réalisées : les demandes de changement sont enregistrées et évaluées, mais les changements d'urgence ne font l'objet d'aucune procédure, et l'autorisation n'est pas tracée pour les changements jugés mineurs. Deux activités de niveau 3 sur huit sont réalisées.

Analyse (confiance élevée). Capacité constatée : **niveau 2, largement atteint**. L'écart avec la cible est d'un niveau. Pour progresser, il faut d'abord porter le niveau 2 à « complètement » (procédure d'urgence, traçabilité de toutes les autorisations), puis réaliser les activités de niveau 3.

Exigence de contrôle

Une évaluation de capacité opposable. Pour qu'une évaluation de capacité puisse être présentée au conseil ou au régulateur, le dossier doit contenir :

- l'objectif évalué, l'édition de COBIT et l'échelle de notation utilisées ;
- le périmètre (entités, systèmes, période) et la méthode d'échantillonnage ;
- pour chaque activité, la pièce examinée et le constat (réalisée ou non) ;
- le taux et la note de chaque niveau, et la règle d'attribution appliquée ;
- la capacité constatée, la capacité cible et l'écart ;
- la date, le nom de l'évaluateur et son indépendance par rapport au processus évalué.

Application Auditeur SI

Conduire une évaluation de capacité

1. Partir de la fiche officielle de l'objectif : lister ses activités, niveau par niveau.
2. Pour chaque activité, définir la pièce qui prouve sa réalisation (procès-verbal, ticket, journal, rapport).
3. Échantillonner : une activité réalisée une fois n'est pas une activité réalisée.
4. Noter chaque niveau sur l'échelle F, L, P, N, puis appliquer la règle d'attribution.
5. Restituer à l'audité avant de conclure : il peut détenir une pièce que vous n'avez pas vue.

8.5 La Mise en Œuvre en Sept Phases

8.5.1 Un programme, pas un projet

Le guide de mise en œuvre de COBIT 2019 part d'un constat : beaucoup de démarches de gouvernance échouent parce qu'elles ne sont pas lancées et pilotées comme de véritables *programmes*, parrainés par la direction générale, au périmètre maîtrisé et aux objectifs atteignables. Le but final n'est pas de terminer un projet, mais d'installer une pratique durable : le programme se clôt quand l'amélioration de la gouvernance produit des bénéfices mesurables et fait partie du fonctionnement normal.

8.5.2 Sept phases, trois anneaux

La démarche comporte sept phases, chacune formulée comme une question. Chaque phase se lit sur trois anneaux : le *management du programme* (anneau extérieur), l'*accompagnement du changement* (anneau intermédiaire) et le *cycle d'amélioration continue* (anneau intérieur) [23].

Phase	Programme	Changement	Amélioration
1. Quels sont les moteurs ?	Lancer le programme	Créer le désir de changer	Reconnaître la nécessité d'agir
2. Où en sommes-nous ?	Définir problèmes et opportunités	Former l'équipe de mise en œuvre	Évaluer l'état actuel
3. Où voulons-nous aller ?	Définir la feuille de route	Communiquer le résultat visé	Définir l'état cible
4. Que faut-il faire ?	Planifier le programme	Identifier les acteurs	Construire les améliorations
5. Comment y arriver ?	Exécuter le plan	Mettre en service et utiliser	Mettre en œuvre les améliorations
6. Y sommes-nous arrivés ?	Réaliser les bénéfices	Ancrer les nouvelles pratiques	Exploiter et mesurer
7. Comment garder l'élan ?	Examiner l'efficacité	Pérenniser	Surveiller et évaluer

Tableau 8.4. La feuille de route de mise en œuvre de COBIT 2019 (d'après ISACA, notre traduction)

8.5.3 Le lien avec la conception

Les deux démarches s'emboîtent. La conception du système de gouvernance (Chapitre 7) nourrit les trois premières phases de la mise en œuvre : la compréhension du contexte alimente la phase 1, la détermination et l'affinage du périmètre alimentent la phase 2, et la conclusion de la conception fixe l'état cible de la phase 3. Les évaluations de capacité, enfin, mesurent l'état actuel en phase 2 et les progrès en phase 6.

8.6 Construire une Feuille de Route

8.6.1 De l'écart au plan

La phase 3 compare l'état cible et l'état actuel, puis cherche des solutions. COBIT recommande de distinguer les *gains rapides* des chantiers de long terme, de donner la priorité aux actions faciles et à fort bénéfice, et de découper les chantiers longs en étapes maîtrisables.

Scénario Opérationnel · Opération SANAGA. La feuille de route à dix-huit mois

Mme EKAMBI reprend son tableau sur ces bases. Il ne compte plus quarante cases rouges, mais une ligne par objectif prioritaire. Voici les sept objectifs du profil de conception (Chapitre 7) ; EDM01, DSS02 et MEA03 suivent le même format.

Objectif	Constatée	Cible	Écart	Première action
DSS04	1	4	3	Tester le plan de continuité du système central (gain rapide : 3 mois)
EDM03	1	4	3	Faire approuver l'appétence au risque par le conseil
APO12	2	4	2	Registre des risques SI relié au registre de la banque
BAI06	2	3	1	Procédure des changements d'urgence (gain rapide)
APO10	1	3	2	Renégocier le contrat de DIGICORE AFRIQUE
BAI07	1	3	2	Recette et retour arrière obligatoires avant bascule
MEA02	2	3	1	Suivi trimestriel des recommandations au comité d'audit

Échelonnement. Mois 1 à 3 : gains rapides (DSS04, BAI06, MEA02). Mois 4 à 12 : chantiers de fond (EDM03, APO12, APO10, BAI07). Mois 13 à 18 : mesure des progrès (phase 6) et nouvelle évaluation de capacité.

Application Responsable GRC

Piloter la feuille de route

1. Donner à chaque ligne un propriétaire, une échéance et un indicateur de progrès.
2. Rendre compte chaque trimestre au comité stratégique des SI, et chaque semestre au conseil.
3. Réévaluer la capacité des objectifs traités à mi-parcours, par une personne indépendante du processus.
4. Mettre à jour la conception (Chapitre 7) si un facteur change : c'est le principe du système dynamique.

Viser le niveau 5 partout ?

Rien ne serait plus coûteux, ni plus inutile. Le niveau 5 suppose une amélioration continue fondée sur des mesures quantitatives : il se justifie pour quelques processus réellement critiques, rarement plus. Pour la plupart des organisations camerounaises, atteindre durablement le niveau 3 sur les objectifs prioritaires serait déjà un progrès décisif : des processus définis, appliqués partout, qui ne dépendent plus de la bonne volonté d'une personne. La gouvernance, ici encore, est affaire de proportion.

❍

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Capacité et maturité** : la capacité se mesure processus par processus (0 à 5) ; la maturité se mesure par domaine d'intérêt, et vaut celle du processus le plus faible.
- **Six niveaux** : absence, initial, réalisé, défini, mesuré, optimisé. On fait, on standardise, on mesure, on améliore.
- **Des activités rattachées à des niveaux** : c'est ce qui rend la mesure objective, à condition de l'étayer par des pièces.
- **Quatre notes** : complètement (plus de 85 %), largement (50 à 85 %), partiellement (15 à 50 %), pas (moins de 15 %). Un niveau ne s'acquiert que si les niveaux inférieurs sont complètement atteints.
- **Sept phases, trois anneaux** : programme, changement, amélioration continue. La gouvernance s'installe par un programme, pas par un projet.
- **La feuille de route** part des écarts entre capacité constatée et cible, commence par des gains rapides, et se pilote devant le comité stratégique.

✍ Exercice 8.1. Noter un niveau ★☆☆

Pour chacun des cas suivants, donnez la note (F, L, P ou N) du niveau concerné, puis la capacité du processus.

(a) Niveau 2 : 9 activités sur 10 réalisées ; niveau 3 : 3 sur 6.

(b) Niveau 2 : 7 activités sur 10 réalisées ; niveau 3 : 6 sur 6.

(c) Niveau 2 : 1 activité sur 10 réalisée.

(d) Niveau 2 : 12 sur 12 ; niveau 3 : 8 sur 9 ; niveau 4 : 1 sur 5.

✍ Exercice 8.2. La maturité de la continuité ★★☆

Le domaine d'intérêt « continuité » de KRIBILOG SA regroupe quatre processus. Leurs capacités constatées sont : DSS04 niveau 2, BAI04 niveau 3, DSS01 niveau 3, APO10 niveau 1.

(a) Quelle est la maturité du domaine ? Justifiez.

(b) Le directeur général affirme que « la continuité est au niveau 3 en moyenne ». Que lui répondez-vous ?

(c) Quelle action aurait le plus d'effet sur la maturité du domaine ?

✍ Exercice 8.3. La feuille de route de l'ANPP ★★★

À partir des capacités cibles calculées à l'Exercice 7.2, et des capacités constatées suivantes : EDM02 niveau 0, APO05 niveau 1, APO10 niveau 1, BAI11 niveau 2, DSS04 niveau 1.

(a) Construisez le tableau des écarts.

(b) Identifiez deux gains rapides et deux chantiers de long terme.

(c) Organisez la feuille de route selon les sept phases, en précisant pour chaque phase une action sur chacun des trois anneaux.

(d) Indiquez comment la feuille de route s'inscrit dans le budget programme de l'agence (Chapitre 3).

● Note

Transition. La Partie II a construit, avec COBIT 2019, un système de gouvernance mesuré et une feuille de route. La Partie III replace ce système dans son cadre normatif et juridique. Le Chapitre 9 présente les normes internationales de la gouvernance et des services (ISO/IEC 38500, ISO/IEC 20000-1, ISO/IEC 27001, ISO 31000, COSO).

partie III

Cadre Normatif, Juridique et Déontologique

© MaletYon

9

LES NORMES INTERNATIONALES DE LA GOUVERNANCE ET DES SERVICES

« Une norme ne dit pas ce qu'il faut penser.
Elle dit ce qu'il faudra pouvoir démontrer. »

Adage des auditeurs de systèmes de management

Niveau : *Fondamental* • Maîtrise du Chapitre 4 (natures des référentiels et carte d'articulation).

✦ Objectifs du chapitre

- ➢ Présenter les principes et le modèle « évaluer, diriger, surveiller » de l'ISO/IEC 38500.
- ➢ Décrire les exigences d'un système de management des services (ISO/IEC 20000-1).
- ➢ Articuler la gouvernance des SI avec l'ISO/IEC 27001, l'ISO 31000 et COSO ERM.
- ➢ Distinguer certification, conformité et alignement volontaire.

Question directrice : faut-il un certificat ?

KRIBILOG SA vient de recevoir l'appel d'offres d'un grand armateur pour la gestion de ses conteneurs au port de Kribi. Une clause l'arrête : « Le prestataire devra justifier, dans un délai de dix-huit mois, d'une certification ISO/IEC 20000-1 sur le périmètre du service. » Au même moment, le conseil de la BANQUE SANAGA demande s'il ne faudrait pas « se faire certifier ISO 27001 pour rassurer la COBAC ».

La Partie III, qui s'ouvre ici, place la gouvernance des SI dans son cadre normatif, puis juridique (Chapitre 10), puis dans celui de l'audit (Chapitre 11). Ce chapitre présente les normes internationales qui comptent pour la gouvernance des SI : leur architecture commune (section 9.1), la norme de la gouvernance (section 9.2), celles des services et de la sécurité (sections 9.3 et 9.4), celles du risque (section 9.5), et enfin la question du certificat (section 9.6).

© MaletYon

9.1 L'Architecture des Systèmes de Management

9.1.1 Qu'est-ce qu'un système de management ?

Définition

Système de management (*management system*) : ensemble d'éléments corrélés ou en interaction d'une organisation (politiques, objectifs, rôles, processus) qui sert à établir des politiques et des objectifs, et à atteindre ces objectifs. Un système de management de la qualité, de la sécurité de l'information ou des services en sont des exemples.

9.1.2 Une structure harmonisée

Les normes ISO de systèmes de management certifiables partagent une même structure, dite **structure harmonisée** (anciennement « structure de haut niveau »). Elle facilite la mise en place de systèmes intégrés : une organisation certifiée à la fois ISO/IEC 27001 et ISO/IEC 20000-1 n'a qu'un seul cycle de revue de direction, d'audit interne et d'amélioration.

Art.	Titre	Contenu
4	Contexte de l'organisation	Enjeux internes et externes, parties intéressées, périmètre du système
5	Leadership	Engagement de la direction, politique, rôles et responsabilités
6	Planification	Risques et opportunités, objectifs et plans pour les atteindre
7	Support	Ressources, compétences, sensibilisation, communication, informations documentées
8	Fonctionnement	Planification et maîtrise opérationnelles : c'est là que chaque norme place ses exigences propres
9	Évaluation des performances	Surveillance, mesure, audit interne, revue de direction
10	Amélioration	Non-conformités, actions correctives, amélioration continue

Tableau 9.1. La structure harmonisée des normes ISO de systèmes de management (articles 4 à 10)

Cette structure suit le cycle *planifier, réaliser, vérifier, agir* : les articles 4 à 7 planifient, l'article 8 réalise, l'article 9 vérifie, l'article 10 améliore. On y retrouve, à une autre échelle, la logique de COBIT : le domaine EDM correspond aux articles 5 et 9 (direction et surveillance), les domaines de management aux articles 6 à 8 et 10.

9.2 ISO/IEC 38500 : la Norme de la Gouvernance

9.2.1 Une norme pour l'organe de gouvernance

L'ISO/IEC 38500 s'adresse à l'organe de gouvernance : conseil d'administration, conseil de surveillance, direction d'un établissement public. Elle ne décrit ni processus ni contrôles, mais des principes et un modèle. Elle n'est pas certifiable. Sa troisième édition a été publiée en février 2024 [26].

9.2.2 Le modèle évaluer, diriger, surveiller

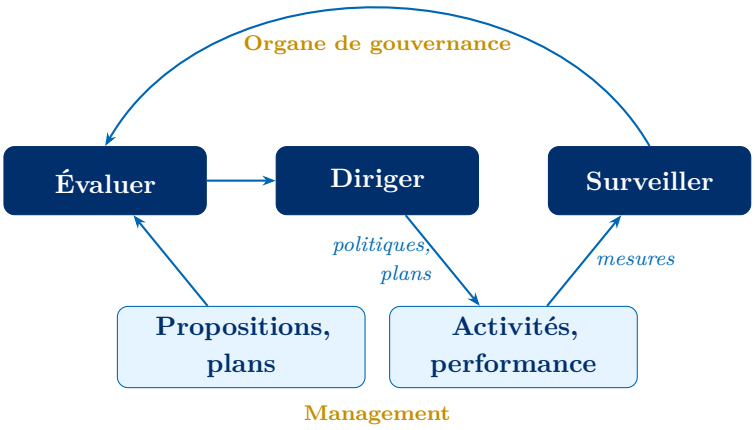


Figure 9.1. Le modèle évaluer, diriger, surveiller (représentation simplifiée)

L'organe de gouvernance **évalue** l'usage actuel et futur de l'informatique, ainsi que les propositions que lui soumet le management ; il **dirige** la préparation et la mise en œuvre des plans et des politiques ; il **surveille** la performance et la conformité. Ce sont les trois verbes du domaine EDM de COBIT, qui s'inspire directement de la norme.

9.2.3 Des principes de 2015 à ceux de 2024

L'édition de 2015 [24] reposait sur six principes : *responsabilité*, *stratégie*, *acquisition*, *performance*, *conformité* et *comportement humain*. L'édition de 2024 les remplace par les onze principes de la norme ISO 37000 sur la gouvernance des organisations, et précise comment ils s'appliquent à la gouvernance des SI. Elle fait de la gouvernance des SI une partie intégrante de la gouvernance de l'organisation, et l'oriente vers trois résultats : une performance effective, une gestion responsable et un comportement éthique.

Catégorie	Principes (d'après ISO 37000)
Principe premier	Raison d'être (*purpose*)
Principes fondateurs	Création de valeur ; stratégie ; supervision ; redevabilité
Principes facilitateurs	Engagement des parties prenantes ; leadership ; données et décisions ; gouvernance des risques ; responsabilité sociétale ; viabilité et performance dans la durée

Tableau 9.2. Les onze principes de gouvernance repris par l'ISO/IEC 38500:2024 (notre traduction)

Scénario Opérationnel · Opération MEFOU. Une charte inspirée de l'ISO/IEC 38500

Le nouveau président du conseil d'administration de l'ANPP demande que la charte du comité stratégique des SI (Chapitre 1) s'appuie sur l'ISO/IEC 38500. La division informatique propose trois articles :

1. *Raison d'être* : tout projet informatique doit être rattaché à la mission de l'agence (payer l'État à bonne date) et à un programme budgétaire.
2. *Supervision* : le comité *évalue* chaque année le portefeuille, *dirige* par la décision d'investissement et *surveille* chaque trimestre les projets en cours.
3. *Données et décisions* : le conseil reçoit, avant toute décision d'investissement, un dossier normalisé (coût total, bénéfices, risques).

La charte ne cite pas la norme pour la forme : elle en traduit les principes en règles vérifiables.

9.3 ISO/IEC 20000-1 : le Management des Services

9.3.1 Les exigences

L'ISO/IEC 20000-1, dont l'édition en vigueur date de 2018, formule les exigences d'un **système de management des services** (SMS). Elle suit la structure harmonisée, et place à l'article 8 ses exigences propres au fonctionnement des services.

Art.	Thème	Exigences principales
8.2	Portefeuille de services	Planifier les services, gérer le catalogue, les actifs et la configuration
8.3	Relations et accords	Relations avec les clients, gestion des niveaux de service, gestion des fournisseurs
8.4	Offre et demande	Budgétisation des services, demande et capacité
8.5	Conception, construction et transition	Gestion des changements, conception et transition des services, mises en production et déploiement
8.6	Résolution et réalisation	Gestion des incidents, des demandes de service et des problèmes
8.7	Assurance des services	Disponibilité, continuité, sécurité de l'information

Tableau 9.3. Les exigences de l'article 8 de l'ISO/IEC 20000-1:2018 (synthèse, notre traduction)

9.3.2 ITIL, COBIT et ISO/IEC 20000-1

Les trois référentiels se recouvrent largement sur la gestion des services, et c'est précisément pourquoi il faut savoir ce que chacun apporte. **ITIL** décrit *comment* mener chaque pratique ; **ISO/IEC 20000-1** dit *ce qui doit être démontré* pour obtenir un certificat ; **COBIT** relie ces pratiques aux objectifs de l'organisation et à sa gouvernance. Une organisation qui vise la certification ISO/IEC 20000-1 s'appuie le plus souvent sur ITIL pour construire ses pratiques. Le Chapitre 16 établira la correspondance détaillée entre les trois.

Application Responsable des services IT

Préparer KRIBILOG à l'ISO/IEC 20000-1

1. Définir le périmètre : le service de suivi des conteneurs, depuis Douala et Kribi, et non toute l'informatique de l'entreprise.
2. Établir que KRIBILOG reste *responsable* du service même s'il est exploité par NETPORT SERVICES : la norme exige la maîtrise des processus confiés à des tiers.
3. Mettre d'abord en place les pratiques de l'article 8.6 (incidents, demandes, problèmes) et de l'article 8.5 (changements), qui sont aujourd'hui les plus défaillantes.
4. Conduire un audit interne et une revue de direction avant de solliciter l'organisme de certification.

Dix-huit mois sont un délai serré, mais réaliste si le périmètre reste limité au service demandé par l'armateur.

9.4 ISO/IEC 27001 et 27002 : la Sécurité de l'Information

9.4.1 Le système de management de la sécurité

L'ISO/IEC 27001 formule les exigences d'un **système de management de la sécurité de l'information** (SMSI). Le vocabulaire de la famille est fixé par l'ISO/IEC 27000 [25]. La démarche est fondée sur le risque : l'organisation apprécie ses risques de sécurité (selon une méthode que précise l'ISO/IEC 27005), choisit les mesures qui les traitent, et justifie ses choix.

Définition

Déclaration d'applicabilité (*statement of applicability*, SoA) : document qui liste les mesures de sécurité de l'annexe A de l'ISO/IEC 27001, indique pour chacune si elle est retenue ou exclue, et justifie ce choix. C'est la pièce centrale d'un audit de certification ISO/IEC 27001.

9.4.2 Deux éditions à ne pas confondre

Élément	Édition 2013	Édition 2022
Mesures de l'annexe A	114 mesures en 14 domaines	93 mesures en 4 thèmes
Thèmes	·	Organisationnelles (37), humaines (8), physiques (14), technologiques (34)
Nouvelles mesures	·	Notamment renseignement sur les menaces, sécurité de l'informatique en nuage, préparation des TIC à la continuité
Statut	Remplacée	En vigueur

Tableau 9.4. ISO/IEC 27001 et 27002 : éditions 2013 et 2022

★ Attention

Violation typique. Une organisation rédige en 2026 sa politique de sécurité et sa déclaration d'applicabilité à partir des éditions 2013 des normes, trouvées dans un dossier partagé. L'auditeur de certification relève aussitôt l'écart : la référence n'est plus celle en vigueur, et les mesures relatives à l'informatique en nuage manquent.

Règle : toujours vérifier l'édition en vigueur d'une norme dans le catalogue de l'ISO avant de s'en servir de référence, et indiquer l'édition dans chaque document.

9.4.3 Le lien avec la gouvernance

La sécurité de l'information n'est pas la gouvernance des SI (Chapitre 1), mais elle en relève par trois voies. Le conseil fixe l'appétence au risque de sécurité (EDM03). Le management conduit le SMSI (APO13, dont la finalité recouvre celle de l'ISO/IEC 27001). L'exploitation met en œuvre les mesures (DSS05). Un SMSI certifié est un excellent moyen d'atteindre APO13 ; il ne dit rien de la valeur des investissements ni de la qualité des services.

Application RSSI

Répondre au conseil de la BANQUE SANAGA

1. Une certification ISO/IEC 27001 ne « rassure » le régulateur que si son périmètre couvre les systèmes qui l'intéressent : les systèmes de paiement et le système central.
2. Elle ne remplace ni les audits prévus par la loi n° 2010/012 (Chapitre 4), ni les exigences de la COBAC sur le contrôle interne.
3. Elle n'aurait pas évité la panne de mars 2026, qui ne relevait pas de la sécurité

mais de la gestion des changements.

4. Recommandation : viser la certification à trois ans sur le périmètre des paiements, comme le prévoit la carte des référentiels (Chapitre 4), et traiter d'abord la feuille de route COBIT (Chapitre 8).

9.5 Le Risque : ISO 31000 et COSO

9.5.1 ISO 31000 : des lignes directrices pour tout risque

L'ISO 31000 (édition 2018) donne des lignes directrices sur le management du risque, applicables à tout type de risque et à toute organisation. Elle n'est pas certifiable. Elle s'articule en trois parties : des *principes* (un management du risque intégré, structuré, adapté, inclusif, dynamique, fondé sur la meilleure information disponible, attentif aux facteurs humains et culturels, et en amélioration continue), un *cadre organisationnel*, et un *processus* : établir le contexte et les critères, apprécier les risques (les identifier, les analyser, les évaluer), les traiter, puis surveiller, communiquer et rendre compte.

9.5.2 COSO : contrôle interne et risques de l'entreprise

Les deux cadres du COSO (Chapitre 4) sont la référence des auditeurs et des régulateurs financiers.

Cadre	Composantes
Contrôle interne (2013)	Environnement de contrôle ; évaluation des risques ; activités de contrôle ; information et communication ; activités de pilotage. Cinq composantes et 17 principes.
Management des risques (2004)	Huit éléments : environnement interne ; fixation des objectifs ; identification des événements ; évaluation des risques ; traitement des risques ; activités de contrôle ; information et communication ; pilotage [8].
Management des risques (2017)	Cinq composantes : gouvernance et culture ; stratégie et définition des objectifs ; performance ; revue et révision ; information, communication et reporting. Vingt principes [9].

Tableau 9.5. Les cadres du COSO

Le résumé en français disponible dans le dossier `Normes` est celui de l'édition de 2004. L'édition de 2017 en déplace le centre de gravité : elle ne traite plus le risque comme un sujet de contrôle, mais comme une composante de la stratégie et de la performance. C'est la lecture que retient aussi COBIT avec la finalité d'optimisation des risques (Chapitre 3).

9.5.3 Articuler les risques

La règle d'articulation est la suivante : **le risque informatique est un risque de l'entreprise**. Le registre des risques liés aux SI (APO12) doit alimenter le registre des risques de l'organisation, selon la même échelle et les mêmes critères, et l'appétence au risque fixée par le conseil (EDM03) s'applique aux deux. Une organisation qui tient deux registres séparés, avec deux échelles, ne peut pas comparer un risque informatique à un risque de crédit : elle ne peut donc pas arbitrer.

9.6 Certification, Conformité, Alignement

9.6.1 Trois démarches

Définition

Certification : attestation, par un organisme tiers accrédité, qu'un système de management est conforme aux exigences d'une norme, sur un périmètre donné et pour une durée donnée.

Conformité : respect d'exigences obligatoires (lois, règlements, contrats). Elle ne se choisit pas ; elle se démontre.

Alignement volontaire : choix d'une organisation de s'inspirer d'un référentiel ou d'une norme sans viser de certificat. C'est le cas de tout usage de COBIT, d'ITIL ou de l'ISO 31000.

9.6.2 Le cycle de certification

Une certification de système de management suit un cycle de trois ans : un audit initial en deux étapes (revue de la documentation et de l'état de préparation, puis audit de la mise en œuvre), la délivrance du certificat, des audits de surveillance au moins annuels, puis un audit de renouvellement. Les organismes de certification doivent eux-mêmes satisfaire aux exigences de l'ISO/IEC 17021-1, complétées pour la sécurité de l'information par l'ISO/IEC 27006, et être accrédités par un organisme d'accréditation. Un certificat délivré par un organisme non accrédité n'a qu'une valeur commerciale.

Exigence de contrôle

Préparer un audit de certification. Avant de solliciter l'organisme de certification, l'organisation doit pouvoir présenter :

- le périmètre du système, écrit et justifié ;
- la politique et les objectifs, approuvés par la direction ;
- l'appréciation des risques et, pour l'ISO/IEC 27001, la déclaration d'applicabilité ;
- les procédures exigées et les enregistrements de leur fonctionnement sur plusieurs mois ;

- au moins un cycle complet d'audit interne et de revue de direction ;
- le suivi des non-conformités relevées et des actions correctives.

Scénario Opérationnel · Opération KRIBI. Le calendrier de la certification

Contrainte. Certification ISO/IEC 20000-1 exigée dans dix-huit mois sur le service de suivi des conteneurs.

Plan retenu par M. MBARGA. Mois 1 à 2 : périmètre, politique et objectifs, analyse d'écart. Mois 3 à 9 : mise en place des pratiques (incidents, demandes, problèmes, changements, niveaux de service, fournisseurs), avec un avenant au contrat de NETPORT SERVICES. Mois 10 à 13 : fonctionnement et enregistrements. Mois 14 : audit interne. Mois 15 : revue de direction et actions correctives. Mois 16 à 17 : audit de certification en deux étapes. Mois 18 : certificat.

Analyse (confiance moyenne). Le calendrier tient si l'avenant avec l'infogérant est signé dans les trois premiers mois : sans lui, KRIBILOG ne pourra démontrer la maîtrise d'un service exploité par un tiers.

Application Auditeur SI

Lire un certificat en cinq questions

1. Quelle norme, et quelle édition ?
2. Quel périmètre exact (sites, services, systèmes) ?
3. Quel organisme l'a délivré, et est-il accrédité ?
4. Quelle date de validité, et le dernier audit de surveillance a-t-il eu lieu ?
5. Le périmètre couvre-t-il le service qui vous intéresse ?

À retenir

Ce qu'il faut retenir de ce chapitre :

- **Une structure harmonisée** : les normes de systèmes de management partagent les articles 4 à 10 (contexte, leadership, planification, support, fonctionnement, évaluation, amélioration), ce qui permet des systèmes intégrés.
- **ISO/IEC 38500** s'adresse à l'organe de gouvernance : évaluer, diriger, surveiller. Depuis 2024, elle reprend les onze principes de l'ISO 37000. Elle n'est pas certifiable.
- **ISO/IEC 20000-1** exige un système de management des services ; ITIL dit

comment le construire, COBIT le relie à la gouvernance.

- **ISO/IEC 27001 et 27002** : un SMSI fondé sur le risque, une déclaration d'applicabilité, 93 mesures depuis 2022. Vérifier toujours l'édition en vigueur.
- **ISO 31000 et COSO** : le risque informatique est un risque de l'entreprise, à inscrire dans un registre et une échelle communs.
- **Certification, conformité, alignement** : la certification atteste un périmètre, la conformité répond à une obligation, l'alignement est un choix.

✍ Exercice 9.1. Quel article ? ★☆☆

Indiquez l'article de la structure harmonisée (4 à 10) auquel se rattache chacun des éléments suivants.

(a) La revue annuelle du système par la direction générale.

(b) La liste des parties intéressées et de leurs attentes.

(c) Le plan de formation des techniciens du centre de services.

(d) Le traitement d'une non-conformité relevée en audit interne.

(e) La procédure de gestion des incidents.

✍ Exercice 9.2. Deux registres, une échelle ★★☆

La BANQUE SANAGA tient un registre des risques de crédit et de marché (échelle de 1 à 4) et, à la DSI, un registre des risques informatiques (échelle de 1 à 5, définie différemment).

(a) Expliquez pourquoi cette situation empêche le conseil d'arbitrer.

(b) Proposez une échelle commune, avec des critères d'impact exprimés en FCFA et en durée d'indisponibilité.

(c) Reclassez sur cette échelle le risque « échec d'une migration du système central ».

✍ Exercice 9.3. Une stratégie normative pour NOUN PAY ★★★

Les investisseurs de NOUN PAY exigent « des certifications internationales ». Les moyens de l'entreprise ne permettent d'en viser qu'une dans les deux ans.

(a) Comparez l'intérêt d'une certification ISO/IEC 27001 et d'une certification ISO/IEC 20000-1 pour NOUN PAY.

(b) Proposez un périmètre réaliste pour la certification retenue.

(c) Indiquez les référentiels que l'entreprise suivra par simple alignement volontaire, et pourquoi.

(d) Rédigez la réponse de Mme KAMGA aux investisseurs, en distinguant certification, conformité légale (loi n° 2024/017) et alignement.

Note

Transition. Les normes sont des engagements volontaires ; la loi, elle, s'impose. Le Chapitre 10 présente le cadre juridique et réglementaire camerounais et africain de la gouvernance des SI : cybersécurité, communications électroniques, données personnelles, réglementation bancaire et droit des sociétés.

10

CADRE JURIDIQUE ET RÉGLEMENTAIRE CAMEROUNAIS ET AFRICAIN

« Nul n'est censé ignorer la loi, pas même le DSI. »

Adage revisité

Niveau : *Fondamental* • Maîtrise du Chapitre 9 (normes, certification, conformité).

✦ Objectifs du chapitre

- ➢ Identifier les obligations des lois n° 2010/012 et 2010/013 qui touchent la gouvernance des SI.
- ➢ Exposer le rôle de l'ANTIC et des autres régulateurs (ART, COBAC).
- ➢ Appliquer les exigences de la loi de 2024 sur les données personnelles à un système d'information.
- ➢ Situer les responsabilités des dirigeants dans le droit OHADA.
- ➢ Identifier les obligations de contrôle interne et de risque opérationnel des banques en zone CEMAC.
- ➢ Situer la Convention de Malabo.

Question directrice : quelles obligations ont été méconnues ?

Trois semaines après la panne, le conseil d'administration de la BANQUE SANAGA reçoit une note de son avocat. Elle commence ainsi : « La banque risque d'avoir à répondre de ses manquements devant trois autorités au moins : la COBAC, au titre du contrôle interne ; l'ANTIC, au titre de la sécurité de ses systèmes d'information ; et, le cas échéant, les juridictions, au titre de la responsabilité de ses dirigeants. » À Bafoussam, NOUN PAY reçoit au même moment une demande d'information de l'Autorité de protection des données à caractère personnel sur son modèle de notation.

Ce chapitre dresse la carte de ces obligations. Il suit l'ordre du modèle : le fait, la règle, le texte, l'analyse. Il présente d'abord le panorama des textes (section 10.1), puis la loi sur la cybersécurité (section 10.2), les régulateurs (section 10.3), les données

© MaletYon

personnelles (section 10.4), la réglementation bancaire (section 10.5), le droit des sociétés (section 10.6) et le cadre africain (section 10.7). Il se termine par les erreurs de qualification les plus fréquentes (section 10.8).

★ Attention

Règle de lecture. Ce chapitre cite textuellement les seuls articles dont le texte a pu être vérifié. Pour les autres, il en décrit la substance d'après des sources secondaires identifiées, sans guillemets. Avant tout usage professionnel (avis juridique, rapport au régulateur), reportez-vous au texte publié au Journal officiel.

10.1 Panorama des Textes

Texte	Objet	Autorité	Cas du cours
Loi n° 2010/012 du 21 décembre 2010	Cybersécurité et cybercriminalité	ANTIC	Tous
Loi n° 2010/013 du 21 décembre 2010, modifiée en 2015	Communications électroniques	ART, MINPOSTEL	NOUN PAY
Loi n° 2024/017 du 23 décembre 2024	Protection des données à caractère personnel	Autorité de protection des données	NOUN PAY, SANAGA
Règlement COBAC R-2016/04	Contrôle interne des établissements de crédit	COBAC	SANAGA
Acte uniforme OHADA (révisé en 2014)	Sociétés commerciales, responsabilité des dirigeants	Juridictions	SANAGA, KRIBILOG
Lois n° 2017/010 et 2017/011	Établissements et entreprises publics	Tutelle	ANPP
Loi n° 2018/012	Régime financier de l'État	MINFI, Chambre des comptes	ANPP
Convention de Malabo (2014)	Cybersécurité et données personnelles en Afrique	Union africaine	·

Tableau 10.1. Les principaux textes applicables à la gouvernance des SI au Cameroun

10.2 La Loi sur la Cybersécurité

10.2.1 L'ANTIC, régulateur de la sécurité

La loi n° 2010/012 confie la régulation de la sécurité électronique à l'Agence nationale des technologies de l'information et de la communication (ANTIC), instituée par la loi sur les communications électroniques [29].

⚖ Jurisprudence & Droit applicable

Loi n° 2010/012, article 7, alinéa 2 (version anglaise officielle) :

« The Agency [...] shall be responsible for the regulation, control and monitoring of activities related to the security of electronic communication networks, information systems, and electronic certification on behalf of the State. »

Soit : l'Agence est chargée, pour le compte de l'État, de la régulation, du contrôle et du suivi des activités liées à la sécurité des réseaux de communications électroniques, des systèmes d'information et de la certification électronique. Parmi ses missions, la loi énumère notamment le contrôle des activités de sécurité des systèmes d'information, la régularité et l'efficacité des audits de sécurité, et la veille sur les risques informatiques et la cybercriminalité.

10.2.2 Les obligations des exploitants de systèmes d'information

La loi impose aux exploitants de systèmes d'information (*operators of information systems*) un ensemble d'obligations qui recoupent directement plusieurs objectifs de COBIT.

⚖ Jurisprudence & Droit applicable

Loi n° 2010/012, article 26, alinéa 1 :

« Operators of information systems shall take every technical and administrative measure to ensure the security of services offered. To this end, they shall have standardized systems enabling them to at all times identify, assess, process or manage any risk relating to the security of the information systems of the services provided directly or indirectly. »

Article 29, alinéa 1 : *« Operators of information systems shall be bound to conserve the connection and traffic data of their information systems for a period of 10 (ten) years. »*

Article 30, alinéa 1 : *« Operators of information systems shall assess and revise their security systems and, where necessary, make the appropriate modifications to their security practices, measures and techniques according to technological change. »*

Analyse. L'article 26 impose plus qu'une sécurité technique : il exige des *dispositifs normalisés* permettant d'identifier, d'évaluer et de traiter en permanence les risques de sécurité. C'est, en termes de gouvernance, l'exigence d'un processus de gestion des risques (APO12) et d'un système de management de la sécurité (APO13), dont l'ISO/IEC 27001 fournit précisément le modèle. L'article 30 consacre l'amélioration continue. L'article 29 impose une durée de conservation des données de connexion et de trafic de dix ans, qui pèse sur l'architecture et le budget de stockage.

Article	Obligation	Objectifs COBIT concernés
13 et 32	Audit de sécurité obligatoire et périodique	MEA03, MEA04
26	Mesures de sécurité, dispositifs normalisés de gestion des risques	APO12, APO13, DSS05
29	Conservation des données de connexion et de trafic pendant dix ans	APO14, DSS01, DSS05
30	Évaluation et révision des dispositifs de sécurité	APO13, MEA01
31	Disponibilité des contenus et des données	DSS04, BAI04
42	Confidentialité des informations acheminées	DSS05, APO14

Tableau 10.2. Obligations de la loi n° 2010/012 et objectifs COBIT correspondants

10.2.3 Les sanctions et la responsabilité des personnes morales

Jurisprudence & Droit applicable

Loi n° 2010/012, article 64, alinéas 1 à 3 :

« (1) Corporate bodies shall be criminally liable for offences committed on their account by their management structures. (2) The criminal liability of corporate bodies shall not preclude that of natural persons who commit such offences or are accomplices. (3) The penalties to be meted out on defaulting corporate bodies shall be fines of from 5 000 000 (five million) to 50 000 000 (fifty million) CFA francs. »

Analyse. La personne morale répond pénalement des infractions commises pour son compte par ses organes de direction, sans que cela exonère les personnes physiques. L'article prévoit en outre des peines complémentaires (dissolution, interdiction d'activité, fermeture d'établissement) dans les cas les plus graves. L'article 63 punit par ailleurs d'emprisonnement et d'amende le dirigeant de droit ou de fait de certains prestataires (fournisseurs d'accès et d'hébergement) qui ne conserve pas les données exigées par les articles 25 et 29. La gouvernance des SI n'est donc pas qu'une question de performance : elle engage la responsabilité pénale de l'organisation et, dans certains cas, celle de ses dirigeants.

Application DSI

La conservation des données pendant dix ans

1. Établir si l'organisation est « exploitant de système d'information » au sens de la loi : une banque, un opérateur, une administration le sont presque toujours.

2. Recenser les données de connexion et de trafic produites (journaux d'accès, journaux réseau, traces des applications).
3. Définir l'architecture de conservation : durée, intégrité (les journaux ne doivent pas pouvoir être modifiés), confidentialité, coût sur dix ans.
4. Concilier cette obligation avec le principe de limitation de la conservation des données personnelles (section 10.4) : les deux textes doivent être lus ensemble, avec un avis juridique.

10.3 Les Régulateurs

La gouvernance des SI d'une organisation camerounaise s'exerce sous le regard de plusieurs autorités, qu'il faut savoir distinguer.

Autorité	Fondement	Ce qui intéresse la gouvernance des SI
MINPOSTEL	Ministère chargé des télécommunications	Politique du secteur ; destinataire des rapports d'audit de sécurité (loi n° 2010/012, art. 32)
ANTIC	Lois n° 2010/012 et 2010/013	Sécurité des systèmes d'information, audits, certification électronique, veille
ART	Loi n° 2010/013 modifiée	Régulation des communications électroniques et des opérateurs
Autorité de protection des données	Loi n° 2024/017	Traitements de données personnelles, plaintes, sanctions
COBAC	Réglementation bancaire de la CEMAC	Contrôle interne et risques des établissements de crédit, dont le risque informatique
Chambre des comptes	Contrôle des finances publiques	Audit des établissements et entreprises publics, y compris de leurs SI

Tableau 10.3. Les autorités de la gouvernance des SI au Cameroun

La loi n° 2010/013 régit les communications électroniques ; elle a été modifiée et complétée par la loi n° 2015/006 du 20 avril 2015. Elle institue l'Agence de régulation des télécommunications (ART) et l'ANTIC. Ses dispositions intéressent surtout les opérateurs et les fournisseurs de services de communications électroniques : une entreprise de paiement mobile comme NOUN PAY, qui s'appuie sur les réseaux des opérateurs, doit en connaître les grandes règles. Le recueil des textes publié par l'ART en donne la version consolidée.

10.4 La Protection des Données Personnelles

10.4.1 De la loi de 2010 à la loi de 2024

La loi n° 2010/012 posait déjà un principe général.

⚖ Jurisprudence & Droit applicable

Loi n° 2010/012, articles 41 et 42 :

« 41. Every individual shall have the right to the protection of their privacy. [. . .] 42. The confidentiality of information channelled through electronic communication and information systems networks, including traffic data, shall be ensured by operators of electronic communication and networks information systems. »

Portée. Ces articles affirment le droit au respect de la vie privée et l'obligation de confidentialité des exploitants. Ils ne constituaient pas, à eux seuls, un régime complet de protection des données personnelles : c'est l'objet de la loi de 2024.

10.4.2 La loi n° 2024/017

La loi n° 2024/017 du 23 décembre 2024 relative à la protection des données à caractère personnel a doté le Cameroun d'un régime complet. D'après les présentations publiées [6], elle a accordé aux organisations un délai de dix-huit mois pour se mettre en conformité, et s'applique pleinement depuis le 23 juin 2026. Elle institue une Autorité de protection des données à caractère personnel, organisme public indépendant, encadre strictement le transfert des données hors du territoire national, consacre une part importante de ses dispositions aux obligations des responsables du traitement et de leurs sous-traitants, et prévoit des sanctions pénales.

★ Attention

À vérifier avant usage. Les numéros d'articles, les définitions exactes (responsable du traitement, sous-traitant, données sensibles), les conditions du transfert des données hors du Cameroun et l'éventuelle obligation de désigner un délégué à la protection des données doivent être lus dans le texte publié et ses décrets d'application. Les présentations disponibles divergent sur certains de ces points.

10.4.3 Ce que la loi change pour la gouvernance des SI

Quelle que soit la lettre exacte de ses articles, une loi de protection des données de cette génération a des conséquences directes sur la gouvernance des SI :

- **un inventaire des traitements** : savoir quelles données personnelles sont traitées, pourquoi, où et par qui (APO14) ;
- **la sécurité des traitements** : mesures techniques et organisationnelles proportionnées aux risques (APO13, DSS05) ;

- **la maîtrise des sous-traitants** : un hébergeur ou un fournisseur de nuage traite les données pour le compte de l'organisation, qui en reste responsable (APO10) ;
- **la localisation des données** : tout transfert hors du territoire doit être examiné au regard de la loi (BAI03, APO10) ;
- **la conformité démontrable** : registres, analyses d'impact, preuves (MEA03).

Scénario Opérationnel · Opération NOUN. La demande de l'Autorité

Faits. L'Autorité de protection des données demande à NOUN PAY : la liste des données utilisées par son modèle de notation de crédit, le lieu où elles sont hébergées, la base juridique du traitement, et la manière dont un client refusé peut contester la décision.

Constatation. NOUN PAY ne dispose d'aucun inventaire de ses traitements. Ses données sont hébergées dans un centre de données situé hors d'Afrique, en vertu d'un contrat type du fournisseur. Aucune procédure ne permet à un client de contester un refus.

Analyse (confiance moyenne, sous réserve de la lecture du texte de la loi). Trois manquements probables : l'absence d'inventaire, un transfert hors du territoire non examiné au regard de la loi, et l'absence de recours contre une décision automatisée. Le Chapitre 19 reprendra le cas sous l'angle de la gouvernance de l'intelligence artificielle.

10.5 La Réglementation Bancaire de la CEMAC

10.5.1 Le règlement COBAC R-2016/04

Les établissements de crédit de la zone CEMAC sont soumis à la réglementation de la Commission bancaire de l'Afrique centrale. Le règlement COBAC R-2016/04, relatif au contrôle interne dans les établissements de crédit et les holdings financières, est le texte de référence pour la gouvernance des SI d'une banque [7].

Jurisprudence & Droit applicable

Règlement COBAC R-2016/04, articles 1 et 2 (texte relevé sur une base réglementaire en ligne) :

Article 1 : *« Le présent règlement fixe les exigences minimales relatives au système de contrôle interne que les établissements assujettis doivent mettre en œuvre. »*

Article 2, définition du risque opérationnel : *« risque de pertes résultant de l'inadéquation ou de la défaillance des processus internes, des personnes et des systèmes, ou d'évènements externes. »* Le même article précise que ce risque inclut le risque juridique, et exclut les risques stratégiques et de réputation.

Analyse. La défaillance d'un système informatique est, par définition, un risque opérationnel au sens du règlement. La panne de la BANQUE SANAGA relève donc du dispositif de contrôle interne exigé par la COBAC, et non d'un simple incident technique. Selon les présentations du règlement, celui-ci impose en outre un dispositif d'identification, de mesure et de surveillance de chaque risque, appuyé sur une cartographie des risques, et compte un système de traitement de l'information parmi les composantes du dispositif de contrôle interne.

10.5.2 Ce que cela implique

Application Responsable GRC

Rédiger la partie SI du rapport à la COBAC

1. Qualifier la panne : incident de risque opérationnel, avec sa chronologie et son coût (Chapitre 0).
2. Situer la défaillance dans le dispositif de contrôle interne : quels contrôles existaient, lesquels n'ont pas fonctionné.
3. Relier le risque informatique à la cartographie des risques de la banque, avec l'échelle commune (Chapitre 9).
4. Présenter le plan d'action, objectif par objectif, à partir de la feuille de route COBIT (Chapitre 8).

10.6 Le Droit des Sociétés OHADA

10.6.1 La responsabilité des dirigeants

L'Acte uniforme OHADA relatif au droit des sociétés commerciales et du groupement d'intérêt économique, révisé le 30 janvier 2014 [1], organise la responsabilité civile des dirigeants sociaux. Selon la doctrine, ses articles 161 et suivants posent le régime général : le dirigeant répond des fautes qu'il commet dans l'exercice de ses fonctions, individuellement ou solidairement selon sa participation, et peut être poursuivi par la société (action sociale) ou par les tiers lésés. Pour la société anonyme, l'article 740 rend les administrateurs responsables, individuellement ou solidairement, envers la société ou envers les tiers.

Un défaut de gouvernance des SI peut-il être une faute de gestion ?

La question n'a pas, à notre connaissance, été tranchée par une jurisprudence publiée en zone OHADA. Mais le raisonnement est accessible : si une banque soumise à des obligations précises (contrôle interne, sécurité des systèmes) subit une perte majeure parce que ses dirigeants ont maintenu une bascule malgré une alerte écrite, sans décision formelle d'acceptation du risque, la qualification de faute de gestion pourra être discutée. La trace écrite des décisions (Chapitre 0) n'est donc pas une formalité : elle est la première défense d'un dirigeant diligent, et la première pièce d'un dossier contre un dirigeant négligent.

10.6.2 Le comité d'audit et le contrôle interne

Le Chapitre 1 a présenté l'article 829-1 de l'Acte uniforme révisé, qui rend le comité d'audit obligatoire dans les sociétés cotées et le charge du suivi de l'efficacité des systèmes de contrôle interne et de gestion des risques. Pour les entreprises et établissements publics, les lois n° 2017/010 et 2017/011 et leur décret d'application organisent le conseil d'administration et la tutelle : la gouvernance des SI de l'ANPP doit s'inscrire dans ce cadre, et dans celui du régime financier de l'État (Chapitre 3).

10.7 Le Cadre Africain

10.7.1 La Convention de Malabo

La Convention de l'Union africaine sur la cybersécurité et la protection des données à caractère personnel, adoptée à Malabo le 27 juin 2014, est entrée en vigueur le 8 juin 2023, trente jours après le dépôt du quinzième instrument de ratification. Elle couvre trois domaines : les transactions électroniques, la protection des données personnelles, et la cybersécurité et la lutte contre la cybercriminalité. Elle oblige les États parties à se doter d'une législation et d'autorités dans ces domaines.

★ **Attention**

À vérifier. Nous n'avons pas trouvé de source établissant que le Cameroun a ratifié la Convention de Malabo. Avant de l'invoquer comme source de droit applicable au Cameroun, consultez la liste officielle des signatures et ratifications tenue par l'Union africaine. Elle reste en tout état de cause une référence de politique publique pour le continent.

10.7.2 Une dynamique continentale

Le Cameroun n'est pas seul. Plusieurs États africains se sont dotés de lois de protection des données personnelles depuis la fin des années 2000, par exemple le Sénégal (loi n° 2008-12 du 25 janvier 2008) ou la Côte d'Ivoire (loi n° 2013-450 du 19 juin 2013). Pour une organisation qui opère dans plusieurs pays de la sous-région, comme une banque de la zone CEMAC ou une entreprise de paiement mobile, la gouvernance des SI doit tenir un registre des obligations pays par pays.

10.8 Les Erreurs de Qualification

Erreur	Pourquoi c'est une erreur
« La panne est un incident technique, pas un sujet réglementaire. »	Pour une banque, la défaillance d'un système est un risque opérationnel au sens du règlement COBAC R-2016/04.
« Nous sommes certifiés ISO 27001, l'audit de l'ANTIC est inutile. »	La certification est volontaire ; l'audit prévu par la loi n° 2010/012 est obligatoire.
« Nos données sont chez un prestataire, c'est lui le responsable. »	L'externalisation ne transfère pas la responsabilité du traitement ni celle de la sécurité (loi n° 2010/012, art. 26 ; loi n° 2024/017).
« Nos serveurs sont à l'étranger, la loi camerounaise ne s'applique pas. »	Le transfert hors du territoire est précisément encadré par la loi n° 2024/017.
« Seule la société est poursuivie, pas ses dirigeants. »	La responsabilité de la personne morale n'exclut pas celle des personnes physiques (loi n° 2010/012, art. 64 ; AUSCGIE).
« La Convention de Malabo s'applique directement. »	Son applicabilité au Cameroun suppose une ratification qui reste à établir.

Tableau 10.4. Erreurs de qualification fréquentes

Exigence de contrôle

Le registre des obligations légales. Pour démontrer la conformité (objectif MEA03), l'organisation tient un registre qui, pour chaque obligation, indique :

- le texte et l'article, avec la date de la version consultée ;
- l'obligation, reformulée en termes opérationnels ;
- le processus et le propriétaire qui la mettent en œuvre ;
- la preuve de conformité (document, enregistrement, rapport d'audit) ;
- la date de la dernière vérification et son résultat.

Le registre est revu au moins une fois par an, et à chaque nouveau texte.

Application Auditeur SI

Auditer la conformité légale d'un SI

1. Demander le registre des obligations, et vérifier qu'il couvre au moins les textes du Tableau 10.1 applicables à l'organisation.
2. Pour un échantillon d'obligations, demander la preuve de conformité.

3. Vérifier la conservation des journaux (durée, intégrité) au regard de l'article 29 de la loi n° 2010/012.
4. Vérifier que les contrats des sous-traitants traitent de la sécurité, de la localisation des données et de l'audit.

❍

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **La loi n° 2010/012** confie la sécurité électronique à l'ANTIC et impose aux exploitants de systèmes d'information des mesures de sécurité et des dispositifs normalisés de gestion des risques (art. 26), la conservation des données de connexion pendant dix ans (art. 29), la révision des dispositifs (art. 30) et des audits obligatoires (art. 13 et 32).
- **La responsabilité est pénale aussi** : la personne morale répond des infractions commises par ses organes, sans exonérer les personnes physiques (art. 64).
- **La loi n° 2024/017**, applicable depuis juin 2026, organise la protection des données personnelles et crée une autorité dédiée : inventaire, sécurité, sous-traitants, localisation, preuve.
- **Pour les banques**, la défaillance d'un système est un risque opérationnel au sens du règlement COBAC R-2016/04.
- **Le droit OHADA** organise la responsabilité civile des dirigeants et le comité d'audit des sociétés cotées : la trace écrite des décisions est la première défense.
- **La Convention de Malabo** est en vigueur depuis 2023 ; son applicabilité au Cameroun est à vérifier.
- **Ne citer que ce qu'on a vérifié** : un rapport au régulateur se fonde sur le texte publié, pas sur un résumé.

✍ Exercice 10.1. Qui est compétent ? ★☆☆

Pour chacune des situations suivantes, indiquez l'autorité principalement compétente (Tableau 10.3) et le texte en cause.

(a) Une banque n'a pas fait réaliser l'audit de sécurité de ses systèmes depuis trois ans.

(b) Un client de NOUN PAY conteste l'usage de ses données par le modèle de notation.

(c) Le dispositif de contrôle interne d'une banque n'a pas détecté une migration non autorisée.

(d) Un établissement public a acquis un logiciel hors de tout programme budgétaire.

✍ Exercice 10.2. Le registre de KRIBILOG ★★☆

KRIBILOG SA exploite un système de suivi des conteneurs qui enregistre les données des chauffeurs (nom, numéro de permis, téléphone) et les journaux d'accès des clients au portail web. L'exploitation est confiée à NETPORT SERVICES, qui héberge une partie des données à l'étranger.

(a) Établissez les cinq premières lignes du registre des obligations légales de KRIBILOG, sur le modèle de l'exigence de contrôle de la section 10.8.

(b) Pour chacune, indiquez si le texte a pu être vérifié, et sinon, où le vérifier.

(c) Quelles clauses faut-il ajouter au contrat de NETPORT SERVICES ?

✍ Exercice 10.3. La note au conseil de la BANQUE SANAGA ★★★

Rédigez, à l'attention du conseil d'administration, la note juridique évoquée en ouverture du chapitre.

(a) Qualifiez la panne au regard du règlement COBAC R-2016/04 et de la loi n° 2010/012, en citant uniquement les articles vérifiés.

(b) Identifiez les obligations probablement méconnues, en séparant constatations et analyses, et en donnant un niveau de confiance.

(c) Discutez l'exposition éventuelle des dirigeants au regard du droit OHADA, en signalant ce qui reste incertain.

(d) Proposez trois mesures immédiates pour réduire le risque juridique de la banque.

● Note

Transition. Les obligations ne valent que si quelqu'un vérifie qu'elles sont tenues. Le Chapitre 11 présente l'audit, le contrôle et l'assurance de la gouvernance des SI : le modèle des trois lignes, les normes de l'audit interne, l'audit public selon l'INTOSAI, et le test des contrôles généraux informatiques.

11

AUDIT, CONTRÔLE ET ASSURANCE DE LA GOUVERNANCE DES SI

« Une réponse orale n'est pas une preuve. »

Règle des auditeurs

Niveau : *Intermédiaire* • Maîtrise des Chapitres 8 (évaluation de capacité) et 10 (obligations légales).

✦ Objectifs du chapitre

- ➢ Appliquer le modèle des trois lignes.
- ➢ Situer les Normes mondiales d'audit interne de l'IIA (2024) et le cadre de 2017.
- ➢ Mener un audit des SI selon l'INTOSAI GUID 5100 dans le secteur public.
- ➢ Tester des contrôles généraux informatiques (accès, changements, exploitation).
- ➢ Rédiger un constat d'audit qui sépare constatation, critère, cause, conséquence et recommandation.
- ➢ Identifier les exigences déontologiques de l'auditeur et du DSI.

Question directrice : qui vérifie que tout cela fonctionne ?

Les chapitres précédents ont construit un système de gouvernance, fixé des capacités cibles et dressé la liste des obligations légales. Il reste une question : *qui vérifie, et avec quelle indépendance, que ce système fonctionne réellement ?* À Yaoundé, la Chambre des comptes vient d'annoncer à l'ANPP (opération MEFOU) un audit de ses systèmes d'information. À Douala, Mme EKAMBI, directrice de l'audit interne de la BANQUE SANAGA, doit expliquer au comité d'audit pourquoi sa recommandation d'octobre 2025 est restée sans suite.

Ce chapitre présente l'organisation de l'assurance (le modèle des trois lignes, section 11.1), les normes de l'audit interne (section 11.2) et de l'audit public (section 11.3), la pratique du test des contrôles généraux informatiques (section 11.4), la rédaction des constats (section 11.5) et la déontologie (section 11.6). Le laboratoire GCI-LAB-05 fait

© MaletYon

tester des contrôles à partir des pièces de l'ANPP.

11.1 Le Modèle des Trois Lignes

11.1.1 Qui fait quoi dans la maîtrise des risques

L'Institut des auditeurs internes (IIA) a publié en 2020 le **modèle des trois lignes** (*Three Lines Model*), qui a succédé au modèle des « trois lignes de défense ». Il répartit les rôles entre l'organe de gouvernance, le management et l'audit interne [43].

Acteur	Rôle	À la BANQUE SANAGA
Organe de gouvernance	Rend compte aux parties prenantes, fixe la direction, supervise	Conseil d'administration, comité d'audit, comité stratégique des SI
Première ligne	Le management opérationnel, qui porte et maîtrise les risques dans ses activités	DSI, exploitation, chefs de projet, métiers
Deuxième ligne	Les fonctions d'expertise, de soutien et de surveillance des risques	Gestion des risques, conformité, RSSI, responsable GRC
Troisième ligne	L'audit interne, qui fournit une assurance indépendante et objective	Direction de l'audit interne (Mme EKAMBI)
Prestataires d'assurance externes	Assurance complémentaire, indépendante de l'organisation	Commissaire aux comptes, COBAC, audit de sécurité prévu par la loi n° 2010/012

Tableau 11.1. Le modèle des trois lignes appliqué à la BANQUE SANAGA

11.1.2 Trois erreurs fréquentes

1. **Confier la deuxième ligne à la première.** Un RSSI rattaché au DSI, et noté par lui, ne peut pas surveiller librement les risques que le DSI prend. Le modèle ne prescrit pas un rattachement, mais il exige que la deuxième ligne puisse remonter ses alertes sans filtre.
2. **Faire faire le travail de la première ligne par la troisième.** Un audit interne qui rédige les procédures qu'il auditera ensuite perd son indépendance.
3. **Croire que l'audit est responsable du risque.** La troisième ligne donne une assurance ; elle ne maîtrise pas le risque. La recommandation non suivie de Mme EKAMBI n'est pas une faute de l'audit : c'est une défaillance du suivi par la première ligne et par le comité d'audit (MEA02).

11.2 Les Normes de l'Audit Interne

11.2.1 Du cadre de 2017 aux Normes mondiales de 2024

L'IIA définit l'audit interne comme une activité indépendante et objective qui donne à une organisation une assurance sur le degré de maîtrise de ses opérations, lui apporte des conseils pour les améliorer et contribue à créer de la valeur, en évaluant de manière systématique ses processus de gouvernance, de management des risques et de contrôle [42].

Jusqu'en 2024, la profession se référait au *Cadre de référence international des pratiques professionnelles* (CRIPP), dans son édition de 2017, disponible en français dans le dossier `Normes`. Il comprenait notamment la définition de l'audit interne, le Code de déontologie et des normes réparties entre normes de qualification (série 1000) et normes de fonctionnement (série 2000).

En janvier 2024, l'IIA a publié les **Normes mondiales d'audit interne** (*Global Internal Audit Standards*), applicables depuis janvier 2025 [44]. Elles remplacent le CRIPP et s'organisent en cinq domaines :

Dom.	Intitulé	Contenu
I	Raison d'être de l'audit interne	Ce que l'audit interne apporte à l'organisation
II	Éthique et professionnalisme	Intégrité, objectivité, compétence, conscience professionnelle, confidentialité
III	Gouvernance de la fonction d'audit interne	Relation avec le conseil, mandat, indépendance, supervision
IV	Management de la fonction d'audit interne	Stratégie, ressources, méthodologie, qualité
V	Réalisation des missions	Planification, conduite, communication des résultats, suivi

Tableau 11.2. Les cinq domaines des Normes mondiales d'audit interne (2024, notre traduction)

Le domaine III est le plus directement lié à la gouvernance : il place expressément sous la responsabilité du conseil la supervision de la fonction d'audit interne, son mandat et les moyens de son indépendance.

★ Attention

Violation typique. La charte d'audit interne de la BANQUE SANAGA date de 2015 et renvoie aux « normes de l'IIA » sans préciser l'édition. Le plan d'audit est approuvé par le directeur général, et non par le comité d'audit.

Règle : la charte d'audit doit se référer aux Normes mondiales de 2024, et le plan d'audit comme les moyens de la fonction doivent être approuvés par l'organe de gouvernance, non par la direction auditée.

11.3 L'Audit Public des SI : l'INTOSAI GUID 5100

11.3.1 Les institutions supérieures de contrôle

Dans le secteur public, l'audit externe relève des institutions supérieures de contrôle des finances publiques (ISC), qui appliquent les normes de l'INTOSAI (les ISSAI). Au Cameroun, cette fonction est assurée par la Chambre des comptes de la Cour suprême. Le GUID 5100 de l'INTOSAI (2019) fournit le cadre général de la vérification des systèmes d'information [21].

Définition

Vérification des systèmes d'information (*information systems audit*) : selon le GUID 5100, examen des contrôles liés aux systèmes d'information pour déceler les écarts par rapport à des critères, définis selon le type de mission (audit financier, de conformité ou de performance).

Contrôles généraux : procédures manuelles ou automatisées qui visent à assurer la confidentialité, l'intégrité et la disponibilité de l'information dans l'environnement où les systèmes sont développés, gérés et exploités.

Contrôles d'application : procédures, dépendantes des TI, intégrées à un système et qui agissent sur le traitement des transactions : validation des données d'entrée, exactitude du traitement, contrôle des sorties, intégrité des données de référence.

11.3.2 La démarche du GUID 5100

Le GUID 5100 suit les quatre étapes de tout audit public : planification, réalisation, rapport et suivi. Trois de ses apports sont particulièrement utiles.

Les trois risques d'audit. L'auditeur apprécie le *risque inhérent* (la probabilité que les caractéristiques mêmes d'un système nuisent à la fonction qu'il remplit), le *risque de contrôle* (la probabilité que les contrôles mis en place ne suffisent pas) et le *risque de détection* (la probabilité que l'auditeur lui-même ne décèle pas une défaillance). Le portail de paiement de l'ANPP, ouvert à tous les fournisseurs de l'État, porte un risque inhérent élevé de saturation.

Treize domaines. Le GUID 5100 propose de délimiter la vérification parmi treize domaines, dont la plupart sont adaptés de l'ISO/IEC 27001 : politique de l'organisation en matière de TI, structures de gouvernance, contrôles généraux, gestion des actifs, développement et maintenance, exploitation, environnement physique, ressources humaines, communications, sécurité de l'information, conformité réglementaire, continuité et reprise, contrôles d'application.

Conception, mise en œuvre, efficacité. Le GUID 5100 distingue trois niveaux d'examen d'un contrôle. Pour la *conception*, un entretien ou l'examen des règles docu-

mentées peut suffire. Pour la *mise en œuvre*, l'entretien ne suffit plus : il faut une revue structurée ou une analyse de données. Pour l'*efficacité opérationnelle*, il faut tester un échantillon d'opérations sur toute la période.

Exigence de contrôle

Recevoir une extraction de données. Le GUID 5100 recommande que toute extraction de données remise par l'entité auditée soit accompagnée d'une lettre qui précise :

- la source des données et leur horodatage, avec l'empreinte numérique (valeur de hachage) du fichier, pour en garantir l'intégrité ;
- les paramètres d'extraction (requêtes utilisées, états exécutés) ;
- l'environnement d'origine (production ou autre).

À défaut de lettre, l'auditeur documente lui-même ces informations.

Scénario Opérationnel · Opération MEFOU. La lettre de mission de la Chambre des comptes

Mandat. Audit de conformité et de performance des systèmes d'information de l'ANPP, période 2023–2026.

Délimitation retenue (parmi les treize domaines) : structures de gouvernance des TI, développement et acquisition (le schéma directeur de 14 milliards FCFA), contrôles généraux (accès et changements) et conformité réglementaire.

Critères. Le régime financier de l'État (loi n° 2018/012), la loi n° 2010/012, les procédures internes de l'agence et, comme référentiel de bonnes pratiques, COBIT 2019.

Équipe. Le magistrat vérificateur, M. NJOYA, est assisté d'un auditeur des SI certifié, recruté sur contrat, conformément à la possibilité qu'ouvre le GUID 5100 de recourir à des ressources externes supervisées.

11.4 Tester les Contrôles Généraux Informatiques

11.4.1 Trois familles de contrôles

Les contrôles généraux informatiques (Chapitre 1) conditionnent la fiabilité de toutes les applications. L'auditeur les teste en priorité, parce que leur défaillance invalide la confiance que l'on peut accorder aux contrôles automatisés des applications : si n'importe qui peut modifier un programme, le contrôle que ce programme réalise ne vaut plus rien.

Famille	Contrôles typiques	Test typique
Accès	Création et suppression des comptes, revue périodique des droits, comptes à privilèges	Rapprocher la liste des comptes actifs de la liste des agents présents
Changements	Autorisation, test, séparation entre développement et production, mise en production tracée	Vérifier, sur un échantillon de changements, l'autorisation préalable et le test
Exploitation	Sauvegardes et tests de restauration, ordonnancement des traitements, gestion des incidents	Vérifier les journaux de sauvegarde et la preuve d'une restauration réussie

Tableau 11.3. Les trois familles de contrôles généraux informatiques

11.4.2 L'échantillonnage

On ne teste pas tous les comptes ni tous les changements : on échantillonne. La taille de l'échantillon dépend de la fréquence du contrôle et du risque. Les cabinets d'audit utilisent couramment des ordres de grandeur comme ceux du tableau suivant ; ce ne sont pas des exigences normatives, et chaque organisation d'audit fixe sa propre méthode.

Fréquence du contrôle	Échantillon indicatif
Annuelle	1
Trimestrielle	2
Mensuelle	2 à 5
Hebdomadaire	5 à 15
Quotidienne	20 à 40
Plusieurs fois par jour	25 à 60

Tableau 11.4. Ordres de grandeur d'échantillonnage pratiqués en audit (indicatifs)

Scénario Opérationnel · Opération MEFOU. Le test des accès

Test. L'auditeur rapproche la liste des 312 comptes actifs du système de paiement de l'ANPP et la liste du personnel au 30 juin 2026 fournie par les ressources humaines. Il examine en outre un échantillon de 25 comptes pour vérifier que les droits correspondent aux fonctions.

Résultats. 14 comptes appartiennent à des agents partis de l'agence, dont 3 depuis plus d'un an ; l'un de ces comptes a été utilisé en mai 2026. Sur les 25 comptes examinés, 6 cumulent les droits de saisie et de validation d'un paiement. Aucune

revue des droits n'a été documentée depuis 2023.

Qualification. Le contrôle « revue périodique des accès » n'est pas mis en œuvre ; le contrôle « séparation des tâches » est défaillant. Ces écarts relèvent des objectifs DSS05 et DSS06 de COBIT et de l'obligation de dispositifs de sécurité de l'article 26 de la loi n° 2010/012 (Chapitre 10).

Application Auditeur SI

Tester un contrôle en cinq temps

1. Décrire le contrôle tel qu'il est censé fonctionner (qui, quoi, quand, avec quelle preuve).
2. Vérifier sa conception : le contrôle, s'il fonctionne, traite-t-il le risque ?
3. Vérifier sa mise en œuvre sur un cas (test de cheminement).
4. Tester son efficacité sur un échantillon couvrant la période.
5. Documenter chaque pièce examinée, et conclure : efficace, partiellement efficace, inefficace.

11.5 Rédiger un Constat d'Audit

11.5.1 Les cinq éléments

Un constat d'audit n'est pas une opinion : c'est un raisonnement en cinq éléments, que l'on retrouve dans les normes de l'IIA comme dans celles de l'INTOSAI.

Élément	Question	Exemple (ANPP)
Constatation	Que se passe-t-il réellement ?	14 comptes d'agents partis restent actifs ; l'un a été utilisé en mai 2026
Critère	Que devrait-il se passer ?	Procédure interne : désactivation sous 48 heures ; loi n° 2010/012, art. 26
Cause	Pourquoi l'écart existe-t-il ?	Les départs ne sont pas notifiés par les RH à la division informatique
Conséquence	Quel risque ou quel effet ?	Paiement frauduleux possible au nom d'un agent parti ; exposition juridique
Recommandation	Que faut-il faire ?	Notification automatique des départs, revue trimestrielle des accès

Tableau 11.5. Les cinq éléments d'un constat d'audit

★ Attention

Violation typique. « La sécurité des accès est insuffisante et doit être renforcée. » Cette phrase ne contient ni constatation chiffrée, ni critère, ni cause : elle ne peut être ni vérifiée ni mise en œuvre, et l'audité peut la contester sans peine.

Règle : chaque constat chiffre la constatation, cite son critère, identifie la cause, mesure la conséquence, et formule une recommandation qui traite la *cause*, et non le symptôme.

11.5.2 Le suivi des recommandations

Une recommandation non suivie est une assurance perdue. Le suivi relève de la première ligne (qui met en œuvre), de l'audit interne (qui vérifie) et de l'organe de gouvernance (qui exige). C'est l'objectif MEA02 de COBIT.

☑ Exigence de contrôle

Le tableau de suivi des recommandations. Pour chaque recommandation, le tableau présenté au comité d'audit indique :

- la date du rapport et la priorité de la recommandation ;
- le responsable de la mise en œuvre et l'échéance convenue ;
- l'état (non commencée, en cours, mise en œuvre, vérifiée) ;
- pour l'état « mise en œuvre », la pièce qui le prouve ;
- les reports d'échéance, avec leur motif et leur approbation.

La mention « en cours » sans échéance ni pièce, qui figurait dans le rapport de la BANQUE SANAGA d'octobre 2025, est précisément ce qu'il faut proscrire.

11.6 La Déontologie

11.6.1 L'auditeur

Le Code de déontologie de l'IIA (édition 2017) pose quatre principes, que les Normes mondiales de 2024 reprennent dans leur domaine II en y ajoutant la conscience professionnelle [42].

Principe	Exigence (résumé)
Intégrité	Elle fonde la confiance accordée au jugement de l'auditeur : honnêteté, diligence, responsabilité.
Objectivité	L'auditeur évalue équitablement tous les éléments pertinents, sans se laisser influencer par ses intérêts ou par autrui.
Confidentialité	Il respecte la valeur et la propriété des informations reçues, et ne les divulgue qu'avec autorisation, sauf obligation légale ou professionnelle.
Compétence	Il met en œuvre les connaissances, les savoir-faire et l'expérience que requiert sa mission.

Tableau 11.6. Les principes du Code de déontologie de l'IIA (résumé d'après l'édition française de 2017)

11.6.2 Le DSI

Le DSI n'est pas soumis à un code de déontologie professionnel obligatoire, mais sa position l'expose à des situations délicates : il choisit des fournisseurs et dispose d'accès étendus aux données. Trois règles de conduite en découlent.

- **Déclarer ses conflits d'intérêts**, notamment dans le choix des prestataires, et s'abstenir dans les décisions concernées.
- **Rendre compte loyalement**, y compris des mauvaises nouvelles : la note de la DSI de la BANQUE SANAGA du 20 février 2026 en est l'exemple.
- **Ne pas faire obstacle à l'audit** : donner accès aux pièces et aux systèmes, et ne pas « préparer » les données remises.

L'auditeur peut-il conseiller ?

Oui, et les normes de l'IIA le prévoient expressément : l'audit interne donne une assurance *et* des conseils. Mais il y a une limite. Un auditeur qui conçoit un dispositif ne peut pas, ensuite, en donner une assurance objective. Dans une petite organisation, où l'audit interne compte une ou deux personnes, cette tension est permanente. La solution consiste à déclarer la situation au comité d'audit, et à faire réaliser l'évaluation du dispositif par un tiers.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Trois lignes** : le management porte le risque, les fonctions de deuxième

ligne le surveillent, l'audit interne donne une assurance indépendante, sous la supervision de l'organe de gouvernance.

- **Les Normes mondiales de l'IIA (2024)** remplacent le cadre de 2017 : cinq domaines, dont la gouvernance de la fonction d'audit par le conseil.
- **Le GUID 5100 de l'INTOSAI** guide l'audit public des SI : trois risques d'audit, treize domaines, et la distinction entre conception, mise en œuvre et efficacité des contrôles.
- **Les contrôles généraux informatiques** (accès, changements, exploitation) se testent en priorité, par échantillonnage.
- **Un constat a cinq éléments** : constatation, critère, cause, conséquence, recommandation. La recommandation traite la cause.
- **Le suivi est une responsabilité de gouvernance** : une recommandation « en cours » sans échéance ni pièce est une assurance perdue.
- **La déontologie** repose sur l'intégrité, l'objectivité, la confidentialité et la compétence ; elle concerne aussi le DSI.

✍ Exercice 11.1. Quelle ligne ? ★☆☆

Rattachez chacun des acteurs suivants à la ligne qui convient (première, deuxième, troisième, ou prestataire d'assurance externe), et justifiez.

(a) Le responsable de l'exploitation de la BANQUE SANAGA.

(b) Le RSSI, rattaché au directeur des risques.

(c) Le commissaire aux comptes.

(d) La directrice de l'audit interne.

(e) Le cabinet agréé qui réalise l'audit de sécurité prévu par la loi n° 2010/012.

✍ Exercice 11.2. Rédiger un constat ★★☆

À partir des résultats du test des accès de l'ANPP (section 11.4), rédigez le constat relatif à la séparation des tâches (6 comptes sur 25 cumulant saisie et validation d'un paiement).

(a) Rédigez les cinq éléments du constat.

(b) Proposez une priorité (élevée, moyenne, faible) et justifiez.

(c) Proposez l'indicateur qui permettra au comité d'audit de suivre la mise en œuvre.

✍ Exercice 11.3. Planifier l'audit des changements de la BANQUE SANAGA ★★★

Le comité d'audit demande à Mme EKAMBI un audit de la gestion des changements après la panne.

(a) Rédigez l'objectif, le périmètre et les critères de la mission.

(b) Listez les contrôles à tester, en distinguant conception, mise en œuvre et efficacité, et indiquez pour chacun la pièce attendue.

(c) Déterminez la taille de l'échantillon de changements à examiner, en justifiant au regard de la fréquence des changements.

(d) Mme EKAMBI avait elle-même proposé, en 2025, la procédure de gestion des changements. Quelle difficulté déontologique cela pose-t-il, et comment la traiter ?

Note

Transition. La Partie III a placé la gouvernance des SI sous le regard des normes, de la loi et de l'audit. La Partie IV descend au niveau de la pratique quotidienne. Le Chapitre 12 ouvre la gestion des services avec ITIL 4 et son système de valeur des services.

partie IV

ITIL 4 et Pratique Opérationnelle

© MaletYon

12

ITIL 4 : LE SYSTÈME DE VALEUR DES SERVICES

« La valeur ne se livre pas.
Elle se crée avec celui qui reçoit le service. »

Idée centrale d'ITIL 4

Niveau : *Intermédiaire* • Maîtrise du Chapitre 5 (architecture de COBIT 2019) et du Chapitre 4 (place d'ITIL parmi les référentiels).

✦ Objectifs du chapitre

- ➢ Retracer l'évolution d'ITIL (v2, v3 et son cycle de vie, ITIL 4).
- ➢ Définir service, valeur, produit et relation de service.
- ➢ Décrire le système de valeur des services et sa chaîne de valeur.
- ➢ Appliquer les sept principes directeurs et les quatre dimensions.
- ➢ Situer ITIL version 5 (2026) par rapport à ITIL 4.

Question directrice : que veut vraiment le client ?

Chez KRIBILOG SA, le centre de services traite 4 800 tickets par mois, et 30 % d'entre eux sont rouverts. Les indicateurs de l'infogérant NETPORT SERVICES sont pourtant au vert : les serveurs sont disponibles à 99,8 %. Le directeur des opérations portuaires résume le malentendu : « Vos serveurs fonctionnent, mais mes conteneurs restent bloqués. »

Ce malentendu est l'objet d'ITIL 4. La Partie IV, qui s'ouvre ici, passe de la gouvernance à la pratique quotidienne des services. Ce chapitre en pose les fondations : l'histoire d'ITIL (section 12.1), ses concepts clés (section 12.2), le système de valeur des services et sa chaîne de valeur (sections 12.3 et 12.4), les quatre dimensions et les sept principes (sections 12.5 et 12.6), et enfin la place d'ITIL version 5 (section 12.7).

© MaletYon

12.1 Trente-Cinq Ans d'ITIL

Version	Logique	Apport
Fin des années 1980	Recueil de pratiques	L'administration britannique rassemble les bonnes pratiques de gestion de ses services informatiques
ITIL v2 (2000–2001)	Processus	Deux ouvrages centraux : le soutien et la fourniture des services ; diffusion mondiale
ITIL v3 (2007, révisé en 2011)	Cycle de vie	Cinq étapes : stratégie, conception, transition, exploitation et amélioration continue des services
ITIL 4 (2019)	Système de valeur	Co-création de la valeur, 34 pratiques, intégration de l'agilité, de DevOps et du *lean*
ITIL version 5 (2026)	Produits et services	Voir la section 12.7

Tableau 12.1. Évolution d'ITIL

Le passage d'ITIL v3 à ITIL 4 est le plus profond. ITIL v3 décrivait *comment le fournisseur gère ses services* au long de leur cycle de vie. ITIL 4 décrit *comment la valeur se crée entre le fournisseur et ses clients*, et intègre les méthodes agiles et DevOps qui s'étaient développées en dehors d'ITIL. Le mot « processus » cède la place au mot « pratique », plus large : une pratique comprend des processus, mais aussi des personnes, des informations et des outils, comme les composantes de COBIT (Chapitre 5).

12.2 Les Concepts Clés

12.2.1 Service et valeur

Définition

Service : moyen de permettre la co-création de valeur, en facilitant l'obtention des résultats que le client veut atteindre, sans qu'il ait à gérer lui-même certains coûts et certains risques.

Valeur : bénéfices, utilité et importance perçus de quelque chose. La valeur est *perçue* par celui qui la reçoit : elle ne se décrète pas chez le fournisseur.

Co-création de valeur : idée selon laquelle la valeur naît de la collaboration entre le fournisseur et le consommateur du service, et non de la seule action du fournisseur.

Définitions reformulées d'après ITIL 4 [2].

12.2.2 Résultats, produits et relations

ITIL 4 distingue soigneusement ce que le fournisseur *produit* de ce que le client *obtient*.

Notion	Sens	Exemple KRIBILOG
Livrable (*output*)	Ce qu'une activité produit	Un écran de suivi affiché, un ticket clos
Résultat (*outcome*)	Ce que le client obtient grâce aux livrables	Un conteneur localisé et chargé à l'heure
Produit	Configuration de ressources conçue pour offrir de la valeur	Le logiciel de suivi, l'infrastructure, l'équipe de support
Offre de service	Description d'un ou plusieurs services, pour un groupe de clients	« Suivi des conteneurs 24 h/24, support en 30 minutes »
Relation de service	Coopération entre fournisseur et consommateur	Fourniture, consommation et gestion du service

Tableau 12.2. Les notions clés d'ITIL 4 (reformulées)

Le malentendu de KRIBILOG s'éclaire : NETPORT SERVICES mesure des *livrables* (serveurs disponibles, tickets clos), le directeur des opérations attend un *résultat* (conteneurs chargés). Un ticket clos qui est rouvert le lendemain est un livrable sans résultat.

12.2.3 Utilité et garantie

Définition

Utilité (*utility*) : fonctionnalité offerte par un service pour répondre à un besoin : ce que fait le service.

Garantie (*warranty*) : assurance que le service répondra aux exigences convenues : disponibilité, capacité, sécurité, continuité. C'est *comment* le service le fait.

Un service n'a de valeur que s'il a les deux : une utilité sans garantie (un logiciel parfait, mais indisponible un jour sur deux) n'en a pas davantage qu'une garantie sans utilité.

12.3 Le Système de Valeur des Services

12.3.1 Cinq composantes

Le cœur d'ITIL 4 est le **système de valeur des services** (*service value system*, SVS). Il décrit comment les composantes et les activités d'une organisation fonctionnent ensemble pour transformer une *opportunité* ou une *demande* en *valeur*.

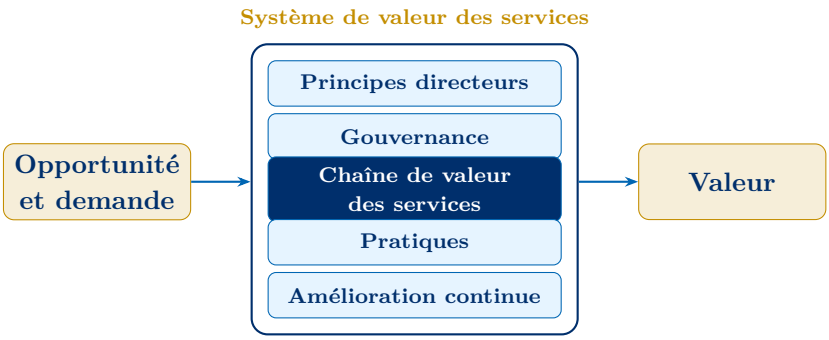


Figure 12.1. Le système de valeur des services d'ITIL 4 (représentation simplifiée)

Composante	Rôle
Principes directeurs	Recommandations qui guident les décisions en toutes circonstances (section 12.6)
Gouvernance	Moyens par lesquels l'organisation est dirigée et contrôlée : évaluer, diriger, surveiller
Chaîne de valeur des services	Modèle des six activités qui répondent à la demande et créent la valeur (section 12.4)
Pratiques	Ensembles de ressources organisationnelles conçus pour accomplir un travail ou atteindre un objectif (34 pratiques)
Amélioration continue	Activité récurrente, à tous les niveaux, qui assure que la performance répond aux attentes

Tableau 12.3. Les composantes du système de valeur des services

12.3.2 ITIL et la gouvernance

La deuxième composante est la *gouvernance*. ITIL 4 y reprend le modèle de l'ISO/IEC 38500 : évaluer, diriger, surveiller (Chapitre 9). C'est le point d'ancrage d'ITIL dans la gouvernance des SI : ITIL ne prétend pas organiser la gouvernance, mais il s'y soumet. Le système de valeur des services d'une organisation doit être dirigé et contrôlé par son organe de gouvernance, celui que COBIT organise avec le domaine EDM.

12.4 La Chaîne de Valeur des Services

12.4.1 Six activités

Activité	Finalité
Planifier	Partager une vision commune de l'état actuel, des orientations et des améliorations, pour tous les produits et services
Améliorer	Améliorer en continu les produits, les services et les pratiques
S'engager	Comprendre les besoins des parties prenantes, entretenir la transparence et de bonnes relations
Concevoir et faire la transition	Faire en sorte que les produits et services répondent aux attentes de qualité, de coût et de délai
Obtenir ou construire	Disposer des composants de service nécessaires, quand et où il le faut
Fournir et soutenir	Livrer et soutenir les services selon les spécifications et les attentes convenues

Tableau 12.4. Les six activités de la chaîne de valeur des services (finalités reformulées)

12.4.2 Des chaînes de valeur, pas un ordre fixe

Les six activités ne forment pas un cycle à parcourir dans l'ordre, comme les étapes d'ITIL v3. Elles se combinent, dans un ordre propre à chaque situation, en **flux de valeur** (*value streams*) : la suite d'étapes qu'une organisation enchaîne pour créer un résultat donné pour un client. Une même pratique peut intervenir dans plusieurs activités.

Scénario Opérationnel · Opération KRIBI. Conteneur bloqué

Déclencheur. Un agent du port signale qu'un conteneur n'apparaît plus dans le logiciel de suivi.

Flux de valeur.

1. *S'engager* : le centre de services enregistre l'appel et comprend l'impact (un navire attend).
2. *Fournir et soutenir* : le support diagnostique, contourne le problème et relocalise le conteneur.
3. *Obtenir ou construire* : l'éditeur corrige l'anomalie logicielle.
4. *Concevoir et faire la transition* : la correction est testée, autorisée, puis déployée.
5. *Améliorer* : l'analyse de cause alimente le registre des problèmes.

Constatation. Chez KRIBILOG, le flux s'arrête aujourd'hui à l'étape 2 : le ticket est clos dès le contournement, sans correction de la cause. Il est rouvert lors du blocage suivant.

Analyse (confiance élevée). Le taux de réouverture de 30 % s'explique par l'absence des étapes 3 à 5 dans le flux réel ; les pratiques de gestion des problèmes et d'habilitation des changements (Chapitres 13 et 14) sont les premières à mettre en place.

12.5 Les Quatre Dimensions

ITIL 4 rappelle qu'un service ne se réduit pas à sa technique. Toute démarche doit tenir compte de quatre dimensions, sous l'influence de facteurs externes (politiques, économiques, sociaux, technologiques, juridiques et environnementaux).

Dimension	Contenu	Chez KRIBILOG
Organisations et personnes	Structures, rôles, compétences, culture	Centre de services sous-dimensionné, pas de responsable des problèmes
Information et technologie	Données, applications, infrastructures, outils	Logiciel de suivi, outil de tickets, base de connaissances absente
Partenaires et fournisseurs	Relations avec les autres organisations qui contribuent au service	NETPORT SERVICES, l'éditeur du logiciel
Flux de valeur et processus	Enchaînement des activités et des processus	Flux « conteneur bloqué » interrompu

Tableau 12.5. Les quatre dimensions de la gestion des services

★ Attention

Violation typique. Un projet ITIL est réduit à l'achat d'un outil de gestion des tickets. L'outil est installé, mais les rôles ne sont pas définis, l'infogérant n'est pas tenu par le contrat d'y saisir ses interventions, et aucun flux de valeur n'est décrit.

Règle : une démarche ITIL traite toujours les quatre dimensions. Un outil ne couvre qu'une partie de la deuxième.

12.6 Les Sept Principes Directeurs

Principe	Application
Privilégier la valeur	Tout ce que l'on fait doit, directement ou indirectement, créer de la valeur pour les parties prenantes
Commencer là où l'on est	Partir de l'existant, l'observer et le mesurer, plutôt que de tout reconstruire
Progresser par itérations, avec retour d'information	Avancer par étapes courtes, en recueillant les retours à chaque étape
Collaborer et promouvoir la visibilité	Associer les bonnes personnes, rendre le travail et ses résultats visibles
Penser et travailler de manière globale	Traiter le service comme un tout, avec ses quatre dimensions
Rester simple et pratique	Supprimer ce qui ne crée pas de valeur, préférer le nombre minimal d'étapes
Optimiser et automatiser	Optimiser d'abord, automatiser ensuite ; ne pas automatiser un processus défaillant

Tableau 12.6. Les sept principes directeurs d'ITIL 4 (notre traduction)

Application Responsable des services IT

Appliquer les principes au projet ITIL de KRIBILOG

1. *Privilégier la valeur* : mesurer les conteneurs bloqués et les délais de chargement, pas seulement la disponibilité des serveurs.
2. *Commencer là où l'on est* : analyser les 4 800 tickets du dernier mois avant de choisir un nouvel outil.
3. *Progresser par itérations* : traiter d'abord la gestion des problèmes sur le logiciel de suivi, puis étendre.
4. *Collaborer* : associer les agents du port et NETPORT SERVICES à la définition des priorités.
5. *Optimiser et automatiser* : n'automatiser l'affectation des tickets qu'une fois la classification stabilisée.

12.6.1 Les 34 pratiques

ITIL 4 décrit 34 pratiques, réparties en trois familles [2].

Famille	Nb	Exemples
Management général	14	Amélioration continue, gestion des risques, gestion de la sécurité de l'information, gestion des fournisseurs, gestion des projets, gestion du portefeuille, gestion des relations
Gestion des services	17	Centre de services, gestion des incidents, des problèmes, des demandes de service, habilitation des changements, gestion des mises en production, des niveaux de service, de la disponibilité, de la continuité, de la configuration
Gestion technique	3	Gestion des déploiements, gestion des infrastructures et des plateformes, développement et gestion des logiciels

Tableau 12.7. Les trois familles de pratiques d'ITIL 4

Les Chapitres 13 à 15 présentent les pratiques de gestion des services les plus importantes pour la gouvernance ; le Chapitre 16 les met en correspondance avec COBIT et l'ISO/IEC 20000-1.

Fiche processus · Amélioration continue (pratique ITIL 4)

Finalité : aligner en permanence les pratiques et les services sur les besoins de l'organisation, par l'amélioration des produits, des services et des pratiques.
Modèle en sept étapes : quelle est la vision ? Où en sommes-nous ? Où voulons-nous aller ? Comment y arriver ? Agir. Y sommes-nous arrivés ? Comment garder l'élan ?
Sorties : registre des améliorations, plans d'action, mesures avant et après.
RACI (extrait, KRIBILOG) : *A* au responsable des services informatiques, *R* aux propriétaires des pratiques, *C* aux métiers et à l'infogérant.
Indicateurs : nombre d'améliorations menées à terme, gain mesuré par amélioration.
Correspondance COBIT : objectifs APO11 (qualité) et MEA01 (surveillance de la performance).

On remarquera que le modèle d'amélioration continue d'ITIL reprend les sept questions de la feuille de route de COBIT 2019 (Chapitre 8) : les deux référentiels partagent la même logique d'amélioration.

12.7 Et ITIL Version 5 ?

ITIL version 5 a été annoncée par PeopleCert en janvier 2026, et ses modules de formation sont publiés progressivement depuis [34]. Les sources publiques disponibles permettent d'établir les points suivants.

Aspect	ITIL 4 (2019)	ITIL version 5 (2026)
Objet	Gestion des services	Produits et services numériques, gérés ensemble
Modèle central	Système et chaîne de valeur des services	Cycle de vie des produits et des services, de bout en bout
Principes directeurs	Sept principes	Les mêmes sept principes, selon les présentations disponibles
Pratiques	34 pratiques en trois familles	34 pratiques, regroupées autrement selon les présentations disponibles
Intelligence artificielle	Peu traitée	Présentée comme intégrée dès la conception, avec un module consacré à la gouvernance de l'IA
Certifications	Toujours reconnues	Nouveau schéma, introduit progressivement

Tableau 12.8. ITIL 4 et ITIL version 5 (d'après les sources publiques disponibles en octobre 2026)

Pourquoi ce cours reste-t-il sur ITIL 4 ?

Trois raisons. D'abord, ITIL 4 est la version que pratiquent aujourd'hui les organisations où exerceront les étudiants. Ensuite, ses concepts sont largement repris par la version 5 : principes, pratiques, co-création de la valeur. Enfin, le modèle central de la version 5 n'est pas encore documenté en détail dans les sources publiques : l'enseigner exigerait de s'appuyer sur la publication officielle. Les étudiants qui passeront une certification devront vérifier la version exigée par l'examen.

❍

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **De processus en système de valeur** : ITIL est passé d'un recueil de processus (v2) à un cycle de vie (v3), puis à un système de valeur des services (ITIL 4, 2019).
- **La valeur est co-créée** : elle est perçue par le client. Ne pas confondre livrable (ce que l'on produit) et résultat (ce que le client obtient).
- **Utilité et garantie** : ce que fait le service, et l'assurance qu'il le fera comme convenu.

- **Cinq composantes** : principes directeurs, gouvernance, chaîne de valeur, pratiques, amélioration continue. La gouvernance reprend le modèle évaluer, diriger, surveiller.
- **Six activités** qui se combinent en flux de valeur, sans ordre imposé.
- **Quatre dimensions et sept principes** : un projet ITIL n'est jamais un simple projet d'outil.
- **ITIL version 5** (2026) recentre le référentiel sur les produits et services numériques ; ce cours reste sur ITIL 4.

✍ Exercice 12.1. Livrable ou résultat ? ★☆☆

Pour chacun des éléments suivants, indiquez s'il s'agit d'un livrable ou d'un résultat, et précisez pour quel client.

(a) Un ticket clos dans le délai.

(b) Un fournisseur de l'État payé à bonne date par l'ANPP.

(c) Un serveur disponible à 99,8 %.

(d) Un client de la BANQUE SANAGA qui retire de l'argent un dimanche.

(e) Un rapport mensuel de NETPORT SERVICES.

✍ Exercice 12.2. Un flux de valeur à la BANQUE SANAGA ★★☆

Décrivez le flux de valeur « ouverture d'un compte par l'application mobile », de la demande du client jusqu'au premier virement.

(a) Identifiez les étapes et rattachez chacune à une activité de la chaîne de valeur.

(b) Pour chaque étape, indiquez la pratique ITIL concernée.

(c) Identifiez, pour chacune des quatre dimensions, un risque qui pourrait interrompre le flux.

✍ Exercice 12.3. Le contrat de KRIBILOG au prisme d'ITIL 4 ★★★

Le contrat entre KRIBILOG et NETPORT SERVICES fixe un seul engagement : la disponibilité des serveurs à 99,5 %.

(a) Expliquez, avec les notions d'utilité, de garantie, de livrable et de résultat, pourquoi cet engagement ne protège pas KRIBILOG.

(b) Proposez trois engagements orientés vers le résultat, mesurables.

(c) Montrez comment ces engagements s'inscrivent dans la gouvernance de KRIBI-

LOG (qui les fixe, qui les surveille, qui en rend compte).

(d) Ce travail sera repris au Chapitre 15 : indiquez les pratiques ITIL qu'il mobilisera.

Note

Transition. Le système de valeur fixe le cadre. Le Chapitre 13 entre dans les pratiques du quotidien : le centre de services, la gestion des incidents, des problèmes et des demandes de service, là où se joue la perception du service par ses utilisateurs.

13

CENTRE DE SERVICES, INCIDENTS, PROBLÈMES ET DEMANDES

« Réparer vite, c'est bien.
Ne plus avoir à réparer, c'est mieux. »

Adage des équipes de support

Niveau : *Intermédiaire* • Maîtrise du Chapitre 12 (concepts et système de valeur d'ITIL 4).

✦ Objectifs du chapitre

- ➢ Organiser un centre de services.
- ➢ Prioriser un incident avec une matrice impact × urgence.
- ➢ Distinguer incident, problème, erreur connue et demande de service.
- ➢ Calculer les indicateurs (MTTR, taux de résolution au premier contact).
- ➢ Conduire une analyse de cause racine.

Question directrice : pourquoi les mêmes pannes reviennent-elles ?

Le Chapitre 12 a montré que le flux de valeur « conteneur bloqué » de KRIBILOG SA s'arrête au contournement : le ticket est clos, la cause demeure, et le blocage revient. Avec 4 800 tickets par mois et 30 % de réouvertures, le centre de services est saturé, et M. MBARGA, responsable des services informatiques, ne sait plus par quoi commencer.

Ce chapitre présente les quatre pratiques qui forment le cœur de l'exploitation quotidienne : le centre de services (section 13.2), la gestion des incidents (section 13.3), celle des demandes de service (section 13.4) et celle des problèmes (section 13.5). Il apprend à mesurer leur performance (section 13.6) et à les relier à la gouvernance (section 13.7). Le laboratoire GCI-LAB-06 fait prioriser et analyser vingt tickets réels de KRIBILOG.

© MaletYon

13.1 Quatre Notions à ne pas Confondre

Définition

Incident : interruption non planifiée d'un service, ou dégradation de sa qualité.

Problème : cause, réelle ou potentielle, d'un ou de plusieurs incidents.

Erreur connue (*known error*) : problème qui a été analysé, dont la cause est identifiée, mais qui n'est pas encore résolu.

Solution de contournement (*workaround*) : moyen de réduire ou d'éliminer l'effet d'un incident ou d'un problème, sans en traiter la cause.

Demande de service (*service request*) : demande d'un utilisateur portant sur une prestation déjà prévue dans le service (un accès, une information, un équipement).

Définitions reformulées d'après ITIL 4 [2].

Situation	Qualification	Pratique
Le logiciel de suivi ne répond plus	Incident	Gestion des incidents
Le logiciel perd la position des conteneurs chaque fois que la balise change de réseau	Problème, puis erreur connue une fois la cause établie	Gestion des problèmes
On relance la synchronisation à la main	Solution de contournement	Incidents et problèmes
Un nouvel agent demande un accès au portail	Demande de service	Gestion des demandes de service
Un agent demande une nouvelle fonction du logiciel	Ni incident ni demande : demande de changement	Habilitation des changements (Chapitre 14)

Tableau 13.1. Qualifier une situation

La confusion la plus coûteuse est celle de l'incident et du problème. Le centre de services de KRIBILOG traite chaque blocage comme un incident isolé : il rétablit le service, et le blocage revient. Ce qui manque n'est pas la réactivité, c'est la *gestion des problèmes*.

13.2 Le Centre de Services

13.2.1 Le point d'entrée unique

Le **centre de services** (*service desk*) est le point de contact entre le fournisseur et les utilisateurs du service. Il reçoit les signalements d'incidents et les demandes, les

enregistre, les qualifie, les résout lorsqu'il le peut, et les oriente sinon. ITIL 4 insiste sur sa dimension humaine : il est la vitrine du service, et c'est par lui que l'utilisateur perçoit la valeur.

13.2.2 Organiser le centre de services

Choix	Options et critères
Canaux	Téléphone, courriel, portail en libre-service, messagerie instantanée ; au port, le téléphone et la messagerie mobile restent indispensables
Localisation	Centralisé (un seul site), local (près des utilisateurs), virtuel (équipes réparties, un outil commun)
Horaires	Aligner sur l'activité : le port de Kribi travaille 24 h/24, le centre de services doit le faire aussi pour les incidents prioritaires
Niveaux	Niveau 1 (centre de services), niveau 2 (support spécialisé), niveau 3 (éditeur, infogérant)
Compétences	Écoute, connaissance du métier des utilisateurs, maîtrise de l'outil et de la base de connaissances

Tableau 13.2. Les choix d'organisation d'un centre de services

Application Responsable des services IT

Désengorger le centre de services de KRIBILOG

1. Analyser la répartition des tickets : 20 % sont des réinitialisations de mot de passe, automatisables par un portail en libre-service.
2. Créer une base de connaissances pour les vingt incidents les plus fréquents, avec leur contournement.
3. Définir des modèles de demandes (accès, équipements) avec leur circuit d'approbation.
4. Exiger, par avenant, que NETPORT SERVICES enregistre toutes ses interventions dans l'outil de KRIBILOG.
5. Nommer un responsable de la gestion des problèmes, distinct du responsable du centre de services.

13.3 La Gestion des Incidents

13.3.1 Le cycle d'un incident

La gestion des incidents a pour but de *rétablir le service le plus vite possible* et de limiter l'effet de l'incident sur l'activité. Son cycle comprend l'enregistrement, la classification, la priorisation, le diagnostic, l'escalade éventuelle, la résolution, puis la clôture après vérification auprès de l'utilisateur. Ce sont les pratiques DSS02.02 à DSS02.06 de COBIT (Chapitre 6).

13.3.2 La matrice de priorité

La priorité d'un incident combine deux critères : l'**impact** (l'étendue des effets sur l'activité : combien d'utilisateurs, quels processus) et l'**urgence** (la vitesse à laquelle l'effet s'aggrave). La priorité fixe l'ordre de traitement et le délai cible de résolution.

Impact	Urgence élevée	Urgence moyenne	Urgence faible
Élevé	P1	P2	P3
Moyen	P2	P3	P4
Faible	P3	P4	P5

Tableau 13.3. Matrice de priorité impact × urgence (exemple)

Priorité	Exemple à KRIBILOG	Délai cible de résolution
P1	Logiciel de suivi indisponible pour tout le port, navire à quai	4 heures
P2	Suivi indisponible sur un terminal, chargement en cours	8 heures
P3	Lenteur générale du logiciel	24 heures
P4	Imprimante d'un bureau en panne	72 heures
P5	Erreur d'affichage sans effet sur le travail	5 jours ouvrés

Tableau 13.4. Priorités et délais cibles (convention retenue par KRIBILOG)

Les délais cibles ne sont pas fixés par ITIL : ils relèvent des engagements de service convenus avec les métiers (Chapitre 15). Ce que la gouvernance exige, c'est qu'ils soient *écrits, connus et mesurés.*

13.3.3 L'incident majeur

Un **incident majeur** est un incident dont l'impact sur l'activité exige une réponse dépassant le traitement ordinaire : une coordination dédiée, une communication spécifique, une escalade immédiate. La panne de la BANQUE SANAGA (Chapitre 0) en est l'exemple type.

Exigence de contrôle

Le dossier d'incident majeur. Pour qu'un incident majeur puisse être analysé, présenté au comité de direction ou au régulateur, le dossier doit contenir :

- l'heure de détection, l'heure de déclaration en incident majeur et le nom de la personne qui l'a déclaré ;

- la chronologie des actions, avec leurs auteurs ;
- les communications émises (destinataires, heures, contenu) ;
- l'heure du rétablissement et la vérification auprès des utilisateurs ;
- la revue post-incident, avec l'ouverture d'un problème et les actions décidées.

Application DSI

Les trois premières heures d'un incident majeur

1. Désigner immédiatement un responsable de l'incident, seul habilité à coordonner, distinct de ceux qui réparent.
2. Informer la direction générale dans l'heure, avec un point de situation régulier, même sans nouvelle.
3. Décider, à une heure fixée à l'avance, du recours au plan de continuité si le service n'est pas rétabli (Chapitre 15).
4. Consigner chaque décision : c'est la chronologie dont le régulateur demandera la copie.

13.4 La Gestion des Demandes de Service

Les demandes de service sont prévisibles : elles se standardisent. ITIL 4 recommande de définir pour chaque type de demande un modèle (contenu, circuit d'approbation, délai) et d'offrir autant que possible un libre-service. La pratique DSS02.03 de COBIT exige de vérifier le droit du demandeur, d'obtenir les approbations nécessaires et de satisfaire la demande selon la procédure prévue.

★ **Attention**

Violation typique. À l'ANPP, les demandes d'accès au système de paiement sont traitées par courriel, sans vérification du droit du demandeur ni approbation de son responsable. Le Chapitre 11 a montré la conséquence : des comptes ouverts sans justification, et jamais fermés.

Règle : toute demande d'accès suit un modèle qui impose l'approbation du responsable du demandeur et du propriétaire de l'application, et laisse une trace dans l'outil.

13.5 La Gestion des Problèmes

13.5.1 Trois phases

La gestion des problèmes vise à réduire la probabilité et l'effet des incidents, en identifiant leurs causes et en gérant les contournements et les erreurs connues. ITIL 4 la décrit en trois phases :

- l'**identification des problèmes** : analyse des tendances des incidents, des incidents majeurs, des informations des fournisseurs ;
- le **contrôle des problèmes** : analyse de la cause, documentation des contournements et des erreurs connues ;
- le **contrôle des erreurs** : suivi des erreurs connues jusqu'à leur correction, souvent par un changement.

Fiche processus · DSS03 · Gérer les problèmes

Description : identifier et classer les problèmes et leurs causes racines ; les résoudre à temps pour éviter la répétition des incidents ; formuler des recommandations d'amélioration.
Finalité : accroître la disponibilité, améliorer les niveaux de service, réduire les coûts et accroître la satisfaction des clients, en réduisant le nombre de problèmes d'exploitation.
Objectifs liés : EG01, EG08 ; AG05.
Pratiques : DSS03.01 identifier et classer les problèmes ; DSS03.02 analyser et diagnostiquer ; DSS03.03 enregistrer les erreurs connues ; DSS03.04 résoudre et clore les problèmes ; DSS03.05 conduire une gestion proactive des problèmes.
RACI (extrait, KRIBILOG) : DSS03.02 : *A* au responsable des services informatiques, *R* au responsable des problèmes, *C* à l'éditeur et à NETPORT SERVICES.
Indicateurs : nombre de problèmes ouverts et leur âge, part des incidents liés à une erreur connue, nombre d'incidents évités.

Description, finalité, objectifs liés et pratiques résumés et traduits par nos soins à partir de COBIT 2019 [22].

13.5.2 L'analyse de cause racine

Technique	Principe	Usage
Les cinq pourquoi	Demander « pourquoi ? » jusqu'à la cause (prologue, section 0.2)	Causes simples, enchaînées
Diagramme d'Ishikawa	Classer les causes possibles par familles (méthodes, matériel, personnes, environnement…)	Causes multiples
Analyse de Pareto	Classer les catégories d'incidents par fréquence	Choisir les problèmes à traiter en premier
Analyse chronologique	Reconstituer la suite des événements	Incidents majeurs

Tableau 13.5. Techniques d'analyse de cause

Scénario Opérationnel · Opération KRIBI. Le Pareto des tickets

Faits. Sur les 4 800 tickets du mois, la répartition est la suivante : suivi des conteneurs 1 920 (40 %), mots de passe 960 (20 %), réseau 720 (15 %), imprimantes 480 (10 %), divers 720 (15 %).

Analyse de Pareto. Deux catégories, suivi des conteneurs et mots de passe, représentent 60 % des tickets. La seconde se traite par le libre-service. La première justifie l'ouverture d'un problème.

Cinq pourquoi sur le suivi des conteneurs. Pourquoi le conteneur disparaît-il ? Parce que sa position n'est plus mise à jour. Pourquoi ? Parce que la balise perd la connexion en changeant de réseau mobile entre le port et l'entrepôt. Pourquoi le logiciel ne la retrouve-t-il pas ? Parce que la reconnexion n'est pas prévue dans la version installée. Pourquoi n'a-t-elle pas été corrigée ? Parce que l'éditeur a livré le correctif il y a six mois, et qu'aucune demande de changement n'a été ouverte pour l'installer.

Conclusion. Erreur connue, contournement documenté (relance manuelle), correction disponible : le problème se résout par un changement (Chapitre 14). Cause de gouvernance : personne n'était chargé de suivre les correctifs de l'éditeur.

13.6 Mesurer la Performance

13.6.1 Les indicateurs

Indicateur	Calcul	Ce qu'il révèle
Délai moyen de résolution (MTTR)	Somme des durées de résolution / nombre d'incidents résolus	Rapidité du rétablissement
Résolution au premier contact	Incidents résolus par le niveau 1 sans escalade / incidents reçus	Efficacité du centre de services
Taux de réouverture	Incidents rouverts / incidents clos	Qualité de la résolution
Respect des délais cibles	Incidents résolus dans le délai de leur priorité / incidents résolus	Tenue des engagements
Âge des problèmes ouverts	Durée depuis l'ouverture	Capacité à traiter les causes

Tableau 13.6. Indicateurs de la gestion des incidents et des problèmes

13.6.2 Un calcul pas à pas

Scénario Opérationnel · Opération KRIBI. Huit tickets

Ticket	Priorité	Durée (h)	Niveau 1 ?	Rouvert ?
T1	P3	2	Oui	Non
T2	P2	5	Non	Oui
T3	P3	26	Non	Non
T4	P4	1	Oui	Non
T5	P1	49	Non	Oui
T6	P2	3	Non	Non
T7	P3	8	Non	Oui
T8	P4	30	Non	Non

Calculs. MTTR $= (2+5+26+1+49+3+8+30)/8 = 124/8 = 15{,}5$ heures. Résolution au premier contact : $2/8 = 25$ %. Taux de réouverture : $3/8 = 37{,}5$ %. Respect des délais cibles (Tableau 13.4) : T3 (26 h pour P3, cible 24 h) et T5 (49 h pour P1, cible 4 h) sont hors délai, soit $6/8 = 75$ % dans les délais.

Lecture. Le MTTR moyen masque l'essentiel : l'incident P1, le plus grave, a duré douze fois son délai cible. Un indicateur moyen ne remplace jamais l'examen des incidents prioritaires.

★ Attention

Violation typique. Pour améliorer son taux de résolution, l'infogérant clôt les tickets dès qu'une solution de contournement est appliquée, sans vérifier auprès de l'utilisateur. Les indicateurs s'améliorent, le service se dégrade.

Règle : tout indicateur doit être accompagné de son indicateur de contrôle (le taux de réouverture pour le taux de résolution), et la clôture d'un incident exige la confirmation de l'utilisateur (DSS02.06).

13.7 Le Lien avec la Gouvernance

Les incidents et les problèmes relèvent du management, mais ils intéressent la gouvernance par trois voies.

- **L'information du conseil** : les incidents majeurs et les tendances doivent remonter au comité des risques ou au comité stratégique des SI. Le conseil de la BANQUE SANAGA n'avait reçu aucun rapport d'incident en 2025.
- **Le risque** : un problème non résolu est un risque connu et accepté de fait ; il doit figurer au registre des risques (APO12) et être accepté explicitement s'il n'est pas traité.
- **Les fournisseurs** : les incidents imputables à un prestataire alimentent sa supervi-

sion (APO10) et les pénalités prévues au contrat (Chapitre 15).

Application Auditeur SI

Auditer la gestion des incidents et des problèmes

1. Extraire de l'outil tous les tickets de la période, avec la lettre de transmission prévue par le GUID 5100 (Chapitre 11).
2. Vérifier sur un échantillon la cohérence de la priorité avec la matrice, et le respect des délais cibles.
3. Rapprocher les tickets rouverts des problèmes ouverts : une catégorie très rouverte sans problème ouvert est un constat.
4. Vérifier que les incidents majeurs ont donné lieu à une revue post-incident.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Quatre notions** : l'incident est une interruption, le problème sa cause, l'erreur connue une cause identifiée non corrigée, la demande de service une prestation prévue.
- **Le centre de services** est le point d'entrée unique et la vitrine du service ; il se désengorge par le libre-service, la base de connaissances et les modèles de demandes.
- **La priorité** combine impact et urgence ; les délais cibles relèvent des engagements de service et doivent être écrits.
- **L'incident majeur** exige un responsable dédié, une communication réglée et un dossier complet.
- **La gestion des problèmes** (DSS03) traite les causes : identification, contrôle des problèmes, contrôle des erreurs. Sans elle, les mêmes incidents reviennent.
- **Mesurer** : MTTR, résolution au premier contact, taux de réouverture, respect des délais. Une moyenne ne remplace pas l'examen des incidents prioritaires.

Exercice 13.1. Qualifier et prioriser ★☆☆

Qualifiez chacune des situations suivantes (incident, problème, demande de service, demande de changement), puis donnez la priorité des incidents selon la matrice du Tableau 13.3.

(a) Le portail de paiement de l'ANPP est inaccessible la veille de la paie des fonctionnaires.

(b) Un agent de la BANQUE SANAGA demande l'installation d'un logiciel de bureautique.

(c) Les distributeurs d'une agence de Garoua tombent en panne chaque soir vers 22 heures.

(d) Le directeur financier de KRIBILOG ne peut pas imprimer un rapport non urgent.

✍ Exercice 13.2. Calculer les indicateurs ★★☆

Le centre de services de la BANQUE SANAGA a traité dix incidents dans la journée, avec les durées de résolution suivantes (en heures) : 1, 3, 2, 12, 4, 1, 6, 30, 2, 9. Les incidents de 1 heure et le premier incident de 2 heures ont été résolus au premier contact. Deux incidents ont été rouverts.

(a) Calculez le MTTR, le taux de résolution au premier contact et le taux de réouverture.

(b) L'incident de 30 heures était un P1 (cible : 4 heures). Que concluez-vous sur la pertinence du MTTR comme indicateur unique ?

(c) Proposez un tableau de bord de quatre indicateurs pour le comité de direction.

✍ Exercice 13.3. La revue post-incident de la BANQUE SANAGA ★★★

Conduisez la revue post-incident de la panne de mars 2026 (Chapitre 0).

(a) Reconstituez la chronologie de l'incident majeur, et indiquez les pièces qui manquent au dossier (exigence de contrôle de la section 13.3).

(b) Ouvrez le problème correspondant et conduisez une analyse d'Ishikawa des causes.

(c) Distinguez les actions qui relèvent de la gestion des problèmes, de la gestion des changements et de la gouvernance.

(d) Rédigez la partie « incidents » du rapport trimestriel au comité des risques.

● Note

Transition. À KRIBILOG comme à la BANQUE SANAGA, la résolution des problèmes passe par un changement : l'installation d'un correctif, la bascule d'un système. Le Chapitre 14 présente l'habilitation des changements, la gestion des mises

en production et la gestion de la configuration.

14

CHANGEMENTS, MISES EN PRODUCTION ET CONFIGURATION

> « Toutes les grandes pannes de ce cours ont commencé par un changement. »
>
> — Leçon des grandes défaillances

Niveau : *Intermédiaire* • Maîtrise du Chapitre 13 (incidents et problèmes) et du Chapitre 2 (grandes défaillances).

✦ Objectifs du chapitre

- ➢ Distinguer changement standard, normal et urgent.
- ➢ Évaluer le risque d'un changement et organiser son autorisation.
- ➢ Planifier une mise en production et son retour arrière.
- ➢ Exploiter une CMDB pour une analyse d'impact.
- ➢ Relier ces pratiques à l'objectif COBIT BAI06.

Question directrice : comment changer sans casser ?

Knight Capital, TSB, CrowdStrike, la BANQUE SANAGA : le Chapitre 2 a montré que chaque grande panne avait commencé par un changement. Pourtant, une organisation qui ne change rien meurt aussi sûrement : le correctif que KRIBILOG n'a jamais installé (Chapitre 13) est la cause de 40 % de ses tickets. Et la BANQUE SANAGA doit relancer, en 2027, la bascule de son système central.

Le dilemme est celui de COBIT, qui rattache la gestion des changements à l'*agilité* (Chapitre 6) : il faut changer *vite* et changer *bien*. Ce chapitre présente les trois pratiques qui y répondent : l'habilitation des changements (sections 14.1 et 14.2), la gestion des mises en production et des déploiements (section 14.3), et la gestion de la configuration (section 14.4). Le laboratoire GCI-LAB-07 fait évaluer et décider un changement de la banque.

14.1 Les Changements et leurs Types

14.1.1 Qu'est-ce qu'un changement ?

Définition

Changement (*change*) : ajout, modification ou retrait de tout élément susceptible d'avoir un effet, direct ou indirect, sur un service.

Habilitation des changements (*change enablement*) : pratique qui vise à maximiser le nombre de changements réussis, en veillant à ce que les risques soient correctement évalués, à ce que les changements soient autorisés et à ce que leur calendrier soit maîtrisé.

Définitions reformulées d'après ITIL 4 [2]. La pratique s'appelait change control *dans la première édition d'ITIL 4.*

Le mot *habilitation* n'est pas anodin. ITIL 4 ne cherche pas à freiner les changements, mais à en permettre le plus grand nombre possible *avec succès*. Une organisation où chaque changement attend trois semaines l'avis d'un comité contourne tôt ou tard la procédure : c'est l'erreur symétrique de celle de Knight Capital.

14.1.2 Trois types de changements

Type	Caractéristiques	Exemple
Standard	Risque faible, bien connu, procédure documentée ; autorisé d'avance	Créer un compte utilisateur, ajouter de la mémoire à un serveur virtuel
Normal	Doit être évalué et autorisé selon son risque, par l'autorité compétente	Installer le correctif de l'éditeur chez KRIBILOG ; basculer le système central de la BANQUE SANAGA
Urgent	Doit être mis en œuvre au plus vite, par exemple pour résoudre un incident ou combler une faille ; procédure accélérée	Corriger une faille de sécurité activement exploitée

Tableau 14.1. Les trois types de changements

★ Attention

Violation typique. Pour échapper au comité des changements, une équipe qualifie systématiquement ses changements d'« urgents ». À la BANQUE SANAGA, 35 % des changements de 2025 étaient enregistrés comme urgents ; aucun n'avait fait l'objet de la revue a posteriori prévue.

Règle : un changement urgent n'est pas un changement non contrôlé. Il est autorisé par une autorité désignée à l'avance (souvent restreinte), documenté, et revu après

coup (BAI06.02). Un taux de changements urgents élevé est un indicateur d'alerte.

14.1.3 L'autorité de changement

ITIL 4 parle d'**autorité de changement** plutôt que de comité : la personne ou le groupe qui autorise un changement. Elle n'est pas unique : l'autorisation est *déléguée* selon le risque. Un changement standard est autorisé d'avance ; un changement normal à faible risque peut l'être par le responsable de l'équipe ; un changement à risque élevé exige un **comité des changements** (*change advisory board*, CAB), voire la direction.

Cette délégation est une question de **droits de décision** (Chapitre 3) : qui peut décider de quel changement. Elle doit être fixée par écrit et approuvée par la gouvernance.

14.2 Évaluer et Autoriser

14.2.1 Une grille d'évaluation du risque

Chaque organisation définit sa grille. Celle que retient la BANQUE SANAGA après la panne note six critères de 1 (favorable) à 3 (défavorable) ; le total, de 6 à 18, détermine l'autorité compétente.

Critère	1	2	3
Criticité du service	Soutien	Important	Critique (paiements, système central)
Utilisateurs touchés	Moins de 50	50 à 500	Plus de 500 ou clients
Complexité	Un composant	Plusieurs composants	Plusieurs systèmes, données converties
Réversibilité	Retour arrière testé	Retour arrière prévu non testé	Retour arrière impossible
Couverture des tests	Plus de 95 %	80 à 95 %	Moins de 80 %
Expérience	Changement déjà réalisé	Changement analogue	Première fois

Tableau 14.2. Grille d'évaluation du risque d'un changement (convention de la BANQUE SANAGA)

Score	Risque	Autorité de changement
6 à 9	Faible	Responsable de l'équipe concernée
10 à 13	Moyen	Responsable des changements, après avis du RSSI
14 à 18	Élevé	Comité des changements ; et, si la réversibilité vaut 3, décision formelle du comité de pilotage avec acceptation écrite du risque

Tableau 14.3. Score de risque et autorité compétente

Scénario Opérationnel · Opération SANAGA. La bascule notée

Notation a posteriori. Criticité 3, utilisateurs 3, complexité 3, réversibilité 3 (conversion irréversible), tests 3 (63 %), expérience 3 (première migration). Score : **18 sur 18**.

Analyse (confiance élevée). Avec la grille, la bascule aurait relevé du comité des changements *et* d'une décision formelle du comité de pilotage, avec acceptation écrite du risque. Aucune des deux instances ne s'est prononcée. La grille n'aurait pas empêché la décision de basculer, mais elle aurait obligé quelqu'un à la prendre, par écrit, en connaissance de cause.

14.2.2 Le calendrier des changements

Le **calendrier des changements** (*change schedule*) planifie les changements autorisés et en informe les parties concernées. Il permet d'éviter les collisions (deux changements sur le même système le même soir) et d'appliquer des *périodes de gel* pendant les moments sensibles : la clôture des comptes pour une banque, la paie des fonctionnaires pour l'ANPP, l'arrivée d'un grand navire pour KRIBILOG.

Fiche processus · BAI06 · Gérer les changements informatiques

Finalité : permettre la livraison rapide et fiable des changements, en limitant le risque d'affecter la stabilité ou l'intégrité de l'environnement modifié.
Objectifs liés : EG01 (portefeuille compétitif) ; AG06 (agilité).
Pratiques : BAI06.01 évaluer, prioriser et autoriser les demandes de changement ; BAI06.02 gérer les changements d'urgence ; BAI06.03 suivre l'état des changements et en rendre compte ; BAI06.04 clore et documenter les changements.
RACI (extrait, BANQUE SANAGA) : BAI06.01 pour un risque élevé : *A* au président du comité des changements, *R* au responsable des changements, *C* au RSSI, aux métiers et à l'exploitation, *I* au centre de services.
Indicateurs : taux de changements en échec ; taux de changements urgents ; nombre de changements non autorisés détectés ; part des changements à risque élevé dotés d'un retour arrière testé.

Finalité, objectifs liés et pratiques résumés et traduits par nos soins à partir de COBIT 2019 [22].

Application Responsable des services IT

La charte du comité des changements

1. **Mandat** : autoriser les changements à risque élevé, arbitrer les conflits de calendrier, examiner les changements en échec.
2. **Composition** : responsable des changements (président), exploitation, sécurité, représentants des métiers concernés, fournisseur si besoin.
3. **Fréquence** : hebdomadaire, et sur convocation pour un changement urgent à risque élevé.
4. **Pièces exigées** : évaluation du risque, plan de mise en production, plan de retour arrière et preuve de son test, résultats de recette.
5. **Trace** : décision motivée, inscrite au registre des changements avant toute mise en production.

14.3 Mises en Production et Déploiements

14.3.1 Deux pratiques distinctes

ITIL 4 distingue la **gestion des mises en production** (*release management*), qui rend disponibles des services ou des fonctions nouveaux ou modifiés, et la **gestion des déploiements** (*deployment management*), qui transfère les composants vers les environnements cibles. On peut déployer un logiciel sans le rendre disponible aux utilisateurs, puis l'activer plus tard : c'est le principe des fonctions activables à la demande.

14.3.2 Stratégies de mise en production

Stratégie	Principe	Risque
Bascule unique (*big bang*)	Tout le monde passe au nouveau système au même moment	Élevé : tout échec touche tout le monde
Par étapes	Agence par agence, région par région	Modéré : l'échec est circonscrit
Pilote	Un site ou un groupe d'utilisateurs d'abord	Faible pour le pilote, mais long
Fonctionnement en parallèle	Ancien et nouveau systèmes tournent ensemble pendant une période	Faible, mais coûteux
Déploiement progressif (*canary*)	Une petite part du trafic d'abord, puis le reste	Faible ; suppose une architecture adaptée

Tableau 14.4. Stratégies de mise en production

La BANQUE SANAGA avait choisi une bascule unique, avec une conversion des données irréversible, pour ses 38 agences. CrowdStrike avait déployé sa mise à jour en une fois sur tout son parc (Chapitre 2). Dans les deux cas, la stratégie a transformé une erreur en catastrophe.

14.3.3 Le retour arrière

Définition

Plan de retour arrière (*back-out plan, rollback*) : ensemble des actions qui permettent de revenir à l'état antérieur au changement si celui-ci échoue, avec les critères qui déclenchent ce retour et le délai dans lequel il doit être décidé.

Un retour arrière n'existe que s'il a été *testé*. Quand il est impossible (conversion irréversible des données, mise à jour d'un schéma de base de données), le risque doit être traité autrement : fonctionnement en parallèle, sauvegarde complète vérifiée, ou acceptation formelle par l'instance compétente.

14.3.4 Les pratiques de COBIT

L'objectif BAI07 (gérer l'acceptation et la transition des changements) détaille ce qu'il faut maîtriser : établir un plan de mise en œuvre (BAI07.01), planifier la conversion des processus, des systèmes et des données (BAI07.02), planifier et réaliser les tests d'acceptation (BAI07.03 à BAI07.05), passer en production et gérer les versions (BAI07.06), assurer un soutien renforcé au démarrage (BAI07.07) et conduire une revue après la mise en œuvre (BAI07.08) [22]. La pratique BAI07.02, la conversion des données, est exactement celle qui a fait défaut à la BANQUE SANAGA.

Exigence de contrôle

Les critères « go / no-go ». Avant toute mise en production à risque élevé, la décision de passer est prise sur une liste de critères fixée à l'avance, et consignée :

- recette réalisée au taux convenu, anomalies bloquantes closes ;
- retour arrière testé, avec son délai de mise en œuvre ;
- données converties contrôlées sur un échantillon, avec un rapprochement des soldes ;
- équipes de soutien et fournisseur mobilisés pour la période de démarrage ;
- communication aux utilisateurs prête ;
- heure limite au-delà de laquelle le retour arrière est automatiquement déclenché.

Un seul critère non rempli suffit à décider « no-go » ; le passer outre exige une acceptation écrite du risque.

Scénario Opérationnel · Opération SANAGA. La nouvelle bascule

Plan de 2027. Bascule par étapes : une agence pilote à Douala, puis quatre vagues de huit à dix agences, à un mois d'intervalle. Fonctionnement en parallèle de l'ancien système pendant deux semaines pour chaque vague, avec rapprochement quotidien des soldes. Gel des changements pendant la clôture de fin d'année.

Évaluation avec la grille. Criticité 3, utilisateurs 2 (une vague), complexité 3, réversibilité 1 (fonctionnement en parallèle), tests 1, expérience 2 (après le pilote). Score : 12, soit un risque moyen par vague ; mais le comité de pilotage décide de garder le comité des changements comme autorité pour chaque vague, compte tenu de l'histoire de la banque.

14.4 La Gestion de la Configuration

14.4.1 Éléments de configuration et CMDB

Définition

Élément de configuration (*configuration item*, CI) : tout composant qui doit être géré pour fournir un service : un serveur, une application, une base de données, un contrat, une documentation.

Base de données de gestion de la configuration (*configuration management database*, CMDB) : base qui enregistre les éléments de configuration, leurs attributs et surtout leurs *relations* (dépend de, est hébergé sur, utilise).

La gestion de la configuration se distingue de la gestion des actifs (BAI09) : l'actif s'intéresse à la valeur et au cycle de vie financier d'un bien (achat, amortissement, mise au rebut) ; la configuration s'intéresse à son rôle dans le service et à ses relations avec les autres composants.

14.4.2 L'analyse d'impact

La valeur de la CMDB est de répondre, avant un changement, à la question « qu'est-ce qui sera touché ? ».

Scénario Opérationnel · Opération KRIBI. Installer le correctif

Extrait de la CMDB pour le CI « Logiciel de suivi des conteneurs, version 3.2 ».

Élément lié	Relation	Conséquence pour le changement
Serveur d'application SRV-KRI-02	Hébergé sur	Redémarrage nécessaire
Base de données des mouvements	Utilise	Modification du schéma : sauvegarde obligatoire
Passerelle des balises GPS	Reçoit de	Test de reconnexion requis
Portail clients de l'armateur	Fournit à	Interruption à annoncer au client
Contrat NETPORT SERVICES	Exploité par	Intervention de l'infogérant à planifier

Évaluation. Criticité 3, utilisateurs 3, complexité 2, réversibilité 2 (modification du schéma de la base), tests 2, expérience 2. Score 14 : risque élevé, autorité : comité des changements. Fenêtre retenue : dimanche de 2 h à 6 h, hors arrivée de navire.

Ce que révèle l'exercice. Sans la CMDB, la modification du schéma de la base et l'effet sur le portail de l'armateur seraient passés inaperçus. C'est précisément ce que KRIBILOG ignorait lorsqu'elle a renoncé, il y a six mois, à installer le correctif.

14.4.3 L'objectif BAI10

COBIT consacre à la configuration l'objectif BAI10 (gérer la configuration), dont les pratiques couvrent la définition d'un modèle de configuration, la tenue d'un référentiel et de ses versions de référence, la maîtrise des éléments de configuration, les états de configuration, et la vérification périodique de l'intégrité du référentiel. Ses liens principaux sont le risque métier (EG02), la continuité (EG06) et la sécurité (AG07) [22] : une CMDB fausse est un risque, car elle conduit à des analyses d'impact fausses.

★ Attention

Violation typique. Une organisation achète un outil de CMDB, le remplit une fois par un inventaire automatique, puis ne le met plus à jour. Deux ans plus tard, la moitié des relations sont fausses, et plus personne ne s'y fie.

Règle : la CMDB se met à jour par le processus de changement : tout changement clos met à jour les éléments de configuration concernés (BAI06.04, BAI10.03), et un contrôle périodique vérifie son intégrité (BAI10.05).

14.5 Changements et Gouvernance

Application Auditeur SI

Détecter les changements non autorisés

1. Extraire les journaux de la production (déploiements, modifications de configuration) sur la période.
2. Les rapprocher du registre des changements : tout déploiement sans changement autorisé correspondant est un écart.
3. Sur un échantillon de changements autorisés, vérifier que l'autorisation est antérieure à la mise en production, que les tests et le retour arrière sont documentés.
4. Vérifier la séparation des tâches : celui qui développe ne déploie pas seul en production.

Ce rapprochement est le test le plus puissant des contrôles généraux sur les changements : il part de ce qui s'est réellement passé, et non de ce qui a été déclaré.

DevOps tue-t-il la gestion des changements ?

Les organisations qui déploient plusieurs fois par jour ne peuvent pas réunir un comité avant chaque mise en production. Elles ne renoncent pas pour autant au contrôle : elles le *déplacent* dans la chaîne de déploiement automatisée (tests obligatoires, revue de code par un pair, déploiement progressif, retour arrière automatique) et traitent la plupart de leurs changements comme des changements standard. Le Chapitre 18 y reviendra. La gouvernance n'exige pas un comité ; elle exige que le risque soit évalué et que l'autorisation soit traçable.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Changer vite et bien** : l'habilitation des changements vise à maximiser le nombre de changements réussis, pas à les freiner.
- **Trois types** : standard (autorisé d'avance), normal (évalué et autorisé selon son risque), urgent (accéléré, mais contrôlé et revu après coup).
- **L'autorité de changement est déléguée selon le risque** : c'est une question de droits de décision, fixée par la gouvernance.
- **La stratégie de mise en production** détermine l'ampleur d'un échec ; un retour arrière n'existe que s'il a été testé.
- **Les critères go / no-go** sont fixés à l'avance ; les passer outre exige une

acceptation écrite du risque.

➢ **La CMDB** sert l'analyse d'impact ; elle se tient à jour par le processus de changement.

➢ **BAI06, BAI07, BAI10** sont les objectifs COBIT correspondants ; le rapprochement entre journaux de production et registre des changements en est le meilleur test d'audit.

✍ Exercice 14.1. Quel type de changement ? ★☆☆

Qualifiez chacun des changements suivants (standard, normal, urgent) et justifiez.

(a) Ajouter un utilisateur au groupe « consultation » du logiciel de suivi.

(b) Corriger, un samedi soir, une faille activement exploitée sur le portail de paiement de l'ANPP.

(c) Migrer la messagerie de la BANQUE SANAGA vers un service en nuage.

(d) Remplacer un disque défectueux dans une baie redondante.

✍ Exercice 14.2. Évaluer un changement ★★☆

L'ANPP veut mettre en production une nouvelle version de son module de paie, trois jours avant la paie des fonctionnaires. La recette couvre 85 % des scénarios, le retour arrière est prévu mais non testé, le changement touche 400 utilisateurs internes et tous les agents de l'État.

(a) Notez le changement avec la grille du Tableau 14.2 et déduisez l'autorité compétente.

(b) Quels critères go / no-go ne sont pas remplis ?

(c) Que recommandez-vous, et qui doit le décider ?

✍ Exercice 14.3. Refonder la gestion des changements de la BANQUE SANAGA ★★★

Le comité stratégique des SI demande un dispositif de gestion des changements qui atteigne le niveau de capacité 3 en dix-huit mois (Chapitre 7).

(a) Définissez les trois types de changements de la banque, avec des exemples, et la liste initiale des changements standard.

(b) Fixez la délégation de l'autorité de changement, et indiquez qui doit l'approuver.

(c) Proposez cinq indicateurs pour le comité d'audit, avec leur cible.

(d) Indiquez comment l'auditrice interne vérifiera, dans un an, que le dispositif

fonctionne.

Note

Transition. Les changements modifient les services ; encore faut-il savoir ce que l'on a promis à leurs utilisateurs. Le Chapitre 15 traite des engagements de service, de la disponibilité, de la continuité et de la gestion des fournisseurs.

15

NIVEAUX DE SERVICE, DISPONIBILITÉ, CONTINUITÉ ET FOURNISSEURS

« Un engagement que l'on ne mesure pas n'engage personne. »

Adage des acheteurs de services

Niveau : *Intermédiaire* • Maîtrise du Chapitre 13 (incidents, priorités et délais cibles) et du Chapitre 12 (utilité et garantie).

✦ Objectifs du chapitre

- ➢ Rédiger un SLA, un OLA et un contrat de sous-traitance cohérents.
- ➢ Calculer une disponibilité et les pénalités contractuelles en FCFA.
- ➢ Conduire une analyse d'impact sur l'activité et fixer RTO et RPO.
- ➢ Piloter un fournisseur de services informatiques.

Question directrice : que vaut une promesse de 99,5 % ?

Le contrat entre KRIBILOG SA et son infogérant NETPORT SERVICES tient en une ligne d'engagement : « disponibilité des serveurs : 99,5 % ». L'exercice 12.3 a montré que cette promesse ne protège pas KRIBILOG. Mais combien vaut-elle exactement ? Combien d'heures de panne autorise-t-elle chaque mois ? Que rembourse-t-elle quand un navire attend à quai, à 12 millions FCFA de surestaries par jour ? Et que se passe-t-il si le centre de données de NETPORT SERVICES brûle ?

Ce chapitre répond à ces questions. Il présente la gestion des niveaux de service (section 15.1), le calcul de la disponibilité (section 15.2) et des pénalités (section 15.3), la continuité de service (section 15.4) et la gestion des fournisseurs (section 15.5). Le laboratoire GCI-LAB-08 en fait réaliser les calculs sur les données de KRIBILOG.

15.1 Les Engagements de Service

© MaletYon

15.1.1 Trois niveaux d'accord

Définition

Accord de niveau de service (*service level agreement*, SLA) : accord documenté entre un fournisseur de services et son client, qui précise le service fourni et les niveaux de service attendus.

Accord de niveau opérationnel (*operational level agreement*, OLA) : accord entre le fournisseur et une autre équipe interne de la même organisation, qui soutient la fourniture du service.

Contrat de sous-traitance (*underpinning contract*) : contrat entre le fournisseur et un tiers extérieur dont il dépend pour fournir le service.

Notions reformulées d'après ITIL 4 [2].

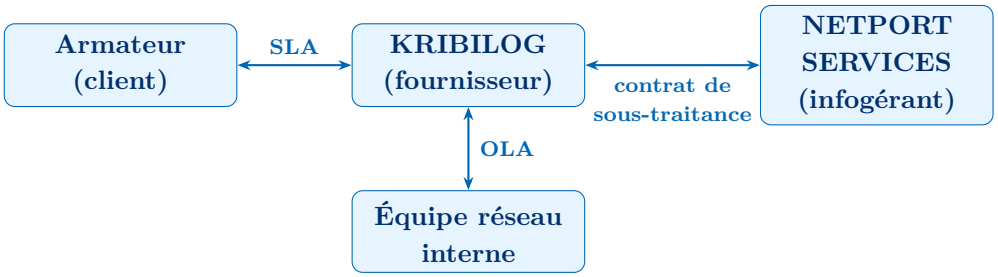


Figure 15.1. SLA, OLA et contrat de sous-traitance du service de suivi des conteneurs

La règle de cohérence est simple : **on ne peut pas promettre au client plus que ce que garantissent les accords qui soutiennent le service**. Si KRIBILOG promet à l'armateur un rétablissement en 4 heures, mais que le contrat de NETPORT SERVICES ne fixe aucun délai d'intervention, la promesse ne repose sur rien.

15.1.2 Rédiger un SLA utile

Rubrique	Contenu	Exemple KRIBILOG
Description du service	Ce que le service permet au client d'obtenir (le résultat)	Localiser en temps réel les conteneurs de l'armateur
Horaires de service	Périodes pendant lesquelles les engagements s'appliquent	24 h/24, 7 j/7
Disponibilité	Part du temps de service où le service est utilisable	99,5 % par mois
Délais de rétablissement	Par priorité (Chapitre 13)	P1 en 4 heures, P2 en 8 heures
Indicateur de résultat	Mesure ce que le client vit	Part des conteneurs localisés en moins de 5 minutes : 99 %
Mesure et compte rendu	Source des données, fréquence	Rapport mensuel produit par KRIBILOG à partir de son outil
Pénalités	Conséquences du non-respect	Section 15.3
Revue	Fréquence de révision de l'accord	Comité de service trimestriel

Tableau 15.1. Les rubriques d'un accord de niveau de service

★ Attention

Violation typique. Tous les indicateurs du rapport mensuel sont au vert, mais le client est mécontent. ITIL 4 appelle ce phénomène l'« effet pastèque » : vert à l'extérieur, rouge à l'intérieur. Il naît d'engagements qui mesurent des livrables (serveurs disponibles) au lieu de résultats (conteneurs localisés).

Règle : chaque SLA comporte au moins un indicateur de résultat, défini avec le client, et la satisfaction du client est mesurée à côté des indicateurs techniques.

Fiche processus · APO09 · Gérer les accords de service

Finalité : s'assurer que les services et les niveaux de service répondent aux besoins actuels et futurs de l'organisation.
Objectifs liés : EG01, EG08 ; AG05.
Pratiques : APO09.01 identifier les services ; APO09.02 cataloguer les services ; APO09.03 définir et préparer les accords de service ; APO09.04 surveiller les niveaux de service et en rendre compte ; APO09.05 revoir les accords de service et les contrats.
RACI (extrait, KRIBILOG) : APO09.03 : *A* au directeur des opérations, *R* au responsable des services informatiques, *C* à l'armateur et à NETPORT SERVICES.
Indicateurs : part des services couverts par un SLA, part des engagements tenus, satisfaction des clients.

Pratiques et objectifs liés traduits par nos soins à partir de COBIT 2019 [22] ; finalité reformulée.

15.2 Calculer une Disponibilité

15.2.1 La formule

Définition

Disponibilité : aptitude d'un service à remplir sa fonction quand on en a besoin. Elle se mesure par

$$A = \frac{T_{\text{convenu}} - T_{\text{indisponible}}}{T_{\text{convenu}}} \times 100,$$

où T_{convenu} est le temps de service convenu sur la période et $T_{\text{indisponible}}$ la durée cumulée des interruptions pendant ce temps.

Sur un mois de 30 jours en service 24 h/24, le temps convenu est de 720 heures. Une disponibilité de 99,5 % autorise donc $0{,}005 \times 720 = 3{,}6$ heures d'interruption par mois ; 99,9 % en autorisent 43 minutes ; 99,99 %, un peu plus de 4 minutes.

Disponibilité	Interruption par mois (720 h)	Interruption par an (8 760 h)
99 %	7,2 heures	87,6 heures
99,5 %	3,6 heures	43,8 heures
99,9 %	43 minutes	8,8 heures
99,99 %	4,3 minutes	53 minutes

Tableau 15.2. Ce que signifie un taux de disponibilité

15.2.2 Composants en série et en parallèle

Un service dépend de plusieurs composants. S'ils sont **en série** (il les faut tous), la disponibilité du service est le produit de leurs disponibilités : $A = A_1 \times A_2 \times \cdots \times A_n$. S'ils sont **en parallèle** (un seul suffit, les autres sont des secours), la disponibilité est $A = 1 - (1 - A_1)(1 - A_2)\cdots(1 - A_n)$.

Scénario Opérationnel · Opération KRIBI. La disponibilité réelle du suivi

Composants en série. Serveur d'application (99,9 %), base de données (99,8 %), passerelle des balises (99,5 %), réseau de l'opérateur mobile (99,0 %).

Calcul. $0{,}999 \times 0{,}998 \times 0{,}995 \times 0{,}990 = 0{,}9821$, soit **98,21 %** : environ 12,9 heures d'interruption attendues par mois, alors que l'engagement de NETPORT SERVICES sur les seuls serveurs (99,5 %) est tenu.

Avec un second opérateur mobile en secours. Le réseau passe à $1 - (0{,}01 \times 0{,}01) = 0{,}9999$, et le service à $0{,}999 \times 0{,}998 \times 0{,}995 \times 0{,}9999 = 0{,}9919$, soit 99,19 %.

Analyse (confiance élevée). Le maillon faible n'est pas le serveur, sur lequel porte le contrat, mais le réseau mobile, sur lequel il ne porte pas. Un SLA sur un composant ne garantit pas le service.

15.3 Les Pénalités

15.3.1 Un mécanisme contractuel

Les pénalités (souvent appelées « crédits de service ») sanctionnent le non-respect des engagements. Elles ont trois fonctions : inciter le fournisseur, compenser partiellement le client, et documenter les manquements. Elles ne compensent presque jamais le préjudice réel.

Scénario Opérationnel · Opération KRIBI. Le calcul du mois de juin

Clause du nouveau contrat. Redevance mensuelle : 25 millions FCFA. Engagement : 99,5 % de disponibilité du service de suivi, mesurée de bout en bout. Pénalité : 4 % de la redevance par tranche complète de 0,1 point en dessous de l'engagement, plafonnée à 30 %.

Faits du mois. Trois interruptions de 2 heures, 4,5 heures et 1,5 heure, soit 8 heures sur 720.

Calcul. Disponibilité : $(720 - 8)/720 = 98{,}89$ %. Écart : $99{,}5 - 98{,}89 = 0{,}61$ point, soit 6 tranches complètes de 0,1 point. Pénalité : $6 \times 4\ \% = 24\ \%$, sous le plafond, soit $0{,}24 \times 25 = 6$ millions FCFA.

Mise en perspective. L'interruption de 4,5 heures a immobilisé un navire une demi-journée : environ 6 millions FCFA de surestaries à elle seule. La pénalité du mois couvre une seule interruption sur trois.

Faut-il des pénalités plus lourdes ?

Pas nécessairement. Des pénalités très lourdes renchérissent le contrat, poussent le fournisseur à contester les mesures et ne remplacent pas un service fiable. La protection réelle du client vient d'ailleurs : des engagements de résultat, une architecture redondante, un plan de continuité, un droit de résiliation en cas de manquements répétés et une supervision effective du fournisseur. La pénalité est un signal, pas une assurance.

15.4 La Continuité de Service

15.4.1 L'analyse d'impact sur l'activité

La continuité vise à maintenir les services à un niveau acceptable en cas de sinistre majeur : incendie du centre de données, coupure prolongée d'électricité, cyberattaque

destructrice. Elle commence par une analyse d'impact sur l'activité.

Définition

Analyse d'impact sur l'activité (*business impact analysis*, BIA) : analyse qui identifie les activités essentielles, mesure l'effet de leur interruption dans le temps, et en déduit les objectifs de reprise.

Durée maximale d'interruption admissible (DMIA) : durée au-delà de laquelle l'interruption d'une activité devient inacceptable pour l'organisation.

RTO (*recovery time objective*, durée maximale de reprise) : délai cible dans lequel le service doit être rétabli après un sinistre. Il doit être inférieur à la DMIA.

RPO (*recovery point objective*, perte de données maximale admissible) : quantité maximale de données, exprimée en durée, que l'on accepte de perdre. Un RPO de 15 minutes impose une réplication ou une sauvegarde au moins toutes les 15 minutes.

Service	DMIA	RTO	RPO	Dispositif
Système central (SANAGA)	8 heures	4 h	15 min	Site de secours répliqué
Paie des fonctionnaires (ANPP)	48 heures	24 h	1 h	Sauvegarde horaire, site de secours
Suivi des conteneurs (KRIBILOG)	4 heures	2 h	15 min	Réplication, second opérateur
Messagerie (KRIBILOG)	3 jours	24 h	24 h	Sauvegarde quotidienne

Tableau 15.3. Objectifs de reprise de quelques services du cours

15.4.2 Le plan et ses tests

Le plan de continuité ne vaut que s'il est *testé*. COBIT y consacre l'objectif DSS04 ; la norme ISO 22301 en formule les exigences (Chapitre 9).

Fiche processus · DSS04 · Gérer la continuité

Finalité : s'adapter rapidement, poursuivre les activités et maintenir la disponibilité des ressources et de l'information à un niveau acceptable en cas de perturbation majeure.
Objectifs liés : EG01, EG02, EG06, EG08 ; AG05, AG07.
Pratiques : DSS04.01 définir la politique, les objectifs et le périmètre de la continuité ; DSS04.02 maintenir la résilience ; DSS04.03 élaborer et mettre en œuvre la réponse ; DSS04.04 exercer, tester et revoir les plans ; DSS04.05 revoir, maintenir et améliorer les plans ; DSS04.06 former ; DSS04.07 gérer les sauvegardes ; DSS04.08 conduire une revue après la reprise.

Indicateurs : part des services critiques dont le plan a été testé dans l'année ; écart entre RTO visé et durée de reprise constatée lors des tests.

Finalité, objectifs liés et pratiques résumés et traduits par nos soins à partir de COBIT 2019 [22].

Type de test	Déroulement	Ce qu'il prouve
Exercice sur table	Les responsables déroulent le plan sur un scénario, autour d'une table	Que chacun connaît son rôle
Simulation	Les équipes exécutent les procédures sans basculer réellement	Que les procédures sont praticables
Bascule réelle	Le service est réellement repris sur le site de secours	Que le RTO et le RPO sont tenus

Tableau 15.4. Types de tests de continuité

★ Attention

Violation typique. La BANQUE SANAGA disposait d'un plan de continuité rédigé en 2022. Il n'avait jamais été testé, et le site de secours qu'il désignait hébergeait encore l'ancienne version du système central. Le jour de la panne, personne n'a pensé à l'ouvrir.

Règle : un plan de continuité se teste au moins une fois par an pour chaque service critique, et se met à jour à chaque changement majeur (Chapitre 14).

15.5 Piloter les Fournisseurs

15.5.1 L'externalisation ne transfère pas la responsabilité

Le Chapitre 2 l'a montré avec TSB, le Chapitre 9 avec l'ISO/IEC 20000-1 : confier un service à un tiers ne décharge pas l'organisation de sa responsabilité. Le droit camerounais le dit aussi.

⚖ Jurisprudence & Droit applicable

Loi n° 2010/012, article 26, alinéa 1 (extrait, version anglaise officielle) :

« Operators of information systems shall take every technical and administrative measure to ensure the security of services offered. To this end, they shall have standardized systems enabling them to at all times identify, assess, process or manage any risk relating to the security of the information systems of the services provided directly or indirectly. »

Portée. L'obligation de gérer les risques de sécurité porte sur les services fournis « directement ou indirectement ». Une organisation qui exploite ses systèmes par

l'intermédiaire d'un infogérant reste tenue d'identifier, d'évaluer et de traiter les risques de sécurité de ces services : elle doit donc s'en donner les moyens dans le contrat (droit d'audit, information sur les incidents, exigences de sécurité).

15.5.2 Le cycle de la relation fournisseur

Fiche processus · APO10 · Gérer les fournisseurs

Finalité : obtenir des fournisseurs les services convenus, en maîtrisant leurs risques, et en entretenant des relations efficaces.
Objectifs liés : EG01, EG08 ; AG05.
Pratiques : APO10.01 identifier et évaluer les relations et les contrats ; APO10.02 sélectionner les fournisseurs ; APO10.03 gérer les relations et les contrats ; APO10.04 gérer les risques liés aux fournisseurs ; APO10.05 surveiller la performance et la conformité des fournisseurs.
RACI (extrait, KRIBILOG) : APO10.05 : *A* au responsable des services informatiques, *R* au gestionnaire du contrat, *C* à la direction des achats et au RSSI.
Indicateurs : part des fournisseurs critiques évalués dans l'année, nombre de manquements contractuels, délai de traitement des écarts.

Pratiques et objectifs liés traduits par nos soins à partir de COBIT 2019 [22] ; finalité reformulée.

15.5.3 Les clauses essentielles

Exigence de contrôle

Le contrat d'un fournisseur critique. Pour qu'un auditeur puisse établir que l'organisation maîtrise un service externalisé, le contrat doit comporter au minimum :

- des engagements de service mesurables, dont au moins un indicateur de résultat, et la méthode de mesure ;
- des pénalités et un droit de résiliation pour manquements répétés ;
- l'obligation de signaler les incidents et les failles de sécurité dans un délai fixé ;
- un droit d'audit, par l'organisation ou par un tiers qu'elle désigne ;
- la localisation des données et les conditions de tout transfert (loi n° 2024/017, Chapitre 10) ;
- les conditions de la sous-traitance en cascade ;
- un plan de continuité du fournisseur, testé ;
- une clause de réversibilité : restitution des données et assistance au transfert vers un autre prestataire.

Application Responsable des services IT

Le comité de service trimestriel avec NETPORT SERVICES

1. Revoir les indicateurs du trimestre, mesurés par KRIBILOG et non par le seul fournisseur.
2. Examiner chaque incident P1 et P2, et les problèmes ouverts imputables au fournisseur.
3. Arrêter les pénalités et les plans d'action.
4. Revoir les risques du fournisseur (dépendance à une personne, santé financière, sous-traitants).
5. Consigner les décisions au procès-verbal, transmis au comité stratégique des SI.

Application Auditeur SI

Auditer un fournisseur critique

1. Vérifier que le contrat contient les clauses essentielles ci-dessus.
2. Recalculer, sur trois mois, la disponibilité et les pénalités à partir des données de l'organisation, et les comparer au rapport du fournisseur.
3. Vérifier que les pénalités dues ont été effectivement appliquées.
4. Vérifier le dernier test du plan de continuité du fournisseur.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **SLA, OLA, contrat de sous-traitance** : on ne promet pas au client plus que ce que garantissent les accords qui soutiennent le service.
- **Un SLA utile** mesure au moins un résultat ; sinon apparaît l'effet pastèque.
- **La disponibilité se calcule** : 99,5 % sur 720 heures autorisent 3,6 heures d'interruption. En série, les disponibilités se multiplient ; en parallèle, les secours se composent.
- **Les pénalités** sont un signal, pas une assurance : elles couvrent rarement le préjudice réel.
- **La continuité** part de l'analyse d'impact (DMIA, RTO, RPO) et ne vaut que si le plan est testé.
- **L'externalisation ne transfère pas la responsabilité** : la loi n° 2010/012

vise les services fournis directement ou indirectement. Le contrat doit donner les moyens du contrôle.

✍ Exercice 15.1. Calculs de disponibilité ★☆☆

(a) Combien d'heures d'interruption par mois de 30 jours autorise une disponibilité de 99,8 % ?

(b) Un service a connu 5 heures d'interruption en avril (30 jours). Quelle est sa disponibilité ?

(c) Un service dépend de trois composants en série disponibles à 99,9 %, 99,7 % et 99,5 %. Quelle est sa disponibilité ?

(d) On double le composant le plus faible par un secours identique. Quelle est la nouvelle disponibilité ?

✍ Exercice 15.2. Les pénalités de juillet ★★☆

Avec la clause du scénario de la section 15.3, le mois de juillet (31 jours) a connu quatre interruptions de 3 heures, 2 heures, 6 heures et 1 heure.

(a) Calculez la disponibilité du mois.

(b) Calculez la pénalité en FCFA.

(c) NETPORT SERVICES conteste l'interruption de 6 heures, qu'elle attribue à l'opérateur mobile. Que dit le contrat, et que devrait-il dire ?

✍ Exercice 15.3. La continuité de l'ANPP ★★★

L'ANPP verse chaque mois les salaires de plus de 300 000 agents publics.

(a) Conduisez une analyse d'impact simplifiée de ses trois services principaux (paie, paiement des fournisseurs, portail d'information), et fixez pour chacun DMIA, RTO et RPO.

(b) Proposez un dispositif de continuité proportionné, et le programme de tests de l'année.

(c) Identifiez les clauses à imposer à l'hébergeur de l'agence.

(d) Indiquez à quelle instance de gouvernance les résultats des tests doivent être présentés, et pourquoi.

Note

Transition. Les Chapitres 12 à 15 ont présenté les pratiques d'ITIL 4 une par une. Le Chapitre 16 apprend à les assembler : modéliser un processus, en attribuer les responsabilités par une matrice RACI, le mesurer, et établir la correspondance entre COBIT, ITIL et l'ISO/IEC 20000-1.

16

PROCESSUS : MODÉLISER, RESPONSABILISER, MESURER

« Quand tout le monde est responsable, personne ne l'est. »

Adage du management

Niveau : *Expert* • Maîtrise des Chapitres 6 (les objectifs COBIT) et 15 (niveaux de service et fournisseurs).

✦ Objectifs du chapitre

- ➢ Modéliser un processus en BPMN.
- ➢ Construire une matrice RACI sans ambiguïté.
- ➢ Mettre en correspondance COBIT, ITIL et ISO/IEC 20000-1.
- ➢ Définir les indicateurs (KPI, KGI) et un tableau de bord.
- ➢ Désigner les propriétaires de processus et organiser l'amélioration continue.

Question directrice : qui fait quoi, et comment le sait-on ?

Les Chapitres 12 à 15 ont présenté les pratiques une par une. Mais une organisation ne vit pas des pratiques isolées : elle vit des enchaînements d'activités, qui traversent les équipes, les fournisseurs et les outils. Chez NOUN PAY, à Bafoussam, la mise à jour du modèle de notation de crédit passe par cinq personnes et un fournisseur de nuage ; personne ne sait qui l'autorise. Chez KRIBILOG, NETPORT SERVICES et le centre de services se renvoient les incidents.

Ce chapitre apprend à assembler les pratiques en processus maîtrisés : les modéliser (section 16.2), répartir les responsabilités (section 16.3), établir la correspondance entre les référentiels (section 16.4), mesurer (section 16.5) et améliorer (section 16.6). Le laboratoire GCI-LAB-09 fait construire la matrice RACI et la correspondance d'un processus de NOUN PAY.

© MaletYon

16.1 Processus et Pratiques

Définition

Processus : ensemble d'activités corrélées qui transforme des entrées en sorties, en vue d'un objectif. Il a un début, une fin, des acteurs et des résultats mesurables.

Propriétaire de processus (*process owner*) : personne qui répond de la conception, de la performance et de l'amélioration d'un processus dans toute l'organisation. Elle ne l'exécute pas nécessairement elle-même.

Gestionnaire de processus (*process manager*) : personne qui pilote l'exécution quotidienne du processus, sur un périmètre donné.

Un processus n'est pas une pratique. Une *pratique* ITIL ou un *objectif* COBIT décrivent un domaine de maîtrise, avec toutes ses composantes (Chapitre 5). Un *processus* est l'enchaînement concret par lequel une organisation réalise une partie de ce domaine. La pratique « gestion des incidents » peut donner lieu à plusieurs processus : incidents ordinaires, incidents majeurs, incidents de sécurité.

16.2 Modéliser en BPMN

16.2.1 Les éléments du langage

Le langage BPMN (*Business Process Model and Notation*), publié par l'Object Management Group dans sa version 2.0 et repris par la norme ISO/IEC 19510, est la notation de référence pour modéliser les processus. Il suffit de quelques éléments pour en tirer l'essentiel.

Élément	Représentation	Usage
Événement	Cercle (début, intermédiaire, fin)	Ce qui déclenche, ponctue ou termine le processus
Activité	Rectangle arrondi	Une tâche ou un sous-processus
Passerelle	Losange	Un choix (exclusif), une séparation en parallèle, une jonction
Flux de séquence	Flèche pleine	L'ordre des activités
Flux de messages	Flèche en pointillé	Un échange entre deux acteurs
Couloir	Bande horizontale	Le rôle ou l'organisation qui exécute les activités

Tableau 16.1. Les éléments essentiels de BPMN 2.0

16.2.2 Un exemple

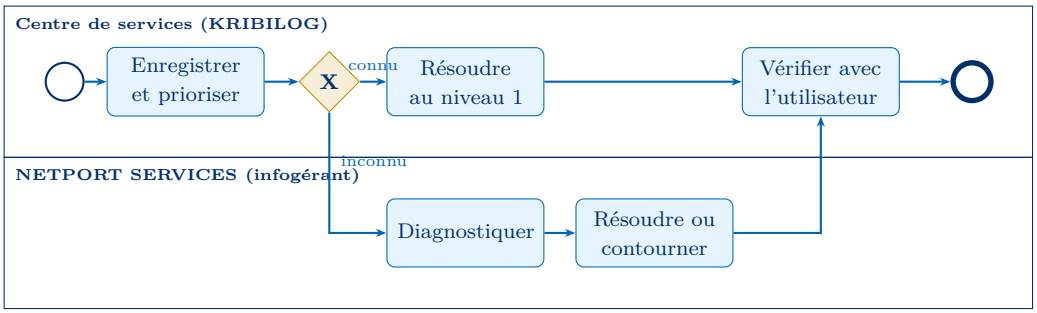


Figure 16.1. Processus de traitement d'un incident chez KRIBILOG (BPMN simplifié)

La figure fait apparaître ce que le texte des procédures masquait : le passage d'un couloir à l'autre. C'est à ces frontières que se perdent les incidents. Chez KRIBILOG, la flèche de retour de NETPORT SERVICES vers la vérification n'existait pas : l'infogérant clôturait lui-même les tickets (Chapitre 13).

★ Attention

Violation typique. Une organisation modélise ses processus tels qu'ils *devraient* être, à partir des référentiels, sans observer ce qui se passe réellement. Les schémas sont beaux, mais personne ne les applique.

Règle : modéliser d'abord le processus *tel qu'il est*, à partir d'entretiens et des traces de l'outil (principe « commencer là où l'on est », Chapitre 12), puis le processus cible, et mesurer l'écart.

16.3 Responsabiliser : la Matrice RACI

16.3.1 Quatre rôles

■ Définition

Matrice RACI : tableau qui croise les activités d'un processus et les rôles de l'organisation, et indique pour chaque case le rôle tenu :

- **R** (*Responsible*) : réalise l'activité ;
- **A** (*Accountable*) : en répond et l'approuve ;
- **C** (*Consulted*) : est consulté avant ;
- **I** (*Informed*) : est informé après.

COBIT 2019 fournit pour chaque pratique une matrice RACI type, établie avec des rôles génériques (Chapitre 6) ; il revient à chaque organisation de la traduire avec ses propres fonctions.

16.3.2 Cinq règles

1. **Un seul A par activité.** Deux personnes qui « répondent » d'une même activité, c'est n'en avoir aucune.
2. **Au moins un R par activité.** Une activité sans exécutant ne sera pas faite.
3. **Le A au bon niveau.** Celui qui répond doit avoir l'autorité de décider et les moyens d'agir.
4. **Peu de C.** Trop de consultations ralentissent tout ; consulter, c'est s'engager à attendre la réponse.
5. **Des noms de fonctions, pas de personnes.** La matrice survit aux départs.

Scénario Opérationnel · Opération NOUN. Qui autorise ?

Faits. Chez NOUN PAY, une nouvelle version du modèle de notation de crédit est préparée par l'équipe de science des données, testée par le directeur technique, déployée par l'équipe DevOps sur l'infrastructure du fournisseur de nuage. La fondatrice est « tenue au courant ». Le délégué à la protection des données n'est pas associé.

Matrice constatée.

Activité	DG	Dir. tech.	Données	DevOps	DPD
Préparer la version	I	A	R	·	·
Tester	·	A/R	C	·	·
Évaluer l'impact sur les clients	·	·	·	·	·
Autoriser la mise en production	I	A	·	A	·
Déployer	·	·	·	A/R	·

Constatation. L'activité « évaluer l'impact sur les clients » n'a ni R ni A. L'autorisation compte deux A. Le délégué à la protection des données n'apparaît nulle part.

Analyse (confiance élevée). Trois règles sur cinq sont violées. C'est l'explication directe de la demande de l'Autorité de protection des données (Chapitre 10) : personne n'était chargé de vérifier qu'une nouvelle version ne pénalisait pas une catégorie de clients.

Exigence de contrôle

Une matrice RACI auditable. Pour qu'une matrice RACI soit opposable, elle doit :

- porter sur des activités précises, rattachées à une pratique ou à un objectif identifié ;
- utiliser les fonctions réelles de l'organisation, telles qu'elles figurent à l'organigramme ;
- respecter les règles « un seul A » et « au moins un R » ;
- être approuvée par le propriétaire du processus et datée ;
- être cohérente avec les fiches de poste et les délégations de pouvoir.

16.4 COBIT, ITIL et ISO/IEC 20000-1

16.4.1 Pourquoi une correspondance

Une organisation qui utilise COBIT pour sa gouvernance, ITIL pour ses pratiques et vise l'ISO/IEC 20000-1 doit éviter de construire trois dispositifs parallèles. La correspondance permet de n'avoir qu'un processus, documenté une fois, qui répond aux trois référentiels.

COBIT 2019	Pratiques ITIL 4	ISO/IEC 20000-1:2018
APO08 Relations	Gestion des relations	8.3.2 Relations avec les clients
APO09 Accords de service	Gestion des niveaux de service, du catalogue	8.3.3 Niveaux de service ; 8.2.4 Catalogue
APO10 Fournisseurs	Gestion des fournisseurs	8.3.4 Fournisseurs
APO06 Budget et coûts	Gestion financière des services	8.4.1 Budgétisation et comptabilité
BAI04 Disponibilité et capacité	Gestion de la disponibilité, de la capacité et des performances	8.7.1 Disponibilité ; 8.4.3 Capacité
BAI06 Changements	Habilitation des changements	8.5.1 Changements
BAI07 Transition	Mises en production, déploiements, validation et tests	8.5.2 Conception et transition ; 8.5.3 Mises en production et déploiement
BAI09 Actifs	Gestion des actifs informatiques	8.2.5 Actifs
BAI10 Configuration	Gestion de la configuration des services	8.2.6 Configuration
DSS02 Demandes et incidents	Centre de services, incidents, demandes de service	8.6.1 Incidents ; 8.6.2 Demandes de service
DSS03 Problèmes	Gestion des problèmes	8.6.3 Problèmes
DSS04 Continuité	Gestion de la continuité des services	8.7.2 Continuité
APO13, DSS05 Sécurité	Gestion de la sécurité de l'information	8.7.3 Sécurité de l'information
MEA01 Performance	Mesure et compte rendu	9.1 Surveillance et mesure

Tableau 16.2. Correspondance entre COBIT 2019, ITIL 4 et l'ISO/IEC 20000-1:2018 (établie par nos soins ; numéros d'articles de la norme à vérifier dans son texte)

16.4.2 Les limites d'une correspondance

Une correspondance n'est jamais une équivalence. Trois précautions s'imposent.

- **Les périmètres diffèrent.** L'objectif BAI07 de COBIT couvre la conversion des données et la revue après mise en œuvre, que la pratique ITIL de gestion des mises en production ne traite pas de la même manière.
- **Les natures diffèrent.** COBIT fixe un objectif, ITIL décrit une pratique, la norme formule une exigence : satisfaire l'une ne garantit pas de satisfaire les autres.
- **Les éditions changent.** Une correspondance se date et se révise à chaque nouvelle édition d'un des référentiels.

Application Responsable GRC

Construire un référentiel unique de processus

1. Partir des objectifs COBIT prioritaires (Chapitre 7).
2. Pour chacun, désigner le processus de l'organisation qui le réalise, et la pratique ITIL qui guide sa conception.
3. Repérer les exigences de l'ISO/IEC 20000-1 si une certification est visée, et les obligations légales (Chapitre 10).
4. Documenter le processus une seule fois, avec un tableau de correspondance en annexe.
5. Faire approuver l'ensemble par le comité stratégique des SI.

16.5 Mesurer : KPI, KGI et Tableau de Bord

16.5.1 Deux familles d'indicateurs

Définition

Indicateur clé d'objectif (*key goal indicator*, KGI) : indicateur qui dit si un objectif est atteint. Il mesure un résultat, après coup.

Indicateur clé de performance (*key performance indicator*, KPI) : indicateur qui dit si un processus fonctionne bien et a des chances d'atteindre l'objectif. Il mesure une performance, en cours de route.

Cette distinction, mise en avant par COBIT 4.1 [27], reste utile : COBIT 2019 propose pour chaque objectif d'entreprise, chaque objectif d'alignement et chaque pratique des « exemples d'indicateurs », qui relèvent de l'une ou l'autre famille.

Niveau	Indicateur (KRIBILOG)	Destinataire
Objectif d'entreprise (KGI)	Nombre de navires retardés par une panne du suivi	Conseil d'administration
Objectif d'alignement (KGI)	Disponibilité de bout en bout du service de suivi	Comité stratégique des SI
Processus (KPI)	Taux de réouverture des incidents ; âge moyen des problèmes ouverts	Responsable des services informatiques
Activité (KPI)	Part des tickets enregistrés dans les 5 minutes	Responsable du centre de services

Tableau 16.3. La cascade des indicateurs

16.5.2 Un bon indicateur

Un indicateur utile est **défini** (formule, source, fréquence), **assorti d'une cible**, **attribué** à un responsable, **difficile à manipuler** (accompagné de son indicateur de contrôle, Chapitre 13) et **suivi d'action** : un indicateur dont l'écart ne déclenche jamais rien est un indicateur inutile.

Fiche processus · MEA01 · Gérer la surveillance de la performance et de la conformité

Finalité : assurer la transparence de la performance et de la conformité, et piloter l'atteinte des objectifs.
Contenu (résumé) : fixer l'approche de surveillance, définir les cibles, collecter et traiter les données, analyser et rendre compte de la performance, assurer la mise en œuvre des actions correctives.
Sorties : tableau de bord, rapports de performance, plans d'action.
RACI (extrait, KRIBILOG) : *A* au directeur général, *R* au responsable des services informatiques et au responsable GRC, *I* au conseil.
Indicateurs : part des indicateurs dotés d'une cible et d'un responsable ; délai entre l'écart constaté et l'action décidée.

Résumé établi par nos soins à partir de COBIT 2019 [22].

16.6 Propriétaires et Amélioration Continue

Un processus sans propriétaire se dégrade. Le propriétaire répond de quatre choses : la conception du processus et sa documentation, la définition de ses indicateurs, sa performance dans toute l'organisation, et son amélioration. Il conduit, au moins une fois par an, une revue du processus : indicateurs, incidents, constats d'audit, retours des utilisateurs, et alimente le registre des améliorations (Chapitre 12).

Application DSI

Désigner les propriétaires de processus

1. Un propriétaire par processus prioritaire, de rang suffisant pour imposer ses décisions aux équipes concernées.
2. Pour les processus qui traversent un fournisseur, un propriétaire *interne* : on n'externalise pas la propriété d'un processus.
3. Une lettre de mission, qui précise les pouvoirs, les indicateurs et le rythme de la revue.
4. Une présentation annuelle de chaque propriétaire au comité stratégique des SI.

Le processus n'est-il pas l'ennemi de l'agilité ?

Un processus lourd, imposé d'en haut et jamais révisé, l'est sans doute. Mais l'absence de processus n'est pas l'agilité : c'est la dépendance aux personnes. Les organisations agiles ont des processus courts, visibles, automatisés quand c'est possible, et révisés souvent ; elles appliquent les principes d'ITIL « rester simple et pratique » et « progresser par itérations ». Le Chapitre 18 y reviendra.

❍

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Processus et pratique** : la pratique décrit un domaine de maîtrise, le processus l'enchaînement concret par lequel l'organisation le réalise.
- **BPMN** rend visibles les frontières entre acteurs, là où se perdent les dossiers. Modéliser d'abord l'existant.
- **RACI** : un seul A, au moins un R, le A au bon niveau, peu de C, des fonctions et non des personnes.
- **La correspondance COBIT, ITIL, ISO/IEC 20000-1** permet un seul processus pour trois référentiels ; ce n'est jamais une équivalence.
- **KGI et KPI** : le premier dit si l'objectif est atteint, le second si le processus a des chances de l'atteindre. Les indicateurs se déclinent du conseil à l'activité.
- **Un propriétaire par processus**, interne même quand le processus traverse un fournisseur, qui en conduit la revue annuelle.

✍ Exercice 16.1. Corriger une matrice RACI ★☆☆

Reprenez la matrice constatée de NOUN PAY (section 16.3).

(a) Listez toutes les violations des cinq règles.

(b) Proposez une matrice corrigée, en ajoutant les activités qui manquent.

(c) Indiquez qui doit approuver la matrice corrigée.

✍ Exercice 16.2. Modéliser le processus de changement de l'ANPP ★★☆

Modélisez en BPMN le processus de changement normal de l'ANPP, depuis la demande d'une direction métier jusqu'à la clôture, avec quatre couloirs : direction métier, division informatique, comité des changements, prestataire.

(a) Faites figurer au moins une passerelle exclusive (autorisé ou refusé) et un flux de messages.

(b) Repérez les frontières où le dossier risque de se perdre.

(c) Établissez la matrice RACI correspondante.

(d) Rattachez chaque activité à une pratique de BAI06 et à l'article correspondant de l'ISO/IEC 20000-1.

✍ Exercice 16.3. Le tableau de bord de la BANQUE SANAGA ★★★

Construisez le tableau de bord de la gouvernance des SI de la BANQUE SANAGA pour l'année qui suit la panne.

(a) Proposez deux KGI par niveau (objectifs d'entreprise prioritaires, objectifs d'alignement) et deux KPI pour chacun des dix objectifs prioritaires (Chapitre 6).

(b) Pour chaque indicateur, précisez la formule, la source, la fréquence, la cible et le responsable.

(c) Associez à chaque indicateur susceptible d'être manipulé son indicateur de contrôle.

(d) Indiquez ce qui sera présenté au conseil, au comité stratégique des SI et au comité d'audit.

Note

Transition. Le cours a désormais présenté toutes les pièces : la gouvernance, COBIT, le cadre normatif et juridique, ITIL et les processus. Le Chapitre 17 les assemble sur les quatre cas fil rouge, en études de cas intégratrices.

17

ÉTUDES DE CAS INTÉGRATEURS

« On ne comprend vraiment un référentiel que le jour où il faut l'appliquer à une organisation qui ne lui ressemble pas. »

Principe de l'apprentissage par les cas

Niveau : *Expert* • Maîtrise des Chapitres 8 (capacité et feuille de route), 11 (audit et constats) et 16 (processus, RACI, indicateurs).

✦ Objectifs du chapitre

- ➢ Mobiliser l'ensemble du cours sur les quatre cas fil rouge.
- ➢ Produire un diagnostic de gouvernance complet.
- ➢ Bâtir une feuille de route COBIT–ITIL chiffrée.
- ➢ Présenter et défendre ses recommandations.
- ➢ Se préparer à l'examen (grille d'erreurs, simulation).

Mode d'emploi du chapitre

Ce chapitre ne présente aucune notion nouvelle. Il reprend les quatre organisations du cours, un an après les événements qui les ont fait connaître, et pose à chaque fois la même question : *la gouvernance des SI a-t-elle réellement progressé, et que faut-il faire maintenant ?*

Chaque cas suit quatre temps. Le **brief** donne la situation et la demande. L'**investigation guidée** propose les questions à se poser, avec le chapitre qui permet d'y répondre. Les **révélations** apportent, par étapes, des faits nouveaux qui obligent à réviser le premier jugement. La **synthèse** donne une réponse de référence, à comparer avec la vôtre. Travaillez chaque cas *avant* de lire sa synthèse.

La section 17.1 fixe la méthode commune. Les sections 17.2 à 17.5 traitent les quatre cas. Les sections 17.6 et 17.7 proposent une grille d'erreurs et une simulation d'examen. Le laboratoire GCI-LAB-10 de NDAP SUKULU reprend la démarche sur les quatre dossiers.

© MaletYon

17.1 La Méthode du Diagnostic Intégré

17.1.1 Six volets

Un diagnostic de gouvernance des SI couvre six volets. Chacun mobilise une partie du cours.

Volet	Questions	Chapitres
1. Organes et décisions	Qui décide de quoi ? Les organes fonctionnent-ils ?	1, 3
2. Valeur et portefeuille	Les investissements sont-ils arbitrés et leurs bénéfices suivis ?	3
3. Système COBIT	Objectifs prioritaires, capacité constatée et cible, écarts	6 à 8
4. Conformité	Obligations légales et réglementaires, preuves	9, 10
5. Services	Pratiques ITIL, niveaux de service, indicateurs	12 à 16
6. Fournisseurs et continuité	Contrats, supervision, plans testés	15

Tableau 17.1. Les six volets du diagnostic intégré

17.1.2 Le livrable

Exigence de contrôle

Le rapport de diagnostic. Le rapport remis à l'organe de gouvernance comporte :

- une synthèse d'une page, avec trois messages et trois décisions demandées ;
- le périmètre, les sources et la méthode (entretiens, pièces, tests) ;
- pour chaque volet, les constats en cinq éléments (Chapitre 11), chacun avec son niveau de confiance ;
- le tableau des écarts de capacité (Chapitre 8) ;
- la feuille de route chiffrée, avec ses propriétaires et ses échéances ;
- les risques de la feuille de route elle-même.

17.2 Cas 1 : la BANQUE SANAGA, un An Après

17.2.1 Brief initial

Scénario Opérationnel · Opération SANAGA. Mars 2027

Un an après la panne, la COBAC annonce une mission de contrôle sur place consacrée au risque informatique. Le président du conseil d'administration vous demande, comme consultant indépendant, un diagnostic préalable : « Avons-nous fait ce que nous avions annoncé à la COBAC, et sommes-nous prêts ? »

Pièces remises. Le rapport circonstancié à la COBAC (avril 2026), la feuille de route à dix-huit mois (Chapitre 8), les procès-verbaux du comité stratégique des SI, le registre des changements de l'année, le contrat renégocié avec DIGICORE AFRIQUE, le compte rendu de l'agence pilote de la nouvelle bascule.

17.2.2 Investigation guidée

1. Le comité stratégique des SI fonctionne-t-il selon les critères du Chapitre 1 ? Reçoit-il une information indépendante de celle du directeur général ?
2. Où en est chaque ligne de la feuille de route ? Quelles capacités ont été réévaluées, et par qui (Chapitre 8) ?
3. Le registre des changements montre-t-il une gestion conforme à la grille de risque (Chapitre 14) ?
4. Le contrat de DIGICORE AFRIQUE contient-il les clauses essentielles (Chapitre 15), et sont-elles appliquées ?
5. Les obligations légales et réglementaires sont-elles tenues et prouvées (Chapitre 10) ?

17.2.3 Révélations progressives

Scénario Opérationnel · Opération SANAGA. Première révélation

Le comité stratégique des SI s'est réuni quatre fois, comme prévu. Mais ses procès-verbaux montrent qu'il n'a examiné que des présentations du directeur général ; la DSI et l'audit interne n'ont jamais été entendus séparément. Le pouvoir d'accès direct prévu par la charte n'a pas été exercé.

Scénario Opérationnel · Opération SANAGA. Deuxième révélation

Le registre compte 412 changements dans l'année, dont 91 qualifiés d'urgents (22 %). La procédure des changements urgents a bien été rédigée, mais 64 de ces 91 changements n'ont pas fait l'objet de la revue a posteriori prévue.

Scénario Opérationnel · Opération SANAGA. Troisième révélation

Le contrat renégocié avec DIGICORE AFRIQUE contient désormais des engagements de service, des pénalités et un droit d'audit. Les pénalités dues pour deux manquements en 2026 (évaluées à 38 millions FCFA) n'ont pas été réclamées : la direction des achats « ne voulait pas dégrader la relation pendant la nouvelle bascule ». Le droit d'audit n'a jamais été exercé.

17.2.4 Synthèse et rapport

Volet	Constat principal	Conf.	Objectif
Organes	Le comité existe, mais reproduit l'asymétrie d'information qu'il devait réduire	Élevée	EDM01
COBIT	Gains rapides réalisés (DSS04, MEA02) ; chantiers de fond en retard (EDM03, APO12)	Moyenne	EDM03, APO12
Changements	Taux d'urgence élevé, revues a posteriori non faites (70 %)	Élevée	BAI06
Fournisseurs	Clauses présentes mais non appliquées	Élevée	APO10
Conformité	Audit de sécurité légal réalisé en 2026	Élevée	MEA03

Tableau 17.2. Synthèse du diagnostic de la BANQUE SANAGA

Message principal au conseil. La banque a mis en place les *structures* et les *documents* annoncés, mais pas encore les *comportements* : le comité n'écoute qu'une voix, les contrôles sont contournés quand ils dérangent, les clauses ne sont pas appliquées. C'est exactement ce que la grille de De Haes et Van Grembergen permet de diagnostiquer (Chapitre 1) : des structures sans mécanismes relationnels. La COBAC le verra.

Scénario Opérationnel · Opération SANAGA. Feuille de route

Action	Propriétaire	Coût (M FCFA)	Échéance
Audition séparée de la DSI et de l'audit interne à chaque comité	Président du comité	0	Immédiat
Revue a posteriori obligatoire des changements urgents, indicateur trimestriel	Responsable des changements	15	3 mois
Réclamation des pénalités 2026 et premier audit de DIGICORE AFRIQUE	Direction des achats, RSSI	25	3 mois
Appétence au risque approuvée par le conseil, registre des risques SI relié au registre de la banque	Directeur des risques	60	6 mois
Réévaluation indépendante de la capacité des dix objectifs	Audit interne et cabinet externe	45	9 mois
Formation des administrateurs à la gouvernance des SI	Secrétaire du conseil	12	6 mois
Total		**157**	

Le coût est à rapporter aux 1,9 milliard FCFA de la panne de 2026 : moins de 9 %.

17.3 Cas 2 : KRIBILOG, la Certification en Jeu

17.3.1 Brief initial

Scénario Opérationnel · Opération KRIBI. Mois 12 sur 18

KRIBILOG SA doit obtenir la certification ISO/IEC 20000-1 dans six mois pour conserver le contrat de l'armateur (Chapitre 9). M. MBARGA vous demande un avis : « Pouvons-nous solliciter l'organisme de certification comme prévu au mois 16 ? »

Pièces remises. Le plan de certification, l'avenant au contrat de NETPORT SERVICES, les indicateurs mensuels des six derniers mois, le registre des problèmes, le rapport d'audit interne du mois 11.

17.3.2 Investigation guidée

1. Les pratiques des articles 8.5 et 8.6 de la norme fonctionnent-elles depuis assez longtemps pour produire des enregistrements probants (Chapitre 9) ?
2. Les indicateurs ont-ils progressé, et sont-ils mesurés par KRIBILOG elle-même (Chapitres 13 et 15) ?
3. Le correctif de l'éditeur a-t-il été installé, et le problème clos (Chapitre 14) ?

4. L'avenant donne-t-il à KRIBILOG la maîtrise d'un service exploité par un tiers ?

17.3.3 Révélations progressives

Scénario Opérationnel · Opération KRIBI. Première révélation

Les progrès sont réels. Le taux de réouverture est passé de 30 % à 12 %, le volume mensuel de tickets de 4 800 à 3 100, grâce au libre-service et à l'installation du correctif. La disponibilité de bout en bout du service de suivi atteint 99,3 % en moyenne sur six mois, avec un second opérateur mobile depuis le mois 8.

Scénario Opérationnel · Opération KRIBI. Deuxième révélation

L'audit interne du mois 11 relève que NETPORT SERVICES a confié, sans en informer KRIBILOG, l'hébergement des sauvegardes à un sous-traitant situé à Casablanca. L'avenant ne traite ni de la sous-traitance en cascade, ni de la localisation des données.

Scénario Opérationnel · Opération KRIBI. Troisième révélation

La revue de direction prévue au mois 15 par la norme n'est pas encore programmée ; le directeur général « n'en voit pas l'intérêt, puisque les indicateurs sont bons ».

17.3.4 Synthèse et rapport

Avis. Le calendrier peut être tenu, *sous deux conditions*. La première tient au fournisseur : un nouvel avenant doit traiter la sous-traitance et la localisation des données avant l'audit, faute de quoi l'organisme de certification relèvera une non-conformité majeure sur la maîtrise des processus confiés à des tiers, et KRIBILOG s'exposera au titre de la loi n° 2024/017 (Chapitre 10). La seconde tient à la direction : la revue de direction est une exigence de la norme (article 9 de la structure harmonisée), et non une formalité ; sans elle, pas de certification.

Application Responsable des services IT

Présenter l'avis au directeur général

1. Commencer par les progrès, chiffrés : ils sont réels et mesurés.
2. Présenter les deux conditions comme des risques pour le contrat de l'armateur, en termes d'affaires et non de norme.
3. Proposer la date de la revue de direction et son ordre du jour.
4. Demander une décision écrite sur l'avenant avec NETPORT SERVICES.

17.4 Cas 3 : l'ANPP face à la Chambre des Comptes

17.4.1 Brief initial

Scénario Opérationnel · Opération MEFOU. Le rapport provisoire

La Chambre des comptes a transmis à l'ANPP son rapport provisoire d'audit des SI (Chapitre 11). Le directeur général dispose de deux mois pour répondre. Il vous demande de préparer la réponse et le plan d'action.

Constats du rapport provisoire. Absence de comité stratégique des SI jusqu'en 2026 ; projets lancés sans dossier d'investissement ; trois projets ayant consommé 71 % du budget du schéma directeur sans être achevés ; 14 comptes d'agents partis actifs sur le système de paiement ; séparation des tâches défaillante sur 6 comptes sur 25.

17.4.2 Investigation guidée

1. Quels constats sont fondés, et lesquels peuvent être nuancés par des pièces que l'auditeur n'a pas vues (Chapitre 11) ?
2. Comment réarbitrer le portefeuille restant (Chapitre 3) ?
3. Comment rattacher les projets aux programmes budgétaires (loi n° 2018/012) ?
4. Quelles actions immédiates sur les accès (Chapitres 13 et 11) ?

17.4.3 Révélations progressives

Scénario Opérationnel · Opération MEFOU. Première révélation

Le projet de paie dématérialisée, présenté comme « inachevé » dans le rapport, est en réalité en service depuis janvier 2027. Mais aucun suivi des bénéfices n'a été fait : personne ne sait si les délais de paiement ont diminué.

Scénario Opérationnel · Opération MEFOU. Deuxième révélation

Les 14 comptes actifs d'agents partis ont été désactivés le lendemain du passage de l'auditeur. Mais la cause (l'absence de notification des départs par les ressources humaines) n'a pas été traitée : trois nouveaux départs, depuis, n'ont pas été signalés.

17.4.4 Synthèse et rapport

La réponse à la Chambre des comptes admet les constats fondés, apporte les pièces qui nuancent le constat sur le projet de paie, et présente un plan d'action qui traite les *causes* :

- un comité stratégique des SI, créé par décision du conseil, avec une charte inspirée de l'ISO/IEC 38500 (Chapitre 9) ;
- un réarbitrage du portefeuille restant par score multicritère (Chapitre 3), et l'arrêt d'un projet ;

- un suivi des bénéfices du projet de paie, avec un indicateur rattaché au projet de performance annuel du programme ;
- une notification automatique des départs et une revue trimestrielle des accès (DSS05, DSS06).

★ Attention

Violation typique. Corriger le symptôme le lendemain de l'audit (désactiver les 14 comptes) et présenter la correction comme une réponse au constat. L'auditeur vérifiera la cause, et constatera la récidive.

Règle : une réponse à un rapport d'audit traite la cause, désigne un responsable et une échéance, et indique la pièce qui prouvera la mise en œuvre.

17.5 Cas 4 : NOUN PAY, Croître sans Perdre la Confiance

17.5.1 Brief initial

Scénario Opérationnel · Opération NOUN. La levée de fonds

NOUN PAY prépare une levée de fonds de 2 milliards FCFA. Les investisseurs exigent un diagnostic de gouvernance des SI avant de signer. Au même moment, l'Autorité de protection des données poursuit son enquête sur le modèle de notation (Chapitre 10).

Pièces remises. La matrice RACI du processus de mise à jour du modèle (Chapitre 16), le contrat type du fournisseur de nuage, la réponse provisoire à l'Autorité, les statistiques de refus de crédit par région.

17.5.2 Investigation guidée

1. Quels facteurs de conception caractérisent NOUN PAY, et quel système de gouvernance proportionné en découle (Chapitre 7) ?
2. Le contrat du fournisseur de nuage permet-il de maîtriser la localisation des données, la réversibilité et l'audit (Chapitre 15) ?
3. Qui répond, dans l'entreprise, des effets du modèle sur les clients (Chapitre 16) ?

17.5.3 Révélations progressives

Scénario Opérationnel · Opération NOUN. Première révélation

Les statistiques montrent que le taux de refus est de 61 % pour les demandeurs d'une région, contre 24 % en moyenne nationale. Le modèle utilise, parmi ses variables, l'opérateur mobile du demandeur, très corrélé à la région.

Scénario Opérationnel · Opération NOUN. Deuxième révélation

Le contrat type du fournisseur de nuage ne permet ni de choisir la localisation des données, ni d'auditer le fournisseur ; il renvoie à ses propres certifications. Un contrat d'entreprise négocié existe chez le même fournisseur, pour un surcoût annuel de 18 millions FCFA.

17.5.4 Synthèse et rapport

Message aux investisseurs. NOUN PAY n'a pas besoin d'un système COBIT complet, mais de six objectifs bien tenus (Chapitre 7) : EDM03 (appétence au risque), APO10 (fournisseur de nuage), APO12 (risques), APO14 (données), BAI06 (changements du modèle) et MEA03 (conformité). Deux décisions sont urgentes : souscrire le contrat d'entreprise du fournisseur de nuage, et suspendre l'usage de la variable « opérateur mobile » en attendant une analyse d'impact du modèle. Le Chapitre 19 reprendra ce cas sous l'angle de la gouvernance de l'intelligence artificielle.

17.6 Grille des Erreurs Transversales

Les quatre cas font réapparaître, sous des formes différentes, les mêmes erreurs. La grille du Chapitre 2 s'enrichit de celles que révèle la mise en œuvre.

Erreur	Cas	Antidote
Des structures sans comportements	SANAGA	Évaluer le fonctionnement des organes, pas leur existence (Chapitre 8)
Des contrôles contournés quand ils gênent	SANAGA	Indicateur de contournement (taux d'urgence, revues non faites)
Des clauses non appliquées	SANAGA	Comité de service, réclamation systématique des pénalités
Une sous-traitance en cascade ignorée	KRIBI	Clause de sous-traitance et de localisation, droit d'audit
Un indicateur bon qui dispense de la revue	KRIBI	La revue de direction est une exigence, pas une option
Un symptôme corrigé, une cause intacte	MEFOU	Traiter la cause, prouver par une pièce
Un projet livré sans suivi des bénéfices	MEFOU	EDM02, indicateur rattaché au programme
Une décision automatisée sans responsable	NOUN	Un A pour l'évaluation de l'impact sur les clients

Tableau 17.3. Erreurs transversales de mise en œuvre

17.7 Simulation d'Examen

● Note

Sujet type. *Durée : 3 heures. Documents autorisés : aucun, sauf le tableau des 40 objectifs COBIT fourni.*

Cas *(fictif, construit pour l'examen).* La SOCIÉTÉ D'EAU DU NORD, entreprise publique installée à Garoua, distribue l'eau potable à 180 000 abonnés. Son système de facturation, exploité par un prestataire, a émis en septembre des factures erronées à 30 000 abonnés. Le conseil d'administration, qui se réunit deux fois par an, l'a appris par la presse. La direction informatique compte huit personnes. Aucun comité ne traite du numérique.

1. **(4 points)** Distinguez la cause technique probable et les causes de gouvernance, en appliquant les trois questions réflexes.
2. **(4 points)** Proposez les organes de gouvernance des SI adaptés à une entreprise publique de cette taille, en tenant compte de la tutelle.
3. **(4 points)** Renseignez les facteurs de conception et retenez six objectifs COBIT prioritaires, avec leur capacité cible.
4. **(4 points)** Rédigez deux constats d'audit en cinq éléments, l'un sur la gestion des changements, l'autre sur le contrat du prestataire.
5. **(4 points)** Présentez une feuille de route à douze mois, chiffrée en FCFA, en distinguant gains rapides et chantiers de fond.

★ Attention

Ce que le correcteur attend. Des constatations séparées des analyses ; des références précises (objectifs COBIT, pratiques ITIL, textes de loi vérifiés) ; des recommandations qui traitent des causes ; une gouvernance *proportionnée* à une organisation de huit informaticiens. Une copie qui recommande de « déployer COBIT et ITIL » sans choisir n'obtient pas la moyenne.

❍

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- ➢ **Six volets** : organes et décisions, valeur, système COBIT, conformité, services, fournisseurs et continuité. Un diagnostic les couvre tous.
- ➢ **Les structures ne suffisent pas** : un an après, la BANQUE SANAGA a ses comités et ses documents, mais pas encore les comportements.
- ➢ **Les bons indicateurs ne dispensent de rien** : KRIBILOG progresse,

mais une sous-traitance cachée et une revue de direction négligée menacent sa certification.

- **Traiter les causes** : l'ANPP corrige des symptômes le lendemain de l'audit et voit les écarts revenir.
- **La proportion** : NOUN PAY n'a besoin que de six objectifs bien tenus, et de deux décisions urgentes.
- **Une feuille de route se chiffre** : à rapporter au coût des défaillances qu'elle prévient.

✍ Exercice 17.1. Le rapport de la BANQUE SANAGA ★☆☆

Rédigez la synthèse d'une page du diagnostic de la BANQUE SANAGA : trois messages, trois décisions demandées au conseil, et le coût de la feuille de route rapporté au coût de la panne.

✍ Exercice 17.2. L'avenant de KRIBILOG ★★☆

Rédigez les clauses de l'avenant au contrat de NETPORT SERVICES qui traitent la sous-traitance en cascade, la localisation des sauvegardes et le droit d'audit. Pour chacune, indiquez le risque traité et la pièce qui permettra de vérifier son application.

✍ Exercice 17.3. Traiter le sujet d'examen ★★★

Traitez en trois heures le sujet de la section 17.7, puis comparez votre copie avec les attentes du correcteur. Pour chaque question, indiquez les chapitres du cours que vous avez mobilisés.

● Note

Transition. La Partie IV s'achève. Les quatre cas ont montré que la gouvernance des SI se joue sur des terrains qui évoluent vite : l'informatique en nuage, les méthodes agiles, les données et l'intelligence artificielle. La Partie V les aborde, en commençant par le Chapitre 18 : gouverner à grande vitesse.

partie V

Défis Avancés et Émergents

© MaletYon

18

AGILITÉ, DEVOPS ET CLOUD : GOUVERNER À GRANDE VITESSE

« La vitesse n'est pas l'ennemie du contrôle.
C'est le contrôle manuel qui est l'ennemi de la vitesse. »

Principe des équipes DevOps

Niveau : *Expert* • Maîtrise des Chapitres 14 (gestion des changements) et 15 (niveaux de service et fournisseurs).

✦ Objectifs du chapitre

- ➢ Concilier contrôle et agilité (DevOps, gestion automatisée des changements).
- ➢ Gouverner l'informatique en nuage (responsabilité partagée, réversibilité, localisation des données).
- ➢ Évaluer un contrat d'informatique en nuage au regard du droit camerounais.
- ➢ Comparer les approches de gouvernance numérique de plusieurs pays africains.

Question directrice : peut-on gouverner ce qui change chaque jour ?

La nouvelle équipe mobile de la BANQUE SANAGA déploie une version de l'application chaque semaine, et voudrait passer à un déploiement par jour. Le comité des changements, qui se réunit le mardi, ne peut pas suivre. À Bafoussam, NOUN PAY n'a pas un seul serveur à elle : tout son système d'information est loué, à la minute, à un fournisseur de nuage étranger.

Les Parties II à IV ont construit une gouvernance faite de comités, de procédures et d'autorisations. La Partie V, qui s'ouvre ici, la confronte aux pratiques qui en bousculent les rythmes et les frontières. Ce chapitre traite de l'agilité et de DevOps (sections 18.1 et 18.2), de l'informatique en nuage (section 18.3), du contrat de nuage au regard du droit camerounais (section 18.4), puis des approches africaines de la gouvernance numérique (section 18.5).

18.1 L'Agilité

18.1.1 Le manifeste et ses conséquences

Le *Manifeste pour le développement agile de logiciels*, publié en 2001 par dix-sept praticiens, pose quatre préférences : les individus et leurs interactions plutôt que les processus et les outils, des logiciels opérationnels plutôt qu'une documentation exhaustive, la collaboration avec les clients plutôt que la négociation contractuelle, l'adaptation au changement plutôt que le suivi d'un plan [3]. Il précise que les éléments de droite gardent leur valeur, mais que ceux de gauche en ont davantage.

★ Attention

Violation typique. Une équipe invoque l'agilité pour ne rien documenter, ne rien faire autoriser et ne rendre compte à personne. Lors d'un incident, personne ne sait quelle version est en production ni qui l'a validée.

Règle : l'agilité change la *forme* du contrôle, pas son existence. Le manifeste ne supprime ni la documentation, ni les contrats, ni les plans : il en change le poids relatif.

18.1.2 Ce qui change pour la gouvernance

Sujet	Approche traditionnelle	Approche agile
Décision d'investissement	Un projet, un budget, une date de fin	Un produit, une équipe stable, un financement par période
Pilotage	Respect du plan, du budget, des délais	Valeur livrée à chaque itération
Exigences	Définies au départ	Priorisées en continu par un responsable de produit
Contrôle	Jalons et validations formelles	Démonstrations régulières, critères de « fini »

Tableau 18.1. Gouvernance traditionnelle et gouvernance agile

La gouvernance ne disparaît pas : elle se déplace. Le comité stratégique n'approuve plus un cahier des charges, il fixe les objectifs d'un produit, l'enveloppe d'une équipe et les indicateurs de valeur (Chapitre 3), puis revoit ces décisions à intervalles réguliers.

18.2 DevOps

18.2.1 Rapprocher le développement et l'exploitation

Définition

DevOps : ensemble de pratiques culturelles et techniques qui rapproche les équipes de développement et d'exploitation, pour livrer des changements fréquents, fiables et réversibles, grâce à l'automatisation de la construction, des tests et du déploiement.

Chaîne de déploiement (*pipeline*) : suite automatisée des étapes par lesquelles un changement de code passe, de sa validation par un pair à sa mise en production.

18.2.2 Mesurer la performance de la livraison

Les travaux de Forsgren, Humble et Kim [16] ont popularisé quatre indicateurs de la performance de la livraison logicielle. Ils ont une propriété précieuse pour la gouvernance : ils mesurent à la fois la vitesse *et* la stabilité.

Indicateur	Mesure	Dimension
Fréquence de déploiement	Nombre de mises en production par période	Vitesse
Délai de livraison des changements	Temps entre la validation du code et sa mise en production	Vitesse
Taux d'échec des changements	Part des déploiements qui provoquent un incident ou un retour arrière	Stabilité
Délai de rétablissement	Temps pour rétablir le service après un échec	Stabilité

Tableau 18.2. Les quatre indicateurs de la performance de livraison

Le taux d'échec des changements et le délai de rétablissement sont les indicateurs de BAI06 et de DSS02 (Chapitres 14 et 13) : DevOps ne remplace pas la gestion des changements, il en mesure le résultat.

18.2.3 Déplacer le contrôle dans la chaîne

Contrôle traditionnel	Équivalent dans une chaîne DevOps
Autorisation par le comité des changements	Changement standard pré-autorisé, si la chaîne valide toutes les étapes ; comité réservé aux changements hors norme
Séparation des tâches entre développeur et exploitant	Revue obligatoire du code par un pair ; le développeur ne peut pas fusionner seul son code
Tests de recette manuels	Tests automatisés obligatoires, avec seuil de couverture bloquant
Plan de retour arrière	Déploiement progressif et retour arrière automatique en cas d'erreur
Procès-verbal d'autorisation	Journal inaltérable de la chaîne (qui, quoi, quand, avec quels résultats de tests)

Tableau 18.3. Les contrôles de la gestion des changements dans une chaîne DevOps

Scénario Opérationnel · Opération SANAGA. L'équipe mobile

Demande. L'équipe mobile veut déployer chaque jour, sans passer par le comité des changements.

Décision du comité stratégique. Les déploiements de l'application mobile sont reconnus comme *changements standard* à quatre conditions, vérifiées par la chaîne : revue du code par un pair, tests automatisés couvrant au moins 90 % des fonctions de paiement, déploiement progressif (5 % des clients pendant une heure), retour arrière automatique. Tout changement touchant l'interface avec le système central reste un changement normal, soumis au comité.

Contrôle. L'auditrice interne examine chaque trimestre un échantillon de déploiements dans le journal de la chaîne : elle teste désormais un contrôle *automatisé*, et non plus une signature.

Application Auditeur SI

Auditer une chaîne DevOps

1. Obtenir la description de la chaîne et des contrôles qu'elle impose, puis vérifier qu'ils sont bloquants (un test échoué arrête le déploiement).
2. Vérifier qui peut modifier la chaîne elle-même : c'est le nouveau point de contrôle critique.
3. Rapprocher les déploiements en production du journal de la chaîne : un déploiement hors chaîne est un changement non autorisé.
4. Suivre les quatre indicateurs de performance de livraison, et notamment le taux

d'échec.

18.3 L'Informatique en Nuage

18.3.1 Définitions

La définition de référence est celle du NIST [30] : l'informatique en nuage permet un accès à la demande, par le réseau, à un ensemble partagé de ressources informatiques configurables, rapidement mises à disposition et libérées avec un effort de gestion minimal. Elle présente cinq caractéristiques : libre-service à la demande, large accès par le réseau, mutualisation des ressources, élasticité rapide, service mesuré.

Modèle	Ce que fournit le prestataire	Exemple
IaaS (infrastructure)	Serveurs, stockage, réseau virtuels	L'hébergement des serveurs de NOUN PAY
PaaS (plateforme)	Environnement d'exécution, bases de données gérées	La base de données gérée du modèle de notation
SaaS (logiciel)	Application complète	La messagerie de la BANQUE SANAGA

Tableau 18.4. Les trois modèles de service du NIST

18.3.2 La responsabilité partagée

Dans le nuage, la responsabilité de la sécurité et de l'exploitation est *partagée* entre le client et le fournisseur, selon le modèle de service. Quel que soit le modèle, **le client reste responsable de ses données, de ses utilisateurs et de ses droits d'accès**.

Domaine	IaaS	PaaS	SaaS
Données et leur classification	Client	Client	Client
Identités et droits d'accès	Client	Client	Client
Application	Client	Client	Fournisseur
Système d'exploitation, intergiciels	Client	Fournisseur	Fournisseur
Infrastructure physique, réseau	Fournisseur	Fournisseur	Fournisseur

Tableau 18.5. Le modèle de responsabilité partagée (simplifié)

★ Attention

Violation typique. « Nos données sont chez un grand fournisseur mondial, elles sont donc en sécurité. » Le stockage de NOUN PAY était configuré en accès public par erreur ; le fournisseur, dont la plateforme fonctionnait parfaitement, n'y était pour rien.

Règle : la sécurité du nuage est celle du fournisseur ; la sécurité *dans* le nuage est celle du client.

18.3.3 Gouverner le nuage

Le nuage déplace quatre risques que la gouvernance doit arbitrer explicitement :

- **la dépendance** : changer de fournisseur peut être long et coûteux, surtout en PaaS ;
- **la localisation** : les données peuvent être stockées hors du territoire, ce que le droit encadre (section 18.4) ;
- **l'informatique fantôme** : n'importe quel service peut souscrire un abonnement avec une carte bancaire, hors de tout contrôle ;
- **le coût** : payé à l'usage, il dérive vite sans pilotage.

Deux normes aident à traiter la sécurité : l'ISO/IEC 27017, qui donne des mesures de sécurité propres aux services en nuage, et l'ISO/IEC 27018, qui traite de la protection des données personnelles dans le nuage public.

18.4 Le Contrat de Nuage et le Droit Camerounais

⚖ Jurisprudence & Droit applicable

Loi n° 2010/012, articles 26 et 29 (version anglaise officielle, extraits) :

« [Operators of information systems] shall have standardized systems enabling them to at all times identify, assess, process or manage any risk relating to the security of the information systems of the services provided directly or indirectly. » (art. 26, al. 1)

« Operators of information systems shall be bound to conserve the connection and traffic data of their information systems for a period of 10 (ten) years. » (art. 29, al. 1)

Loi n° 2024/017 (d'après les présentations publiées). La loi encadre strictement le transfert des données personnelles hors du territoire national (Chapitre 10).

Portée pour un contrat de nuage. Une organisation qui confie son système d'information à un fournisseur de nuage reste tenue de maîtriser les risques de sécurité des services fournis « indirectement », de conserver ses données de connexion pendant dix ans, et de faire examiner tout transfert de données personnelles hors du Cameroun au regard de la loi n° 2024/017. Le contrat type d'un fournisseur mondial

n'a pas été écrit pour ces obligations : il faut en vérifier chaque point.

Exigence de contrôle

La grille d'évaluation d'un contrat de nuage. Avant de signer, ou lors de l'audit, chaque point est noté conforme, partiellement conforme ou non conforme, avec la clause correspondante :

- localisation des données et des sauvegardes, et liste des pays ;
- conditions de transfert hors du Cameroun ;
- conservation et accès aux journaux pendant la durée légale ;
- droit d'audit, ou rapports d'audit indépendants et leur périmètre ;
- notification des incidents de sécurité, dans un délai fixé ;
- engagements de service et pénalités ;
- sous-traitants du fournisseur et information du client ;
- réversibilité : formats, délais, assistance, coûts ;
- droit applicable et juridiction compétente.

Scénario Opérationnel · Opération NOUN. Deux contrats comparés

Point de la grille	Contrat type	Contrat d'entreprise
Localisation des données	Non conforme (non choisie)	Conforme (région choisie, liste des pays)
Droit d'audit	Non conforme (renvoi aux certifications)	Partiel (rapports d'audit indépendants)
Notification des incidents	Partiel (« dans les meilleurs délais »)	Conforme (72 heures)
Réversibilité	Non conforme	Partiel (exports, sans assistance)
Journaux	Partiel (90 jours)	Partiel (configurable, coût de stockage)

Analyse (confiance moyenne). Le contrat d'entreprise, pour un surcoût de 18 millions FCFA par an (Chapitre 17), corrige les points les plus graves. Il ne règle pas tout : la conservation des journaux pendant dix ans suppose un archivage complémentaire, et la réversibilité doit être préparée par NOUN PAY elle-même (formats ouverts, exercice de restitution annuel).

Application RSSI

Gouverner les abonnements en nuage

1. Tenir l'inventaire des services en nuage utilisés, y compris ceux payés par carte bancaire par les métiers.
2. Classer les données selon leur sensibilité, et interdire les plus sensibles sur les services non évalués.
3. Vérifier la configuration des services (accès publics, chiffrement, comptes à privilèges) au moins chaque mois.
4. Présenter chaque année au comité des risques la carte des dépendances aux fournisseurs de nuage.

18.5 La Gouvernance Numérique en Afrique

18.5.1 Un cadre continental

L'Union africaine a adopté en 2020 une *Stratégie de transformation numérique pour l'Afrique 2020–2030*, puis en 2022 un *Cadre stratégique sur les données*, qui encourage l'harmonisation des règles de circulation des données sur le continent. La Convention de Malabo, entrée en vigueur en 2023, en constitue le volet juridique (Chapitre 10). L'initiative Smart Africa, lancée en 2013, réunit des États autour de projets numériques communs.

18.5.2 Des lois nationales de protection des données

Pays	Texte	Année
Sénégal	Loi sur la protection des données à caractère personnel	2008
Maroc	Loi n° 09-08 relative à la protection des personnes physiques à l'égard du traitement des données personnelles	2009
Ghana	Data Protection Act	2012
Côte d'Ivoire	Loi relative à la protection des données à caractère personnel	2013
Kenya	Data Protection Act	2019
Rwanda	Loi sur la protection des données personnelles et de la vie privée	2021
Nigeria	Nigeria Data Protection Act	2023
Cameroun	Loi n° 2024/017	2024

Tableau 18.6. Quelques lois africaines de protection des données (intitulés abrégés)

18.5.3 Trois enseignements

1. **La localisation des données est un choix politique.** Certains États privilégient la libre circulation pour attirer les services, d'autres la conservation sur le territoire

pour des raisons de souveraineté. Une organisation présente dans plusieurs pays doit en tenir un registre (Chapitre 10).

2. **Les infrastructures nationales se développent.** Plusieurs États ont investi dans des centres de données nationaux, qui offrent une alternative au nuage étranger ; leur niveau de service et de sécurité doit être évalué comme celui de tout fournisseur.
3. **Le droit précède souvent les autorités.** Une loi n'a d'effet que si l'autorité qu'elle crée dispose de moyens. L'efficacité réelle d'un régime se mesure à ses décisions publiées, encore rares (Chapitre 2).

Souveraineté numérique ou isolement ?

Imposer que toutes les données restent au Cameroun protège contre certains risques (accès par des autorités étrangères, coupure de connectivité internationale), mais en crée d'autres : dépendance à un nombre réduit de fournisseurs locaux, coûts plus élevés, moindre résilience si un seul centre de données héberge tout. La bonne réponse de gouvernance n'est ni l'interdiction ni l'indifférence, mais la *classification* : localiser ce qui doit l'être, et choisir librement pour le reste, contrat par contrat.

❍

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **L'agilité change la forme du contrôle, pas son existence** : la gouvernance finance des produits et des équipes, et revoit ses décisions à intervalles réguliers.
- **DevOps déplace le contrôle dans la chaîne** : revue par un pair, tests bloquants, déploiement progressif, retour arrière automatique, journal inaltérable. Le point critique devient la chaîne elle-même.
- **Quatre indicateurs** mesurent ensemble la vitesse et la stabilité de la livraison.
- **Dans le nuage, la responsabilité est partagée** : le client reste responsable de ses données, de ses utilisateurs et de ses accès.
- **Le contrat de nuage s'évalue au regard du droit camerounais** : risques des services fournis indirectement, conservation des journaux pendant dix ans, transferts hors du territoire.
- **L'Afrique se dote de règles** : stratégie continentale, lois nationales de protection des données, centres de données nationaux. La réponse de gouvernance est la classification des données.

✍ Exercice 18.1. Qui est responsable ? ★☆☆

Pour chacune des situations suivantes, indiquez si la responsabilité incombe au client ou au fournisseur de nuage, selon le Tableau 18.5.

(a) Un ancien salarié de NOUN PAY se connecte encore à la console d'administration.

(b) Une panne électrique arrête le centre de données du fournisseur.

(c) La messagerie en SaaS de la BANQUE SANAGA présente une faille logicielle.

(d) Une base de données gérée (PaaS) est accessible depuis Internet sans mot de passe.

✍ Exercice 18.2. Calculer les indicateurs de livraison ★★☆

En un mois, l'équipe mobile de la BANQUE SANAGA a réalisé 22 déploiements. Trois ont provoqué un incident ; les délais de rétablissement ont été de 20 minutes, 45 minutes et 3 heures. Le délai moyen entre la validation du code et la mise en production est de 2 jours.

(a) Calculez le taux d'échec des changements et le délai moyen de rétablissement.

(b) L'incident de 3 heures a touché le paiement. Qu'en déduisez-vous sur le périmètre des changements standard ?

(c) Proposez une cible pour chacun des quatre indicateurs.

✍ Exercice 18.3. Migrer l'ANPP vers le nuage ? ★★★

Un fournisseur propose à l'ANPP d'héberger son système de paiement dans son nuage, hors du Cameroun, pour un coût annuel inférieur de 30 % à celui de son centre de données actuel.

(a) Classez les données de l'agence selon leur sensibilité.

(b) Appliquez la grille d'évaluation du contrat de nuage à l'offre, en indiquant les informations qui vous manquent.

(c) Identifiez les obligations légales en jeu, en citant uniquement les articles vérifiés, et signalez ce qui reste à vérifier.

(d) Rédigez la recommandation au conseil d'administration, en présentant au moins deux options.

Note

Transition. Le nuage concentre les données ; l'intelligence artificielle les exploite pour décider. Le Chapitre 19 traite de la gouvernance des données et de l'intelligence artificielle, à partir du cas de la notation de crédit de NOUN PAY.

19

GOUVERNANCE DES DONNÉES ET DE L'INTELLIGENCE ARTIFICIELLE

« Un algorithme ne décide jamais seul.
Quelqu'un a décidé de le laisser décider. »

Principe de la gouvernance de l'IA

Niveau : *Expert* • Maîtrise des Chapitres 10 (protection des données personnelles) et 18 (informatique en nuage).

✦ Objectifs du chapitre

- ➢ Définir la gouvernance des données (propriété, qualité, cycle de vie).
- ➢ Présenter l'ISO/IEC 38507 et l'ISO/IEC 42001.
- ➢ Évaluer les risques d'un système d'IA (biais, explicabilité, responsabilité).
- ➢ Appliquer la loi de 2024 sur les données personnelles à un cas de notation par IA.

Question directrice : qui répond d'une décision prise par un modèle ?

Le Chapitre 17 l'a établi : le modèle de notation de crédit de NOUN PAY refuse 61 % des demandes d'une région, contre 24 % en moyenne nationale. Il utilise l'opérateur mobile du demandeur, très corrélé à la région. Personne, dans l'entreprise, n'était chargé d'évaluer les effets du modèle sur les clients (Chapitre 16). L'Autorité de protection des données demande des comptes.

Ce cas réunit les deux sujets de ce chapitre. La **gouvernance des données** (sections 19.1 et 19.2) traite de ce que l'organisation possède : qui en répond, avec quelle qualité, pour combien de temps. La **gouvernance de l'intelligence artificielle** (sections 19.3 à 19.5) traite de ce que l'organisation en fait quand elle confie des décisions à des modèles.

© MaletYon

19.1 La Gouvernance des Données

19.1.1 Les données, un actif

Définition

Gouvernance des données : exercice de l'autorité et du contrôle sur la gestion des données : qui décide de leur définition, de leur usage, de leur qualité, de leur protection et de leur conservation, selon quelles règles, et qui en rend compte.

COBIT 2019 consacre aux données un objectif de management à part entière, APO14, qui couvre tout le cycle de vie des données, de leur création à leur archivage. Ses liens principaux sont la qualité de l'information financière (EG04) et de l'information de gestion (EG07, AG10) : les données sont d'abord ce sur quoi l'on décide.

Fiche processus · APO14 · Gérer les données

Description : gérer efficacement les actifs de données de l'organisation sur tout leur cycle de vie, de la création à la diffusion, à la maintenance et à l'archivage.
Finalité : assurer l'utilisation efficace des données critiques pour atteindre les objectifs de l'organisation.
Objectifs liés : EG04, EG07 ; AG10.
Pratiques : APO14.01 définir la stratégie de gestion des données et les rôles ; APO14.02 tenir un glossaire métier ; APO14.03 gérer les métadonnées ; APO14.04 définir une stratégie de qualité des données ; APO14.05 profiler les données ; APO14.06 évaluer leur qualité ; APO14.07 définir leur nettoyage ; APO14.08 gérer le cycle de vie des actifs de données ; APO14.09 organiser l'archivage et la conservation ; APO14.10 gérer les sauvegardes et les restaurations.
Indicateurs : part des données critiques dotées d'un propriétaire, taux d'anomalies de qualité, part des données conservées au-delà de leur durée prévue.

Description, finalité, objectifs liés et pratiques résumés et traduits par nos soins à partir de COBIT 2019 [22].

19.1.2 Les rôles

Rôle	Responsabilité	Chez NOUN PAY
Propriétaire des données	Répond d'un domaine de données : usage autorisé, niveau de qualité, accès	Directeur commercial pour les données clients
Intendant des données (*data steward*)	Veille au quotidien à la définition et à la qualité	Analyste du crédit
Dépositaire	Assure le stockage, la sécurité et la sauvegarde	Directeur technique et fournisseur de nuage
Délégué à la protection des données	Veille au respect du droit des données personnelles	M. DJOUMESSI

Tableau 19.1. Les rôles de la gouvernance des données

La règle cardinale : **le propriétaire des données est un métier, pas l'informatique**. La DSI conserve et protège ; c'est le métier qui décide de ce que les données signifient et de l'usage qui en est fait.

19.2 Qualité et Cycle de Vie

19.2.1 Les dimensions de la qualité

Dimension	Question	Exemple
Exactitude	La donnée reflète-t-elle la réalité ?	Le solde converti est-il le bon (SANAGA) ?
Complétude	Toutes les données requises sont-elles présentes ?	Revenus manquants dans 18 % des dossiers de crédit
Cohérence	La même donnée a-t-elle la même valeur partout ?	L'adresse du client dans deux systèmes
Actualité	La donnée est-elle à jour ?	Position d'un conteneur vieille de six heures (KRIBILOG)
Validité	Respecte-t-elle le format et les règles ?	Numéro de téléphone au bon format
Unicité	Chaque entité n'apparaît-elle qu'une fois ?	Un fournisseur enregistré trois fois à l'ANPP

Tableau 19.2. Les dimensions de la qualité des données

19.2.2 Le cycle de vie

Une donnée se crée, s'utilise, se partage, s'archive et se détruit. La gouvernance fixe, pour chaque catégorie, sa *durée de conservation* : assez longue pour répondre aux

obligations (dix ans pour les données de connexion selon l'article 29 de la loi n° 2010/012, Chapitre 10), pas plus longue que nécessaire pour les données personnelles. Conserver « au cas où » n'est pas une politique, c'est un risque.

Exigence de contrôle

Le registre des données critiques. Pour qu'un auditeur puisse établir que les données critiques sont gouvernées, l'organisation tient un registre qui indique, pour chaque domaine de données :

- le propriétaire métier et l'intendant ;
- la définition, dans le glossaire métier ;
- la classification (publique, interne, confidentielle, personnelle, sensible) ;
- la localisation (systèmes, pays) ;
- les règles de qualité et leur dernier contrôle ;
- la durée de conservation et son fondement.

19.3 Gouverner l'Intelligence Artificielle

19.3.1 Ce que l'IA change

Un système d'intelligence artificielle n'est pas un logiciel comme un autre, pour trois raisons qui intéressent directement la gouvernance :

- **il apprend des données** : ses erreurs viennent souvent de biais présents dans les données d'entraînement, que personne n'a voulus ;
- **il est difficile à expliquer** : certains modèles produisent un résultat sans que l'on puisse dire simplement pourquoi ;
- **il évolue** : un modèle réentraîné est un nouveau modèle, et ses effets peuvent dériver avec le temps.

19.3.2 Les normes et cadres de référence

Référence	Nature	Objet
ISO/IEC 38507 (2022)	Lignes directrices	Implications, pour l'organe de gouvernance, de l'usage de l'IA par l'organisation ; prolonge l'ISO/IEC 38500
ISO/IEC 42001 (2023)	Norme certifiable	Système de management de l'IA, selon la structure harmonisée (Chapitre 9)
ISO/IEC 23894 (2023)	Lignes directrices	Management des risques liés à l'IA, dans la logique de l'ISO 31000
NIST AI RMF 1.0 (2023)	Cadre	Quatre fonctions : gouverner, cartographier, mesurer, gérer [32]
Recommandation de l'UNESCO (2021)	Instrument normatif international	Valeurs et principes éthiques de l'IA, adoptés par les États membres [47]

Tableau 19.3. Normes et cadres de la gouvernance de l'IA

La Recommandation de l'UNESCO sur l'éthique de l'intelligence artificielle, adoptée en novembre 2021, est le premier instrument normatif mondial sur le sujet. Elle insiste sur la proportionnalité, la sécurité, l'équité et la non-discrimination, la transparence et l'explicabilité, la responsabilité et la surveillance humaine. Pour une formation dispensée par une Chaire UNESCO, elle est le point de départ naturel.

Note

Le contexte africain et international. L'Union africaine a adopté en 2024 une stratégie continentale sur l'intelligence artificielle. L'Union européenne a adopté le règlement (UE) 2024/1689 sur l'intelligence artificielle, qui classe l'évaluation de la solvabilité des personnes physiques parmi les systèmes à haut risque [38]. Ce règlement ne s'applique pas au Cameroun en tant que tel, mais il s'impose aux entreprises qui y servent des clients, et sert déjà de référence aux investisseurs.

19.4 Évaluer les Risques d'un Système d'IA

19.4.1 Une grille en six risques

Risque	Question	Mesure de maîtrise
Biais et discrimination	Le modèle traite-t-il défavorablement un groupe ?	Mesure des écarts entre groupes, revue des variables
Explicabilité	Peut-on expliquer une décision à la personne concernée ?	Motifs principaux de chaque décision, documentation du modèle
Responsabilité	Qui répond d'une décision du modèle ?	Un A dans la matrice RACI (Chapitre 16)
Robustesse	Le modèle résiste-t-il aux données inhabituelles et aux manipulations ?	Tests de robustesse, surveillance des entrées
Dérive	Ses performances se dégradent-elles avec le temps ?	Indicateurs suivis en production, réentraînement contrôlé
Conformité	Les données sont-elles traitées licitement ?	Analyse au regard de la loi n° 2024/017

Tableau 19.4. Les risques d'un système d'IA

19.4.2 Mesurer un biais

Une mesure simple de l'écart entre groupes est le **ratio d'impact disproportionné** : le taux de décisions favorables du groupe le moins favorisé, divisé par celui du groupe le plus favorisé. Une pratique répandue, issue du droit américain du travail, considère comme suspect un ratio inférieur à 0,8 (la « règle des quatre cinquièmes »). Ce seuil n'a pas de valeur juridique au Cameroun ; il sert de signal d'alerte.

Scénario Opérationnel · Opération NOUN. Le calcul du biais

Données. Taux de refus de 61 % dans la région concernée, soit un taux d'acceptation de 39 %. Taux de refus moyen national de 24 %, soit un taux d'acceptation de 76 %.

Calcul. Ratio d'impact $= 0{,}39/0{,}76 \approx 0{,}51$, très en dessous du seuil d'alerte de 0,8.

Constatation. Le ratio est de 0,51 ; la variable « opérateur mobile », corrélée à la région, figure parmi les variables du modèle.

Analyse (confiance moyenne). L'écart peut s'expliquer en partie par des différences réelles de risque, mais l'usage d'une variable corrélée à la région fait peser un risque sérieux de discrimination indirecte. Seule une analyse du modèle sans cette variable, à risque égal, permettra de conclure. En attendant, la variable doit être suspendue (Chapitre 17).

19.5 La Notation de NOUN PAY au Regard du Droit

19.5.1 Les questions à instruire

La loi n° 2024/017 (Chapitre 10) s'applique aux données personnelles utilisées par le modèle. Sans préjuger de la lettre de ses articles, que l'on vérifiera dans le texte publié, six questions doivent être instruites :

1. **La base juridique** : sur quel fondement le traitement des données des demandeurs est-il licite ?
2. **La finalité et la proportionnalité** : les données utilisées sont-elles nécessaires à l'évaluation du crédit ? L'opérateur mobile l'est-il ?
3. **L'information des personnes** : les demandeurs savent-ils que leur demande est évaluée par un modèle ?
4. **Les décisions automatisées** : de nombreuses lois de protection des données de cette génération encadrent les décisions fondées exclusivement sur un traitement automatisé et ouvrent un droit à l'intervention humaine ; il faut vérifier si et comment la loi camerounaise le prévoit.
5. **Le transfert hors du territoire** : les données sont hébergées hors du Cameroun (Chapitre 18).
6. **La sécurité et la conservation** : qui accède aux données, et combien de temps sont-elles gardées ?

★ Attention

Violation typique. Une entreprise supprime de son modèle la variable « région » pour éviter toute discrimination, mais conserve des variables qui lui sont étroitement corrélées (opérateur mobile, préfixe téléphonique, agence). Le biais demeure, par une autre voie.

Règle : on ne prouve pas l'absence de biais en retirant une variable ; on la prouve en *mesurant* les résultats par groupe.

19.5.2 Le dispositif de gouvernance

Application Responsable GRC

Doter NOUN PAY d'une gouvernance de l'IA proportionnée

1. **Un inventaire** : lister les modèles en production, leur usage, les données qu'ils emploient et leurs effets sur les clients.
2. **Une classification** : la notation de crédit, qui décide de l'accès d'une personne à un service financier, est à risque élevé.
3. **Un responsable** : désigner un A pour chaque modèle à risque élevé, au niveau de la direction (Chapitre 16).
4. **Une évaluation d'impact avant chaque version** : mesure des écarts entre

groupes, avis du délégué à la protection des données, décision écrite.

5. **Une surveillance en production** : ratio d'impact et taux d'erreur suivis chaque mois, avec un seuil qui déclenche la suspension.
6. **Un recours humain** : toute personne refusée peut demander un réexamen par un analyste.

Application Auditeur SI

Auditer un modèle de décision

1. Demander la documentation du modèle : finalité, données d'entraînement, variables, performances, limites connues.
2. Vérifier que chaque mise à jour a fait l'objet d'une évaluation d'impact et d'une autorisation (BAI06).
3. Recalculer, sur un échantillon de décisions récentes, les taux par groupe et le ratio d'impact.
4. Vérifier l'existence et l'usage effectif du recours humain.

L'humain dans la boucle suffit-il ?

Prévoir qu'un analyste « valide » chaque décision du modèle est souvent présenté comme la garantie ultime. L'expérience montre pourtant qu'un analyste qui traite deux cents dossiers par jour finit par entériner les propositions du modèle. La surveillance humaine n'est réelle que si l'analyste dispose du temps, de l'information (les motifs de la proposition) et du pouvoir de s'écarter du modèle sans avoir à s'en justifier davantage que s'il le suivait.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Les données sont un actif gouverné** : un propriétaire métier, un intendant, un dépositaire ; COBIT y consacre l'objectif APO14.
- **Six dimensions de qualité** (exactitude, complétude, cohérence, actualité, validité, unicité) et un cycle de vie avec des durées de conservation fondées.
- **L'IA apprend, s'explique mal et dérive** : elle appelle une gouvernance propre.
- **Les références** : ISO/IEC 38507 pour le conseil, ISO/IEC 42001 pour le système de management, ISO/IEC 23894 pour les risques, le NIST AI RMF,

et la Recommandation de l'UNESCO pour les principes éthiques.

- ➢ **Mesurer le biais** : le ratio d'impact de NOUN PAY (0,51) est un signal d'alerte ; retirer une variable ne prouve rien.
- ➢ **Un modèle à risque élevé** a un responsable, une évaluation d'impact à chaque version, une surveillance en production et un recours humain réel.

✍ Exercice 19.1. Quelle dimension de qualité ? ★☆☆

Rattachez chacune des anomalies suivantes à une dimension de qualité (Tableau 19.2).

(a) Un agent payé deux fois par l'ANPP parce qu'il figure sous deux matricules.

(b) Un client de la BANQUE SANAGA dont la date de naissance est le 31 février.

(c) Un conteneur localisé à Kribi alors qu'il est à Douala depuis la veille.

(d) Un dossier de crédit sans les revenus du demandeur.

✍ Exercice 19.2. Le registre des données de la BANQUE SANAGA ★★☆

Établissez les cinq premières lignes du registre des données critiques de la BANQUE SANAGA (exigence de contrôle de la section 19.2), en commençant par les soldes des comptes.

(a) Pour chaque domaine, désignez le propriétaire métier et justifiez.

(b) Fixez les règles de qualité et leur fréquence de contrôle.

(c) Indiquez la durée de conservation et son fondement, en signalant ce qui reste à vérifier.

✍ Exercice 19.3. La réponse à l'Autorité de protection des données ★★★

Rédigez, pour Mme KAMGA, la réponse de NOUN PAY à l'Autorité de protection des données.

(a) Exposez les faits, en séparant constatations et analyses.

(b) Répondez aux six questions de la section 19.5, en indiquant ce qui suppose une vérification du texte de la loi.

(c) Présentez les mesures prises et prévues, avec leur échéance.

(d) Expliquez en quoi la Recommandation de l'UNESCO sur l'éthique de l'IA éclaire les engagements pris.

Note

Transition. La Partie V a confronté la gouvernance des SI aux défis de la vitesse, du nuage, des données et de l'intelligence artificielle. La Partie VI prend du recul : le Chapitre 20 présente l'état de la recherche sur la mesure de la gouvernance des SI.

partie VI

Recherche et Contributions

© MaletYon

20

MESURER LA GOUVERNANCE DES SI : ÉTAT DE LA RECHERCHE

> « Ce qui compte ne peut pas toujours être compté,
> et ce qui peut être compté ne compte pas toujours. »
>
> — Maxime attribuée, sous diverses formes, à plusieurs auteurs

Niveau : *Recherche* • Maîtrise du Chapitre 8 (capacité et maturité) et du Chapitre 3 (alignement et valeur).

✦ Objectifs du chapitre

- ➢ Synthétiser les travaux de référence sur la gouvernance des SI.
- ➢ Discuter la validité des modèles de maturité.
- ➢ Lire de façon critique une étude empirique.
- ➢ Formuler une question de recherche sur la gouvernance des SI en Afrique centrale.

Question directrice : la gouvernance des SI sert-elle à quelque chose ?

Tout ce cours repose sur une conviction : une meilleure gouvernance des SI produit de meilleurs résultats. Le praticien l'admet volontiers ; le chercheur demande des preuves. Qu'entend-on par « meilleure gouvernance » ? Comment la mesure-t-on ? Et si l'on observe que les organisations bien gouvernées réussissent mieux, est-ce la gouvernance qui produit le succès, ou le succès qui permet de financer la gouvernance ?

La Partie VI, qui s'ouvre ici, prend ce recul. Ce chapitre présente les grandes étapes de la recherche (section 20.1), ce qu'elle a établi (section 20.2), le débat sur les modèles de maturité (section 20.3), une méthode de lecture critique (section 20.4), puis les pistes de recherche ouvertes en Afrique centrale (section 20.5). Il s'adresse en particulier aux étudiants qui préparent un mémoire.

Note

Règle de lecture. Les travaux cités dans ce chapitre sont des publications académiques identifiées dans la bibliographie. Leurs résultats sont résumés et attribués à leurs auteurs. Un résumé n'est pas une lecture : avant de citer une étude dans un mémoire, lisez-la.

20.1 Trois Courants de Recherche

20.1.1 Les structures de décision

Le premier courant s'est demandé *où* se prennent les décisions informatiques. Dans les années 1990, la recherche oppose les modèles centralisés, décentralisés et fédéraux. Sambamurthy et Zmud montrent que le bon arrangement dépend de plusieurs facteurs de contingence qui agissent ensemble : la taille, la stratégie, la structure de l'organisation [39]. Weill et Ross prolongent ce travail avec les archétypes et la matrice des droits de décision (Chapitre 3) [49].

20.1.2 Les mécanismes

Le deuxième courant passe de la question « qui décide ? » à la question « par quels moyens ? ». Peterson distingue les structures, les processus et les capacités relationnelles [35] ; De Haes et Van Grembergen reprennent et outillent cette distinction en structures, processus et mécanismes relationnels (Chapitre 1), et étudient leur effet sur l'alignement [13], [14].

20.1.3 L'effet sur la performance

Le troisième courant cherche à établir le lien entre gouvernance des SI, alignement et performance de l'organisation. Brown et Grant en ont dressé une revue structurante au milieu des années 2000 [5]. Les études quantitatives se sont depuis multipliées, avec des méthodes de plus en plus exigeantes, comme celle de Wu, Straub et Liang, qui croise les réponses de dirigeants métiers et de responsables informatiques des mêmes entreprises [51].

Courant	Question	Travaux de référence
Structures	Où se prennent les décisions ?	Sambamurthy et Zmud (1999) ; Weill et Ross (2004)
Mécanismes	Par quels moyens la gouvernance s'exerce-t-elle ?	Peterson (2004) ; De Haes et Van Grembergen (2009, 2015)
Performance	La gouvernance améliore-t-elle les résultats ?	Brown et Grant (2005) ; Wu, Straub et Liang (2015)

Tableau 20.1. Trois courants de la recherche sur la gouvernance des SI

20.2 Ce que la Recherche a Établi

20.2.1 Des résultats convergents

Avec les précautions qui s'imposent, trois résultats reviennent avec régularité dans la littérature.

1. **La gouvernance compte.** Weill et Ross ont rapporté, sur un large échantillon d'entreprises, que celles dont la gouvernance des SI était la plus efficace obtenaient, à stratégie comparable, une rentabilité nettement supérieure à celles dont la gouvernance était la plus faible, de l'ordre de 20 % selon leurs mesures [49].
2. **Les mécanismes relationnels comptent autant que les structures.** Plusieurs études observent qu'à structures égales, ce sont la compréhension mutuelle et la collaboration entre métiers et informatique qui font la différence (Chapitre 17 : le cas de la BANQUE SANAGA un an après).
3. **L'effet passe par l'alignement.** La gouvernance agit sur la performance surtout par l'intermédiaire de l'alignement stratégique : elle aide à faire les bons choix plus qu'elle ne produit directement des résultats [51].

20.2.2 Ce qui reste débattu

Question	État du débat
Le sens de la causalité	Les organisations performantes ont-elles une bonne gouvernance parce qu'elles en ont les moyens ? Les études transversales ne permettent pas de trancher.
La mesure de la gouvernance	Elle repose souvent sur l'autoévaluation d'un seul répondant, ce qui fragilise les résultats.
La transposition des résultats	La plupart des études portent sur des organisations d'Amérique du Nord, d'Europe et d'Asie ; leur validité ailleurs n'est pas démontrée.
L'effet des référentiels	L'adoption de COBIT ou d'ITIL est fréquente, mais leur effet propre, toutes choses égales par ailleurs, reste mal établi.

Tableau 20.2. Questions débattues

★ Attention

Violation typique. Un mémoire affirme que « COBIT améliore la performance des entreprises de 20 % », en citant Weill et Ross. Or Weill et Ross n'étudient pas COBIT, et leur écart de rentabilité est une association mesurée sur leur échantillon, pas un effet causal transposable.

Règle : citer un résultat, c'est citer aussi ce qu'il mesure, sur quel échantillon, et

avec quelle méthode.

20.3 Le Débat sur les Modèles de Maturité

20.3.1 Un succès considérable

Depuis le modèle de maturité du logiciel de l'université Carnegie Mellon, les modèles de maturité se sont multipliés : COBIT en utilise un depuis sa version 3, et le modèle de capacité de COBIT 2019 s'inspire du CMMI (Chapitre 8). Leur succès tient à leur simplicité : une échelle de 0 à 5, que tout dirigeant comprend.

20.3.2 Quatre critiques

La recherche en a pourtant relevé les limites [4], [36].

1. **La linéarité.** Les modèles supposent un chemin unique, du niveau 1 au niveau 5. Or une organisation peut avoir de bonnes raisons de ne pas viser le niveau 5, ou de progresser autrement.

2. **Le fondement théorique.** Beaucoup de modèles sont construits à partir de l'expérience de leurs auteurs, sans validation empirique de leurs niveaux ni de leurs critères.

3. **La fiabilité de la mesure.** Deux évaluateurs n'attribuent pas toujours le même niveau au même processus, surtout en autoévaluation.

4. **Le lien avec la performance.** Qu'un niveau de maturité plus élevé produise de meilleurs résultats est postulé plus souvent que démontré. Certaines études l'observent [41], d'autres non, et le lien dépend du contexte.

Faut-il renoncer aux modèles de maturité ?

Non, mais il faut les utiliser pour ce qu'ils sont : des outils de *diagnostic* et de *dialogue*, pas des instruments de mesure scientifique. COBIT 2019 en tient compte de deux manières, déjà vues dans ce cours : il fait dépendre la capacité *cible* des facteurs de conception, ce qui répond à la critique de la linéarité (Chapitre 7), et il rattache chaque niveau à des activités précises, ce qui améliore la fiabilité de l'évaluation (Chapitre 8). Pöppelbuß et Röglinger ont proposé des principes de conception qui permettent de juger si un modèle de maturité est utile [36].

20.4 Lire une Étude Empirique

20.4.1 Une grille de lecture

Élément	Questions à se poser
Question et théorie	Quelle question précise ? Quelle théorie justifie les hypothèses (agence, alignement, contingence) ?
Échantillon	Combien d'organisations, de quels pays, secteurs, tailles ? Comment ont-elles été choisies ?
Mesures	Comment la gouvernance et la performance sont-elles mesurées ? Par qui ? Les échelles sont-elles validées ?
Biais de méthode	Le même répondant décrit-il à la fois la gouvernance et la performance ?
Causalité	L'étude est-elle transversale (une seule date) ou longitudinale ? Peut-elle établir le sens de l'effet ?
Généralisation	Les résultats valent-ils au-delà de l'échantillon ? Pour une organisation camerounaise ?
Statut	Article évalué par des pairs, communication, prépublication, rapport de cabinet ?

Tableau 20.3. Grille de lecture critique d'une étude empirique

20.4.2 Le statut des sources

Définition

Évaluation par les pairs (*peer review*) : examen d'un article par des chercheurs indépendants avant sa publication dans une revue ou des actes de conférence. Elle ne garantit pas que les résultats sont justes, mais qu'ils ont été soumis à une critique méthodologique.

Prépublication (*preprint*) : version d'un travail rendue publique avant son évaluation par les pairs. Elle doit être citée comme telle.

Les enquêtes des cabinets de conseil et des éditeurs de logiciels sont utiles pour connaître les pratiques, mais elles poursuivent souvent un objectif commercial et publient rarement leur méthode. Elles se citent avec cette réserve.

Scénario Opérationnel · Exercice de lecture. Une étude fictive

Résumé. « Une enquête menée auprès de 85 DSI d'entreprises camerounaises montre que les entreprises qui ont adopté COBIT ont une satisfaction client supérieure de 15 % à celles qui ne l'ont pas adopté ($p < 0{,}05$). »

Lecture critique. L'échantillon est-il représentatif (85 DSI volontaires, sans doute les plus sensibles au sujet) ? La satisfaction client est-elle mesurée auprès des clients, ou estimée par le DSI ? Les entreprises qui adoptent COBIT sont-elles plus grandes, plus riches, mieux organisées par ailleurs ? Une différence statistiquement significative n'est pas une preuve d'effet. Conclusion : résultat intéressant, à présenter comme une association observée sur un échantillon de convenance.

20.5 Des Pistes de Recherche en Afrique Centrale

20.5.1 Un champ peu exploré

La recherche publiée sur la gouvernance des SI porte majoritairement sur des organisations des pays industrialisés. Les travaux consacrés à l'Afrique centrale restent peu nombreux, alors que le contexte y présente des caractéristiques propres : concentration du pouvoir de décision, tutelle publique, dépendance aux intégrateurs étrangers, régulation récente, contraintes d'infrastructure (Chapitre 1). C'est une raison suffisante pour que les mémoires et les thèses s'en emparent.

20.5.2 Des questions possibles

Question	Méthode adaptée	Terrain
Comment les droits de décision informatiques se répartissent-ils dans les établissements publics camerounais ?	Études de cas multiples	Trois à cinq établissements
Les comités stratégiques des SI créés après une crise fonctionnent-ils réellement ?	Étude longitudinale	Une banque, sur trois ans
Quels facteurs de conception COBIT pèsent le plus dans les organisations de la zone CEMAC ?	Enquête par questionnaire	Banques et assurances
Comment adapter un modèle de capacité aux PME camerounaises ?	Recherche orientée conception [19]	PME de Douala et Yaoundé
L'entrée en vigueur de la loi n° 2024/017 modifie-t-elle la gouvernance des données ?	Études de cas avant et après	Entreprises de paiement mobile

Tableau 20.4. Exemples de questions de recherche

20.5.3 Les méthodes

- **L'étude de cas** convient aux questions « comment ? » et « pourquoi ? » dans des contextes peu connus ; elle exige un accès de confiance au terrain et une rigueur dans la collecte des preuves.
- **L'enquête par questionnaire** permet de mesurer des associations ; elle exige des échelles validées et un échantillon suffisant, souvent difficile à réunir.
- **La recherche orientée conception** construit un artefact (un modèle, une méthode, un outil) et l'évalue en situation ; elle convient bien aux praticiens qui préparent un mémoire professionnel [19].

Exigence de contrôle

Un projet de mémoire recevable. Le projet présenté au directeur de mémoire comporte :

- une question de recherche précise, et sa justification au regard de la littérature ;
- le cadre théorique mobilisé ;
- la méthode, le terrain et l'accès obtenu (accord écrit de l'organisation) ;
- les règles de confidentialité et d'anonymisation des données recueillies ;
- le calendrier et les livrables ;
- une bibliographie d'au moins quinze références, dont une majorité évaluées par les pairs.

Application Auditeur SI

Faire de sa pratique un terrain de recherche

1. Les missions d'audit produisent des données rares sur la gouvernance réelle des organisations : écarts, causes, capacités.
2. Elles ne peuvent servir à la recherche qu'avec l'accord des organisations et une anonymisation rigoureuse, dans le respect de la confidentialité (Chapitre 11).
3. Agrégées sur plusieurs missions, elles permettent de répondre à des questions qu'aucune enquête par questionnaire n'atteint.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Trois courants** : les structures de décision, les mécanismes, l'effet sur la performance.
- **Des résultats convergents** : la gouvernance compte, les mécanismes relationnels comptent autant que les structures, et l'effet passe par l'alignement.
- **Des questions ouvertes** : le sens de la causalité, la fiabilité des mesures, la transposition des résultats, l'effet propre des référentiels.
- **Les modèles de maturité** sont des outils de diagnostic et de dialogue, pas des instruments scientifiques : linéarité, fondement, fiabilité et lien avec la performance sont discutés.
- **Lire une étude**, c'est en examiner l'échantillon, les mesures, les biais, la causalité et le statut.

➢ **L'Afrique centrale** est un terrain peu exploré, qui appelle études de cas, enquêtes et recherche orientée conception.

✍ Exercice 20.1. Association ou causalité ? ★☆☆

Pour chacune des affirmations suivantes, indiquez si elle décrit une association ou un effet causal, et ce qu'il faudrait pour établir la causalité.

(a) « Les banques dotées d'un comité stratégique des SI ont moins d'incidents majeurs. »

(b) « Après la création de son comité, la BANQUE SANAGA a réduit ses incidents majeurs de moitié. »

(c) « Les entreprises certifiées ISO/IEC 27001 subissent moins de fuites de données. »

✍ Exercice 20.2. Lire un article ★★☆

Choisissez l'un des articles cités dans ce chapitre et appliquez-lui la grille du Tableau 20.3. Rédigez une note de lecture de deux pages : question, théorie, méthode, résultats, limites, intérêt pour une organisation camerounaise.

✍ Exercice 20.3. Un projet de mémoire ★★★

Rédigez un projet de mémoire sur l'une des questions du Tableau 20.4, ou sur une question de votre choix, en respectant l'exigence de contrôle de la section 20.5. Justifiez en particulier le choix de la méthode et la manière d'obtenir l'accès au terrain.

● Note

Transition. Ce chapitre a présenté l'état de la recherche et les questions qu'elle laisse ouvertes. Le Chapitre 21 présente des contributions et des pistes de recherche propres à l'auteur et à son laboratoire.

21

CONTRIBUTIONS ET PISTES DE RECHERCHE

Niveau : *Recherche* • Maîtrise du Chapitre 20

✦ Objectifs du chapitre

➢ Objectifs à définir avec l'auteur selon les travaux présentés.

★ Attention

Ce chapitre est en cours de rédaction.

© *MaletYon*

A

GLOSSAIRE

Ce glossaire reprend, sous une forme abrégée, les définitions données dans les chapitres. Le renvoi indique où le terme est défini et illustré.

Accord de niveau de service (SLA) Accord documenté entre un fournisseur et son client, qui précise le service et les niveaux attendus (Ch. 15).

Accord de niveau opérationnel (OLA) Accord entre le fournisseur et une autre équipe interne qui soutient le service (Ch. 15).

Activité (COBIT) Action concrète qui met en œuvre une pratique ; rattachée à un niveau de capacité de 2 à 5 (Ch. 6).

Alignement stratégique Degré de cohérence entre la stratégie de l'organisation, celle des technologies de l'information, et les infrastructures et processus qui les mettent en œuvre (Ch. 3).

Alignement volontaire Choix de s'inspirer d'un référentiel ou d'une norme sans viser de certificat (Ch. 9).

Analyse d'impact sur l'activité (BIA) Analyse qui identifie les activités essentielles, mesure l'effet de leur interruption dans le temps et en déduit les objectifs de reprise (Ch. 15).

Autorité de changement Personne ou groupe qui autorise un changement ; l'autorisation est déléguée selon le risque (Ch. 14).

Base de données de gestion de la configuration (CMDB) Base qui enregistre les éléments de configuration, leurs attributs et leurs relations (Ch. 14).

Cadre de référence Ensemble structuré de principes et d'objectifs qui guide un domaine sans imposer d'exigences vérifiables par un tiers ; par exemple COBIT, COSO (Ch. 4).

Capacité d'un processus Mesure de la manière dont un processus est mis en œuvre et fonctionne, de 0 à 5 dans COBIT 2019 (Ch. 8).

Cascade des objectifs Chaîne qui relie les besoins des parties prenantes, les objectifs d'entreprise, les objectifs d'alignement et les objectifs de gouvernance et de management (Ch. 6).

© *MaletYon*

Certification Attestation, par un organisme tiers accrédité, qu'un système de management est conforme à une norme, sur un périmètre et pour une durée donnés (Ch. 9).

Chaîne de déploiement Suite automatisée des étapes par lesquelles un changement de code passe jusqu'à la mise en production (Ch. 18).

Changement Ajout, modification ou retrait de tout élément susceptible d'avoir un effet sur un service (Ch. 14).

Chronologie de défaillance Suite datée des faits, décisions et absences de décision autour d'une défaillance, chaque entrée rattachée à une pièce (Ch. 0).

Co-création de valeur Idée selon laquelle la valeur naît de la collaboration entre fournisseur et consommateur du service (Ch. 12).

Comité stratégique, comité de pilotage des SI Le premier assiste le conseil sur les orientations, la valeur et les risques du numérique ; le second, au niveau de la direction générale, priorise les projets et arbitre les ressources (Ch. 1).

Composante Élément qui contribue au fonctionnement du système de gouvernance ; COBIT 2019 en distingue sept types (Ch. 5).

Conformité Respect d'exigences obligatoires (lois, règlements, contrats) ; elle se démontre (Ch. 9).

Contrat de sous-traitance Contrat entre le fournisseur et un tiers extérieur dont il dépend pour fournir le service (Ch. 15).

Contrôles d'application Contrôles intégrés à un système, qui agissent sur le traitement des transactions (Ch. 11).

Contrôles généraux informatiques Contrôles qui s'appliquent à tout l'environnement informatique : accès, changements, exploitation, développement et acquisition (Ch. 1, 11).

Coûts d'agence Dépenses de surveillance du principal, dépenses d'engagement de l'agent, et perte résiduelle due aux divergences d'intérêts (Ch. 1).

Coût total de possession (TCO) Somme des coûts sur la durée de vie d'une solution, de l'acquisition à la sortie (Ch. 3).

Déclaration d'applicabilité Liste des mesures de l'annexe A de l'ISO/IEC 27001, retenues ou exclues, avec leur justification (Ch. 9).

Défaillance de gouvernance Absence, inadéquation ou contournement d'un mécanisme de décision, de contrôle ou de reddition de comptes, qui laisse un risque connu se réaliser (Ch. 0).

Demande de service Demande d'un utilisateur portant sur une prestation déjà prévue dans le service (Ch. 13).

DevOps Pratiques qui rapprochent développement et exploitation, pour livrer des changements fréquents, fiables et réversibles (Ch. 18).

Disponibilité Aptitude d'un service à remplir sa fonction quand on en a besoin ; se mesure sur le temps de service convenu (Ch. 15).

Domaine d'intérêt Thème de gouvernance traité par un ensemble d'objectifs et de composantes (Ch. 5).

Droits de décision Répartition formelle du pouvoir de décider sur une question donnée (Ch. 0, 3).

Durée maximale d'interruption admissible (DMIA) Durée au-delà de laquelle l'interruption d'une activité devient inacceptable (Ch. 15).

Élément de configuration Tout composant qui doit être géré pour fournir un service (Ch. 14).

Erreur connue Problème analysé, dont la cause est identifiée, mais pas encore résolu (Ch. 13).

Évaluation par les pairs Examen d'un article par des chercheurs indépendants avant sa publication (Ch. 20).

Facteur de conception Facteur qui influence la conception du système de gouvernance ; COBIT 2019 en retient onze (Ch. 5).

Garantie Assurance que le service répondra aux exigences convenues : disponibilité, capacité, sécurité, continuité (Ch. 12).

Gestionnaire de processus Personne qui pilote l'exécution quotidienne d'un processus (Ch. 16).

Gouvernance d'entreprise Relations, règles et mécanismes par lesquels une société est dirigée et contrôlée (Ch. 1).

Gouvernance des données Exercice de l'autorité et du contrôle sur la gestion des données (Ch. 19).

Gouvernance des SI Activités par lesquelles l'organe de gouvernance évalue, dirige et surveille l'usage de l'information et des technologies, pour qu'il crée de la valeur (Ch. 0, 1).

Habilitation des changements Pratique qui maximise le nombre de changements réussis, en évaluant les risques, en autorisant et en maîtrisant le calendrier (Ch. 14).

Incident Interruption non planifiée d'un service, ou dégradation de sa qualité (Ch. 13).

Incident majeur Incident dont l'impact exige une réponse dépassant le traitement ordinaire (Ch. 13).

Indicateur clé d'objectif (KGI), de performance (KPI) Le premier dit si un objectif est atteint, après coup ; le second, si un processus a des chances de l'atteindre, en cours de route (Ch. 16).

Management des SI Activités qui planifient, bâtissent, exploitent et surveillent les SI, selon la direction fixée par la gouvernance (Ch. 0).

Matrice RACI Tableau qui croise activités et rôles : qui réalise (R), qui en répond (A, un seul), qui est consulté (C), qui est informé (I) (Ch. 16).

Maturité Mesure de performance d'un domaine d'intérêt : il atteint un niveau quand tous ses processus l'atteignent (Ch. 8).

Modèle des trois lignes Répartition des rôles entre l'organe de gouvernance, le management et l'audit interne (Ch. 11).

Niveau de capacité cible Niveau de 0 à 5 que l'organisation décide d'atteindre pour un processus (Ch. 7).

Norme certifiable Norme qui formule des exigences dont le respect peut être audité par un organisme de certification (Ch. 4).

Objectif d'alignement, d'entreprise Le second est un but de l'organisation ; le premier, un but que l'informatique doit atteindre pour le soutenir (Ch. 6).

Objectif de gouvernance ou de management Ce qu'il faut atteindre pour que l'information et les technologies contribuent aux objectifs ; COBIT 2019 en compte quarante (Ch. 5).

Optimisation des ressources, des risques Disposer des ressources suffisantes et bien utilisées ; maintenir les risques dans l'appétence fixée par la gouvernance (Ch. 3).

Partie prenante Groupe ou individu qui affecte les objectifs d'une organisation ou en est affecté (Ch. 1).

Plan de retour arrière Actions qui ramènent à l'état antérieur si un changement échoue, avec leurs critères et leur délai (Ch. 14).

Portefeuille Ensemble des projets, programmes et services, géré comme un tout pour maximiser la valeur (Ch. 3).

Pratique (COBIT) Action clé pour atteindre un objectif ; codée, par exemple DSS02.04 (Ch. 6).

Prépublication Version d'un travail rendue publique avant son évaluation par les pairs (Ch. 20).

Problème Cause, réelle ou potentielle, d'un ou de plusieurs incidents (Ch. 13).

Processus Ensemble d'activités corrélées qui transforme des entrées en sorties, en vue d'un objectif (Ch. 16).

Propriétaire de processus Personne qui répond de la conception, de la performance et de l'amélioration d'un processus (Ch. 16).

Ratio d'impact disproportionné Taux de décisions favorables du groupe le moins favorisé divisé par celui du plus favorisé ; un ratio inférieur à 0,8 est un signal d'alerte (Ch. 19).

Réalisation des bénéfices Créer de la valeur grâce aux technologies, et éliminer ce qui n'en crée pas assez (Ch. 3).

Recueil de bonnes pratiques Pratiques reconnues, présentées comme recommandations, que l'organisation adapte ; par exemple ITIL (Ch. 4).

Redevabilité Obligation de rendre compte d'une responsabilité reçue, et d'en assumer les conséquences (Ch. 0).

Relation d'agence Contrat par lequel un principal délègue à un agent un pouvoir de décision (Ch. 1).

RTO, RPO Durée maximale de reprise d'un service ; perte de données maximale admissible, exprimée en durée (Ch. 15).

Service Moyen de permettre la co-création de valeur, en facilitant les résultats que veut le client (Ch. 12).

Solution de contournement Moyen de réduire l'effet d'un incident ou d'un problème sans en traiter la cause (Ch. 13).

Source de première main Document produit par une partie qui a eu accès direct aux faits et engage sa responsabilité sur leur exactitude (Ch. 2).

Système de management Ensemble d'éléments en interaction qui sert à établir des politiques et des objectifs, et à les atteindre (Ch. 9).

Système de valeur des services Selon ITIL 4, la manière dont les composantes et activités d'une organisation transforment une demande en valeur (Ch. 12).

Utilité Ce que fait le service pour répondre à un besoin (Ch. 12).

Valeur Bénéfices, utilité et importance perçus ; elle est perçue par celui qui la reçoit (Ch. 12).

Valeur actuelle nette (VAN) Somme des flux d'un projet ramenés à aujourd'hui par un taux d'actualisation (Ch. 3).

Vérification des systèmes d'information Selon le GUID 5100, examen des contrôles liés aux SI pour déceler des écarts à des critères (Ch. 11).

B

RÉFÉRENTIEL DES OUTILS

Cette annexe rassemble les outils de la gouvernance et de la gestion des services mobilisés dans le cours et dans les labs de NDAP SUKULU. Les noms de logiciels sont des exemples : les offres évoluent, et un outil ne remplace ni une décision ni une procédure.

Gouvernance et conception

Outil	Usage	Chapitre, lab
Cascade des objectifs (tableur)	Relier besoins des parties prenantes, objectifs d'entreprise, d'alignement et objectifs COBIT	Ch. 6, GCI-LAB-03
Canevas de conception	Appliquer les onze facteurs de conception et fixer les capacités cibles	Ch. 7, GCI-LAB-02
Grille d'évaluation de capacité	Coter les activités d'un processus, niveau par niveau	Ch. 8, GCI-LAB-04
Tableau de portefeuille	VAN, coût total de possession, risque, alignement	Ch. 3, GCI-LAB-01
Matrice des droits de décision	Qui est consulté, qui décide, pour chaque type de décision	Ch. 3

Gestion des services

Outil	Usage	Chapitre, lab
Outil de gestion des services	Tickets d'incidents et de demandes, priorités, escalade, problèmes	Ch. 13, GCI-LAB-06
Registre des changements	Demande, évaluation du risque, autorisation, calendrier, retour arrière	Ch. 14, GCI-LAB-07
CMDB	Éléments de configuration et leurs relations, pour l'analyse d'impact	Ch. 14
Supervision	Mesure de la disponibilité, alertes	Ch. 15, GCI-LAB-08
Matrice RACI	Un seul A par activité ; rôles et non personnes	Ch. 16, GCI-LAB-09

© MaletYon

Architecture, livraison et données

Outil	Usage	Chapitre
Cadre d'architecture d'entreprise (par exemple TOGAF)	Décrire processus, données, applications et technologies, et leur évolution	Ch. 4
Chaîne de déploiement	Construire, tester et déployer automatiquement, avec traçabilité	Ch. 18
Catalogue et dictionnaire de données	Propriétaires, définitions, qualité, conservation	Ch. 19

Contrôle et audit

Outil	Usage	Chapitre, lab
Extractions et empreintes	Tester les contrôles généraux sur des données tracées	Ch. 11, GCI-LAB-05
Tableur ou SQL	Rapprochements (départs et comptes actifs, déploiements et changements autorisés)	Ch. 11, 14

Le bureau de NDAP SUKULU

Les labs s'exécutent dans un bureau d'analyste virtuel. Les pièces sont remises dans `~/preuves`, en lecture seule, avec leur manifeste d'empreintes ; une copie de travail se trouve dans `~/travail`. Le bureau propose un terminal et une suite bureautique ; l'activité dans le terminal est journalisée.

C

MODÈLES DE DOCUMENTS OPÉRATIONNELS

Chaque modèle reprend les rubriques présentées dans un chapitre. Ils sont à adapter à la taille de l'organisation : un modèle complet mal tenu vaut moins qu'un modèle simple tenu à jour.

1. Charte d'un comité stratégique des SI (Chapitre 1)

Rubrique	Contenu
Mission	Assister le conseil dans l'évaluation de la stratégie numérique, de la valeur des investissements et des risques liés au SI
Composition	Au moins deux administrateurs, dont le président ; DG et DSI membres ; audit interne invité permanent
Pouvoirs	Accès direct à la DSI et à l'audit interne ; droit de demander une expertise externe
Fréquence	Au moins trimestrielle ; sur convocation pour un projet majeur en difficulté
Quorum et décisions	Règle de quorum ; décisions inscrites au procès-verbal avec un responsable et une échéance
Reddition de comptes	Rapport écrit au conseil après chaque séance

2. Fiche d'investissement (Chapitre 3)

Rubrique	Contenu
Objectif	Objectif d'entreprise servi, et objectif d'alignement
Coût	Coût total de possession sur la durée de vie, par poste
Bénéfices	Bénéfices attendus, datés, avec leur indicateur et leur propriétaire
Rentabilité	Valeur actuelle nette, taux d'actualisation retenu
Risques	Risques du projet et risques de ne pas le faire
Décision	Organe qui décide, date, conditions ; revue des bénéfices prévue

© MaletYon

3. Grille d'évaluation de la capacité d'un processus

Pratique	Niv.	Activité	Preuve et cote
BAI06.01	2	…	Pièce ; note : complètement, largement, partiellement, pas
BAI06.01	3	…	…
…	…	…	…

Notes : complètement (plus de 85 %), largement (50 à 85 %), partiellement (15 à 50 %), pas (moins de 15 %). Un niveau est atteint s'il est noté au moins « largement » et si tous les niveaux inférieurs sont notés « complètement » ; la capacité retenue est celle que les preuves établissent, non celle que l'on déclare (Chapitre 8).

4. Demande de changement (Chapitre 14)

Rubrique	Contenu
Description	Ce qui change, pourquoi, éléments de configuration concernés
Type	Standard, normal ou urgent
Risque	Impact et probabilité ; services et clients exposés (analyse d'impact sur la CMDB)
Tests	Recette réalisée, taux, anomalies bloquantes closes
Mise en production	Date dans le calendrier, période de gel, équipes mobilisées
Retour arrière	Plan testé, critères de déclenchement, heure limite
Autorisation	Autorité de changement compétente, décision motivée
Revue	Résultat constaté après la mise en production

5. Accord de niveau de service (Chapitre 15)

Rubrique	Contenu
Description du service	Ce que le service permet au client d'obtenir
Horaires	Périodes où les engagements s'appliquent
Disponibilité	Part du temps de service convenu où le service est utilisable
Délais de rétablissement	Par priorité
Indicateur de résultat	Ce que le client vit, défini avec lui
Mesure et compte rendu	Source des données, fréquence
Pénalités	Conséquences du non-respect, et leur application
Revue	Fréquence de révision, comité de service

6. Matrice RACI

Activité	Rôle 1	Rôle 2	Rôle 3	Rôle 4	Rôle 5
Activité 1	A	R	C	I	
Activité 2		A	R	C	I
...					

Règles (Chapitre 16) : un seul A par activité ; au moins un R ; le A au bon niveau ; peu de C ; des fonctions et non des personnes.

7. Constat d'audit en cinq éléments (Chapitre 11)

Élément	Question
Constatation	Que se passe-t-il réellement ?
Critère	Que devrait-il se passer ? Avec sa source
Cause	Pourquoi l'écart existe-t-il ?
Conséquence	Quel risque, ou quel effet ?
Recommandation	Que faut-il faire, par qui, pour quand ?

8. Chronologie de défaillance

Date	Fait établi	Pièce
...	Fait, décision, ou absence de décision	Procès-verbal, courriel, journal

La chronologie ne contient que des constatations ; l'analyse vient ensuite, avec son niveau de confiance (Chapitre 0).

D

TEXTES LÉGISLATIFS ET RÉGLEMENTAIRES

Cette annexe rassemble les textes cités dans le cours, avec leur degré de vérification. Seuls les extraits lus dans leur version officielle sont reproduits entre guillemets ; les autres sont présentés sans citation.

Degré de vérification

Texte	Vérification	Chapitres
Loi n° 2010/012 (cybersécurité)	Version anglaise officielle lue	Prologue, 4, 7, 10
Règlement COBAC R-2016/04	Art. 1 et 2 relevés en ligne ; à collationner	10
AUSCGIE révisé (2014), art. 829-1	D'après la présentation de la réforme par l'OHADA	1, 10
Loi n° 2018/012 (régime financier), art. 69	D'après la présentation du MINFI ; à vérifier au Journal officiel	3
Loi n° 2024/017 (données personnelles)	D'après les présentations publiées ; à vérifier au Journal officiel	7, 10
Convention de Malabo (UA, 2014)	Entrée en vigueur vérifiée ; statut du Cameroun non établi	10

Loi n° 2010/012 relative à la cybersécurité et à la cybercriminalité

Jurisprudence & Droit applicable

Article 7, alinéa 2 : *« The Agency [...] shall be responsible for the regulation, control and monitoring of activities related to the security of electronic communication networks, information systems, and electronic certification on behalf of the State. »*

© MaletYon

Article 11 (extrait) : *« The following activities may be subject to authorization: [...] the provision of security auditing, security programs editing, and other authorized security services to the public. »*

Article 26, alinéa 1 : *« Operators of information systems shall take every technical and administrative measure to ensure the security of services offered. To this end, they shall have standardized systems enabling them to at all times identify, assess, process or manage any risk relating to the security of the information systems of the services provided directly or indirectly. »*

Article 29, alinéa 1 : *« Operators of information systems shall be bound to conserve the connection and traffic data of their information systems for a period of 10 (ten) years. »*

Article 30, alinéa 1 : *« Operators of information systems shall assess and revise their security systems and, where necessary, make the appropriate modifications to their security practices, measures and techniques according to technological change. »*

Article 31, alinéa 1 : *« Electronic communication networks and information systems content providers shall be bound to ensure the availability of material, as well as the data stored in their installations. »*

Article 32, alinéas 1 et 2 : *« (1) Electronic communication networks and information systems shall be subject to a regime of compulsory and periodic auditing of their security systems by the Agency. (2) Security audit and severity scale rating shall be undertaken each year or as required by the prevailing circumstances. »*

Articles 41 et 42 : *« 41. Every individual shall have the right to the protection of their privacy. [...] 42. The confidentiality of information channelled through electronic communication and information systems networks, including traffic data, shall be ensured by operators of electronic communication and networks information systems. »*

Article 64, alinéas 1 à 3 : *« (1) Corporate bodies shall be criminally liable for offences committed on their account by their management structures. (2) The criminal liability of corporate bodies shall not preclude that of natural persons who commit such offences or are accomplices. (3) The penalties to be meted out on defaulting corporate bodies shall be fines of from 5 000 000 (five million) to 50 000 000 (fifty million) CFA francs. »*

L'article 13 soumet en outre les systèmes d'information des opérateurs à un audit de sécurité obligatoire, dont les modalités sont fixées par voie réglementaire ; il est présenté sans citation (Prologue).

Règlement COBAC R-2016/04

Jurisprudence & Droit applicable

Articles 1 et 2 (texte relevé sur une base réglementaire en ligne, à collationner avec la version du SG-COBAC) : article 1 : *« Le présent règlement fixe les exigences minimales relatives au système de contrôle interne que les établissements assujettis doivent mettre en œuvre. »* ; article 2, risque opérationnel : *« risque de pertes résultant de l'inadéquation ou de la défaillance des processus internes, des personnes et des systèmes, ou d'évènements externes. »*

Textes présentés sans citation

- **AUSCGIE révisé, article 829-1** : selon la présentation de la réforme, comité d'audit obligatoire dans les sociétés cotées, chargé notamment du suivi de l'efficacité du contrôle interne et de la gestion des risques (Chapitre 1). Responsabilité des dirigeants : articles 161 et suivants, 740, d'après la doctrine (Chapitre 10).
- **Loi n° 2018/012, article 69** : selon le MINFI, rôle du responsable de programme dans le budget par programmes (Chapitre 3).
- **Loi n° 2024/017** : protection des données à caractère personnel ; autorité de protection, encadrement des transferts, délai de mise en conformité de dix-huit mois, d'après les présentations publiées (Chapitres 7 et 10).
- **Convention de Malabo** : cybersécurité et protection des données, en vigueur depuis le 8 juin 2023 ; ratification par le Cameroun non établie (Chapitre 10).

E

BIBLIOGRAPHIE COMMENTÉE

Pour chaque partie, quelques lectures, avec ce qu'elles apportent. Les références complètes figurent dans la bibliographie du livre. Les publications d'ISACA et d'AXELOS sont paraphrasées dans le cours ; leur lecture directe reste indispensable.

Prologue et Partie I · Fondements

- Weill et Ross [49] : les droits de décision et les archétypes de gouvernance ; le livre fondateur.
- Jensen et Meckling [28], Freeman [17], Davis et al. [12] : agence, parties prenantes, intendance ; les théories sous la gouvernance.
- Cadbury [10], principes de l'OCDE [33], King IV [20] : les codes de gouvernance d'entreprise.
- Henderson et Venkatraman [18] : le modèle d'alignement stratégique.
- Les sources de première main sur les défaillances : SEC sur Knight Capital [46], FCA et PRA sur TSB [15], analyses de l'incident CrowdStrike [11], [50].
- Thorp [45] et Weill et Broadbent [48] : valeur et portefeuille.

Partie II · COBIT 2019

- ISACA, *Introduction and Methodology* [23] : principes, composantes, facteurs de conception, capacité.
- ISACA, *Governance and Management Objectives* [22] : les quarante objectifs, à consulter objectif par objectif.
- COBIT 4.1 [27] : encore cité dans beaucoup de dossiers ; les modèles de maturité.
- De Haes et Van Grembergen [14] : la gouvernance des SI d'entreprise, entre recherche et pratique.

Partie III · Cadre normatif, juridique et déontologique

- ISO/IEC 38500 [24], [26] et ISO/IEC 27000 [25].
- COSO ERM [8], [9] : la gestion des risques de l'entreprise.
- IIA : CRIPP [42], Normes mondiales [44], modèle des trois lignes [43] ; INTOSAI, GUID 5100 [21].

➢ Textes : loi n° 2010/012 [29], COBAC R-2016/04 [7], AUSCGIE [1], régime financier de l'État [31], Sarbanes-Oxley [40] ; voir l'Annexe D.

Partie IV · ITIL 4 et pratique opérationnelle

➢ AXELOS, ITIL 4 [2] : le système de valeur des services et les pratiques.

➢ PeopleCert, ITIL (2026) [34] : l'évolution du référentiel, à suivre.

Partie V · Défis avancés

➢ Manifeste agile [3] et Forsgren et al. [16] : agilité et performance de la livraison.

➢ NIST, définition du nuage [30].

➢ NIST AI RMF [32], Recommandation de l'UNESCO [47], règlement européen sur l'IA [38] : gouverner l'IA.

Partie VI · Recherche

➢ Sambamurthy et Zmud [39], Peterson [35], De Haes et Van Grembergen [13], Brown et Grant [5], Wu et al. [51] : les arrangements et mécanismes de gouvernance.

➢ Becker et al. [4], Pöppelbuß et Röglinger [36], Simonsson et al. [41] : concevoir et éprouver un modèle de maturité.

➢ Hevner et al. [19] : la science du design en systèmes d'information.

F

CONTACTS ET RESSOURCES

Les adresses ci-dessous sont celles des sites institutionnels à la date de rédaction ; elles peuvent changer et sont à vérifier avant usage.

Autorités camerounaises et régionales

Institution	Rôle dans le cours	Site
ANTIC	Sécurité des SI, audits de sécurité (loi n° 2010/012)	`www.antic.cm`
ART	Régulation des communications électroniques	`www.art.cm`
MINPOSTEL	Politique du secteur ; destinataire des rapports d'audit de sécurité	`www.minpostel.gov.cm`
COBAC (Secrétariat général)	Contrôle interne et risques des établissements de crédit de la CEMAC	`www.sgcobac.org`
OHADA	Droit des sociétés, responsabilité des dirigeants, comité d'audit	`www.ohada.org`
Autorité de protection des données	Loi n° 2024/017	·
Chambre des comptes de la Cour suprême	Contrôle des finances publiques	·
Union africaine	Convention de Malabo	`au.int`

Organisations professionnelles et normatives

Organisation	Ressources	Site
ISACA	COBIT, certifications (CISA, CGEIT)	`www.isaca.org`
PeopleCert (AXELOS)	ITIL et ses certifications	`www.peoplecert.org`
ISO	ISO/IEC 38500, 20000-1, 27001, 27002, 31000	`www.iso.org`
IIA	Normes mondiales d'audit interne, modèle des trois lignes	`www.theiia.org`
COSO	Contrôle interne, gestion des risques	`www.coso.org`
INTOSAI	ISSAI, GUID 5100	`www.intosai.org`
NIST	Définition du nuage, AI RMF	`www.nist.gov`
UNESCO	Recommandation sur l'éthique de l'IA	`www.unesco.org`

NDAP SUKULU

Les fiches d'auto-évaluation et les dix labs du cours sont disponibles sur NDAP SUKULU, sous le code MSN-2S3-MSI03. Leur présentation et le tableau des labs figurent au début du livre, dans « NDAP SUKULU, la salle de classe compagnon ». NDAP SUKULU est une propriété de MaletYon, mise à la disposition des étudiants et des praticiens souhaitant se perfectionner : `maletyon@proton.me`.

RÉFÉRENCES BIBLIOGRAPHIQUES

[1] *Acte uniforme relatif au droit des sociétés commerciales et du groupement d'intérêt économique (révisé)*, Journal officiel de l'OHADA, numéro spécial du 4 février 2014, 30 jan. 2014.

[2] AXELOS, *ITIL Foundation: ITIL 4 Edition*. Londres : The Stationery Office, 2019.

[3] K. Beck et al., *Manifesto for Agile Software Development*, agilemanifesto.org, 2001.

[4] J. Becker, R. Knackstedt et J. Pöppelbuss, « Developing Maturity Models for IT Management: A Procedure Model and its Application, » *Business & Information Systems Engineering*, t. 1, n° 3, p. 213-222, 2009.

[5] A. E. Brown et G. G. Grant, « Framing the Frameworks: A Review of IT Governance Research, » *Communications of the Association for Information Systems*, t. 15, p. 696-712, 2005.

[6] CIO Mag, *La protection des données à caractère personnel au Cameroun à la lecture de la loi du 23 décembre 2024*, Article de presse spécialisée, 2026. adresse : https://cio-mag.com/?p=59861.

[7] Commission bancaire de l'Afrique centrale, *Règlement COBAC R-2016/04 relatif au contrôle interne dans les établissements de crédit et les holdings financières*, Secrétariat général de la COBAC, 2016. adresse : http://www.sgcobac.org.

[8] Committee of Sponsoring Organizations of the Treadway Commission, *Le management des risques de l'entreprise : cadre de référence, synthèse*, Version française du résumé de l'édition 2004, COSO, 2004.

[9] Committee of Sponsoring Organizations of the Treadway Commission, *Enterprise Risk Management: Integrating with Strategy and Performance*, COSO, 2017.

[10] Committee on the Financial Aspects of Corporate Governance, « Report of the Committee on the Financial Aspects of Corporate Governance, » Gee et Co., London, 1992, Rapport Cadbury.

[11] CrowdStrike, *Channel File 291 Incident: Root Cause Analysis*, Analyse de cause publiée par l'éditeur, 6 août 2024. adresse : https://www.crowdstrike.com/en-us/blog/channel-file-291-rca-available/.

[12] J. H. Davis, F. D. Schoorman et L. Donaldson, « Toward a Stewardship Theory of Management, » *Academy of Management Review*, t. 22, n° 1, p. 20-47, 1997.

[13] S. De Haes et W. Van Grembergen, « An Exploratory Study into IT Governance Implementations and its Impact on Business/IT Alignment, » *Information Systems Management*, t. 26, n° 2, p. 123-137, 2009.

[14] S. De Haes et W. Van Grembergen, *Enterprise Governance of Information Technology: Achieving Alignment and Value, Featuring COBIT 5*, 2e éd. Cham : Springer, 2015.

[15] Financial Conduct Authority et Prudential Regulation Authority, *TSB fined £48.65m for operational resilience failings*, Communiqué et décisions finales, 20 déc. 2022. adresse : https://www.fca.org.uk/news/press-releases/tsb-fined-48m-operational-resilience-failings.

[16] N. Forsgren, J. Humble et G. Kim, *Accelerate: The Science of Lean Software and DevOps*. Portland : IT Revolution Press, 2018.

[17] R. E. Freeman, *Strategic Management: A Stakeholder Approach*. Boston : Pitman, 1984.

[18] J. C. Henderson et N. Venkatraman, « Strategic Alignment: Leveraging Information Technology for Transforming Organizations, » *IBM Systems Journal*, t. 32, n° 1, p. 4-16, 1993.

[19] A. R. Hevner, S. T. March, J. Park et S. Ram, « Design Science in Information Systems Research, » *MIS Quarterly*, t. 28, n° 1, p. 75-105, 2004.

[20] Institute of Directors in Southern Africa, « King IV Report on Corporate Governance for South Africa 2016, » IoDSA, Johannesburg, 2016.

[21] INTOSAI, *GUID 5100 : Lignes directrices sur la vérification des systèmes d'information*, Organisation internationale des institutions supérieures de contrôle des finances publiques, 2019.

[22] ISACA, *COBIT 2019 Framework: Governance and Management Objectives*, ISACA, Schaumburg, IL, 2018.

[23] ISACA, *COBIT 2019 Framework: Introduction and Methodology*, ISACA, Schaumburg, IL, 2018.

[24] ISO/IEC, *ISO/IEC 38500:2015 – Information technology – Governance of IT for the organization*, Genève : Organisation internationale de normalisation, 2015.

[25] ISO/IEC, *ISO/IEC 27000:2018 – Technologies de l'information – Techniques de sécurité – Systèmes de management de la sécurité de l'information – Vue d'ensemble et vocabulaire*, Genève : Organisation internationale de normalisation, 2018.

[26] ISO/IEC, *ISO/IEC 38500:2024 – Information technology – Governance of IT for the organization*, Genève : Organisation internationale de normalisation, 2024.

[27] IT Governance Institute, *COBIT 4.1 : cadre de référence, objectifs de contrôle, guide de management, modèles de maturité*, IT Governance Institute, 2007.

[28] M. C. Jensen et W. H. Meckling, « Theory of the Firm: Managerial Behavior, Agency Costs and Ownership Structure, » *Journal of Financial Economics*, t. 3, nº 4, p. 305-360, 1976.

[29] *Loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et la cybercriminalité au Cameroun*, Version anglaise officielle : Law No. 2010/012 of 21 December 2010 relating to cybersecurity and cybercriminality in Cameroon, 21 déc. 2010.

[30] P. Mell et T. Grance, « The NIST Definition of Cloud Computing, » National Institute of Standards et Technology, Special Publication 800-145, 2011.

[31] Ministère des Finances du Cameroun, *Régime financier de l'État et des autres entités publiques*, Collection « Les essentiels de la réforme », présentation de la loi n° 2018/012 du 11 juillet 2018, MINFI, Yaoundé, 2023.

[32] National Institute of Standards and Technology, « Artificial Intelligence Risk Management Framework (AI RMF 1.0), » NIST, NIST AI 100-1, 2023.

[33] OCDE, *Principes de gouvernance d'entreprise du G20 et de l'OCDE 2023*, Éditions OCDE, Paris, 2023.

[34] PeopleCert, *New ITIL Explained for Certified Professionals*, Annonce de l'éditeur, 2026. adresse : https://www.peoplecert.org/news-and-announcements/itil-version-5-explained.

[35] R. Peterson, « Crafting Information Technology Governance, » *Information Systems Management*, t. 21, nº 4, p. 7-22, 2004.

[36] J. Pöppelbuss et M. Röglinger, « What Makes a Useful Maturity Model? A Framework of General Design Principles for Maturity Models and its Demonstration in Business Process Management, » in *Proceedings of the European Conference on Information Systems (ECIS)*, 2011.

[37] Prudential Regulation Authority, *PRA fines former TSB Chief Information Officer for failings in outsourcing oversight*, Décision finale, 2023.

[38] *Règlement (UE) 2024/1689 du Parlement européen et du Conseil du 13 juin 2024 établissant des règles harmonisées concernant l'intelligence artificielle*, Journal officiel de l'Union européenne, 13 juin 2024.

[39] V. Sambamurthy et R. W. Zmud, « Arrangements for Information Technology Governance: A Theory of Multiple Contingencies, » *MIS Quarterly*, t. 23, nº 2, p. 261-290, 1999.

[40] *Sarbanes-Oxley Act of 2002, Public Law 107-204*, 116 Stat. 745, États-Unis, 30 juill. 2002.

[41] M. Simonsson, P. Johnson et M. Ekstedt, « The Effect of IT Governance Maturity on IT Governance Performance, » *Information Systems Management*, t. 27, nº 1, p. 10-24, 2010.

[42] The Institute of Internal Auditors, *Cadre de référence international des pratiques professionnelles de l'audit interne (CRIPP), édition 2017 : Normes et Code de déontologie*, IIA, 2017.

[43] The Institute of Internal Auditors, *The IIA's Three Lines Model: An Update of the Three Lines of Defense*, IIA, 2020.

[44] The Institute of Internal Auditors, *Global Internal Audit Standards*, IIA, Lake Mary, FL, 2024.

[45] J. Thorp, *The Information Paradox: Realizing the Business Benefits of Information Technology*. Toronto : McGraw-Hill Ryerson, 1998.

[46] U.S. Securities and Exchange Commission, *In the Matter of Knight Capital Americas LLC: Order Instituting Administrative and Cease-and-Desist Proceedings*, Securities Exchange Act Release No. 70694, File No. 3-15570, 16 oct. 2013.

[47] UNESCO, *Recommandation sur l'éthique de l'intelligence artificielle*, Organisation des Nations unies pour l'éducation, la science et la culture, Paris, 2021.

[48] P. Weill et M. Broadbent, *Leveraging the New Infrastructure: How Market Leaders Capitalize on Information Technology*. Boston : Harvard Business School Press, 1998.

[49] P. Weill et J. W. Ross, *IT Governance: How Top Performers Manage IT Decision Rights for Superior Results*. Boston : Harvard Business School Press, 2004.

[50] D. Weston, *Helping our customers through the CrowdStrike outage*, Microsoft, blog officiel, 20 juill. 2024.

[51] S. P.-J. Wu, D. W. Straub et T.-P. Liang, « How Information Technology Governance Mechanisms and Strategic Alignment Influence Organizational Performance: Insights from a Matched Survey of Business and IT Managers, » *MIS Quarterly*, t. 39, nº 2, p. 497-518, 2015.

INDEX

Accord de niveau de service, 196
accord de niveau de service, 196
Accord de niveau opérationnel, 196
accord de niveau opérationnel, 196
Activité, 86
activité (COBIT), 86
Alignement stratégique, 47
alignement stratégique, 47
Alignement volontaire, 128
alignement volontaire, 128
Analyse d'impact sur l'activité, 200
analyse d'impact sur l'activité, 200
architecture d'entreprise, 64
asymétrie d'information, 22
autorité de changement, 185

Base de données de gestion de la configuration, 189
bonnes pratiques, 60

Cadre de référence, 60
cadre de référence, 60
calendrier des changements, 186
canevas de conception, 104
Capacité d'un processus, 110
capacité d'un processus, 110
cascade des objectifs, 91
centre de services, 172
Certification, 128
certification, 128
Changement, 184
changement, 12, 184
Chaîne de déploiement, 233
chaîne de déploiement, 233
Chronologie de défaillance, 4
chronologie de défaillance, 4
CMDB, 189
Co-création de valeur, 160
co-création de valeur, 160
comité de pilotage des SI, 27
comité des changements, 185
comité stratégique des SI, 27
Composante, 76
composante, 76
composantes, 76
composantes du système de gouvernance, 76
Conformité, 128
conformité, 128
Contrat de sous-traitance, 196
contrat de sous-traitance, 196
Contrôles d'application, 148
contrôles d'application, 148
Contrôles généraux, 148
contrôles généraux, 148
Contrôles généraux informatiques, 23
contrôles généraux informatiques, 23
coût total de possession, 51
Coûts d'agence, 21
coûts d'agence, 21

Demande de service, 172
demande de service, 172
DevOps, 233
Disponibilité, 198
disponibilité, 198
Domaine d'intérêt, 80
domaine d'intérêt, 80
Droits de décision, 7
droits de décision, 7
Durée maximale d'interruption admissible, 200
durée maximale d'interruption admissible, 200
Déclaration d'applicabilité, 126
déclaration d'applicabilité, 126
Défaillance de gouvernance, 6

défaillance de gouvernance, 6
dépendance critique, 38
déploiement, 187

Erreur connue, 172
erreur connue, 172

Facteur de conception, 80
facteur de conception, 80
flux de valeur, 163

Garantie, 161
garantie, 161
gestion des déploiements, 187
gestion des mises en production, 187
Gestionnaire de processus, 208
gestionnaire de processus, 208
Gouvernance d'entreprise, 20
gouvernance d'entreprise, 19, 20
Gouvernance des données, 244
gouvernance des données, 244
Gouvernance des SI, 9, 25
gouvernance des SI, 9
    définition de travail, 25

Habilitation des changements, 184
habilitation des changements, 184

impact, 174
Incident, 172
incident, 172
incident majeur, 174
Indicateur clé d'objectif, 213
indicateur clé d'objectif, 213
Indicateur clé de performance, 213
indicateur clé de performance, 213

Management des SI, 9
management des SI, 9
matrice des droits de décision, 49
Matrice RACI, 209
matrice RACI, 209
Maturité, 112
maturité, 112
mise en production, 187
modèle des trois lignes, 146

Niveau de capacité cible, 100
niveau de capacité cible, 100
Norme certifiable, 60
norme certifiable, 60

Objectif d'alignement, 92
objectif d'alignement, 92
Objectif d'entreprise, 92
objectif d'entreprise, 92
objectif de gouvernance, 78
Objectif de gouvernance ou de management, 78
objectif de management, 78
Optimisation des ressources, 50
optimisation des ressources, 50
Optimisation des risques, 50
optimisation des risques, 50

Partie prenante, 22
partie prenante, 22
Plan de retour arrière, 188
Portefeuille, 54
portefeuille, 54
Pratique, 86
pratique (COBIT), 86
Problème, 172
problème, 172
Processus, 208
processus, 208
Propriétaire de processus, 208
propriétaire de processus, 208
Prépublication, 259
prépublication, 259

ratio d'impact disproportionné, 248
Recueil de bonnes pratiques, 60
Redevabilité, 7
redevabilité, 7
Relation d'agence, 21
relation d'agence, 21
retour arrière, 188
RPO, 200

RTO, 200
Réalisation des bénéfices, 50
réalisation des bénéfices, 50

Service, 160
service (ITIL), 160
Solution de contournement, 172
solution de contournement, 172
Source de première main, 34
source de première main, 34
structure harmonisée, 122
Système de management, 122
système de management, 122
système de management de la sécurité de l'information, 126
système de management des services, 124
système de valeur des services, 161

termes clés, vi

urgence, 174
Utilité, 161
utilité, 161

Valeur, 160
valeur (ITIL), 160
valeur actuelle nette, 52
Vérification des systèmes d'information, 148
vérification des systèmes d'information, 148

Élément de configuration, 189
Évaluation par les pairs, 259
élément de configuration, 189
évaluation par les pairs, 259

À propos de ce cours

Quand un système d'information s'arrête, la question décisive n'est pas technique : elle porte sur qui avait décidé, et qui devait rendre compte. Ce cours apprend à y répondre avant la panne.

Il progresse en six parties, précédées d'un prologue : les fondements de la gouvernance des systèmes d'information, le référentiel COBIT 2019, le cadre normatif et juridique, ITIL 4 et les processus de gestion des services, les défis de l'agilité, du nuage et de l'intelligence artificielle, et enfin la recherche.

Chaque notion est ancrée à la fois dans les standards internationaux (ISO, ISACA, IIA, INTOSAI) et dans le droit camerounais et communautaire (CEMAC, OHADA). Le cours s'adresse aux étudiants du Master Professionnel en Management des Systèmes d'Information et aux professionnels qui exercent comme DSI, responsables GRC, auditeurs des SI, responsables des services informatiques ou RSSI.

MINKA MI NGUIDJOÏ Thierry Emmanuel

CISA · CISM · CGEIT · CRISC · CDPSE · ISO 27001 · ISO 22301 · ISO 9001

Chercheur au laboratoire d'Ingénierie Mathématiques et des Systèmes d'Information

Chercheur | Cryptologue | Auditeur Senior | Expert Judiciaire | GRC & Sécurité de l'Information